

Sécurité Informatique

Prf Serrhini
S4-Info-App
S6- Genie Info
2025-2026

Cyber-sécurité Cybercriminalité

- Cybercriminalité

Qu'est-ce que la cybercriminalité ?

- Tout comme la criminalité ordinaire, elle existe également sur Internet.
- Voici quelques exemples de cybercriminalité :
 - Vol d'identité
 - Prédateurs en ligne
 - BEC (« compromis de courrier électronique professionnel »)
 - Rançongiciel
 - Vol de propriété intellectuelle sensible



Augmentation de la criminalité

La cybercriminalité augmente régulièrement chaque année.

Pourquoi la cybercriminalité est-elle en hausse ? Voici quelques raisons :

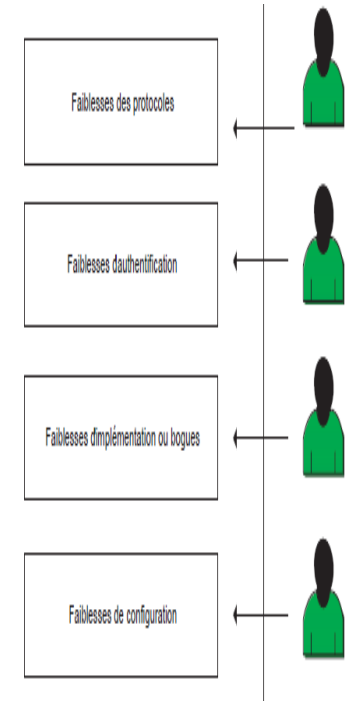
- La cybercriminalité est facile à réaliser
- Faibles risques de se faire prendre
- Pour peu de travail, les rendements sont souvent élevés
- Les attaquants peuvent cibler des milliers de victimes
- Le blanchiment d'argent est plus facile avec les crypto-monnaies

Des problèmes tels que le vol d'identité peuvent avoir des conséquences importantes sur un individu, entraînant non seulement des pertes financières potentielles, mais également de nombreux chagrins personnels.

Internet offre de nombreux services pour faciliter le blanchiment d'argent, ce qui en fait généralement un processus trivial. Comme l'argent est échangé en crypto-monnaie, des services tels que les gobelets rendent difficile le suivi de l'argent.

Figure 1.4

*Typologie des
faiblesses de sécurité*



Remarque : la crypto-monnaie

- Remarque :
- Les Tumblers sont des services qui divisent les transactions en crypto-monnaie et transfèrent l'argent via de nombreux comptes, avec des valeurs différentes, pour des milliers de personnes, ce qui les rend difficiles à suivre
- la crypto-monnaie est de l'argent représenté sous forme numérique plutôt que physique. Il existe de nombreuses crypto-monnaies différentes, certaines très répandues comme le Bitcoin, et d'autres plus petites et inconnues de la plupart des gens. Ces modèles de devises s'appuient sur une cryptographie solide et des systèmes de grand livre public pour suivre les transactions et la quantité de devises sur le marché.

Cybercriminels



- Qui sont les cybercriminels ? Cela peut être n'importe qui, mais parlons de quelques exemples courants que nous voyons constamment dans les médias :
 - Groupes parrainés par l'État ciblant des organisations dans d'autres pays
 - Des groupes de piratage ciblent des entreprises pour leur faire payer une rançon
 - Des enfants dans leur chambre font du piratage illégal

Attraper les cybercriminels

- Les cybercriminels peuvent rester anonymes grâce à des moyens triviaux et il est généralement facile d'éviter de se faire prendre. Lorsque les attaquants se font prendre, c'est souvent à cause d'erreurs commises par les attaquants eux-mêmes, par exemple en raison d'une complaisance. Il existe également un grand potentiel pour que les forces de l'ordre utilisent des cybercriminels arrêtés pour dénoncer d'autres acteurs du secteur.
- Les forces de l'ordre font cependant face à de nombreux défis pour traquer la cybercriminalité. Vous pourriez voir du trafic d'attaque provenant d'un système résidant au Maroc, et lorsque vous démontez ce système, vous réalisez qu'il était contrôlé à distance, par ex. un autre système en Inde.
- En coopérant avec les forces de l'ordre au-delà des frontières, vous pourrez peut-être accéder au système en Inde, mais seulement pour vous rendre compte qu'il était à nouveau contrôlé à distance, par exemple par le biais d'un système de contrôle à distance. Pakistan.

Cyber Security

Menaces pour gagner de l'argent

- Poussé par l'argent Les organisations sont fréquemment confrontées à quelques menaces clés :
 - Les fichiers et les systèmes des **ransomwares** sont cryptés avec les clés des attaquants et ils vous demandent de payer pour récupérer vos données.
 - Mineurs de crypto-monnaie : vos systèmes sont infectés par un outil d'extraction de crypto-monnaie discret. Cet outil utilise le processeur pour essayer de gagner de l'argent sur une crypto-monnaie pour les attaquants.
 - BEC (« Compromis de courrier électronique professionnel »). Les utilisateurs sont piratés par toutes sortes de méthodes et leurs e-mails sont compromis. Grâce à la compromission des e-mails, les attaquants peuvent intercepter des communications, par exemple une facture, et tenter de rediriger les paiements vers d'autres banques et comptes.

Il existe de nombreuses façons de gagner de l'argent pour les cybercriminels, ce qui attire les gens et suscite l'intérêt.

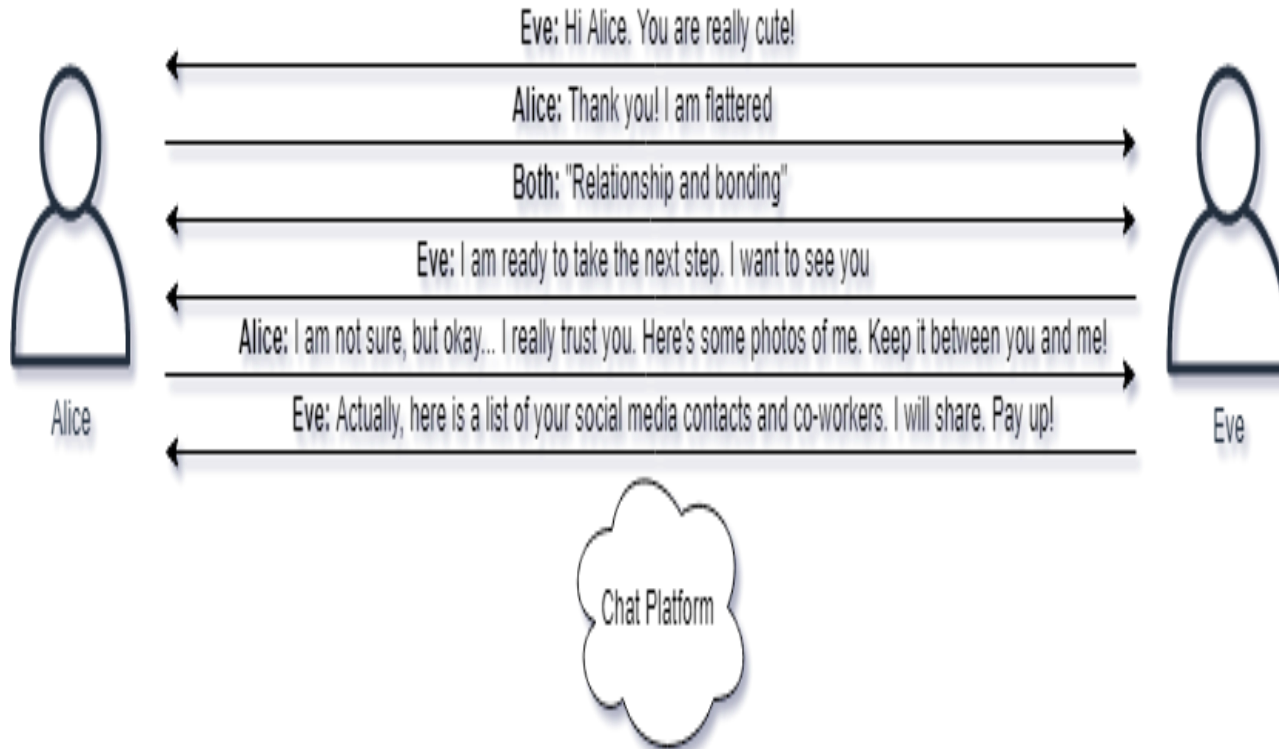
Valeur et puissance

- Il y a de la valeur et du pouvoir dans de nombreux domaines liés à l'informatique, par exemple :
 - La bande passante peut être utilisée pour faire pression sur les entreprises en les ciblant avec des attaques DDOS (« Distributed Denial of Service »).
 - Les systèmes piratés peuvent contenir des informations sensibles valant de l'argent, par exemple des informations commerciales exclusives, des actifs de jeux en ligne, des photographies et des images sensibles.
 - Les attaquants peuvent s'installer dans les navigateurs et tenter de détourner l'utilisation des services bancaires en ligne.
 - La possibilité pour les criminels de gagner d'importantes sommes d'argent dans le domaine cybernétique incite de plus en plus de gangs criminels et d'autres opportunistes à se joindre à l'action et à nous rendre la vie encore plus difficile.

Menacer pour de l'argent

- Une autre attaque courante que les cybercriminels effectuent pour gagner de l'argent est l'acte d'extorsion, qui consiste à prendre des individus en otage sur la base des informations dont ils disposent sur un individu, en essayant de leur faire payer de l'argent pour être libérés de la tentative d'extorsion. Considérez le scénario courant suivant :
- ✓ Une personne rencontre quelqu'un en ligne, l'autre partie est en fait un escroc qui tente de tromper la victime.
- ✓ Ils s'engagent dans des conversations intéressantes et semblent établir immédiatement un lien profond entre eux.
- ✓ Ils peuvent même engager des conversations vidéo, mais les escrocs utilisent par exemple une vidéo enregistrée ou ont simplement une excuse pour ne pas pouvoir activer leur microphone ou leur webcam.
- ✓ Une chose peut en entraîner une autre et la relation peut devenir sexuelle. L'escroc tente de convaincre la victime de lui donner des photos personnelles et des enregistrements d'elle-même, probablement dans des situations compromettantes.
- ✓ Une fois que l'escroc reçoit ce matériel, voire même en lui renvoyant de fausses photos de personnes innocentes dans des situations similaires, l'extorsion commence.
- ✓ L'escroc peut désormais menacer de divulguer le matériel compromettant aux membres de sa famille, à ses collègues et à d'autres personnes, en proposant de supprimer le matériel si une somme d'argent est versée sur le compte de l'escroc.

scenario



Cyber Crime



Des histoires comme celles-ci sont loin d'être rares, et il existe d'innombrables scénarios et opportunités permettant aux criminels de tirer profit des victimes utilisant Internet sans connaître les risques qui y sont associés.

Cyber Security Dark Web الويب المظلم

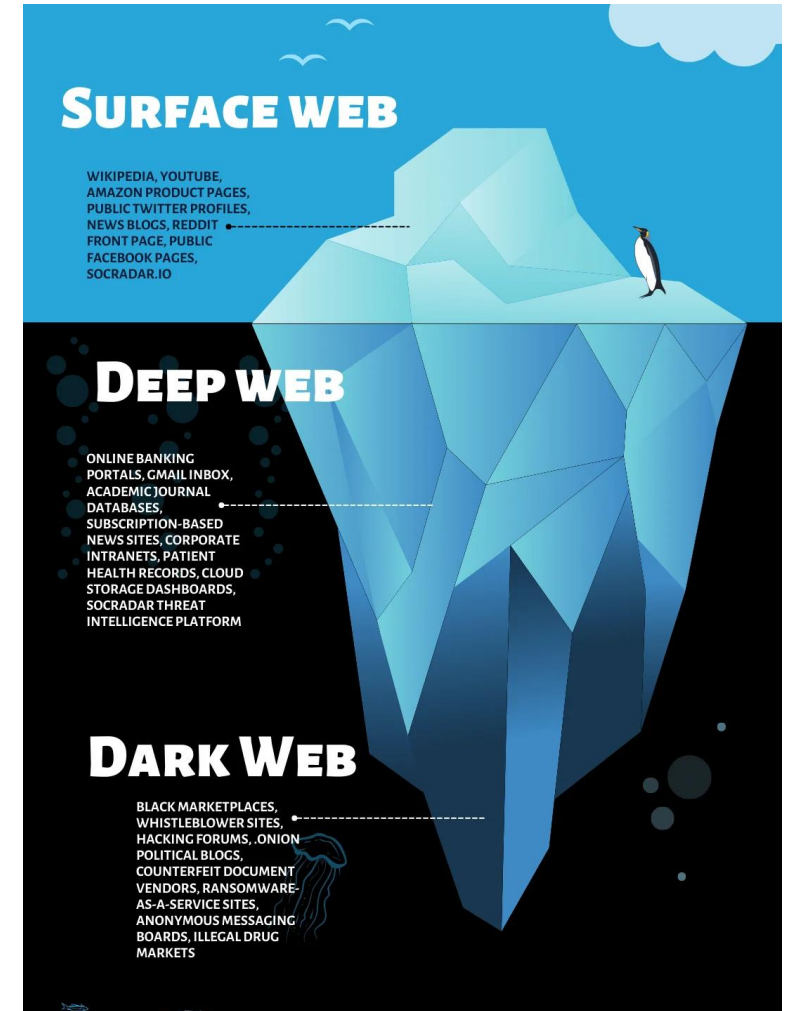
- Le Web sombre :Le Dark Web (également appelé Dark Net) est un réseau au sein d'Internet qui n'est accessible qu'à l'aide de certains logiciels et protocoles.

Le Dark Web a de nombreux noms, par exemple Tor Network ou Onion Router.

Tout le monde peut accéder au Dark Web en téléchargeant simplement un logiciel correspondant. Un navigateur populaire et très utilisé est le navigateur Tor du projet Tor.

C'est comme n'importe quel autre navigateur tel que Google Chrome ou Microsoft Edge, sauf qu'il peut également accéder à des adresses de sites Web spéciales qui se terminent par .onion au lieu de .com et autres.

Tout trafic envoyé via le navigateur Tor est automatiquement anonymisé et crypté via de nombreux hôtes différents. Le navigateur dispose également d'une protection intégrée pour de nombreux types de fonctionnalités de suivi et de désanonymisation.



Accéder au Dark Web

- Vous pouvez accéder à de nombreux sites Web amusants et intéressants via ce navigateur, dont beaucoup coexistent également sur Internet classique. Par exemple, si vous accédez aux URL suivantes dans le navigateur Tor, vos communications seront entièrement cryptées et anonymisées dans le Dark Web :

Facebook – <http://www.facebookcorewwi.onion/>

- DuckDuckGo Search Engine - <http://3g2upl4pq6kufc4m.onion/>
- Facebook – <http://www.facebookcorewwi.onion/>
- The American CIA ("Central Intelligence Agency") - <http://ciadotgov4sjwlzihbbgxng3xiyrg7so2r2o3lt5wz5ypk4sxyjstad.onion>
- The Hidden Wiki, a collection of links and places to explore - http://zqktlwiauavvqq4ybvvgvi7tyo4hjl5xgfuvpdf6otjiycgwqbym2qad.onion/wiki/index.php/Main_Page

En raison des fonctionnalités d'anonymisation et de cryptage intégrées, le Dark Net héberge également de nombreux sites Web, marchés et réseaux criminels.

- Remarque : Soyez prudent lorsque vous naviguez sur le Dark Net. Les liens ci-dessus ne fonctionneront que si vous utilisez le logiciel approprié.

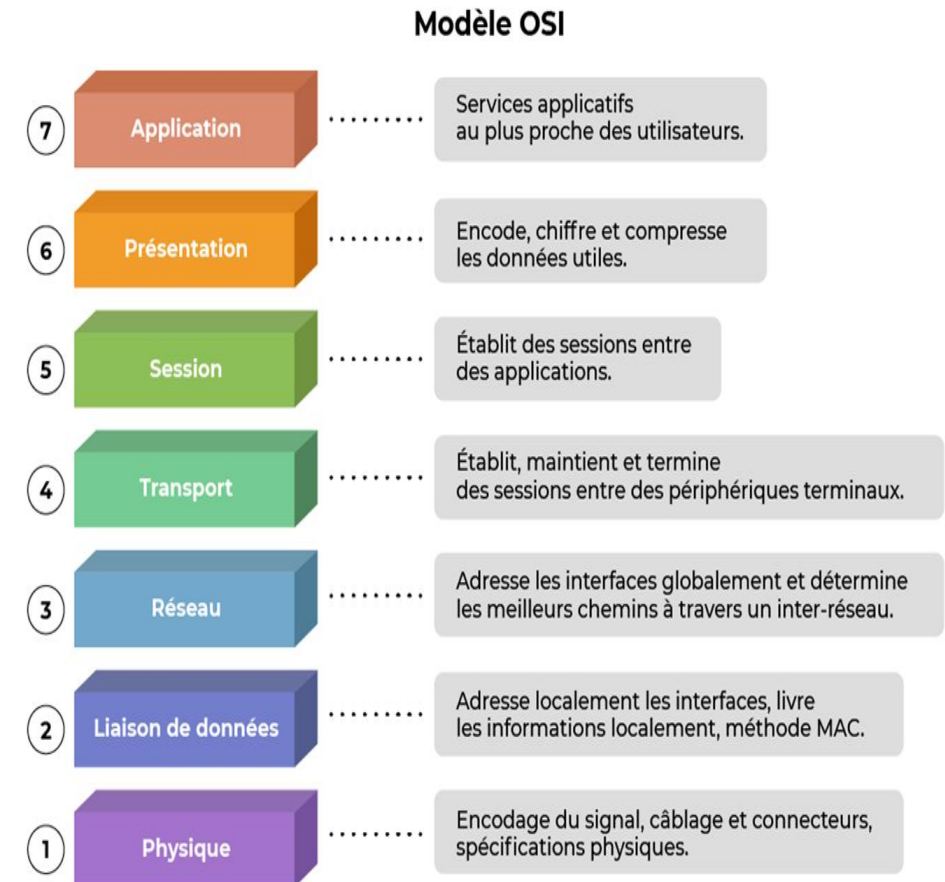
Bases des réseaux de cybersécurité

- Protocoles et réseaux : Il est essentiel que les professionnels de la cybersécurité aient une solide compréhension de la façon dont les ordinateurs communiquent. Il se passe bien plus de choses dans les coulisses des réseaux informatiques que ce que l'on peut observer lors de l'utilisation d'applications.
- Le modèle OSI : Le modèle OSI (« Open Systems Interconnection ») représente un moyen simple et intuitif de standardiser les différentes parties nécessaires à la communication sur les réseaux.

Le modèle indique clairement ce qui est requis pour communiquer sur un réseau en divisant les exigences en plusieurs couches.

Voici à quoi ressemble le modèle OSI :

- Couche et ce qu'elle fait
 - 7 – Application: Là où les humains traitent des données et des informations
 - 6 – Présentation: Garantit que les données sont dans un format utilisable
 - 5 – Session: Capable de maintenir les connexions
 - 4 - Les données de transport: sont transmises à un service capable de traiter les demandes
 - 3 - Couche réseau: Responsable du chemin que les paquets doivent parcourir sur un réseau
 - 2 - Liaison de données: Responsable des appareils physiques vers lesquels les paquets doivent être envoyés
 - 1 - Physique :L'infrastructure physique pour transporter les données



Les couches

- Les 3 couches supérieures sont généralement implémentées dans les logiciels du système d'exploitation :
Couche Où il est implémenté
7 - couche application Logiciel
6 - couche présentation Logiciel
5 – couche séance Logiciel
- Les 3 couches inférieures sont généralement implémentées dans le matériel des appareils du réseau, par ex. Commutateurs, routeurs et pare-feu :
Couche Où il est implémenté
3 - couche réseau Matériel de
2 - couche liaison de données Matériel
1 – couche physique Matériel
- La couche 4, la couche Transport, connecte le logiciel aux couches matérielles.

SDN (« Software Defined Networking ») est une technologie qui permet de mettre en œuvre plusieurs couches de matériel via un logiciel.

Couche 7 - Couche d'application

- La logique métier et les fonctionnalités de l'application résident ici. C'est ce que les utilisateurs utilisent pour interagir avec les services sur un réseau. La plupart des développeurs créent des applications sur la couche application.

La plupart des applications que vous utilisez se trouvent sur la couche application, la complexité des autres couches étant masquée.

Exemples d'applications de couche 7 :

HTTP (« Hypertext Transfer Protocol ») - Nous permet d'accéder aux applications Web
FTP ("File Transfer Protocol") - Permet aux utilisateurs de transférer des fichiers
SNMP (« Simple Network Management Protocol ») - Protocole pour lire et mettre à jour les configurations des périphériques réseau

Il existe de nombreuses applications qui utilisent ces protocoles comme Google Chrome, Microsoft Skype et FileZilla.

Couche 6 – Couche de présentation

- Il s'agit généralement d'une couche invisible, mais chargée d'adapter, de transformer et de traduire les données. Cela permet de garantir que l'application et les couches situées en dessous peuvent se comprendre.
- Schémas de codage utilisés pour représenter du texte et des données, par exemple ASCII (American Standard Code for Information Interchange) et UTF (Unicode Transformation Format).
- Chiffrement des services, par exemple SSL (« Secure Sockets Layer ») et TLS (« Transport Security Layer »)
- Compression, par exemple GZip utilisée dans de nombreuses implémentations de HTTP.

Couche 5 - Couche de session

- La responsabilité de cette couche consiste à gérer les connexions entre l'application et les couches inférieures. Cela implique l'établissement, le maintien et la fin de connexions, autrement appelées sessions.

Les protocoles courants qui représentent bien la couche session sont :

- SOCKS - Un protocole pour envoyer des paquets via un serveur proxy.
- NetBIOS - Un ancien protocole Windows pour établir des sessions et résoudre des noms.
- SIP (« Session Initiation Protocol ») - Pour engager des communications VOIP (« Voice Over IP »)

Couche 4 - Transports

- La couche qui permet aux applications d'être représentées sur le réseau.

Quelques applications bien connues sur cette couche :

- TCP (« Transmission Control Protocol ») - Utilisé pour de nombreuses applications, garantissant la stabilité, le contrôle de la quantité de données pouvant être envoyées à un moment donné, la fiabilité et bien plus encore.
- UDP ("User Datagram Protocol") - Utilisation de protocole léger et rapide pour de nombreux services.
- QUIC (« Quick UDP Internet Connections ») - Un protocole conçu pour des connexions plus rapides et va de pair avec la version 2 du protocole HTTP.

Couche 3 - Réseau

- Une couche responsable du routage des paquets entre les réseaux via des routeurs.

Sur cette couche, résident les protocoles suivants :

- IP (« Internet Protocol ») - Utilisé quotidiennement lors de l'accès à Internet. Existe en deux versions, IP version 4 et 6.
- ICMP (« Internet Control Message Protocol ») - Utilisé par les périphériques réseau et les opérateurs réseau, pour diagnostiquer les connexions réseau ou pour que les périphériques envoient et répondent à des conditions d'erreur, etc.
- IPSec (« Internet Protocol Security ») - Permet des connexions cryptées et sécurisées entre deux périphériques réseau.

Couche 2 - Liaison

- Les réseaux de liens, comme leur nom l'indique, sont constitués de protocoles conçus pour envoyer des paquets via les liens réels (connexions physiques) auxquels les nœuds du réseau sont connectés. Une façon plus simple de voir les choses est que la couche liaison est responsable du déplacement des données du physique vers le logique (vers la couche réseau).

Les protocoles sur cette couche incluent :

- Ethernet - Un protocole essentiel utilisé par la plupart des systèmes d'exploitation lors de la connexion aux réseaux à l'aide d'un câble physique.
- Wi-Fi (« Wireless Fidelity ») - Pour accéder aux réseaux via des signaux radio. Il utilise une famille de protocoles appelée IEEE 802.11.xx
- NDP (« Neighbor Discovery Protocol ») - IP version 6 (IPv6) utilise ce protocole sur la couche liaison pour collecter les informations nécessaires à la communication via IPv6.

Couche 1 – Physique

- La couche physique représente la signalisation qui permet le transfert de bits et d'octets entre un support physique. Il peut être transféré via radio ou par signaux via un câble, en utilisant des signaux électriques ou de la lumière, par exemple une fibre.

Voici des exemples de protocoles de couche physique :

- Bus CAN (« Controller Area Network ») - Utilisé dans les microcontrôleurs et autres appareils pour communiquer avec d'autres appareils similaires, n'impliquant pas un ordinateur. Souvent utilisé dans les ICS (« Industrial Control Systems »).
- Couche physique Ethernet - Utilisée par Ethernet sur la couche physique pour envoyer des signaux avec des vitesses allant jusqu'à plusieurs gigabits de trafic par seconde.
- Couche physique Bluetooth - Bluetooth a également ses propres spécifications sur la manière dont les signaux radio doivent être envoyés et reçus.

Cybersécurité dans les Couches réseau

- IP - Le protocole Internet :IP est utilisé pour communiquer sur les réseaux, non seulement via des liens physiques, mais aussi entre des réseaux de routeurs. Le schéma d'adressage utilisé est soit IPv4 (« IP Version 4 »), soit IPv6 (« IP Version 6 »).
- Les réseaux IP peuvent être divisés en différentes sections, souvent appelées sous-réseaux. Ceci est accompli en ajoutant une information supplémentaire, ainsi que l'adresse IP, appelée masque de réseau. Le masque de réseau dicte la taille d'un réseau et quel paquet est acheminé au sein du réseau et lequel doit être acheminé à l'extérieur du réseau.
- Les masques de réseau peuvent être représentés via des nombres décimaux ou avec une notation barre oblique. Lorsque vous utilisez la notation barre oblique, la barre oblique suit l'adresse IP du système. Voici quelques exemples :

IP

- Certains réseaux IP sont réservés uniquement à un certain type de trafic. Les adresses IP du tableau ci-dessus sont réservées uniquement à un usage interne à l'organisation, ce qui signifie qu'elles ne doivent pas être acheminées sur Internet. Ces types d'adresses IP sont communément appelés adresses RFC1918.

IP Address	Slash Notation	Netmask
10.0.0.1	/8 - Example: 10.0.0.1/8	255.0.0.0
172.16.1.1	/12 - Example: 172.16.1.1/12	255.240.0.0
192.168.0.1	/16 - Example: 192.168.0.1/16	255.255.0.0
192.168.0.1	/24 - Example: 192.168.0.1/24	255.255.255.0

Différents réseaux

- Jetons un coup d'œil aux différents réseaux au sein de la RFC1918 et à leur taille :

10.0.0.0/8 - Plus de 16 millions d'adresses IP

172.16.0.0/12 - Environ 1 million d'adresses IP

192.168.0.0/16 - 65534 adresses IP

Les segments IP peuvent être divisés en réseaux plus petits et plus granulaires.

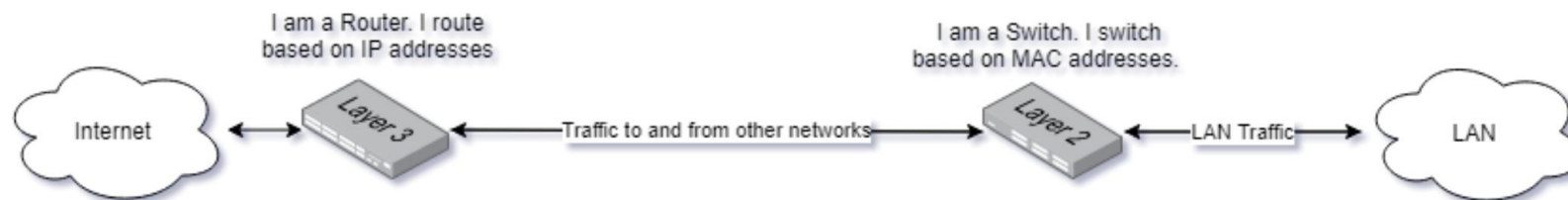
- Chaque réseau possède une adresse réservée pour la diffusion du trafic vers chaque hôte du réseau, c'est ce qu'on appelle l'adresse de diffusion. La diffusion de données consiste à envoyer des données à tous les utilisateurs du réseau au lieu de les envoyer à un seul hôte. Il existe de nombreuses applications et protocoles qui dépendent du trafic de diffusion pour fonctionner.

segment de réseau masque de réseau

- Pour chaque segment de réseau, la diffusion correspond toujours à la dernière adresse IP du réseau. Par exemple dans le réseau 192.168.0.0/24, l'adresse de diffusion est 192.168.0.255.

Le plus petit masque de réseau possible est 255.255.255.255, représenté par /32. Ce réseau n'a qu'une seule adresse IP.

Si le trafic doit être renvoyé à l'hôte, par ex. pour les communications entre applications, il est envoyé à l'adresse localhost. Cette adresse est toujours 127.0.0.1 et est un réseau /8.

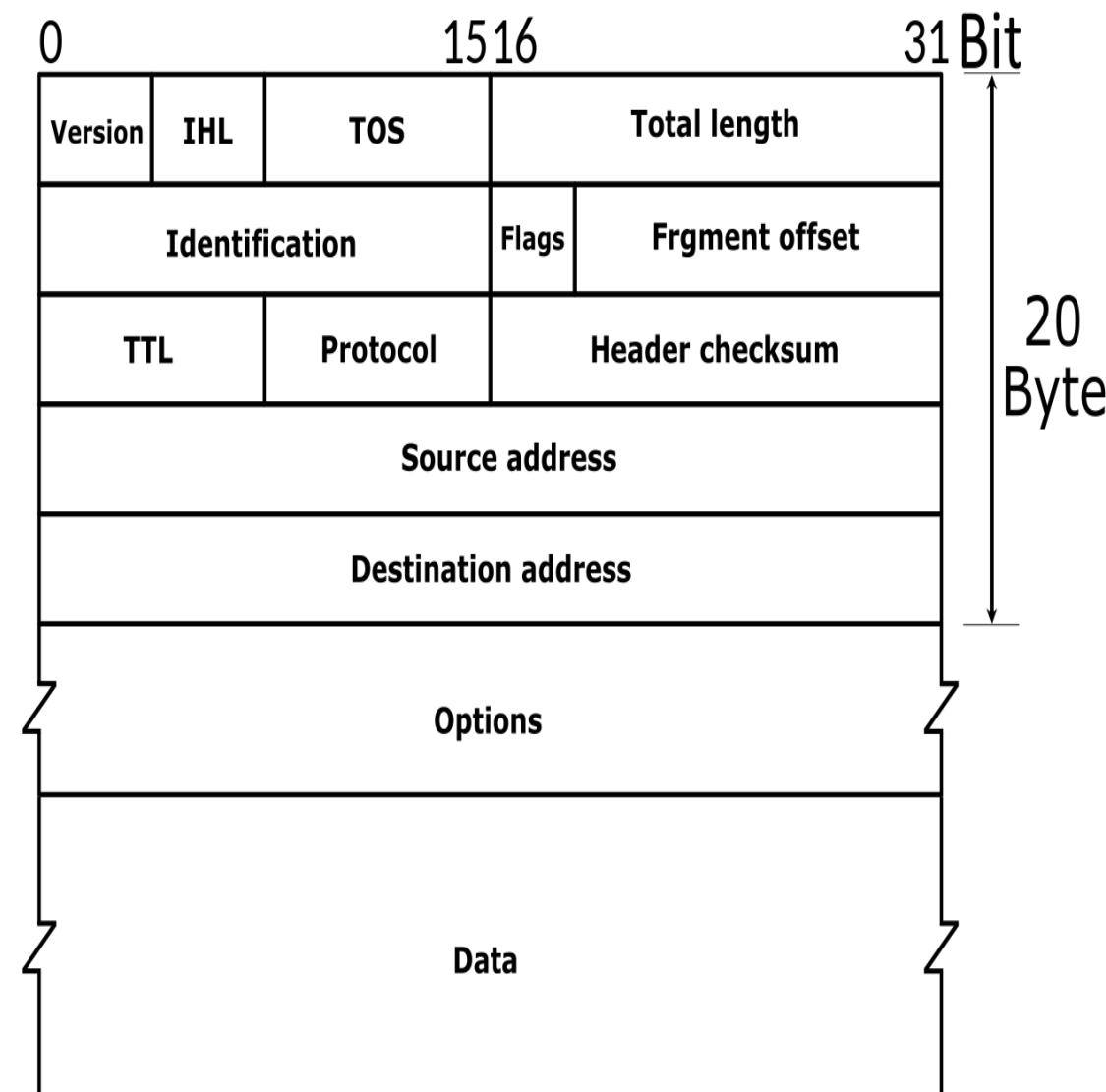


Les paquets sur le réseau

- Les paquets sur le réseau comportent des en-têtes qui décrivent de nombreux détails importants dont nous avons déjà discuté dans le protocole IP. L'en-tête IPv4 ressemble à ceci :
- L'adresse source est l'adresse IP du système qui envoie le paquet et la destination est la personne à qui le paquet est destiné. Il existe également d'autres champs dans l'en-tête qui sont utilisés par les nombreuses fonctionnalités du protocole IP, mais qui sortent du cadre de cette classe d'introduction.

Vous pouvez vérifier votre adresse IP sous Windows en exécutant la commande **ipconfig** dans une fenêtre de ligne de commande. Sous Linux, cela se fait avec la commande `ip addr show` ou **ifconfig**.

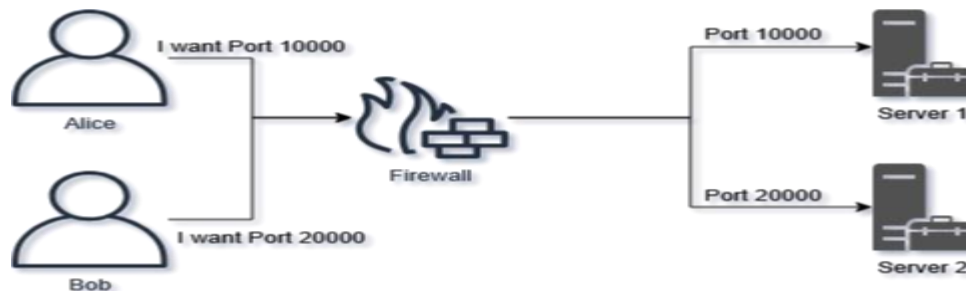
Lorsqu'un ordinateur doit communiquer avec quelque chose qui ne peut pas être trouvé sur le réseau local, il envoie le trafic vers la passerelle par défaut selon la configuration du système. La passerelle par défaut est un routeur capable de transférer le trafic vers l'adresse IP de destination.



NAT ("Network Address Translation")

- NAT permet à un système acceptant des connexions sur une adresse IP publique de mapper ces requêtes à une adresse IP RFC 1918 interne ou vice versa. Les systèmes qui effectuent le NAT sont généralement des pare-feu et des routeurs.

Une implémentation typique de NAT est celle où l'adresse IP externe est utilisée comme façade pour plusieurs adresses IP internes, et le numéro de port de destination est utilisé pour décider à quel serveur les données doivent être envoyées. Cela permet aux adresses IP internes de recevoir le trafic des systèmes externes.



NAT ("Network Address Translation")

- Une autre implémentation très courante consiste à autoriser les adresses IP internes à accéder à Internet avec une adresse IP externe. Le NAT assure le suivi des connexions depuis les adresses internes vers les adresses de destination et transfère le trafic à travers les connexions.

NAT peut être configuré de plusieurs manières, mais dans ce cours, nous n'entrerons pas dans les détails de la méthode.

Remarque : NAT permet aux ingénieurs réseau d'être plus flexibles dans leurs déploiements, permettant ainsi le déploiement de nombreux cas d'utilisation différents.

ICMP

- ICMP est souvent associé à Ping et Traceroute. ICMP peut être utilisé pour d'autres choses, comme demander son heure à un nœud, ce que l'on appelle une demande d'horodatage ICMP. Une requête ICMP Timestamp permet simplement, par ex. un routeur pour demander à un autre routeur de synchroniser son heure, un attribut important dans les communications réseau.
- Une tactique courante utilisée par les attaquants pour vérifier si des systèmes sont disponibles sur un réseau consiste à effectuer un balayage Ping. Le but d'une telle activité est de faire en sorte que le périphérique cible situé à portée du réseau réponde aux requêtes ping afin que l'attaquant sache qu'il est disponible.
- Cette approche est naïve car de nombreux systèmes bloquent par défaut les pings entrants.

Traceroute

- Le tracerouting est un moyen de déterminer quels routeurs sont impliqués dans l'envoi d'un paquet du système A vers B. Savoir quels routeurs empruntent nos paquets peut être utile à la fois pour mieux comprendre nos réseaux et également pour comprendre la surface d'attaque. Un routeur est chargé d'acheminer le colis dans la bonne direction. Imaginez cela comme une conduite sur une route, où les panneaux routiers aux intersections vous guident vers la destination. Ces panneaux aux intersections représentent les routeurs. Traceroute identifie ces panneaux et intersections et vous indique leur distance, mesurée en millisecondes (ms).
- Les en-têtes IPv4 TTL et IPv6 Hop Limit ont la même fonction. Chaque routeur qui achemine un paquet décrémentera cette valeur de 1, et si la valeur atteint 0, le routeur éliminera le paquet et renverra un paquet ICMP Time Exceeded à l'expéditeur.
- Pour effectuer un traceroute sous Windows :
 - `tracert google.com`
- Pour effectuer un traceroute sous Linux (non installé par défaut) :
 - `traceroute google.com`
- Le processus de tracerouting via ces outils est simple :
- Le système d'exploitation envoie un paquet google.com, la valeur TTL est définie sur 1.
- Le paquet est acheminé sur le réseau et le premier routeur décrément la durée de vie de 1, la laissant à 0. Cela amène le routeur à abandonner le paquet et à renvoyer « ICMP Time Exceeded » à la source.
- Le client augmente le TTL 1, permettant au paquet d'être acheminé via un saut supplémentaire.
- Ce processus est répété, augmentant le TTL de 1 jusqu'à ce que la destination soit atteinte.

DNS ("Domain Name System")

- Le DNS est utilisé pour mapper les applications, via des noms, aux adresses IP. Par exemple, si vous souhaitez utiliser votre navigateur pour visiter <http://google.com>, le navigateur doit d'abord adresser une requête à un serveur DNS pour résoudre l'adresse IP derrière google.com.

Les systèmes sont généralement configurés avec un serveur de noms de domaine principal et secondaire. Ces paramètres peuvent être configurés manuellement ou être fournis par un serveur DHCP. Cela permet à nos systèmes informatiques d'atteindre un serveur DNS pour que le problème soit résolu à notre place.

Le serveur DNS se charge alors de résoudre la requête. Il procédera ensuite à la vérification de son propre cache pour voir s'il connaît déjà la réponse. Chaque réponse DNS peut être mise en cache, c'est-à-dire stockée temporairement pour accélérer les requêtes futures, pendant un certain TTL (« Time To Live »). La durée de vie est généralement définie sur quelques minutes, par exemple 10 minutes.

Si un serveur DNS n'a pas de réponse dans son cache, il procédera alors à vérifier qui est responsable de donner la réponse. Cela se fait via un processus récursif qui consiste à demander à un système hiérarchique de serveurs de noms qui feront inévitablement en sorte que la requête DNS aboutisse au serveur de noms faisant autorité.

Test DNS

- Vous pouvez maintenant essayer de faire une recherche DNS avec Windows ou Linux. À partir d'un terminal de ligne de commande sous Windows, tapez nslookup UMP.AC.MA ou sous Linux, tapez dig FSO.UMP.AC.MA. Vous devriez voir un résultat comme celui-ci :

```
C:\WINDOWS\system32\cmd.exe
Serveur : inwi4g.home
Address: fe80::e034:e6ff:fe1e:eec0

*** inwi4g.home ne parvient pas à trouver fso.ump.ac.ma : Non-existent domain

C:\Users\serrh>nslookup fso.ump.ac.ma
Serveur : inwi4g.home
Address: fe80::e034:e6ff:fe1e:eec0

*** inwi4g.home ne parvient pas à trouver fso.ump.ac.ma : Non-existent domain

C:\Users\serrh>
C:\Users\serrh>nslookup ump.ac.ma
Serveur : inwi4g.home
Address: fe80::e034:e6ff:fe1e:eec0

Nom : ump.ac.ma

C:\Users\serrh>nslookup google.fr
Serveur : inwi4g.home
Address: fe80::e034:e6ff:fe1e:eec0

Réponse ne faisant pas autorité :
Nom : google.fr
Addresses: 2a00:1450:4003:801::2003
216.58.215.131

C:\Users\serrh>
```

DHCP ("Dynamic Host Configuration Protocol")

- Comme son nom l'indique, le protocole DHCP permet à n'importe quel système d'un réseau d'accéder à un serveur et de recevoir une configuration. Une telle configuration implique généralement la réception de l'adresse IP et de la plage réseau, de la passerelle par défaut et des serveurs DNS.

DHCP permet une gestion facile des clients rejoignant et quittant un réseau.

Si vous êtes curieux de savoir si vous utilisez DHCP actuellement, vous pouvez taper `ipconfig /all` sur un système Windows et rechercher « DHCP activé : Oui » dans la sortie. Votre ordinateur peut avoir plusieurs interfaces réseau

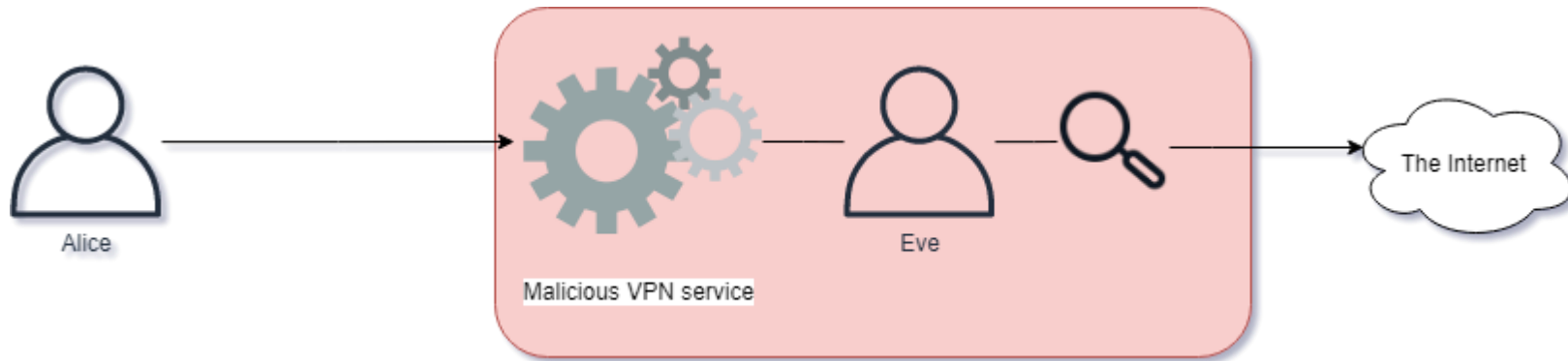
VPN ("Virtual Private Network")

- Un VPN est un système qui permet à deux systèmes d'établir des formes cryptées pour la communication, permettant ainsi de crypter le trafic réseau en transit. De nombreux VPN sont une architecture client à serveur, permettant au client d'accéder à plusieurs services derrière le VPN. Les VPN hébergés sur votre lieu de travail sont également susceptibles de fournir un accès à des ressources autrement uniquement accessibles de l'intérieur.
- Certains services VPN sont conçus pour assurer la confidentialité des utilisateurs et le cryptage des données en transit. Ces services permettent aux utilisateurs d'envoyer des données réseau via le VPN, masquant ainsi efficacement l'adresse IP de l'utilisateur lors de la navigation sur Internet.



VPN

- Il est généralement recommandé d'utiliser des VPN pour sécuriser vos communications réseau, mais nous ne devons utiliser aucun type de service VPN. Les services VPN gratuits peuvent parfois être malveillants, inspectant, lisant et stockant vos données sensibles.



Cyber Security Network Transport

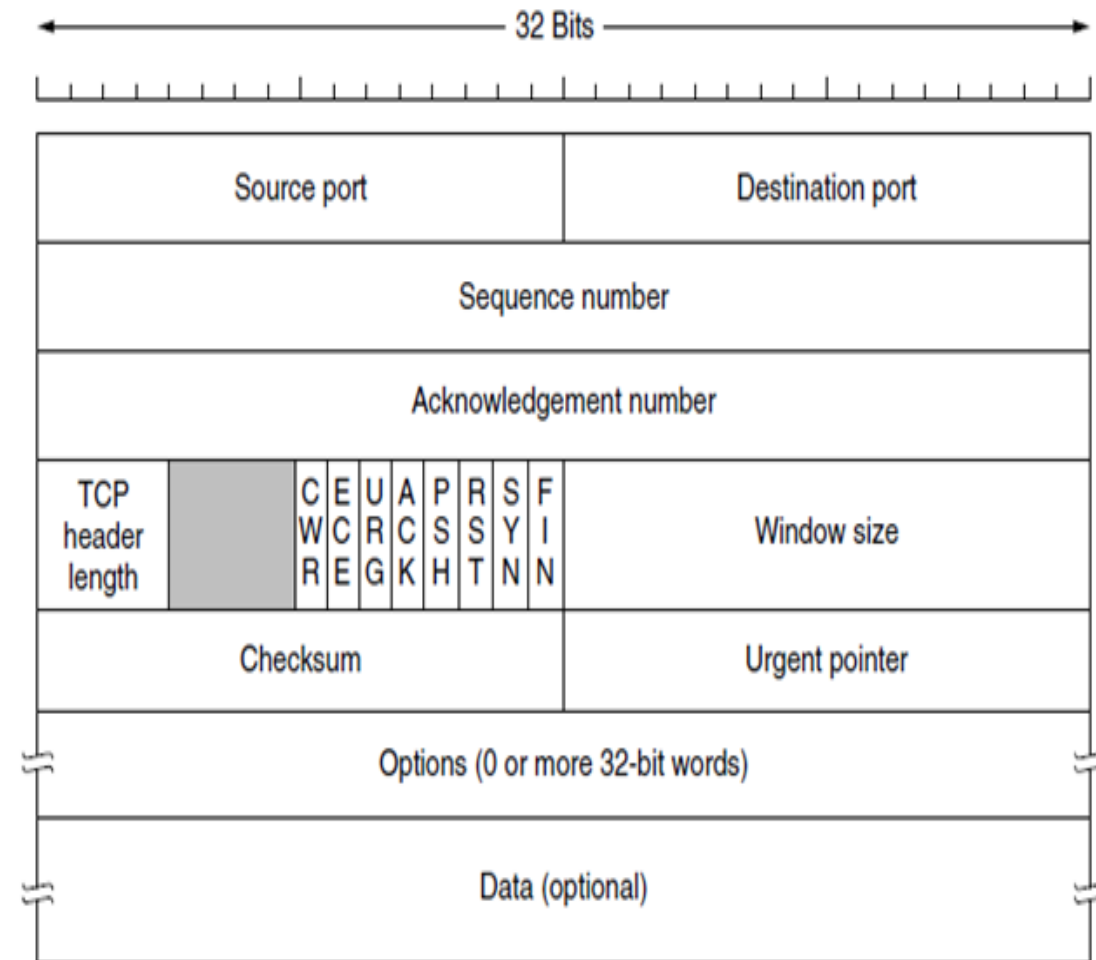
- Couches de transport et de liaison approfondies
- Les systèmes informatiques doivent souvent communiquer avec d'autres systèmes ; cela se fait en les mettant sur le même réseau. Plusieurs technologies différentes sont en place pour permettre aux ordinateurs de communiquer sur différents types de réseaux. Dans cette section, nous approfondirons les protocoles utilisés dans la plupart des réseaux.

TCP ("Transmission Control Protocol")

- Tout comme IP utilise des adresses IP pour l'adressage, TCP et UDP utilisent des ports. Un port, indiqué par un nombre compris entre 0 et 65535, détermine quel service réseau doit traiter la demande.

Dans l'image ci-dessous, nous pouvons voir un paquet TCP et à quoi il ressemblerait pour toute personne inspectant le trafic sur le réseau.

- Nous pouvons voir le graphique montrant 16 bits pour les ports source et de destination, c'est la même chose pour UDP. Les numéros de séquence et d'accusé de réception sont utilisés dans la négociation à trois et pour transférer des données de manière fiable. Nous pouvons également voir les bits de contrôle utilisés pour indiquer de quel type de paquet il s'agit. Les autres en-têtes jouent également un rôle important, mais en dehors du cadre de sécurité bien sûr.

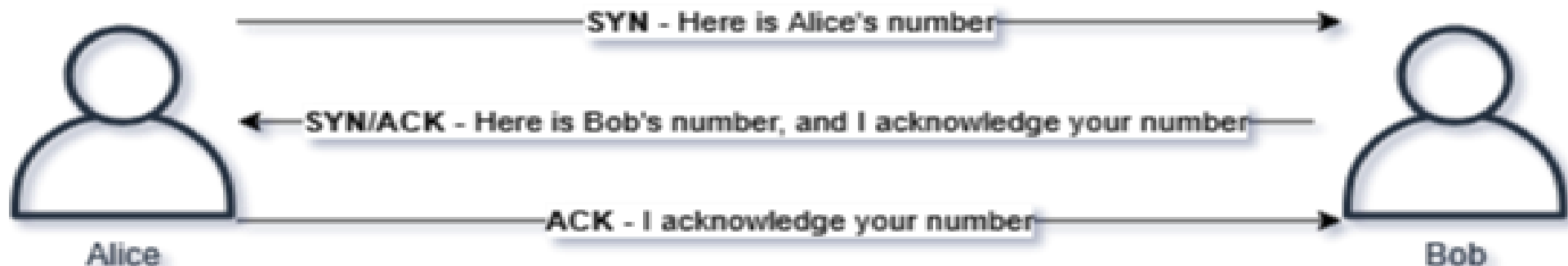


Prise de contact TCP à 3 voies

SYN/ACK

- TCP utilise une négociation à trois pour permettre à deux systèmes d'engager des communications. La poignée de main utilise 32 bits de nombres PRNG (« Pseudo Random Number Generator ») pour établir la poignée de main. La poignée de main confirme que les deux parties ont l'intention de communiquer.

Voici un graphique pour illustrer :

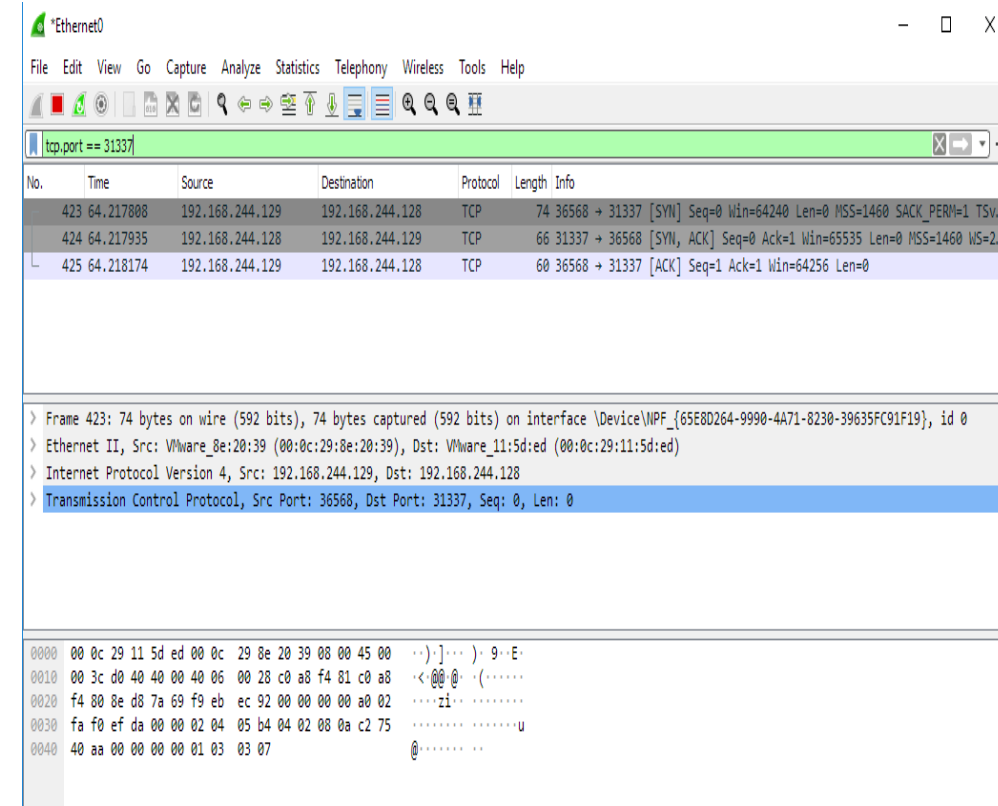


Explication sur la façon dont TCP s'engage dans les communications :

- Le client initie la communication en envoyant un paquet avec le bit de contrôle SYN défini dans l'en-tête, un numéro PRNG dans le champ Numéro de séquence et un port de destination cible. La couche réseau (couche 3) permet au paquet d'être envoyé à un système distant. Ce paquet est appelé paquet SYN.
- Le serveur reçoit le paquet, lit le numéro de séquence du client et rédige une réponse. La réponse définit le champ Acquiescement avec le numéro de séquenceur du client auquel est ajouté le numéro 1. De plus, la réponse contient les bits de contrôle SYN et ACK définis et le numéro de séquence est défini sur le numéro PRNG du serveur.
- Ce paquet est appelé paquet SYN/ACK.
Le client reçoit le paquet SYN-ACK et, pour terminer la prise de contact, renvoie un paquet avec le bit de contrôle ACK défini. Le paquet final confirme également le numéro PRNG du serveur en le renvoyant dans le champ Accusé de réception de l'en-tête.

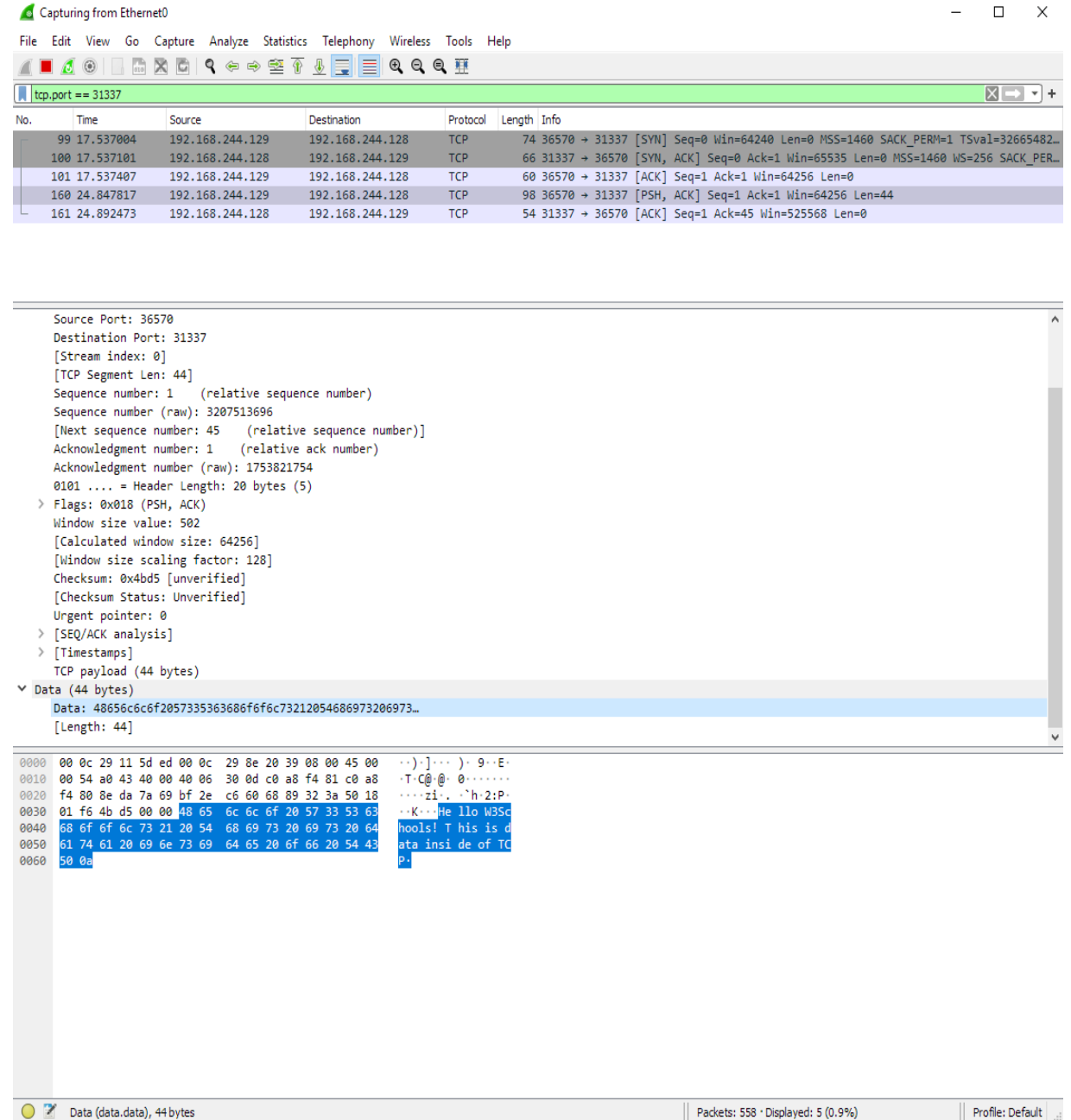
Interception Paquets Wireshark

- Dans l'image suivante, nous pouvons voir deux hôtes effectuer la négociation à trois :
- La capture d'écran montre l'outil Wireshark utilisé pour capturer et inspecter les paquets.
- Wireshark est un très bon utilitaire car il nous permet de visualiser les paquets et de les inspecter plus en profondeur. La capture d'écran montre 3 paquets représentant la poignée de main à 3 voies.
- Notez les colonnes source et destination représentant les deux parties communiquant. Le champ Info affiche le port source et de destination, y compris (entre crochets) le SYN, SYN/ACK et ACK.

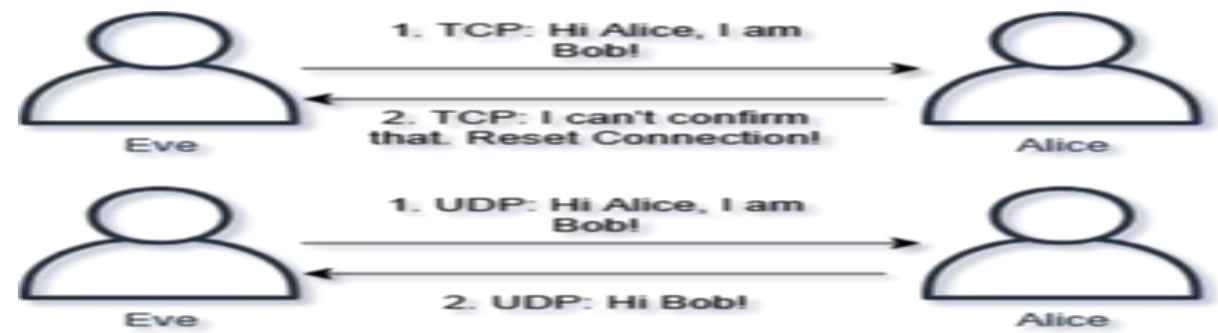


Wireshark

- La capture d'écran suivante montre les données communiquées entre les parties après la poignée de main à trois. Les données contenues dans le paquet TCP ont été mises en évidence en bas de l'image.



Spoofting Traffic



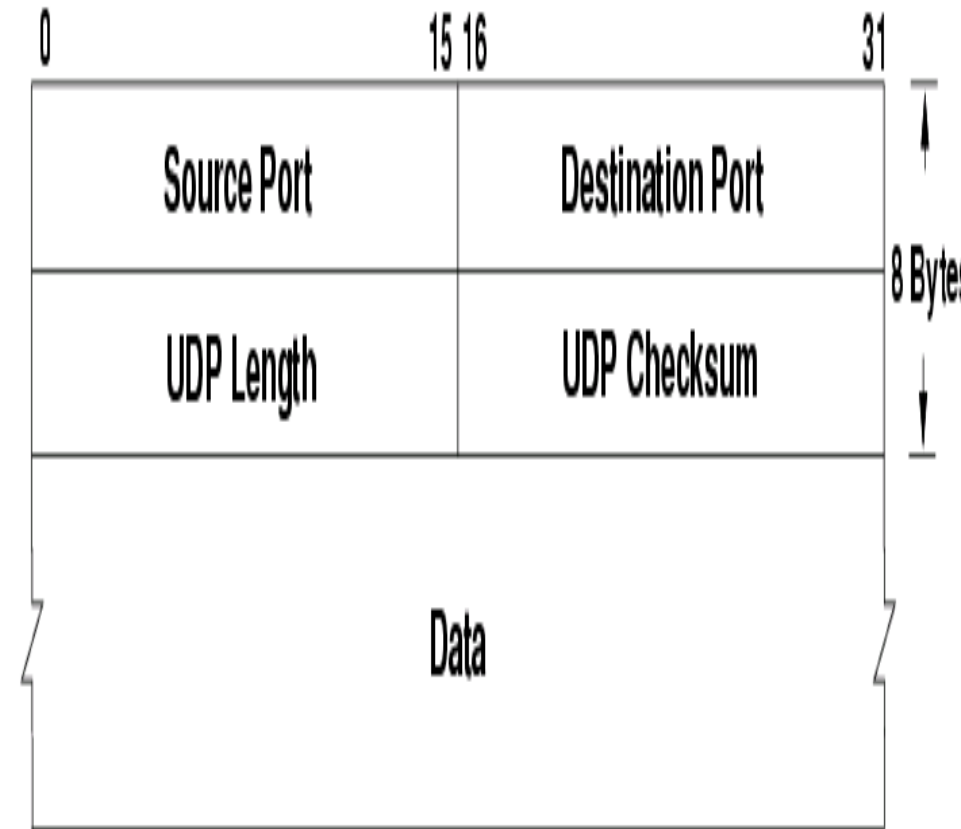
- Il existe aujourd'hui peu de restrictions sur les réseaux permettant à quiconque de créer des paquets à sa guise. N'importe qui peut créer des paquets avec n'importe quel champ d'en-tête défini sur la valeur de son choix. C'est ce qu'on appelle l'usurpation d'identité, qui permet aux attaquants d'envoyer du trafic pour le compte d'autrui.
- TCP a une sécurité intégrée au protocole, mais elle repose sur la puissance des générateurs de nombres PRNG (« Pseudo Random Number Generator »). Si les numéros de séquence des parties communicantes peuvent être devinés, la sécurité de TCP peut être compromise dans le sens où un attaquant peut s'engager dans des communications usurpées via TCP.
- De nombreux protocoles sont facilement falsifiés, mais TCP offre une certaine résilience contre cela. Les protocoles tels que UDP et ICMP n'offrent pas une protection similaire.
- L'usurpation de paquets est généralement effectuée par des attaquants disposant des capacités root/système, c'est-à-dire les privilèges les plus élevés sur le système d'exploitation. La raison en est que les systèmes d'exploitation imposent l'utilisation d'API qui obligent l'utilisateur à se conformer aux règles de communication spécifiées dans les RFC ("Request For Comments"). Si l'attaquant ne dispose pas des privilèges les plus élevés, il ne pourra pas créer ses propres paquets sur le réseau.

UDP ("User Datagram Protocol")

- UDP est utilisé pour le trafic qui n'a pas besoin de la résilience et de la sécurité de TCP, généralement des applications telles que la VOIP, mais dans le monde moderne, de plus en plus d'applications utilisent UDP pour prendre en charge un transfert rapide de paquets avec une résilience et une sécurité intégrées aux niveaux supérieurs du modèle OSI ; QUIC en est un exemple.

En regardant l'en-tête UDP, nous pouvons voir les mêmes ports source et destination utilisés, mais aucun numéro de séquence ni bit de contrôle. Le protocole entraîne beaucoup moins de surcharge, ce qui conduit à une transmission plus rapide des données.

- Étant donné qu'UDP ne dispose pas de fonctionnalités telles que 3-Way-Handshake, UDP peut être facilement usurpé.



Réseaux commutés/ Switched Networks

- Les systèmes sont connectés à un LAN (« Local Area Network ») via un Switch. Les commutateurs utilisent des adresses MAC (« Media Access Control ») pour l'adressage, et non l'adresse IP la plus connue. Permet de transférer le trafic sur les réseaux locaux, c'est-à-dire votre réseau domestique ou au sein des succursales de votre organisation. Les adresses MAC sont conçues pour être uniques, mais n'importe qui peut modifier son adresse MAC à condition de disposer des droits d'administrateur.

L'adresse MAC définie par 6 octets, par exemple : FC:F8:AE:12:34:56

Les trois premiers octets représentent l'organisme qui a fabriqué le dispositif communicant, appelé OUI (« Organizational Unique Identifier »). L'adresse MAC ci-dessus est attribuée à Intel Corporate. Vous pouvez rechercher des adresses MAC à de nombreux endroits, par exemple : <https://www.adminsub.net/mac-address-finder/intel>.

Les trois derniers octets sont déterminés par le fabricant.

ARP

- ARP (« Address Resolution Protocol ») est le protocole qui permet aux systèmes informatiques de savoir quelle adresse MAC appartient à quelle adresse IP. Si le trafic doit être acheminé, le système informatique transmettra le trafic vers la passerelle par défaut configurée sur le système.

ARP, comme DNS, est un protocole qui résout une adresse en une autre. Chaque fois qu'un système tente de communiquer avec une adresse IP située sur le réseau local, il vérifie son cache ARP pour voir si l'adresse a été récemment résolue.

Vous pouvez inspecter votre propre ARP. Exécutez simplement la commande `arp -a` sous Linux ou Windows. Cela révèle avec quels systèmes votre système a récemment communiqué.

```
C:\Users\serrh>arp -a
```

```
Interface : 192.168.8.120 --- 0x15
```

Adresse Internet	Adresse physique	Type
192.168.8.1	e2-34-e6-1e-ee-c0	dynamique
192.168.8.255	ff-ff-ff-ff-ff-ff	statique
224.0.0.22	01-00-5e-00-00-16	statique
224.0.0.251	01-00-5e-00-00-fb	statique
224.0.0.252	01-00-5e-00-00-fc	statique
239.255.255.250	01-00-5e-7f-ff-fa	statique
255.255.255.255	ff-ff-ff-ff-ff-ff	statique

```
Interface : 172.23.64.1 --- 0x28
```

Adresse Internet	Adresse physique	Type
172.23.79.255	ff-ff-ff-ff-ff-ff	statique
224.0.0.22	01-00-5e-00-00-16	statique
224.0.0.251	01-00-5e-00-00-fb	statique
239.255.255.250	01-00-5e-7f-ff-fa	statique
255.255.255.255	ff-ff-ff-ff-ff-ff	statique

```
C:\Users\serrh>
```

VLAN (« LAN virtuel »)

- Le VLAN, souvent appelé VLAN privé, est un moyen permettant à un commutateur d'intégrer des balises (ou un ID de VLAN) dans la trame. Plusieurs commutateurs peuvent alors garantir que les systèmes informatiques du réseau local ne peuvent communiquer qu'avec certains autres systèmes, c'est-à-dire d'autres systèmes utilisant le même ID de VLAN.

Cyber Security Firewalls /Pare-feu

- Pare-feu : Les pare-feu sont un élément architectural central de tout réseau. Ils sont conçus pour empêcher tout trafic réseau d'entrer, à l'exception du trafic que nous autorisons. Les pare-feu fonctionnent sur la couche 4, contrôlant généralement l'accès TCP et UDP aux actifs internes. Les pare-feu de nouvelle génération fonctionnent sur toutes les couches du modèle OSI, y compris la couche 7.

Trafic entrant dans un réseau, par ex. via un pare-feu, est appelé trafic entrant. Le trafic qui part est appelé sortie.

- Pare-feu de couche 4
Le pare-feu traditionnel est un pare-feu de couche 4 doté de fonctionnalités telles que :
 - NAT
 - Routage
 - Bloquer ou autoriser le trafic
 - Suivre les connexions réseau actives
 - Prise en charge des connexions VPN
- Ces pare-feu sont généralement moins chers et offrent plus de débit sur le réseau qu'un pare-feu de nouvelle génération plus moderne.

NGFW ("Next-Generation Firewalls") (« Pare-feu de nouvelle génération »)

- Un pare-feu moderne a des capacités bien plus étendues qu'un pare-feu de couche 4. Ces fonctionnalités sont généralement des fonctionnalités de sécurité.

Un pare-feu NGFW peut également suivre les connexions réseau actives, mais est également généralement capable de suivre :

Localisations via des bases de données de géolocalisation. Cela signifie que le pare-feu peut bloquer ou autoriser des actions en fonction de l'emplacement des utilisateurs. Les services de localisation ne sont pas toujours précis et peuvent souvent être facilement contournés à l'aide de services VPN ou d'autres services tels que des stations de saut pour des attaques.

Utilisateurs

Applications

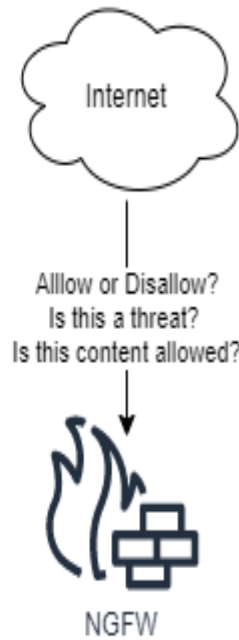
Séances

Ports et services

Adresses IP

Les autres fonctionnalités d'un NGFW

- Les autres fonctionnalités d'un NGFW incluent :
- Identifiez et contrôlez les applications sur le réseau.
- Il peut être virtualisé pour fonctionner comme un pare-feu logiciel.
- Offre souvent une gestion simple et intuitive.
- Prend en charge la protection contre les menaces connues via (« Système de prévention des intrusions »).
- Potentiel de détection et de prévention des menaces inconnues via des solutions de sandboxing.
- Offre la possibilité de gérer un trafic inconnu, par ex. trafic qui ne peut être attribué à une application.
- Capacités de terminer et d'inspecter le trafic crypté.
- Peut contrôler les utilisateurs, pas seulement le système via les adresses IP respectives.
- Les fonctionnalités fournies par votre NGFW dépendent souvent en grande partie des licences achetées et de la capacité du matériel exécutant le pare-feu.



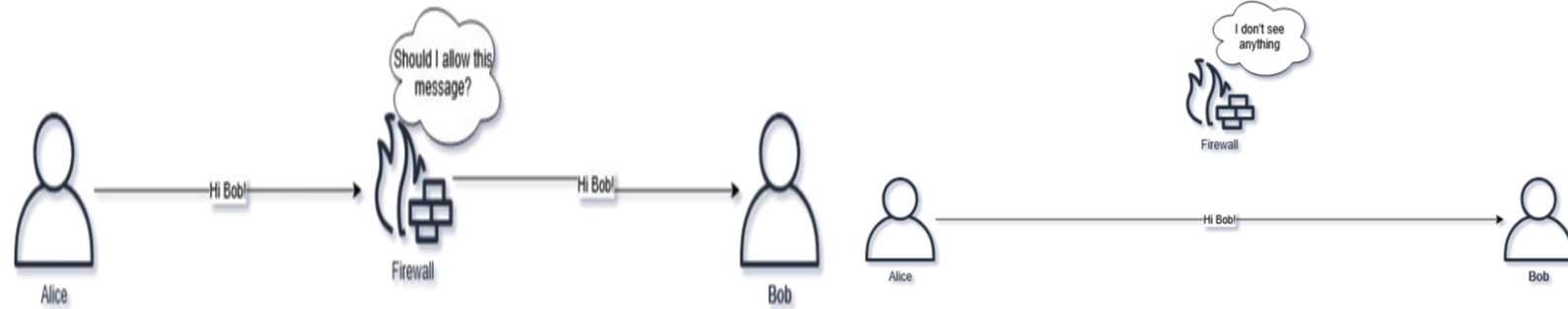
Firewall Administration

- Administration du pare-feu

Un pare-feu peut généralement être administré via une application de gestion propriétaire ou via un navigateur Web accédant à la gestion du pare-feu via HTTP.

Les ports de gestion des pare-feu, y compris les autres services de gestion d'une organisation, devraient idéalement être séparés de l'accès des utilisateurs réguliers. Idéalement, la segmentation des services de gestion est connectée à un annuaire d'utilisateurs d'une organisation, par exemple Active Directory pour les environnements Windows.

Segmentation



- Les pare-feu peuvent segmenter le trafic entre les hôtes et les systèmes en segments, parfois appelés zones. Chaque segment contient des services autorisés à communiquer entre eux.
- Toute connexion vers ou depuis le segment doit être soigneusement contrôlée par le pare-feu, empêchant toute connexion non autorisée d'établir des connexions réussies. Les segments plus petits offrent plus de ségrégation, mais nécessitent plus de gestion.

Sans aucune segmentation, les utilisateurs et les systèmes peuvent communiquer directement entre eux sans l'application de pare-feu. C'est ce qu'on appelle un réseau plat.

- En ajoutant plus de segmentation, nous pouvons imaginer des segments représentant des services, où chaque segment est un service fourni dans l'organisation. Chaque segment pourrait contenir les différents serveurs chargés de rendre le service opérationnel. Les communications au sein du segment sont autorisées, mais tout accès entrant et sortant du segment est contrôlé par le pare-feu.

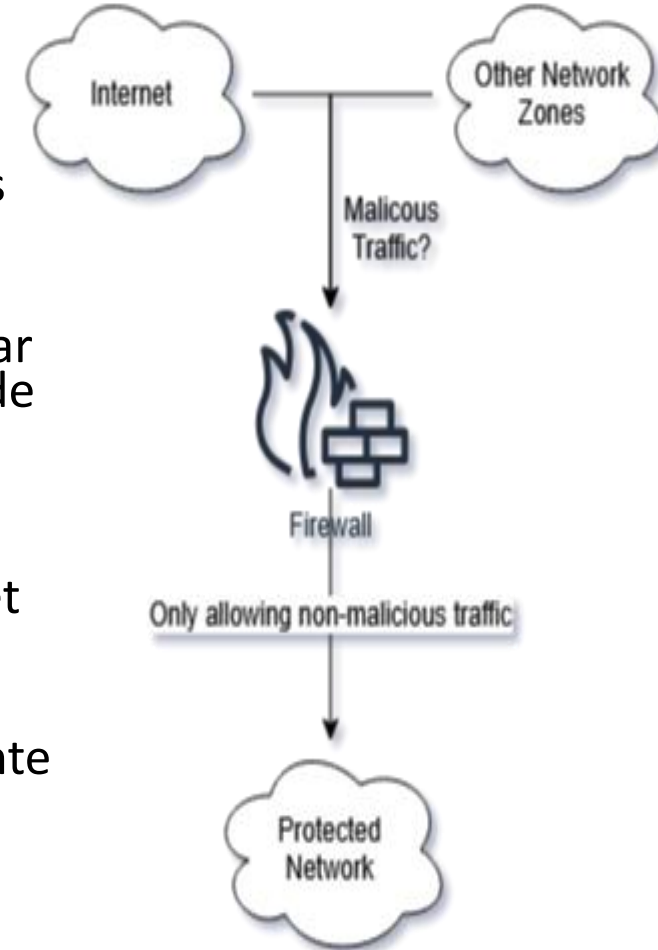
Une autre idée de segmentation consisterait à contrôler les segments en fonction de leurs fonctions, par exemple en regroupant des applications Web au sein d'un segment avec d'autres applications Web, des bases de données au sein d'un segment et d'autres types de services au sein de leur segment.

IPS ("Intrusion Prevention System") et IDS ("Intrusion Detection System")

- Parfois, les systèmes IPS et IDS sont déployés en tant que systèmes autonomes sur le réseau, mais très souvent ils sont inclus dans un NGFW.

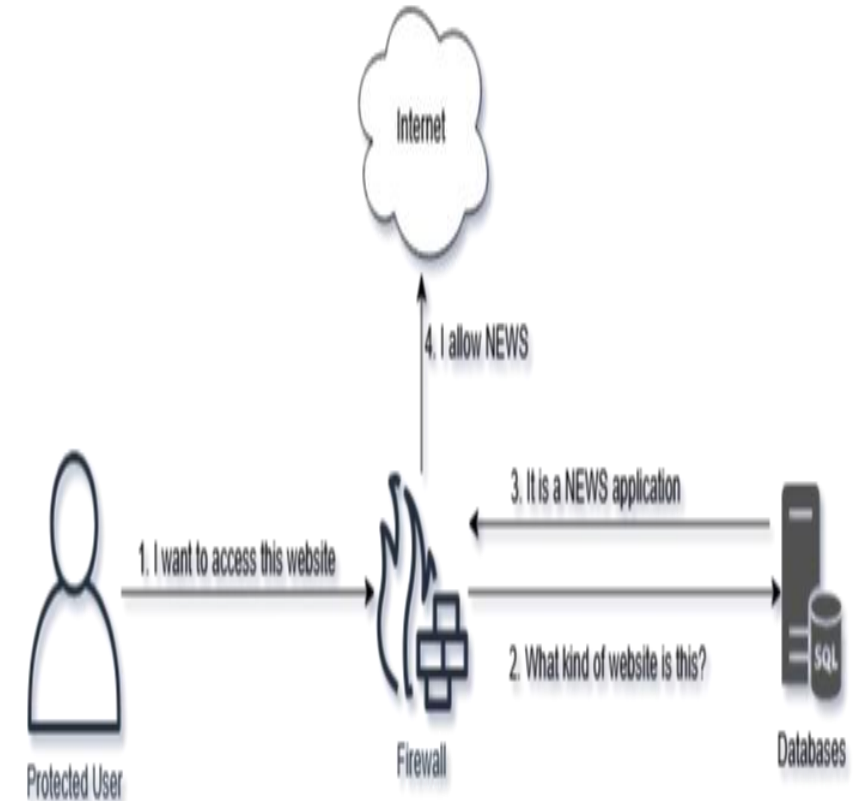
Les systèmes IPS et IDS disposent de signatures, d'algorithmes et d'heuristiques pour détecter les attaques sur le réseau ou l'hôte. Un IDS ou IPS déployé sur un hôte est appelé un HIDS (« Host Intrusion Detection System »).

- Dans ce cours, les termes IDS et IPS sont utilisés de manière interchangeable, car la différence entre eux est souvent simplement une question de configuration de leur fonctionnement. Un système IPS est positionné de manière à pouvoir détecter et bloquer les menaces, tandis qu'un système IDS est uniquement capable de détecter les menaces.
- Les systèmes IPS peuvent être utilisés pour détecter et bloquer les attaquants et s'appuient souvent sur des mises à jour et des inspections fréquentes du trafic crypté.
- Remarque : une fonctionnalité très utile d'IDS et d'IPS est la mise à jour fréquente des nouvelles signatures des menaces en développement provenant des fournisseurs. Cela permet aux défenseurs d'être assurés que les nouvelles menaces seront bloquées à mesure que le pare-feu sera mis à jour avec de nouvelles mises à jour.



Filtrage de contenu et d'applications/ Content and Application Filtering

- Le pare-feu peut tenter de comprendre quelles applications et quels contenus traversent le réseau. Une telle détection peut en outre activer d'autres fonctionnalités de sécurité telles que IPS pour protéger les systèmes entre le pare-feu.
- Filtrage d'URL
- NGFW peut également protéger le contenu accessible via HTTP. Le pare-feu peut rechercher des domaines dans une base de données contenant des listes de domaines et leur catégorisation respective. Le pare-feu peut alors imposer que seules les catégories de domaines acceptables soient autorisées par les utilisateurs, par exemple les actualités sont autorisées alors que les jeux de hasard ne le sont pas.



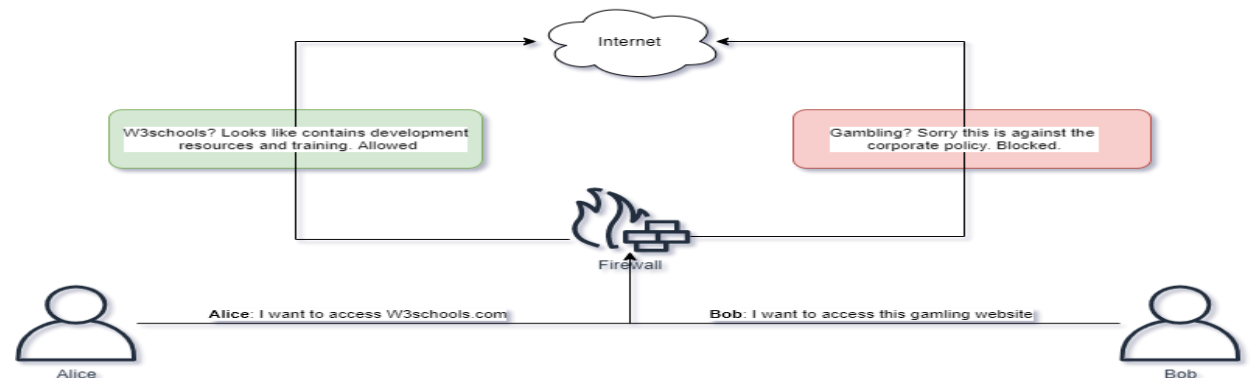
Filtrage de contenu et d'applications/ Content and Application Filtering

- Des éléments tels que l'âge et la validité du domaine pourraient également être vérifiés, empêchant les utilisateurs de visiter des domaines récemment créés et non encore catégorisés, ou vérifiant les activités frauduleuses en analysant le contenu du domaine.

Au lieu de refuser l'accès aux sites Web, le pare-feu pourrait intercepter la demande et renvoyer l'utilisateur vers ce qu'on appelle un portail Web captif. Sur ce portail, l'utilisateur peut être averti d'un danger immédiat ou d'une violation de la politique de l'entreprise, par ex. visiter du contenu inacceptable. Dans certains cas, vous pouvez autoriser l'utilisateur à fournir une raison pour laquelle il doit accéder au contenu, puis le laisser continuer s'il a fourni une raison.

- Les catégories au sein des domaines peuvent être nombreuses, par exemple les sites Web hébergeant du contenu lié à :

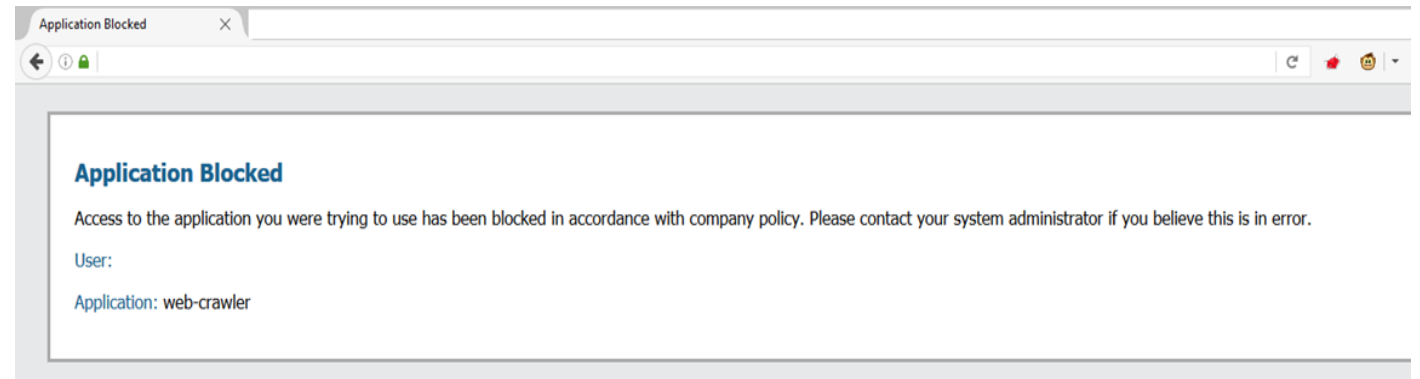
Piratage
Nudité
Violences
Phishing
Rencontres
Messagerie instantanée
Divertissement
Services d'anonymisation



Applications



- Le pare-feu peut tenter de déterminer quelles applications sont utilisées, pas seulement les protocoles. De nombreux protocoles sont capables de transporter d'autres applications, par exemple HTTP peut contenir des milliers d'applications différentes. Un pare-feu peut tenter de décoder les flux réseau sur la couche 4 et tenter de déterminer le contenu présenté sur la couche 7.
- Une capture d'écran montre ce qu'un utilisateur peut voir lorsqu'une application a été bloquée.



Contrôle du contenu

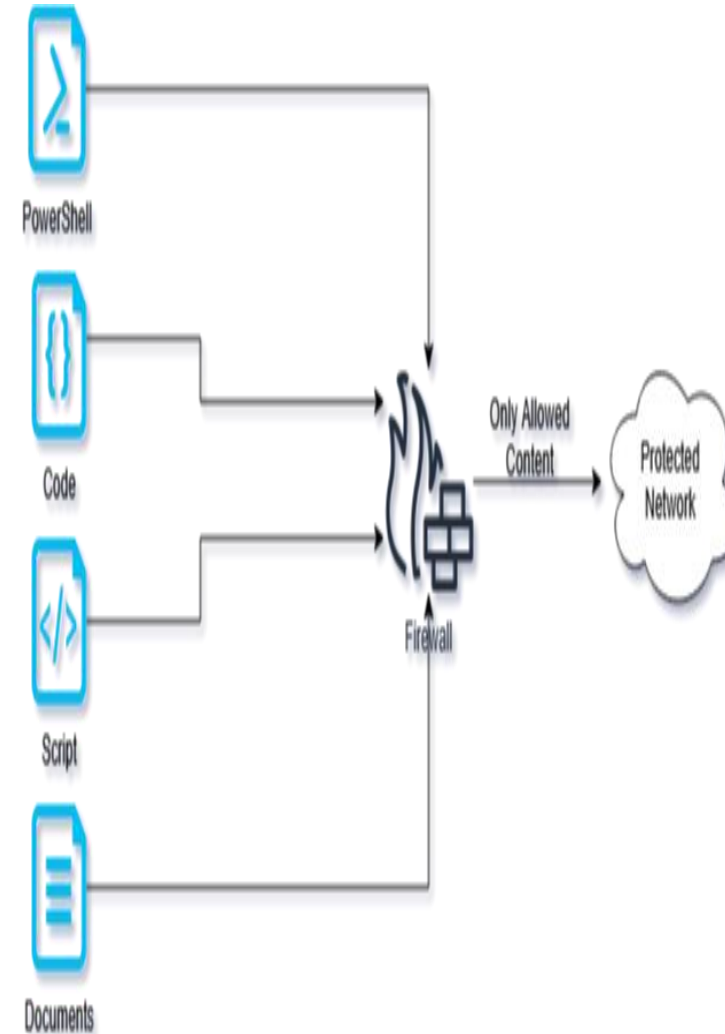
- Au fur et à mesure de l'identification des applications, le pare-feu pourrait tenter de révéler un contenu spécifique au sein des applications, par exemple le contenu en cours de téléchargement :

Documents Word
Exécutables
Code source
Scripts

- Dans ces fichiers, le pare-feu peut tenter d'identifier les logiciels malveillants, les informations propriétaires et confidentielles qui ne sont pas censées quitter le réseau et bien plus encore.

Le pare-feu peut prendre en charge de nombreux protocoles différents et le contenu qui les traverse, par exemple :

HTTP
PME
FTP
IMAP et POP3
SMTP



Sandboxing

- Dans ce contexte, le sandboxing signifie qu'une plateforme exécute des fichiers qui peuvent être malveillants. Le bac à sable enregistre et surveille l'activité du fichier pour voir s'il est malveillant ou non.
- Le sandboxing permet généralement au pare-feu de transférer des fichiers exécutables vers cette plate-forme et d'empêcher les utilisateurs de télécharger le fichier jusqu'à ce qu'un verdict ait été rendu quant à son caractère malveillant ou non.
- Un bac à sable moderne a la capacité d'exécuter des fichiers sur plusieurs plates-formes différentes, par exemple :

Windows 7,8 et 10.
Téléphones Android.
Linux



Sandboxing

- Les fichiers intéressants à exécuter et à explorer dans un bac à sable sont plus qu'un simple fichier exécutable. De nombreux fichiers sont capables d'effectuer des actions malveillantes sur le système d'exploitation de nos utilisateurs :
- Fichiers ZIP avec du contenu à exécuter
- Documents de bureau
- Fichiers PDF
- Applications Java
- Javascript
- Économiseurs d'écran
- Il existe de nombreux bacs à sable en ligne que vous pouvez essayer vous-même, en dehors de ce qu'un NGFW peut fournir :

<https://www.joesandbox.com/>
<https://www.virustotal.com/>
<https://www.hybrid-analysis.com/>
<https://any.run/>

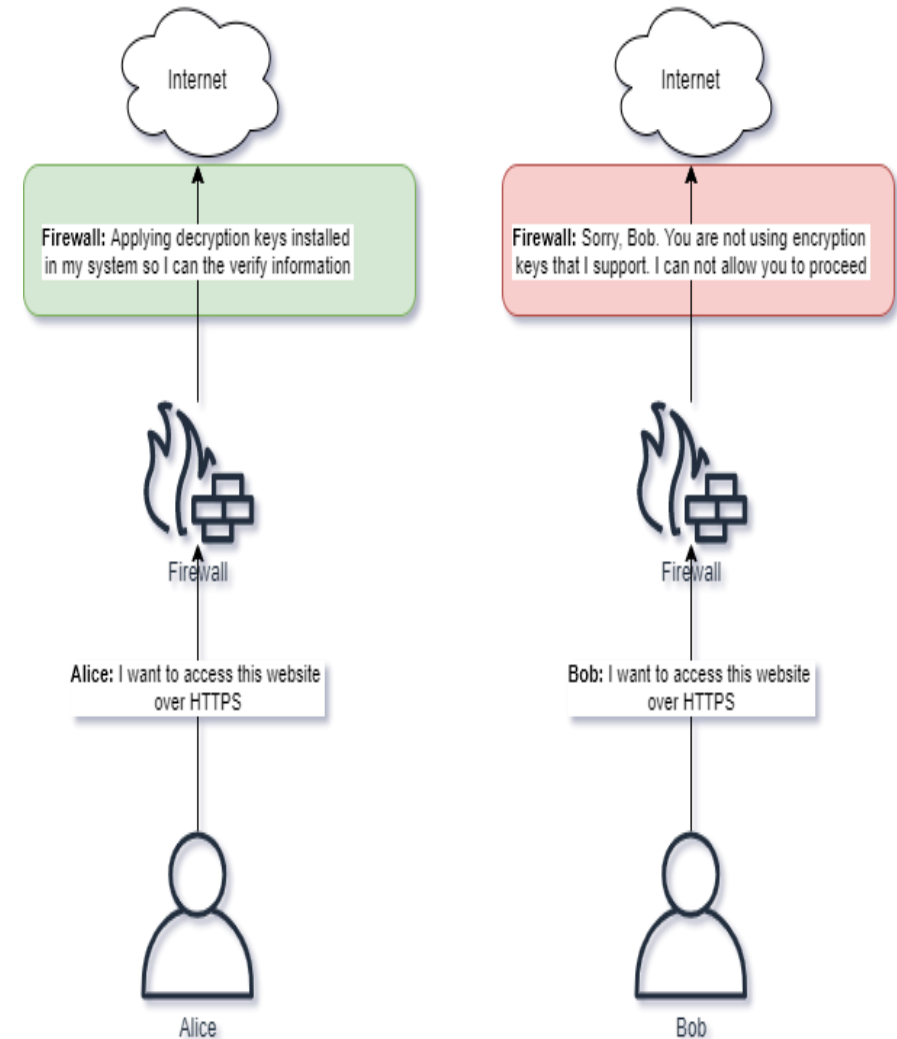
Il existe également des bacs à sable que vous pouvez installer vous-même, par exemple :

<https://cuckoosandbox.org/>

Décryptage du trafic

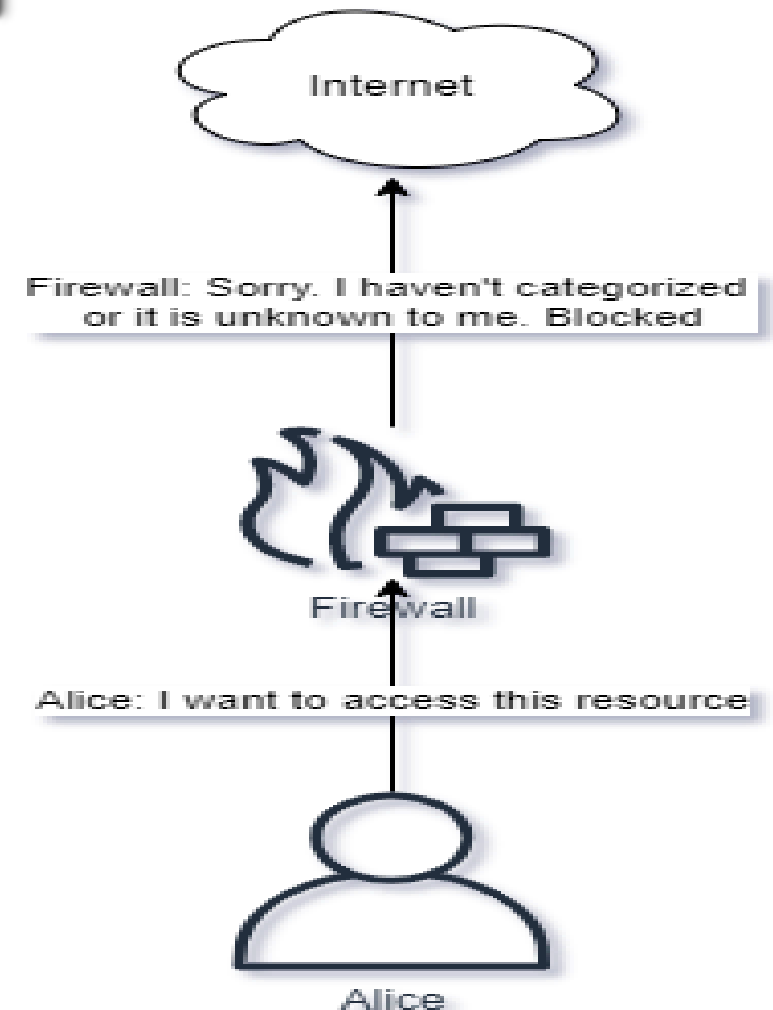
- De nombreux pare-feu prennent en charge l'installation de certificats permettant le décryptage du trafic. Si le contenu est déchiffré, le contenu peut alors être inspecté à la recherche de menaces.
- Le déchiffrement peut avoir lieu sur le trafic de sortie ou d'entrée, ou les deux. Pour le trafic entrant, le pare-feu peut protéger les serveurs contre le trafic entrant. Le trafic de sortie permet au pare-feu de protéger les utilisateurs et les systèmes devant communiquer en sortie.
- Le pare-feu évite souvent de décrypter le trafic tel que les données de santé et financières, car cela peut avoir des implications en matière de confidentialité et autres. Le décryptage du trafic nécessite davantage d'efforts de la part de l'organisation pour distribuer les clés aux clients qui sont utilisées par le pare-feu pour décrypter le trafic.

Remarque : Vous vous souvenez du trafic de sortie et d'entrée ? La sortie signifie le trafic quittant le réseau, tandis que l'entrée signifie le trafic arrivant au réseau.



Trafic inconnu

- Certains trafics ne peuvent pas être déchiffrés ou entièrement compris par le pare-feu. De nombreuses raisons peuvent s'appliquer, par exemple une application propriétaire envoie des données dont le Firewall n'a pas connaissance.
- Ce trafic peut également être classé comme Inconnu. Un administrateur de pare-feu devrait envisager de bloquer ces applications, en particulier celles provenant de réseaux considérés comme à haut risque.



WAF (Pare-feu d'applications Web)

- Bien que les pare-feu puissent faire un travail décent, ils ne comprennent souvent pas pleinement les capacités d'un protocole. Pour cette raison, des pare-feu spécifiques à un protocole sont également développés, WAF étant l'un des plus courants.
- Un WAF offre plus de fonctionnalités spécifiques au protocole HTTP qu'un pare-feu classique, ce qui le rend plus capable de stopper les menaces.
- Bien qu'un WAF tente de faire du bon travail en bloquant les menaces sur HTTP, il fournit souvent d'autres utilitaires très utiles aux organisations, ce qui les rend très viables pour bien plus que le simple blocage des menaces. Voici quelques exemples :
- WAF peut aider à créer une redondance, c'est-à-dire disposer de plusieurs serveurs pour présenter le même service. Cela permet aux organisations de disposer d'un service dans un mode de disponibilité plus élevé, leur permettant de mettre un serveur hors ligne pendant que les autres serveurs sont toujours capables de servir les utilisateurs essayant d'accéder au service. Ceci est utile car des concepts tels que l'application de correctifs nécessitent souvent de redémarrer le service, et la redondance permet aux utilisateurs de toujours accéder au service.
- Un WAF peut aider à appliquer les règles de sécurité des meilleures pratiques, par exemple un endroit unique pour maintenir et appliquer le cryptage, l'authentification multifacteur et d'autres concepts couverts par cette classe.
- Il peut être utilisé pour développer un front unique et un mécanisme de protection pour plusieurs serveurs Web situés derrière le WAF.
- **Remarque :** les WAF sont un pare-feu beaucoup plus spécialisé pour contrer les menaces sur le protocole HTTP. Il contient également généralement des fonctionnalités très pratiques pour les administrateurs.

Cyber Security Web Applications

- Les applications Web font partie intégrante de presque tout ce que nous faisons, qu'il s'agisse d'accéder à Internet ou de contrôler à distance votre tondeuse à gazon. Dans ce cours d'introduction, nous aborderons les bases de la sécurité des applications Web.
- Le protocole HTTP

HTTP est le protocole porteur qui permet à nos navigateurs et applications de recevoir des contenus tels que HTML (« Hyper Text Markup Language »), CSS (« Cascading Style Sheets »), des images et des vidéos.

URL, paramètres de requête

- Pour accéder à une application Web, nous utilisons une URL (« Uniform Resource Locator »), par exemple : <https://www.google.com/search?q=ump+cyber+security&ie=UTF-8>
L'URL vers google.com contient un domaine, un script accessible et des paramètres de requête.

Le script auquel nous accédons s'appelle /search. Le / indique qu'il est contenu dans le répertoire supérieur du serveur sur lequel les fichiers sont servis. Le ? indique les paramètres d'entrée du script et le & délimite les différents paramètres d'entrée. Dans notre URL, les paramètres d'entrée sont :

q: avec une valeur de cybersécurité ump c'est à dire avec une valeur de UTF-8

La signification de ces entrées dépend de l'application du serveur Web à déterminer.

Parfois, vous verrez juste / ou /? indiquant qu'un script a été configuré pour servir à répondre à cette adresse. Généralement, ce script ressemble à un fichier d'index qui intercepte toutes les requêtes à moins qu'un script spécifique ne soit spécifié.

Le schéma est ce qui définit le protocole à utiliser. Dans notre cas il s'agit de la première partie de l'URL : https. Lorsque le schéma n'est pas défini dans l'URL, il permet à l'application de décider quoi utiliser. Les schémas peuvent inclure toute une gamme de protocoles tels que :

HTTP
HTTPS
FTP
SSH

En-têtes HTTP / HTTP Headers

- Le protocole HTTP utilise de nombreux en-têtes, certains personnalisés pour l'application et d'autres bien définis et acceptés par la technologie.

Exemple de requête à <http://google.com>

GET /search?q=ump+cyber+securitycours&ie=UTF-8 HTTP/1.1

Host: google.com

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/87.0.4280.88 Safari/537.36

Accept: image/avif,image/webp,image/apng,image/*,*/*;q=0.8

Referer: https://ump.ac.ma/

Accept-Encoding: gzip, deflate

Cookie: cookie1=value1;cookie2=value2

Explication header

- L'en-tête de la requête spécifie ce que le client souhaite effectuer sur le serveur Web cible. Il contient également des informations indiquant s'il accepte la compression, à quel type de client accède et tous les cookies que le serveur a demandé au client de présenter.
- Les en-têtes de requête HTTP sont expliqués ici :

GET /search... HTTP/1.1 GET est le verbe que nous utilisons pour accéder à l'application. Expliqué en détail dans la section Verbes HTTP. Nous voyons également les paramètres de chemin et de requête et la version HTTP

Host: google.com Cet en-tête indique le service cible que nous souhaitons utiliser. Un serveur peut avoir plusieurs services comme expliqué dans la section sur les VHOSTS.

User-Agent Une application client, qui est le navigateur dans la plupart des cas, peut s'identifier avec la version, le moteur et le système d'exploitation.

Accept Définit le contenu que le client peut accepter

Referer : https://ump.ac.ma/ Si le client a cliqué sur un lien provenant d'un autre site Web, l'en-tête Referer est utilisé pour indiquer d'où vient le client.

Accept-Encoding : gzip, deflate Le contenu peut-il être compressé ou encodé ? Cela définit ce que nous pouvons accepter

Cookie Les cookies sont des valeurs envoyées par le serveur lors de requêtes précédentes et que le client renvoie lors de chaque requête ultérieure. Expliqué en détail dans la section État

Explication header

- **Accept:** Définit le contenu que le client peut accepter
Referer : <https://ump.ac.ma/> Si le client a cliqué sur un lien provenant d'un autre site Web, l'en-tête Referer est utilisé pour indiquer d'où vient le client.
- **Accept-Encoding : gzip, deflate** Le contenu peut-il être compressé ou encodé ? Cela définit ce que nous pouvons accepter
- **Cookie** Les cookies sont des valeurs envoyées par le serveur lors de requêtes précédentes et que le client renvoie lors de chaque requête ultérieure. Expliqué en détail dans la section État

Explication de l'en-tête du serveur

- Avec cette demande, le serveur répondra avec des en-têtes et du contenu. Des exemples d'en-têtes sont présentés ci-dessous :

```
HTTP/1.1 200 OK
Content-Type: text/html
Set-Cookie: <cookie value>
<website content>
```

- L'en-tête et le contenu de la réponse déterminent ce que nous verrons dans notre navigateur. Les en-têtes de réponse HTTP sont expliqués comme suit :
- Explication de l'en-tête
HTTP/1.1 200 OK Le code de réponse HTTP. Expliqué en détail dans la section Codes de réponse HTTP
Content-Type : text/html Spécifie le type de contenu renvoyé, par ex. HTML, JSON ou XML
Set-Cookie : toutes les valeurs spéciales dont le client doit se souvenir et renvoyer lors de la prochaine requête

HTTP Verbs

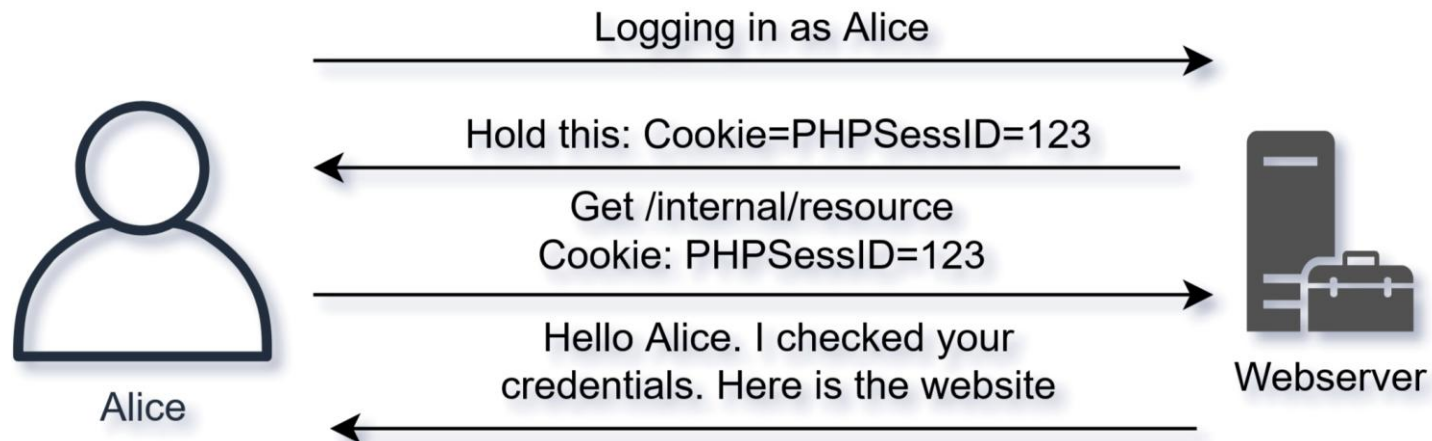
- Lors de l'accès à une application Web, le client est informé de la manière d'envoyer des données à l'application Web. De nombreux verbes peuvent être acceptés par l'application.
- **Verbe utilisé pour http**
 - GET** : Généralement utilisé pour récupérer des valeurs via les paramètres de requête
 - POST**: Utilisé pour envoyer des données à un script via les valeurs dans le corps de la requête envoyée au serveur Web. Cela implique généralement la création, le téléchargement ou l'envoi de grandes quantités de données.
 - PUT**: Souvent utilisé pour télécharger ou écrire des données sur le serveur Web
 - DELETE**: Indique une ressource qui doit être supprimée
 - PATCH**: Peut être utilisé pour mettre à jour une ressource avec une nouvelle valeur

HTTP Response Codes

- L'application exécutée sur le serveur Web peut répondre avec des codes différents en fonction de ce qui s'est passé côté serveur. Vous trouverez ci-dessous les codes de réponse courants que le serveur Web émettra au client et que les professionnels de la sécurité doivent connaître
- Explication du code
 - 200** Demande retournée normalement
 - 301** Le serveur demande au client de se souvenir en permanence d'une redirection vers un nouvel emplacement auquel le client doit accéder
 - 302** Rediriger temporairement. Le client n'a pas besoin d'enregistrer cette réponse
 - 400** Le client a fait une demande invalide
 - 403** Le client n'est pas autorisé à accéder à cette ressource. Une autorisation est requise
 - 404** Le client a tenté d'accéder à une ressource qui n'existe pas
 - 500** Le serveur a commis une erreur en essayant de répondre à la demande

Sessions & State

- il n'existe aucun moyen intégré permettant à un serveur d'identifier un visiteur récurrent en HTTP.
- Pour qu'un serveur Web identifie l'utilisateur, une valeur secrète doit être communiquée vers et depuis le client dans chaque requête. Cela se fait généralement via des cookies dans les en-têtes, mais d'autres moyens sont également courants, par exemple via les paramètres GET et POST ou d'autres en-têtes. La transmission de l'état via les paramètres GET n'est pas recommandée car ces paramètres sont souvent enregistrés sur le serveur ou dans des intermédiaires tels qu'un proxy.



URL Encoding

- Pour qu'une application puisse transférer du contenu en toute sécurité entre le serveur et le client, certains caractères doivent être codés pour garantir qu'ils n'ont pas d'impact sur le protocole. Pour préserver l'intégrité des communications, le codage URL est utilisé.

L'encodage d'URL remplace les caractères non sécurisés par un % et deux chiffres hexadécimaux. Par exemple:

- Le pourcentage est remplacé par %25
- L'espace est remplacé par %20
- Le devis est remplacé par %22

Encode decode URL outil

Pour tester l'encodage URL: <https://gchq.github.io/CyberChef/>

[Download CyberChef](#)  Last build: 3 days ago [Options](#)  [About / Support](#) 

Operations	Recipe	Input
Search...	URL Decode   	Bonjour%20les%20etudiants%20de%20%25%20Genie%20Informatique%20et%20Inform atique%20Appliqu%C3%A9e%20dans%20le%20Cours%20de%20cybersecurite
Favourites 	☒ Treat "+" as space	
To Base64		
From Base64		
To Hex		
From Hex		
To Hexdump		
From Hexdump		
URL Decode		
Regular expression		
Entropy		
Fork		

STEP  **BAKE!** Auto Bake

Output

Bonjour les etudiants de % Genie Informatique et Informatique Appliquée
dans le Cours de cybersecurite

Javascript

- JavaScript

Pour prendre en charge le contenu dynamique, les navigateurs utilisent le langage de script JavaScript. Cela permet aux développeurs de programmer des solutions qui s'exécuteront sur le client, permettant ainsi un contenu Web plus interactif et « vivant ».

Chiffrement avec TLS

- Chiffrement avec TLS

Le protocole HTTP ne prend pas en charge le chiffrement des données en transit, c'est pourquoi un emballage /wrapper autour de HTTP est ajouté pour la prise en charge du chiffrement.

- Ceci est indiqué par un S après HTTP, c'est-à-dire HTTPS.

Le cryptage était autrefois SSL (« Secure Sockets Layer »), mais il est depuis obsolète.

- Au lieu de cela, TLS (« Transport Layer Security ») est généralement utilisé pour appliquer le cryptage.

Cartographie du réseau de cybersécurité et analyse des ports

Cyber Security Network Mapping & Port Scanning

Cyber Security Network

- Si nous voulons défendre, nous devons d'abord savoir quoi défendre. La gestion des actifs s'appuie souvent sur la cartographie du réseau pour identifier les systèmes actifs sur un réseau.

La gestion des actifs et la connaissance de ce que vous exposez sur le réseau, y compris les services hébergés, sont très importantes pour quiconque cherche à défendre son réseau.

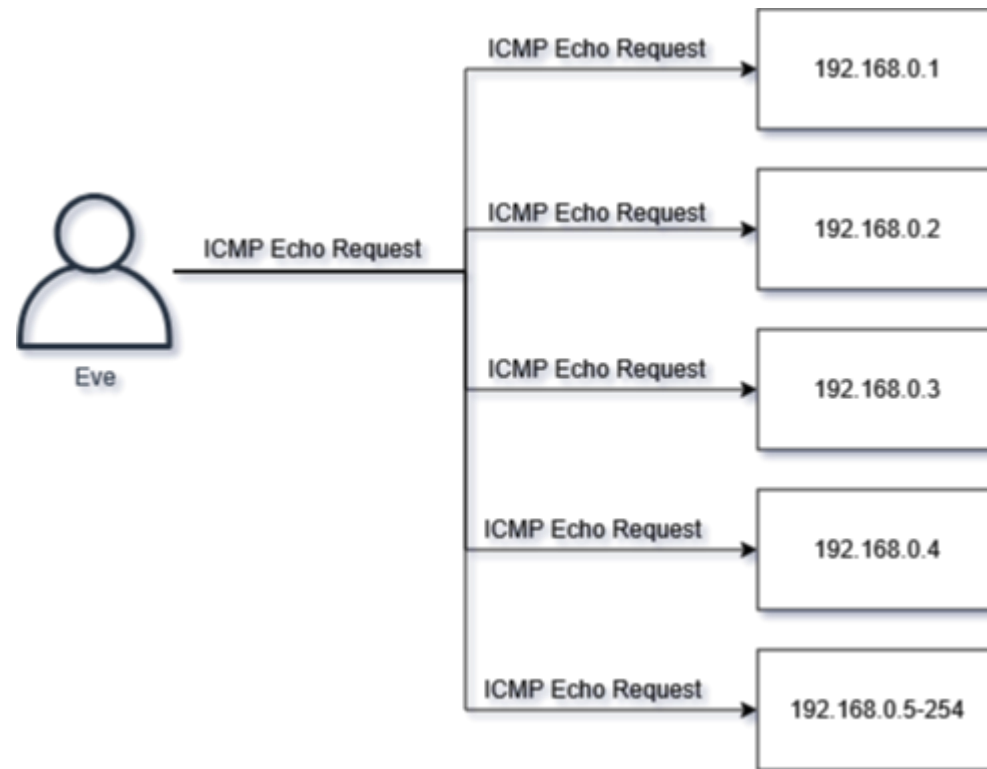
Nmap: Le mappeur de réseau/ The Network Mapper

- Nmap - Le mappeur de réseau

Nmap a longtemps été considéré comme le scanner de ports standard tant pour les ingénieurs réseau que pour les professionnels de la sécurité. Nous pouvons l'utiliser pour découvrir des atouts à attaquer ou à défendre.

Cartographie du réseau/ Network Mapping

- Une façon d'identifier les hôtes actifs sur le réseau consiste à envoyer un ping, c'est-à-dire une demande d'écho ICMP, à toutes les adresses IP du réseau. C'est ce qu'on appelle souvent un balayage Ping.



Cartographie du réseau/ Network Mapping

- Cette approche n'est pas très efficace pour découvrir des actifs. Il est probable que les systèmes du réseau ignorent les pings entrants, peut-être à cause d'un pare-feu qui les bloque ou d'un pare-feu basé sur l'hôte. Un pare-feu basé sur l'hôte est simplement un pare-feu implémenté sur le système plutôt que sur le réseau.
- Une meilleure approche consiste à envoyer différents types de paquets à un système pour essayer de demander n'importe quel type de réponse afin de déterminer si le système est vivant ou non.
- Par exemple, Nmap enverra les paquets suivants au système pour tenter de provoquer une réponse :
- **ICMP Echo Request**
- **TCP SYN packet to port 443**
- **TCP ACK packet to port 80**
- **ICMP Timestamp request**

Nmap : Cartographie du réseau/ Network Mapping

- Sur la base des spécifications TCP, c'est-à-dire des règles de communication, un système doit toujours s'engager dans une négociation à trois avant de commencer à communiquer. Nmap semble enfreindre intentionnellement les règles avec les paquets ci-dessus. Pouvez-vous repérer quel paquet ne se comporte pas comme prévu par les systèmes ?
- L'envoi d'un paquet TCP ACK au port 80 n'est pas conforme aux règles de la norme TCP. Nmap fait cela spécifiquement pour essayer de faire en sorte que le système cible réponde. Afin d'envoyer des paquets qui ne respectent pas les règles, Nmap doit fonctionner avec le niveau de privilèges le plus élevé, par ex. root ou administrateur local. La plupart des scanners de ports seront plus précis pour cette raison.
- La désactivation du mappage réseau peut être effectuée avec Nmap avec l'indicateur -Pn. Nmap considérera désormais que tous les IP/systèmes sont opérationnels et passera directement à l'analyse des ports.
- Attention, si vous travaillez dans un environnement qui n'est le votre obtenez toujours l'autorisation avant de commencer à exécuter des scanners, car vous ne souhaitez enfreindre aucune règle de votre espace de travail.

<https://nmap.org/download#windows>

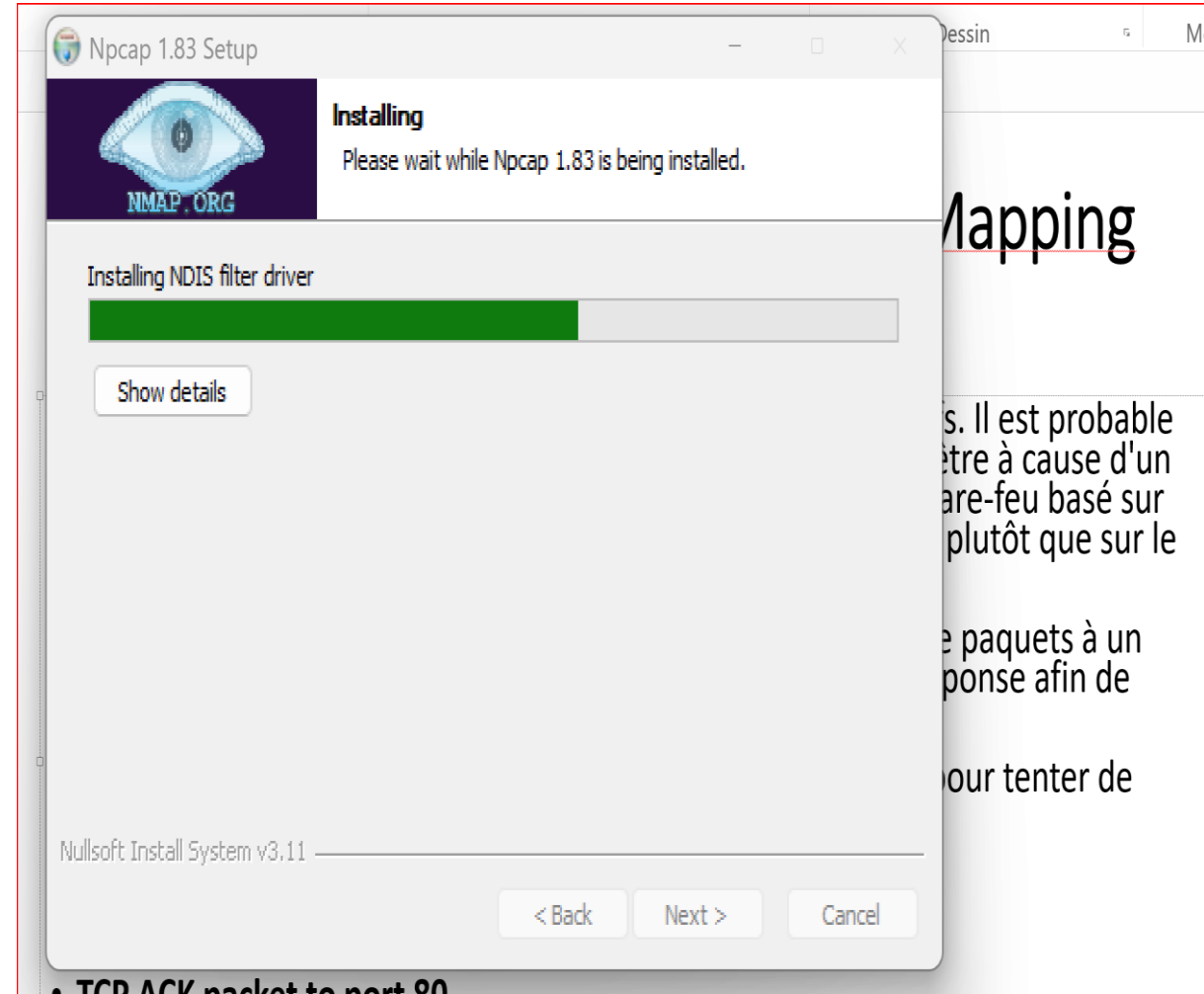
- Pour essayer Nmap maintenant, suivez ces étapes simples :

Allez télécharger Nmap sur <https://nmap.org>. Assurez-vous de télécharger la version qui correspond à votre système d'exploitation

Installez Nmap et lancez l'outil depuis un terminal de ligne de commande

Trouvez votre adresse IP locale et votre sous-réseau

Exécutez Nmap pour l'analyser et voir quels types de systèmes il peut découvrir : `nmap -vv IP/netmask`



Nmap : ligne de command

- Nous ajoutons deux indicateurs -v pour indiquer à Nmap que nous voulons une sortie détaillée, ce qui rend l'analyse plus amusante à regarder pendant qu'elle se termine.

```
Wireless LAN adapter Wi-Fi 2:

Connection-specific DNS Suffix  . : home
IPv6 Address. . . . .           : 
Temporary IPv6 Address. . . . . : 
Link-local IPv6 Address . . . . : fe80::2118:dc0c:2c61:a8cc%21
IPv4 Address. . . . .           : 10.0.0.5
Subnet Mask . . . . .           : 255.255.255.0
Default Gateway . . . . .       : fe80::763a:efff:fe43:4f62%21
                                  10.0.0.138

Ethernet adapter Bluetooth Network Connection 2:

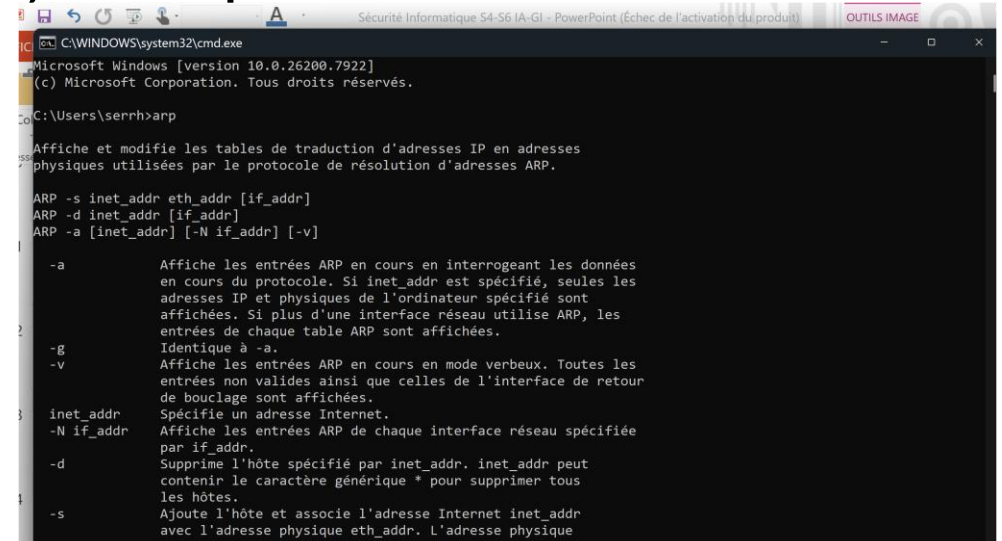
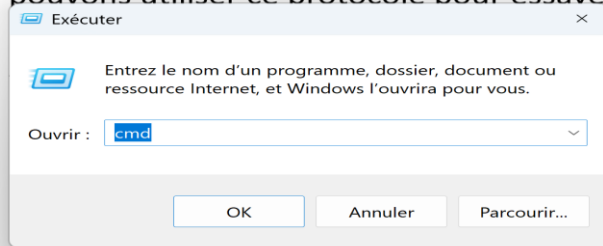
Media State . . . . .           : Media disconnected
Connection-specific DNS Suffix  . : 
PS C:\> nmap -vv 10.0.0.0/24
Starting Nmap 7.91 ( https://nmap.org ) at 2021-02-19 21:04 W. Europe Standard Time
Initiating ARP Ping Scan at 21:04
Scanning 255 hosts [1 port/host]
```

Analyse ARP ARP Scan

- Le protocole ARP est contenu dans un réseau local, mais si les hôtes que vous devez découvrir se trouvent sur le réseau local, nous pouvons utiliser ce protocole pour essayer de révéler les systèmes sur le réseau. En parcourant simplement toutes les adresses IP disponibles sur le réseau LAN avec le protocole ARP, nous essayons de forcer les systèmes à répondre.
- Remarque : L'analyse ARP est un moyen simple et efficace de rechercher des hôtes sur le réseau local, mais pas en dehors du réseau local.

Analyse ARP ARP Scan

- Le protocole ARP est contenu dans un réseau local, mais si les hôtes que vous devez découvrir se trouvent sur le réseau local, nous pouvons utiliser ce protocole pour essayer de révéler les systèmes sur le réseau local. En parcourant simplement toutes les adresses IP disponibles sur le réseau LAN avec le protocole ARP, nous essayons de forcer les systèmes à répondre.

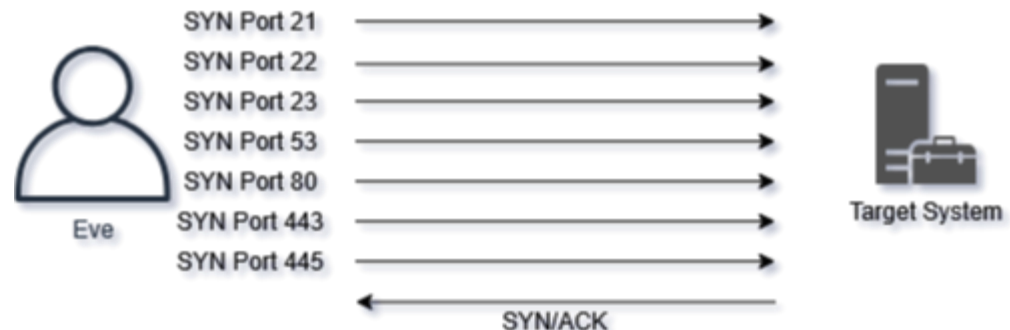


Analyse des ports / Port Scanning

- L'analyse des ports est effectuée pour essayer de déterminer à quels services nous pouvons nous connecter. Chaque service d'écoute fournit une surface d'attaque qui pourrait potentiellement être exploitée par des attaquants. Il est donc important de savoir quels ports sont ouverts.
- Les attaquants souhaitent savoir quelles applications écoutent sur le réseau. Ces applications représentent des opportunités pour les attaquants. Il peut exister des vulnérabilités leur permettant d'attaquer avec succès l'organisation.
- L'analyse des ports fonctionne en envoyant des paquets à une application et en recherchant des réponses. C'est exceptionnellement simple pour TCP, car si un service TCP est disponible, il répondra toujours avec un paquet SYN/ACK. Pour UDP cependant, c'est plus difficile. Afin de détecter si le service est disponible ou non, dans la plupart des cas, l'attaquant doit envoyer une entrée spécifique qui force l'application à répondre. La plupart des applications hébergées dans UDP ne répondront pas à moins que les clients n'envoient exactement l'entrée requise pour engager la communication.

Analyse des ports TCP /TCP Port Scanning

- TCP est un protocole facile à analyser car la norme TCP exige que les systèmes répondent par un SYN/ACK lors de la réception d'un SYN. Nous pouvons envoyer un paquet SYN à tous les 65 536 ports, enregistrer tous les retours SYN/ACK et conclure les ports ouverts en fonction de la réponse d'un SYN/ACK. Lorsqu'aucune réponse n'est reçue, nous pouvons supposer que le port est fermé ou filtré par exemple un pare-feu.
- Avec le SYN/ACK sur le port 445, nous avons identifié que le port est ouvert.



Analyse des ports UDP /UDP Scanning

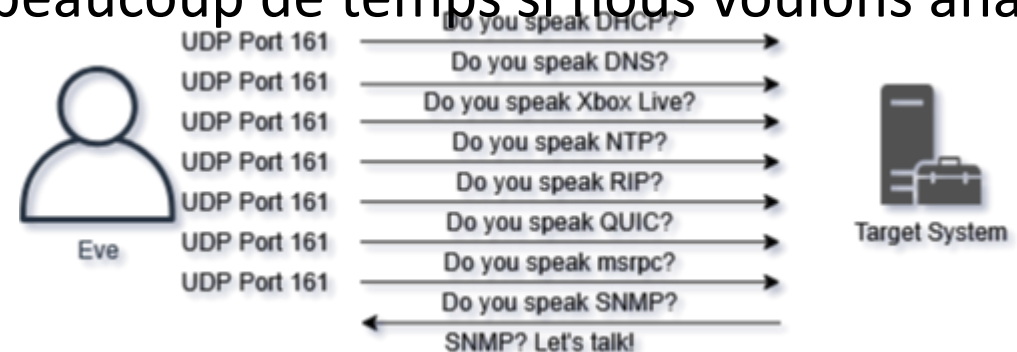
- Avec UDP, il est plus difficile de déterminer si un port est actif ou non. Pour les ports UDP, le scanner ne peut pas s'appuyer sur un SYN/ACK. En fait, le scanner doit presque toujours compter sur le fait que l'écoute du service provoque une sorte de réponse.

Avec autant de ports potentiellement ouverts et différents services ne répondant qu'au bon type de données, il devient long et difficile d'analyser tous les ports dans un délai raisonnable.

Considérez la conversation suivante dans laquelle Eve essaie de déterminer si un port UDP est ouvert :

- Eve doit parler du protocole correct et s'assurer que les paquets atteignent leur destination, par ex. aucune perte de paquets. Sinon, Eve pourrait ne pas découvrir que le port est ouvert.

À cause de cela, l'analyse UDP peut prendre beaucoup de temps si nous voulons analyser tous les ports.



Types et options d'analyse Nmap utiles

- Il existe de nombreux scanners, mais dans cette section, nous nous concentrons sur la manière d'utiliser Nmap au maximum de son potentiel.

Nmap peut être invité à analyser les ports les plus courants avec l'argument `--top-ports`.

- **`nmap --top-ports 100 <target>`**
- Le scanner peut essayer de déterminer les versions de l'application qui écoute derrière un port. This is called service scanning and can be enabled with the `-sV` flag.
- **`nmap -sV <target>`**

Types et options d'analyse Nmap utiles

- Nmap possède de nombreux scripts intégrés conçus pour cibler un service spécifique et interagir avec lui. Les scripts peuvent faire toutes sortes de choses, comme extraire des informations du service ou essayer de les exploiter. Nous pouvons activer le scanner de script avec l'indicateur -sC. Cela permet uniquement des contrôles sécurisés, en tant que tels, aucun déni de service ni tentative d'exploitation.
- **nmap -sC <target>**
- La détection du système d'exploitation peut être effectuée avec le scanner, lui permettant d'essayer de déterminer quel système d'exploitation est en cours d'exécution. Il utilise de nombreux paramètres différents pour essayer de mesurer et d'estimer la probabilité de quel système d'exploitation il s'agit. Cela peut être activé avec l'argument -O.
- **nmap -O <target>**

Types et options d'analyse Nmap utiles

- Le mode agressif de Nmap active plusieurs indicateurs à la fois. Le scanner effectuera la détection de la version et du système d'exploitation, activera le scanner de script et analysera les 1 000 ports les plus courants. Il peut être activé avec l'option -A.
- **nmap -A <target>**
- Nmap peut également analyser IPv6 sur tous les indicateurs ci-dessus. Il est activé en ajoutant l'indicateur -6.
- **nmap -6 <target>**

Nmap Options de synchronisation/ Timing options

- Scanning peut être effectuée à différentes vitesses. Les vitesses plus lentes ont moins de chances d'être détectées par les systèmes IDS, tandis qu'une analyse rapide pourrait surcharger le système. Nmap prend en charge les options suivantes :

T0 – Paranoïaque. Cette option est destinée aux attaquants qui ne souhaitent pas être détectés. Les systèmes IDS peuvent corréler plusieurs demandes dans un certain laps de temps. L'option paranoïaque tentera de contourner ce problème en n'envoyant que très peu de paquets par seconde.

T1 – Sournois. Plus rapide mais conçu pour échapper aux systèmes IDS.

T2 - Poli. Analyse lente faisant de son mieux pour ne pas planter un système.

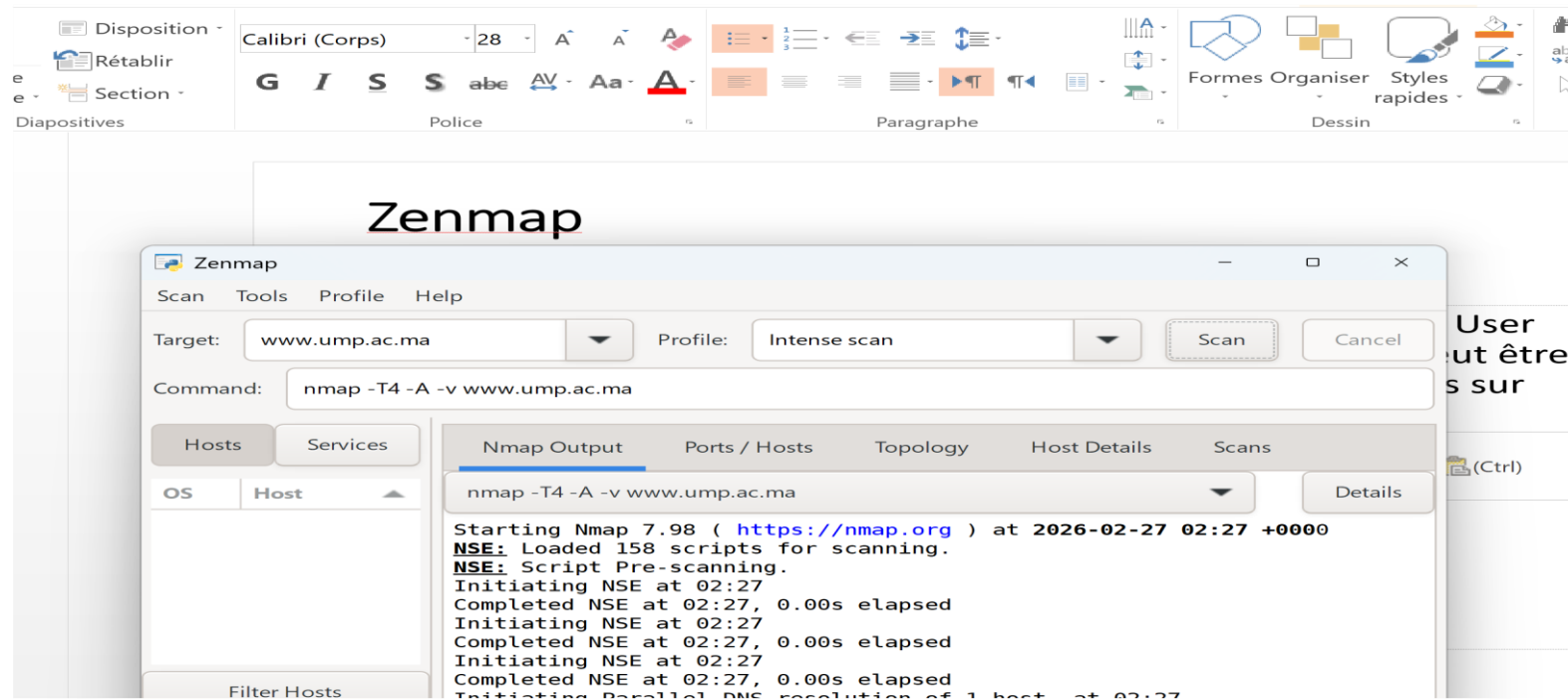
T3 - Normale. C'est simplement la valeur par défaut.

T4 - Agressif. Analyse rapide qui donne des résultats rapides. La plupart des systèmes peuvent gérer cela.

T5 – Fou. Nous envoyons à pleine capacité et performance.

Zenmap

- Nmap possède une interface graphique intégrée ("Graphical User Interface") ainsi que d'autres outils. L'interface graphique peut être utile pour visualiser les réseaux et parcourir les ports ouverts sur différents hôtes. L'interface graphique ressemble à ceci :



Cybersécurité Attaques de réseau

- Les attaques contre les protocoles et les applications hébergées sur le Réseau sont nombreuses. Les applications Web sont couvertes dans leur propre section dans ce cours.
- Les services peuvent contenir des bogues inhérents, ce qui leur permet d'être exploités par des attaquants. Ces attaques impliquent généralement l'utilisation d'instructions spéciales adressées au système d'exploitation, via le service vulnérable, pour prendre le contrôle du processus exploitant le service réseau. Les débordements de tampon sont une catégorie de telles attaques.
- Un réseau contient généralement de nombreuses applications, certaines contenant des connexions simples et d'autres ayant des fonctionnalités complexes. Une façon d'avoir une vue d'ensemble de la surface d'attaque, et également de cartographier les vulnérabilités faciles à exploiter, consiste à analyser les ports de tous les actifs de l'environnement cible, puis à les capturer.
- Des outils comme EyeWitness (<https://github.com/FortyNorthSecurity/EyeWitness>) y parviennent. L'outil nous permet d'avoir rapidement un aperçu des actifs représentés sur le réseau, puis fournit des captures d'écran de chaque service. En disposant des captures d'écran, nous pouvons facilement examiner et évaluer rapidement les systèmes que nous devrions examiner de plus près.
- Exploiter un service signifie en abuser d'une manière non prévue. Souvent, cette activité d'exploitation signifie que les attaquants sont capables d'exécuter leur propre code, c'est ce qu'on appelle RCE (« Remote Code Execution »).
- **EyeWitness - Web Screenshot Tool**

Buffer Overflow

- L'exploitation des services réseau implique parfois d'abuser des fonctions de gestion de la mémoire d'une application. Gestion de la mémoire ? Oui, les applications doivent déplacer les données dans la mémoire de l'ordinateur pour pouvoir fonctionner. Lorsque les langages de programmation donnent au développeur le contrôle de la mémoire, des problèmes tels que Buffer Overflow peuvent survenir. Il existe de nombreuses vulnérabilités similaires et dans cette section, nous examinons les débordements de tampon.
- Les langages de programmation C et C++ permettent aux développeurs de contrôler grandement la façon dont la mémoire est gérée. Ceci est idéal pour les applications qui nécessitent que les développeurs programment en étroite collaboration avec le matériel, mais qui s'ouvrent à des vulnérabilités. Les langages de programmation comme Java, JavaScript, C#, Ruby, Python et autres ne permettent pas facilement aux développeurs de commettre ces erreurs, ce qui rend les débordements de tampon moins probables dans les applications écrites dans ces langages.
- Des débordements de tampon se produisent lorsqu'une entrée non nettoyée est placée dans des variables. Ces variables sont représentées sur le système d'exploitation via une structure mémoire appelée Stack. L'attaquant peut alors écraser une partie de la pile appelée Return Pointer.

Buffer Overflow

- Remarque : La structure de la mémoire de pile est simplement l'endroit où un programme stocke les variables et les informations dont il a besoin pour s'exécuter. La pile sera située dans la RAM d'un ordinateur ("Random Access Memory")
- Le pointeur de retour décide où le CPU (« Central Processing Unit ») doit ensuite exécuter le code. Le processeur contrôle simplement les instructions que le système doit exécuter à un moment donné. Le pointeur de retour est simplement une adresse en mémoire où l'exécution doit avoir lieu. Il faut toujours indiquer au CPU où exécuter le code, et c'est ce que le pointeur de retour lui permet de faire.

Lorsque l'attaquant est capable de contrôler le pointeur de retour, cela signifie qu'il peut contrôler les instructions que le CPU doit exécuter !

Buffer Overflow

- Par exemple, considérons l'exemple de code C suivant (ne vous inquiétez pas, vous n'avez pas besoin d'être un développeur C, mais faites de votre mieux pour essayer de comprendre ce que fait cette application simple) :

- ```
#include <string.h>
void storeName (char *input) {
 char name[12];
 strcpy(name, input);
}

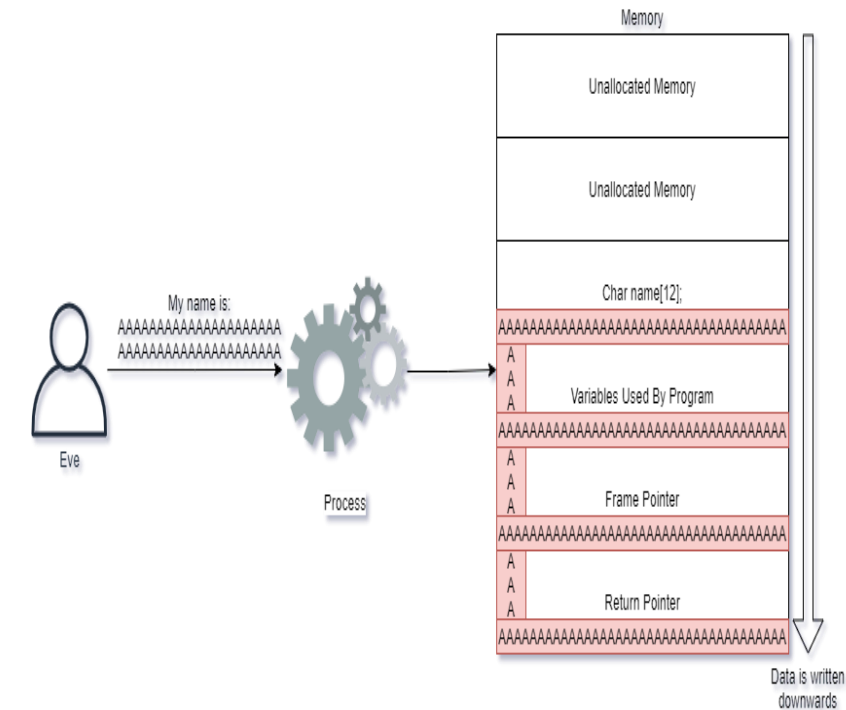
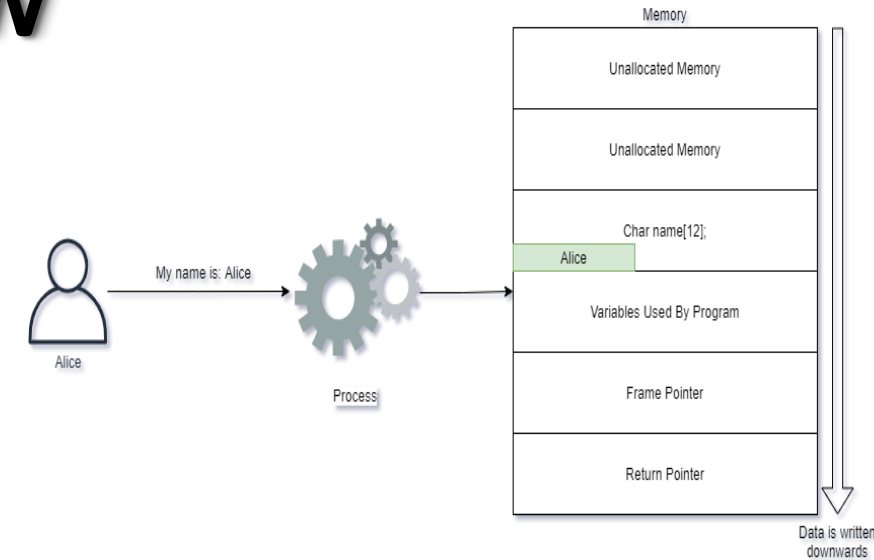
int main (int argc, char **argv) {
 storeName(argv[1]);
 return 0;
}
```

# Buffer Overflow

- Dans de nombreux langages de programmation, dont C, l'application démarre dans une fonction appelée main. Ceci est indiqué dans le code ci-dessus où il est indiqué `int main (int argc, char **argv) {`. À l'intérieur des accolades `{` et `}`, le programme exécute simplement une fonction appelée `storeName(argv[1]);`. Cela acceptera simplement tout ce que l'utilisateur a tapé dans le programme et le fournira à la fonction `storeName`.
- L'application comporte 11 lignes de code, mais concentrez votre attention sur la ligne qui lit `strcpy(name, input);`. Il s'agit d'une fonction qui tente de copier le texte de l'entrée dans la variable appelée `nom`. Le nom peut contenir un maximum de 12 caractères, comme indiqué par la ligne indiquant `char name[12];`. Y a-t-il un endroit dans le code qui empêche le nom fourni de dépasser 12 caractères ? La variable `name` est fournie par l'utilisateur qui utilise l'application et est transmise directement dans la fonction `storeName`.
- Dans cette application, il n'y a pas de nettoyage ou de désinfection, ce qui garantit que la longueur des entrées correspond à celle attendue par l'application. Toute personne exécutant le programme peut facilement saisir une valeur supérieure à ce que la variable de nom peut contenir au maximum. La variable `name` contient 12 caractères, mais que se passe-t-il lorsque le processeur doit écrire plus de 12 caractères ? Il exécutera simplement ce qui lui a été demandé, en écrasant autant de mémoire que nécessaire !
- Lorsqu'une valeur supérieure à celle attendue est tentée d'écrire, le processeur tente toujours d'écrire cette valeur en mémoire. Cela amène effectivement le processeur à écraser d'autres éléments en mémoire, par exemple le pointeur de retour permettant aux attaquants de contrôler le processeur. Encore une fois, si l'attaquant peut écraser et contrôler le pointeur de retour, il contrôle le code que le processeur doit exécuter.

# Buffer Overflow

- Un exemple graphique montre Alice écrivant son nom dans l'application que nous avons utilisée dans l'exemple ici
- Alice se comporte bien et fournit un nom qui fait que l'application se comporte comme elle le devrait. Elle fournit son nom Alice et celui-ci est simplement inscrit dans la mémoire de l'application.
- Eve envoie cependant trop de caractères dans l'application. Que se passe-t-il alors ? Le processeur prend effectivement son entrée et écrit l'entrée en mémoire, écrasant également les autres valeurs existantes !
- L'entrée d'Eve a amené le processeur à écrire beaucoup plus de données que ce à quoi l'application s'attendait, et le pointeur de retour a été écrasé. Lorsque le processeur tente d'exécuter l'instruction suivante, il lui est désormais demandé d'exécuter du code à l'emplacement AAAAAAA...
- Si Eve devait prendre le contrôle de ce serveur, au lieu d'écrire des A, elle devrait plutôt fournir dans la mémoire du code que le CPU peut comprendre. Ensuite, elle donnerait au pointeur de retour une valeur qui indique au CPU d'exécuter le propre code CPU d'Eve. Remarque : En termes simples, les débordements de tampon permettent aux attaquants de prendre le contrôle du processeur d'une victime en écrasant soigneusement la mémoire de la victime.



# Scanners de vulnérabilités

- Un scanner de vulnérabilités recherche automatiquement les vulnérabilités courantes dans les logiciels et les configurations sur le réseau. Il n'est pas conçu pour trouver de nouvelles classes de vulnérabilités, mais utilise plutôt une liste de plugins (ou modules) prédéfinis pour analyser les services à la recherche de problèmes et de vulnérabilités. Il ne recherche pas forcément les vulnérabilités zero-day ! Une vulnérabilité Zero Day est une toute nouvelle vulnérabilité qui était auparavant inconnue du fournisseur du logiciel et des défenseurs ; pour une vulnérabilité Zero Day, il n'existe actuellement aucun correctif connu pour le problème.

Les scanners disposent de fonctionnalités de cartographie du réseau et d'analyse des ports, notamment des moyens d'explorer et de trouver les vulnérabilités dans les différentes applications qu'ils rencontrent.

Un scanner de vulnérabilités prend souvent en charge la configuration avec des informations d'identification, ce qui lui permet de se connecter aux systèmes et d'évaluer les vulnérabilités au lieu de les trouver d'un point de vue non authentifié.

Remarque : les scanners de vulnérabilités recherchent principalement les vulnérabilités connues et les mauvaises configurations, et non les vulnérabilités du jour zéro !

# Exécution de code

- Lorsque les attaquants ont découvert une vulnérabilité qu'ils sont capables d'exploiter, ils doivent décider quelle charge utile ils souhaitent exécuter. La charge utile est le code que l'attaquant souhaite transmettre via un exploit.

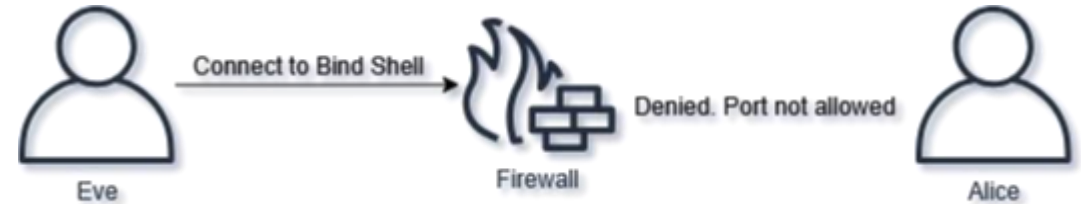
Il existe de nombreuses charges utiles différentes qu'un attaquant peut décider d'utiliser, voici quelques exemples :

- Faire en sorte que la victime s'enregistre auprès d'un serveur C2 ("Command and Control") acceptant les commandes des attaquants
- Créez un nouveau compte utilisateur de porte dérobée sur le système afin que l'attaquant puisse l'utiliser plus tard
- Ouvrir une GUI ("Graphical User Interface") avec la victime afin que l'attaquant puisse la contrôler à distance
- Recevez un terminal de ligne de commande, un shell, via lequel l'attaquant peut envoyer des commandes

Une charge utile courante par les attaquants est un bind-shell. Cela amène la victime à écouter sur un port et lorsque l'attaquant se connecte, il reçoit un shell.



# Exécution de code



- Une charge utile courante par les attaquants est un bind-shell. Cela amène la victime à écouter sur un port et lorsque l'attaquant se connecte, il reçoit un shell.
- Les pare-feu sont utiles pour empêcher les attaquants de se connecter aux victimes. Un pare-feu refuserait effectivement les connexions entrantes à la victime tant que le port n'est pas autorisé. Une seule application peut écouter sur un port, les attaquants ne peuvent donc pas écouter sur les ports déjà utilisés à moins de désactiver ce service.

Pour contourner cette mesure défensive, les attaquants tenteront plutôt de connecter la victime à l'attaquant, lui permettant ainsi d'accéder à la charge utile. De nombreux pare-feu ne sont malheureusement pas configurés pour refuser le trafic de sortie, ce qui rend cette attaque très viable pour les attaquants.

# Exécution de code

- Dans cet exemple, nous voyons un attaquant utiliser un reverse-shell pour permettre à la victime de se connecter à l'attaquant.



- Remarque : Les exécutions de code signifient que les attaquants peuvent exécuter leur code sur le système de la victime. Le code qu'ils choisissent de déployer dépend d'eux, mais cela implique souvent que les attaquants disposent d'un moyen d'exécuter des commandes sur le système de la victime à long terme.

# Surveillance du réseau



- Dans la plupart des cas, les attaquants ont besoin du réseau pour contrôler une cible à distance. Lorsque les attaquants sont capables de contrôler une cible à distance, cela se fait via un canal de commande et de contrôle, souvent appelé C&C ou C2.

Il existe des compromissions via des logiciels malveillants préprogrammés avec des charges utiles qui n'ont pas besoin de C2. Ce type de malware est capable de compromettre même les réseaux isolés.

La détection des compromissions peut souvent être effectuée en trouvant le canal C2. C2 peut prendre n'importe quelle forme, par exemple :

- La détection des compromissions peut souvent être effectuée en trouvant le canal C2. C2 peut prendre n'importe quelle forme, par exemple :
- Utiliser HTTPS pour communiquer avec les serveurs attaquants. Cela fait ressembler le C2 à une navigation réseau
- Utiliser les réseaux sociaux pour publier et lire des messages automatiquement
- Des systèmes comme Google Docs pour ajouter et modifier des commandes aux victimes

# Surveillance du réseau

- Seule l'ingéniosité des attaquants fixe la limite pour C2. Lorsque nous réfléchissons à la manière d'arrêter les attaquants à l'aide de canaux C2 intelligents, nous devons souvent nous appuyer sur la détection des anomalies et des écarts statistiques sur le réseau. Par exemple, les outils de surveillance du réseau peuvent détecter :

connexions longues utilisées par C2, mais qui n'est pas naturelle pour le protocole en question. HTTP est l'un de ces protocoles pour lesquels il n'est pas très courant d'avoir de longues connexions, mais un attaquant l'utilisant pour le contrôle à distance pourrait le faire.

Balises utilisées par C2 pour indiquer que la victime est vivante et prête à recevoir des commandes. Les balises sont utilisées par de nombreux types de logiciels, pas seulement par les attaquants, mais savoir quelles balises existent et lesquelles vous attendez est une bonne pratique.

Des flashes de données jaillissent soudainement du réseau. Cela peut indiquer un téléchargement volumineux depuis une application ou un attaquant volant des données. Essayez de comprendre quelle application et quel utilisateur provoquent des flux de données et appliquez-leur un contexte. Est-ce normal ou pas ?

Il existe de nombreuses façons pour les défenseurs de tenter de trouver des anomalies. Ces anomalies doivent être davantage corrélées aux données du système source qui envoie les données.

Pour la surveillance du réseau, le contexte doit être appliqué pour aider à déterminer le bruit du signal. Cela signifie qu'un SOC (« Security Operations Center ») doit essayer d'enrichir les données, par exemple les adresses IP source et de destination, avec du contexte pour contribuer à rendre les données plus précieuses.

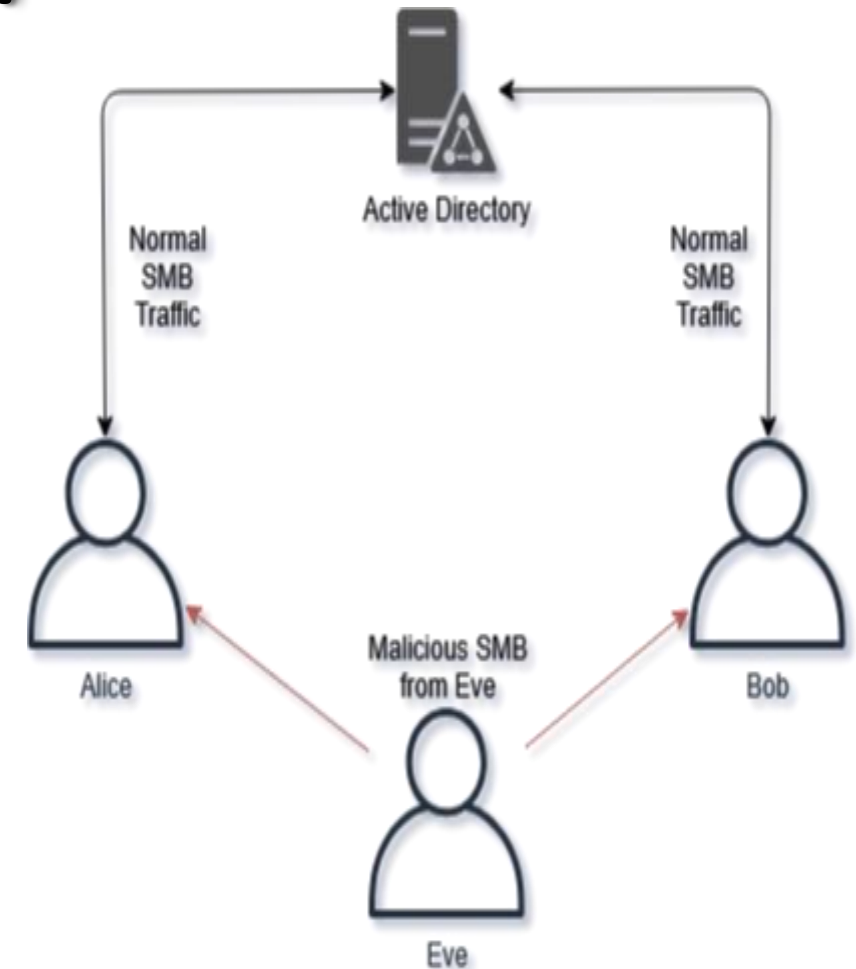
L'application du contexte peut être décrite avec le scénario suivant : Une attaque arrive depuis Internet mais tente d'exploiter une vulnérabilité Linux contre un service Windows. Cela serait généralement considéré comme du bruit et pourrait être ignoré en toute sécurité ; à moins que, que se passe-t-il si l'adresse IP qui effectue l'attaque est une adresse IP de votre propre réseau ou d'un fournisseur en qui vous avez confiance ? Le contexte que nous pouvons appliquer peut alors fournir des informations précieuses sur l'exploration plus approfondie de l'attaque. Après tout, nous ne voulons pas que des systèmes en qui nous avons confiance lancent des attaques !

# Trafic peer to peer

- La plupart des réseaux sont configurés de manière client vers serveur. Les clients accèdent aux serveurs pour obtenir des informations, et lorsque les clients doivent interagir les uns avec les autres, ils le font généralement via un serveur.

Cependant, un attaquant souhaitera probablement utiliser des communications peer-to-peer, c'est-à-dire client à client, pour exploiter des fruits faciles à trouver, comme la réutilisation d'informations d'identification ou l'exploitation de clients faibles ou vulnérables.

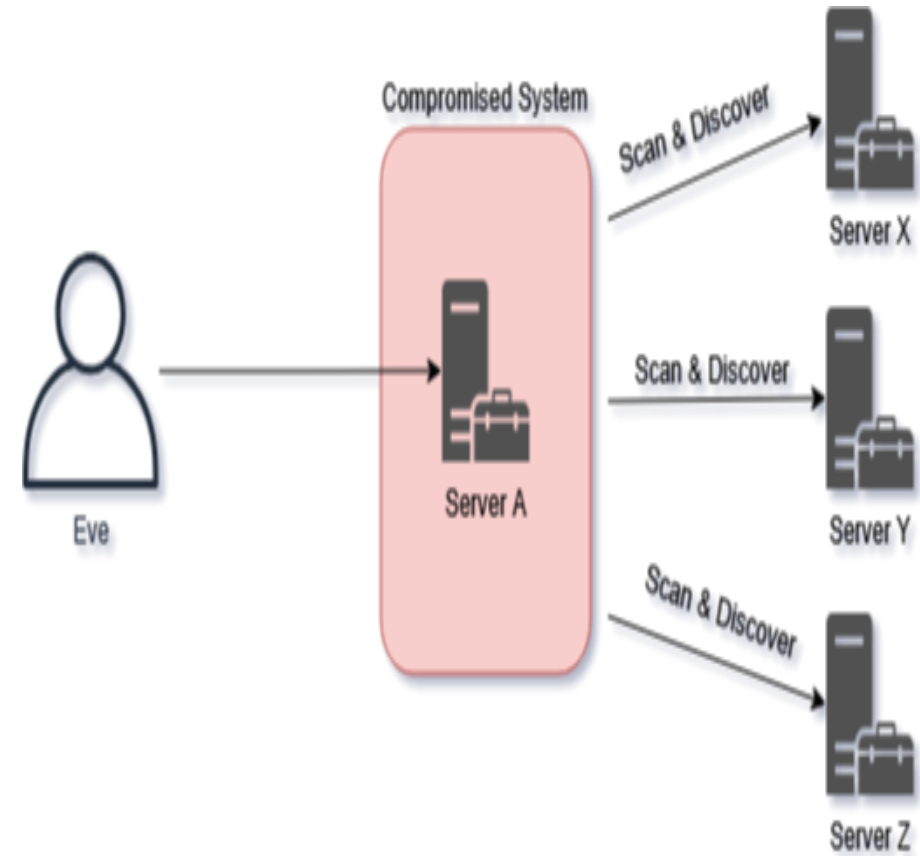
Par exemple, le port 445, utilisé par SMB, est un bon indicateur à utiliser pour détecter les compromissions. Les clients ne devraient pas communiquer entre eux via SMB dans la plupart des environnements. Cependant, lors d'une compromission, il est probable qu'un attaquant essaie d'utiliser SMB pour compromettre davantage les systèmes.



# Mouvement latéral et pivotement

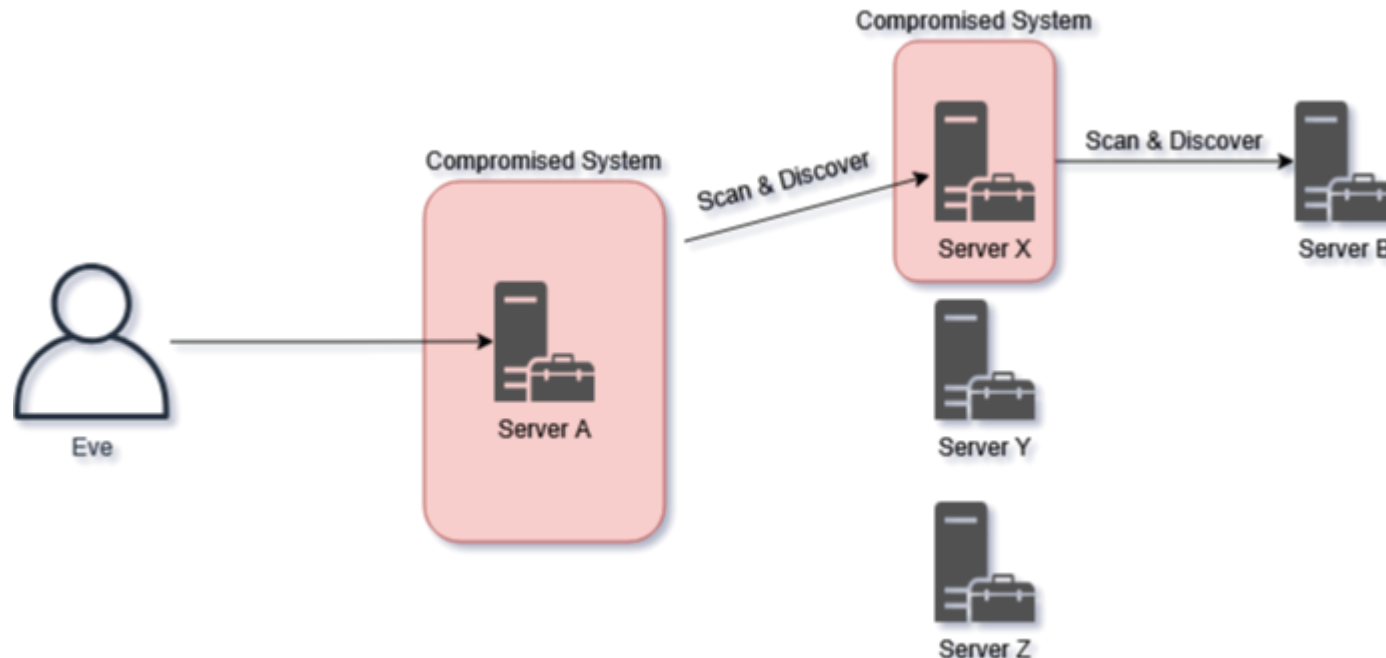
- Une fois qu'un système est compromis, un attaquant peut exploiter ce système pour explorer des réseaux supplémentaires auxquels le système compromis a accès. Cela serait possible dans un environnement dans lequel un système compromis dispose de plus de privilèges via le pare-feu, ou dans lequel le système a accès à d'autres réseaux, par exemple via un réseau local. une carte réseau supplémentaire.

Le pivotement signifie qu'un attaquant utilise un hôte compromis pour accéder à d'autres réseaux. Une illustration de ceci est présentée ici où Eve a compromis un système et l'utilise pour en analyser et en découvrir d'autres :



# Mouvement latéral et pivotement

- Le mouvement latéral est l'acte de profiter du pivot et d'exploiter un autre système utilisant le pivot. Ce nouveau système peut désormais être utilisé davantage pour effectuer des pivotements et davantage de mouvements latéraux. Eve dans cet exemple utilise le serveur X pour découvrir davantage le système B.



# cybersécurité

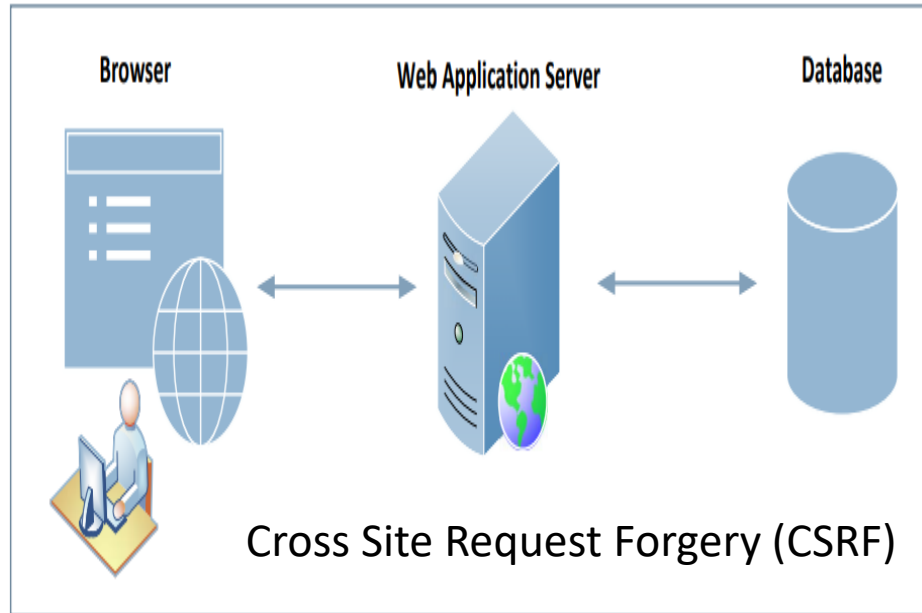
## Attaques d'applications de Web



# Attaques d'applications de Web

- Les applications Web sont omniprésentes aujourd'hui et servent à contrôler à peu près tout ce que vous pouvez imaginer.
- Dans cette section, nous examinerons les attaques et la sécurité des applications Web.

# The Web Architecture



```
<html>
<body>
 <h1>Heading</h1>
 <p>This is a test.</p>
</body>
</html>
```

```
<style type="text/css">
.myclass { background-color: yellow; }
#myid { position: absolute; top: 220px; left: 700px; }
body { background-color: lightblue;
 margin-top: 50px; margin-bottom: 20px;
 margin-right: 0px; margin-left: 80px; }
h1 { font-family: Arial, Helvetica, sans-serif; }
</style>
```

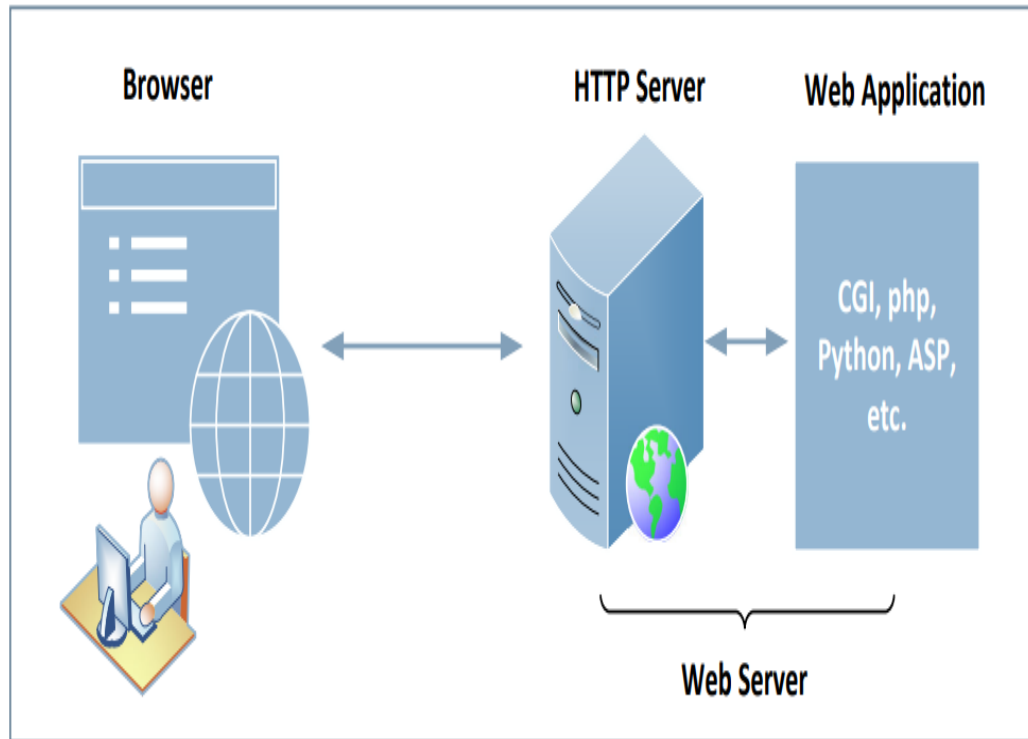
```
<script>
... Code ...
</script>

<script src="myScript.js"></script>
<script src="https://www.example.com/myScript.js"></script>

<button type="button" onclick="myFunction()">Click it</button>
```

```
GET /index.html HTTP/1.1 ①
Host: www.example.com ②
User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:83.0) ...
Accept: text/html,application/xhtml+xml,application/xml; ...
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Connection: keep-alive
Upgrade-Insecure-Requests: 1
```

# HTTP Server & Web Application Server



```
<!doctype html>
<html>
<body>
<h1>PHP Experiment</h1>
<h2>Current time is
<?php echo date("Y-m-d h:i:sa") ?>
</h2>
</body>
</html>
```

```
<?php
$title = "PHP Experiment";
$time = date("Y-m-d h:i:sa")
?>

<!doctype html>
<html>
<body>
<h1><?=$title?></h1>
<h2>Current time is <?=$time?></h2>
</body>
</html>
```

GET /post\_form.php?foo=hello&bar=world HTTP/1.1  
Host: www.example.com  
Cookie: SID=xsdgfergbghedvrbeadv

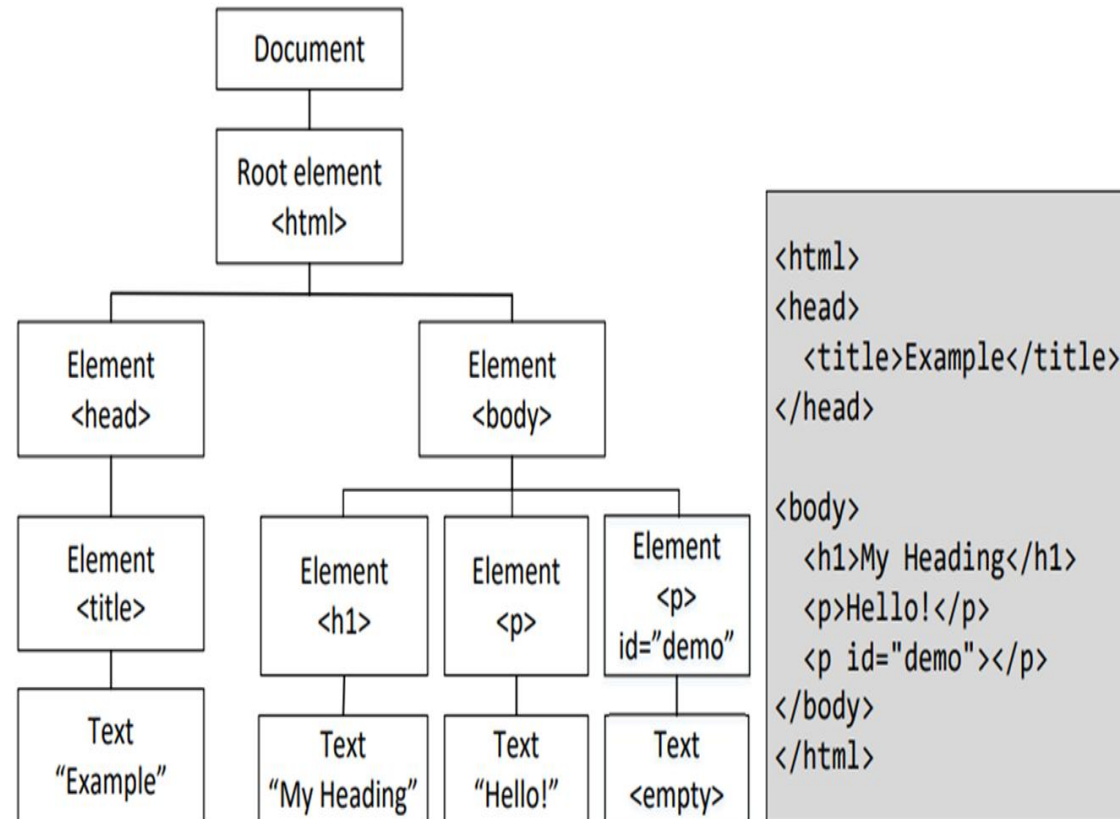
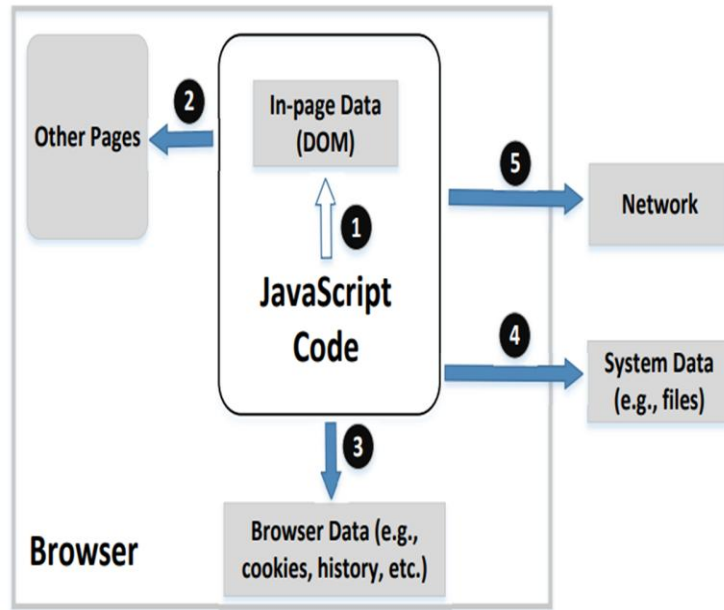
POST /post\_form.php HTTP/1.1  
Host: www.example.com  
Cookie: SID=xsdgfergbghedvrbeadv  
Content-Length: 19  
foo=hello&bar=world

```
<?php
setcookie('cookieA', 'aaaaaa');
setcookie('cookieB', 'bbbbbb', time() + 3600);

echo "<h2>Cookies are set</h2>"
?>
```

GET: HTTP/1.1 200 OK  
Date: Wed, 25 Aug 2021 20:40:15 GMT  
Server: Apache/2.4.41 (Ubuntu)  
Set-Cookie: cookieA=aaaaaa  
cookieB=bbbbbb; expires=Wed, 25-Aug-2021 21:40:15 GMT; Max-Age=3600  
Content-Length: 28  
Keep-Alive: timeout=5, max=99  
Connection: Keep-Alive  
Content-Type: text/html; charset=UTF-8

# JavaScript and sandbox



Cross-Site Scripting Attack  
(XSS)

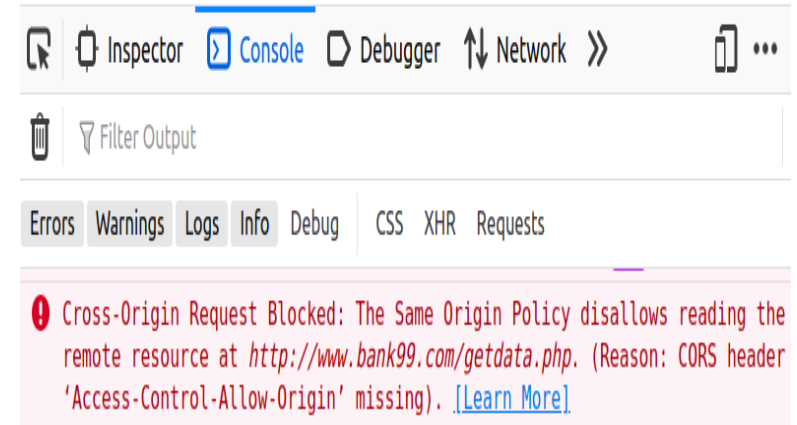
# Same Origin Policy on Ajax

- Page from [www.bank32.com](http://www.bank32.com) trying to access [www.bank99.com](http://www.bank99.com) (using Ajax)
- What is Blocked: Request or Response?
- Request was sent out, response came back
- Browser blocks Ajax code from accessing the response
- Why Blocking the Response?
- Cross-Origin access compromise privacy
  - Same-origin policy is enforced
- Example: Ajax code in Facebook page
  - allowed to access the user's Facebook data
  - not allowed to access the user's Google data

Cross Site Request Forgery  
(CSRF)

Something is wrong!

Send Ajax



```
$ sudo tcpdump -i br-3f00b5edf2b0 -n -v
10.9.0.1.42580 > 10.9.0.5.80: ... HTTP, length: 316
 GET /getdata.php HTTP/1.1
 Host: www.bank32.com
 Origin: http://www.bank99.com
 Referer: http://www.bank99.com/ajax.html

10.9.0.5.80 > 10.9.0.1.42580: ... HTTP, length: 224
 HTTP/1.1 200 OK
 Server: Apache/2.4.41 (Ubuntu)
 Content-Type: text/html; charset=UTF-8

Data from Bank32!
```

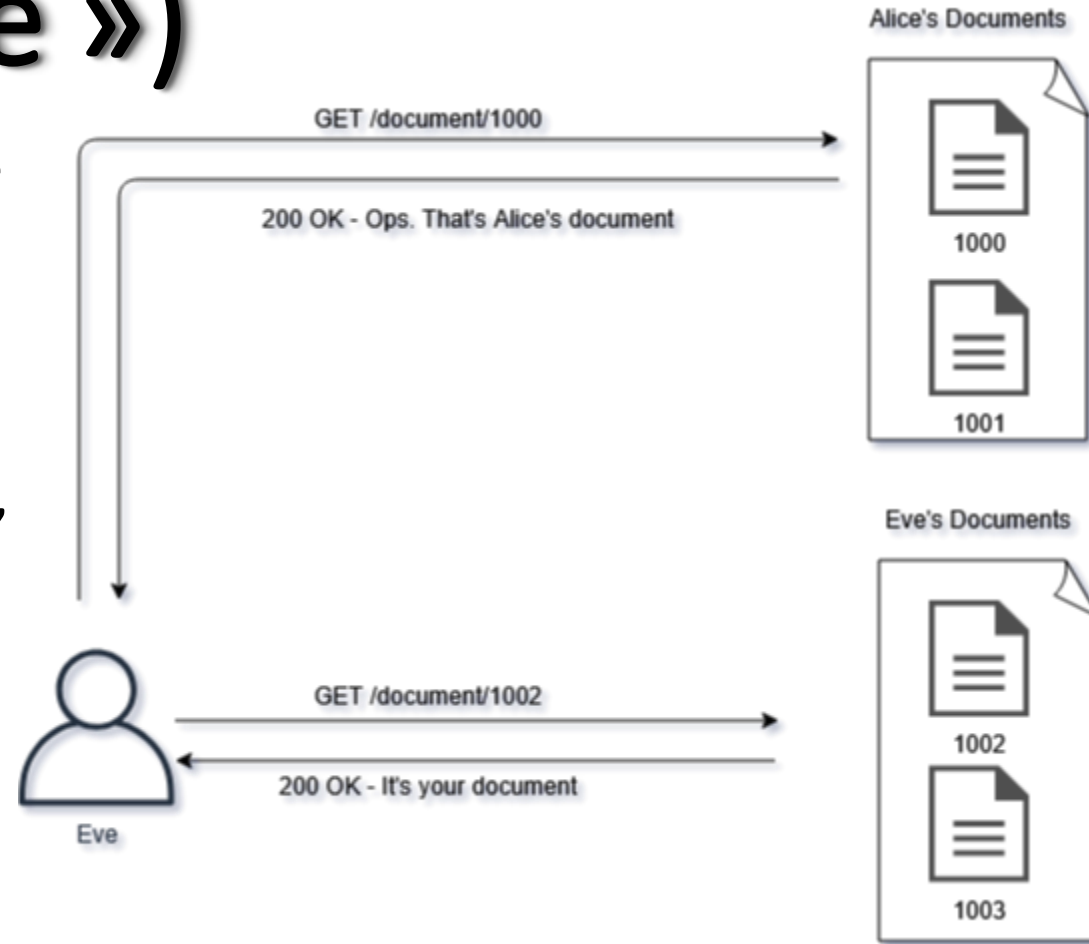
# WebSocket

- Ajax uses HTTP: half-duplex
  - Browser sends request, server responds
  - No “push” mechanism (from server)
- WebSocket is full-duplex
  - Both browser/server can send data (without request)

# IDOR (« Référence d'objet direct non sécurisée »)

- Les vulnérabilités IDOR se produisent lorsque les développeurs n'ont pas mis en œuvre les exigences d'autorisation pour accéder aux ressources.
- Eve, en changeant simplement un identifiant, par ex. le paramètre Rest du document, elle peut accéder aux documents d'Alice.

Cela se produit lorsque l'application Web n'applique pas l'autorisation entre les objets, permettant aux attaquants d'énumérer des valeurs et de tester l'accès à d'autres points de données.



# IDOR (« Référence d'objet direct non sécurisée »)

- Par exemple, nous pourrions avoir le pseudo-code suivant ne montrant aucun signe d'autorisation : d'autres points de données.

```
$id = getInputFromUser();
$doc = getDocument($id);
return $doc;
```

Le code ci-dessus demande une saisie à l'utilisateur, n'effectue aucune validation ni nettoyage, puis effectue directement une recherche avec la fonction `getDocument` et renvoie le document en question.

Une meilleure implémentation serait de vérifier les privilèges :

```
$id = getInputFromUser();
$user = findUsername();
$doc = "";
if (hasAccessToDocument($user, $id)) {
 $doc = getDocument($id);
} else {
 $doc = "Not authorized for this document";
}
return $doc;
```



# remarques

- De telles vulnérabilités sont faciles à trouver car vous pouvez simplement modifier un simple numéro et voir si vous avez accès aux données de quelqu'un d'autre. Vérifier d'abord si l'utilisateur est autorisé évite cette vulnérabilité.

# Éviter les « nombres magiques »

- Une application souhaite éviter d'utiliser des séquences de nombres lors du référencement de données. Dans l'exemple IDOR, les documents avaient des identifiants compris entre 1000 et 1002. Parfois, ces numéros sont appelés « nombres magiques » car ils pointent directement vers une ressource sur le serveur, par ex. via la base de données, et toutes les valeurs peuvent facilement être énumérées. Par exemple, un attaquant peut vérifier tous les identifiants de documents de 0 à 10 000 et enregistrer tous les résultats donnant accès aux données.

Bien que l'autorisation doive être correctement mise en œuvre, il est également utile d'utiliser le GUID (« Globally Unique Identifier ») ou l'UUID (« Universally Unique Identifier ») lors du référencement des données. Ces identifiants sont conçus pour être globalement uniques et impossibles à énumérer en raison de l'entropie intégrée à la génération des nombres.

Voici à quoi peut ressembler un GUID :

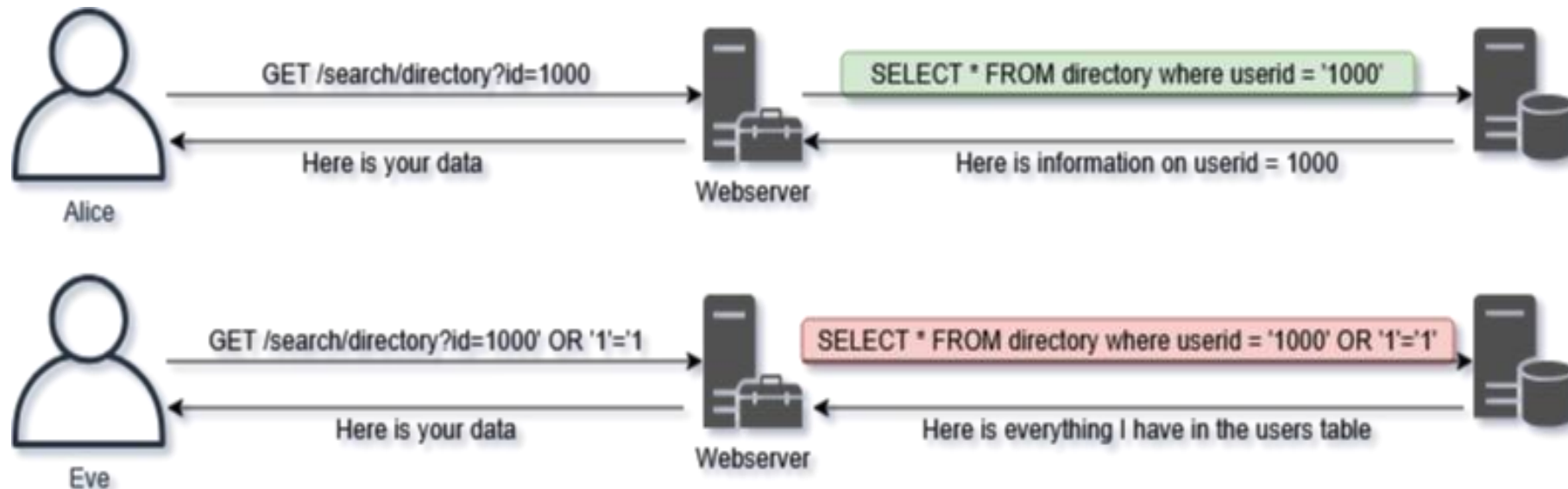
3377d5a6-236e-4d68-be9c-e91b22afd216

Remarque : Si vous examiniez les mathématiques permettant de deviner le nombre ci-dessus, nous verrions rapidement qu'il n'est pas facile à énumérer. L'énumération est une technique qui peut être utilisée pour parcourir toutes les options possibles d'une valeur, le GUID ou l'UUID l'empêche.

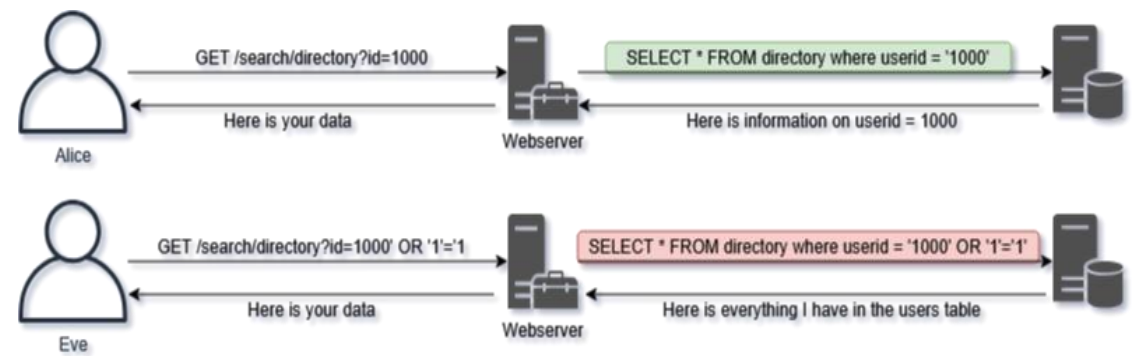
# SQL Injection

- De nombreuses applications Web sont connectées à une base de données. La base de données contient toutes les informations que l'application Web souhaite stocker et utiliser.

L'injection SQL est une technique qui permet aux attaquants de manipuler le SQL ("Structured Query Language") utilisé par le développeur de l'application Web. Cela se produit généralement en raison d'un manque de nettoyage des données. SQL est régulièrement utilisé par les développeurs pour accéder aux ressources de bases de données.



# SQL Injection



- Dans la requête qu'Eve fait dans le graphique ci-dessus, nous voyons qu'elle saisit la valeur : `1000' OR '1'='1`

La requête SQL résultante renvoie alors toutes les lignes de la table, car la base de données évalue l'instruction comme étant toujours vraie. Pensez-y : la base de données reçoit une requête dont la valeur peut être soit 1000 OU 1 est égal à 1 ; il renverra une valeur à chaque fois ! Il existe de nombreuses fonctions et opérations SQL différentes que nous pouvons utiliser pour manipuler la syntaxe, et cet exemple n'est qu'un parmi tant d'autres.

- Vous trouverez ci-dessous un exemple de pseudo-code contenant une vulnérabilité d'injection SQL.

```
$username = getUsername();
$pw = getPassword();
$user = mysql_query("SELECT * FROM userTable WHERE username = $username AND password
= $pw");
if ($user) {
 $loggedIn = True;
} else {
 $loggedIn = False;
}
```

# SQL Injection

- Nous pouvons voir qu'il n'y a pas de nettoyage des variables de nom d'utilisateur et de mot de passe ; au lieu de cela, ils sont utilisés directement dans le SQL, provoquant l'apparition de la vulnérabilité. Le code permet de définir la variable \$loggedin si la requête renvoie quelque chose.

Pour qu'un attaquant puisse exploiter cela, il pourrait simplement créer une URL sur le domaine cible contenant l'attaque, comme ceci :

- **/login?username=admin&password=password' OR '1'='1**
- La variable de mot de passe est définie pour contenir les caractères SQL, ce qui fait que la chaîne SQL résultante renvoie une ligne, même si le mot de passe nous est inconnu. La requête SQL résultante serait :
- **SELECT \* FROM userTable WHERE username = 'admin' AND password = 'password' OR '1'='1'**

# SQL Injection

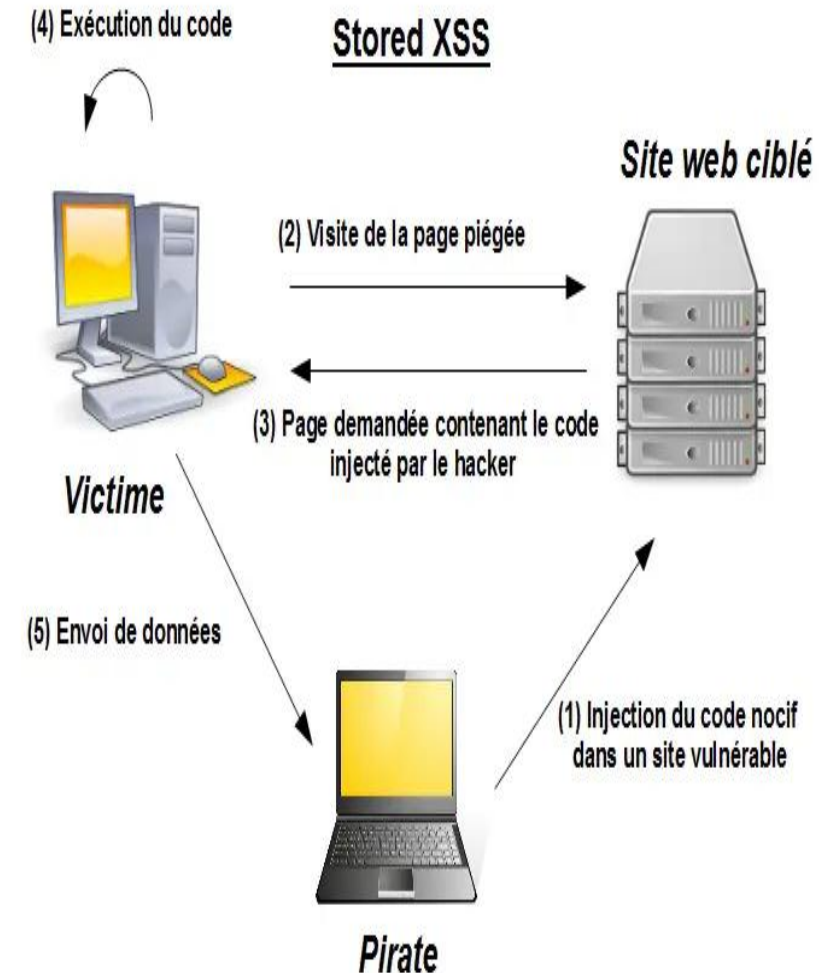
- Les requêtes paramétrées sont la solution recommandée pour vaincre les injections SQL. Dans une requête paramétrée, les développeurs s'assurent soigneusement que chaque entrée de la requête est définie comme une valeur et un type spécifiques. Voici un exemple du code ci-dessus qui est considéré comme une implémentation sécurisée :
- ```
$username = getUsername();  
$pw = getPassword();  
$parameterizedQuery = prepare_query("SELECT * FROM userTable where  
username = ? and password = ?");  
$parameterizedQuery.setString(1, $username)  
$parameterizedQuery.setString(2, $password)  
$user = parameterizedQuery.execute();  
if ($user) {  
    $loggedIn = True;  
} else {  
    $loggedIn = False;  
}
```

Rmearque SQL Injection

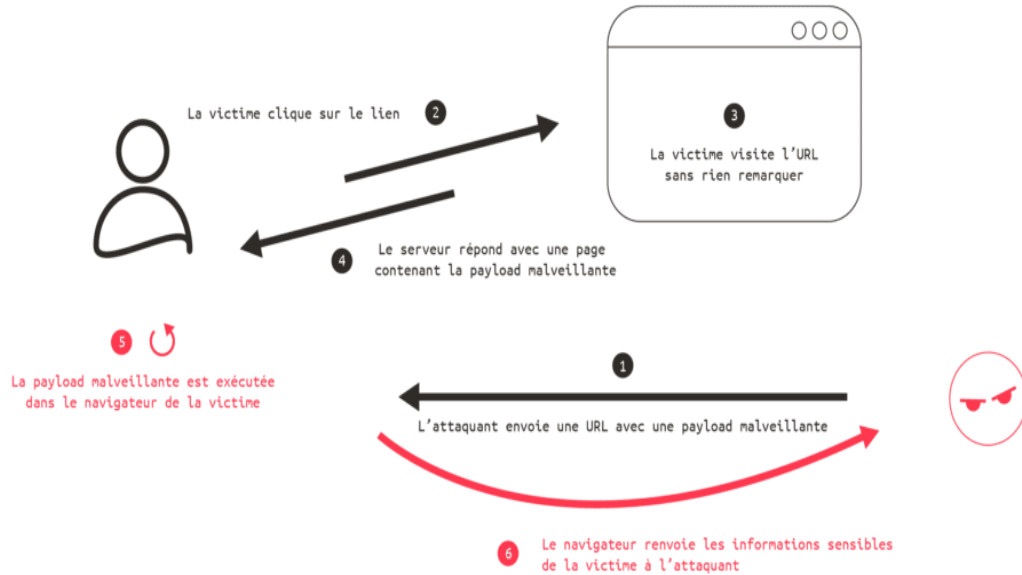
- Dans l'exemple ci-dessus, le développeur a soigneusement indiqué que le paramètre 1 devait être une chaîne et contenir le nom d'utilisateur et le mot de passe dans le deuxième paramètre
- Remarque : L'injection SQL est rendue possible parce que les développeurs ne nettoient pas soigneusement les entrées des utilisateurs et permet ainsi à un attaquant de tromper l'application et la base de données en leur faisant exécuter du code SQL non autorisé.

XSS (Cross-Site Scripting)

- XSS utilise le serveur pour attaquer les visiteurs du serveur. L'attaque ne cible pas le serveur lui-même, mais plutôt les utilisateurs.
- Le serveur est simplement utilisé pour refléter les valeurs des attaquants, généralement JavaScript, contre les visiteurs qui exécutent ensuite les données des attaquants dans leur propre navigateur. L'attaquant doit créer une entrée que le serveur ne nettoie pas et ne désinfecte pas, de cette façon lorsqu'un visiteur clique sur un lien contenant les valeurs de l'attaquant ou visite une ressource de la page Web que l'attaquant a utilisée dans son attaque, l'utilisateur exécute le code fourni par l'attaquant.



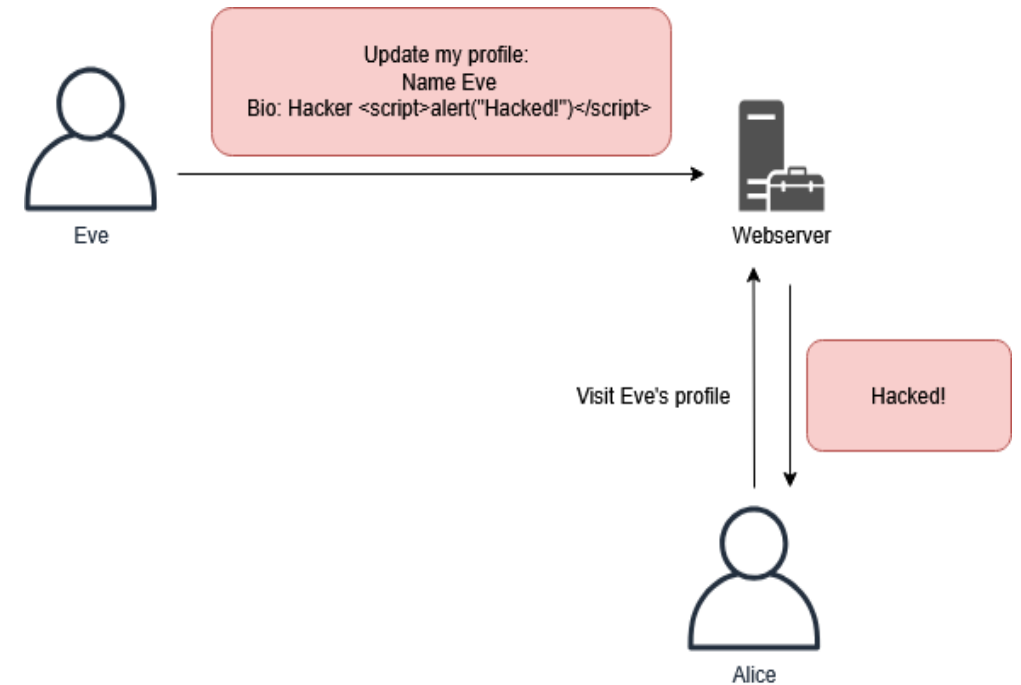
Attaque XSS reflétée



Cette attaque est appelée Reflected XSS et implique qu'Eve trouve la vulnérabilité, puis envoie un lien contenant l'attaque à un utilisateur sans méfiance et lui demande de cliquer sur le lien. Le lien contient l'attaque et oblige le serveur Web à renvoyer l'attaque à la victime en cliquant sur le lien.

Le code derrière cela pourrait être quelque chose de simple comme cet exemple de pseudo-code :

```
$nickname = etNickName();  
echo "Greeting $nickname, nice to meet you!";
```



Un autre type de XSS est appelé attaque Stored XSS. Dans les attaques Stored XSS, l'attaquant est capable de sauvegarder le contenu de la page Web, ce qui se reflète à chaque fois que quelqu'un visite le site Web. Cela n'oblige pas nécessairement quelqu'un à cliquer sur un lien.

Ce graphique décrit comment Eve est capable de stocker du JavaScript malveillant à exécuter dans le navigateur de n'importe qui lors de la visite de la ressource :

XSS ("Cross-Site Scripting")

- Les attaques XSS peuvent accomplir de nombreuses choses, par exemple :

Voler des cookies qui peuvent être utilisés pour l'authentification

Dégradation du site Web, présentation de contenu que le serveur Web n'avait pas l'intention de diffuser

Phishing des utilisateurs en laissant des informations d'identification dans de faux formulaires de connexion

Pour se défendre contre XSS, il existe plusieurs bonnes pratiques à suivre :

Laissez le serveur Web renvoyer les en-têtes CSP (« Content Security Policy ») qui décident strictement où et comment JavaScript est exécuté à partir de

Encodez en toute sécurité la sortie que le serveur Web renvoie aux utilisateurs, transformant ainsi efficacement les caractères HTML en caractères codés sûrs.

CSP (Politique de sécurité du contenu)

- Le serveur Web peut contrôler quel type de JavaScript est autorisé à s'exécuter sur le site Web. Cela ne supprime pas les vulnérabilités mais ajoute une défense en profondeur en cas de vulnérabilité inconnue.

Un CSP commun et strict consiste à fournir aux utilisateurs de l'application Web une liste de tous les fichiers sources JavaScript acceptés.

De plus, il est courant que CSP empêche l'exécution de JavaScript en ligne.

Pour faciliter la mise en œuvre et la détection des attaques en cours, CSP permet aux clients de signaler les violations CSP à une URL fournie par le serveur.

Analyse d'applications Web

- Il existe de nombreux scanners d'applications Web. Ceux-ci permettent d'analyser les applications à la recherche de vulnérabilités telles que l'injection SQL et XSS.
- Contrairement à un scanner de vulnérabilités réseau, un scanner d'applications Web repose généralement sur des heuristiques plutôt que sur des signatures et des listes de vulnérabilités connues.

Les scanners d'applications Web sont utiles, en particulier lorsqu'ils sont intégrés à des processus de développement tels que CI (« Continuous Integration ») et CD (« Continuous Delivery »)

Cyber Security Wi-Fi Attacks

Le WIFI est un domaine puissant et important pour la sécurité informatique. Les appareils et les systèmes ne doivent plus être interconnectés via des câbles physiques, mais peuvent être accessibles à toute personne se trouvant dans le rayon du signal. Le WIFI permet à de nombreux nouveaux appareils d'être capables de se mettre en réseau.

Les bases du Wi-Fi

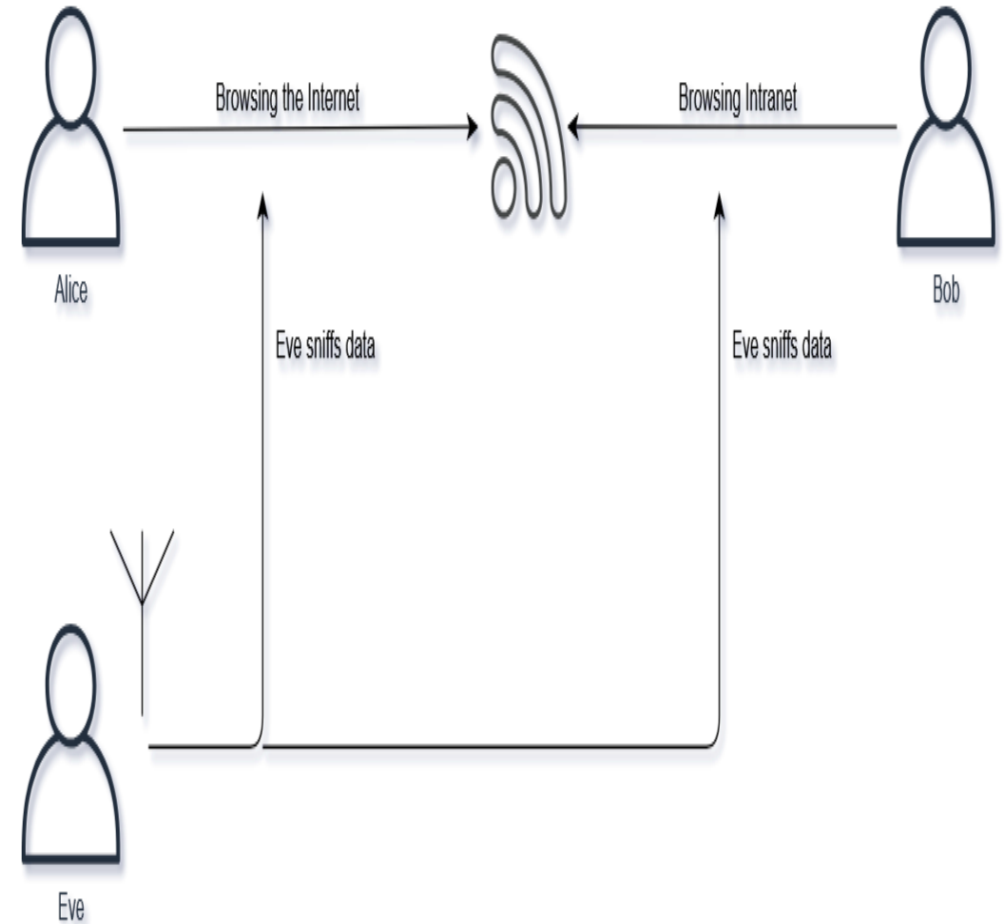
- Le WIFI tel que la plupart des gens le connaissent provient du protocole IEEE 802.11. Il existe d'autres protocoles qui utilisent également la radio pour la signalisation, par exemple :
- Bluetooth, pour communiquer avec les appareils que nous transportons, généralement les smartphones, les écouteurs, etc.
- NFC (« Near Field Communications »), implémenté dans les badges d'accès et les cartes de crédit pour la transmission sans fil de données.
- RFID (« Radio Frequency Identification »), utilisée pour les cartes d'accès et autres dispositifs, par exemple une voiture qui peut transmettre sans fil son identifiant à un système de péage.
- ZigBee et Z-Wave, utilisés pour l'entreprise et la domotique.
- La communication sans fil s'effectue généralement via un AP (« Access Point »), une station de base sans fil qui agit comme un commutateur et un routeur entre les clients souhaitant communiquer. Les communications peer-to-peer sont également possibles, mais moins courantes.
- Le nom d'un réseau sans fil est connu sous le nom de SSID (« Service Set Identifier »).
- Étant donné que les signaux WIFI atteignent toutes les personnes se trouvant à proximité, les attaquants peuvent facilement utiliser une antenne pour « renifler » les communications de toute personne émettant. Renifler signifie simplement écouter les paquets que l'interface réseau peut voir.
- Le WIFI permet parfois aux utilisateurs d'accéder à des applications internes, augmentant ainsi le potentiel d'attaque. De plus, les appareils WIFI disposent d'interfaces de gestion et de micrologiciels qui peuvent contenir des vulnérabilités, parfois pas toujours corrigées aussi rapidement que les autres actifs de l'entreprise.

Sécurité Wi-Fi

- Le WIFI a la possibilité de:
 - Aucune sécurité
 - Liste d'accès basée sur les adresses MAC
 - PSK (« clé pré-partagée ») ("Pre-Shared Key")
 - Authentification d'entreprise
-
- De nombreuses attaques WIFI s'appuient sur des cartes réseau dotées de deux fonctionnalités principales, à savoir :
-
- Mode moniteur : permet à la carte réseau de transmettre les paquets destinés à toutes les adresses MAC au système d'exploitation, pas seulement à la sienne.
 - Injection de paquets : la carte réseau prend en charge la création de paquets avec une adresse MAC source différente de la sienne.

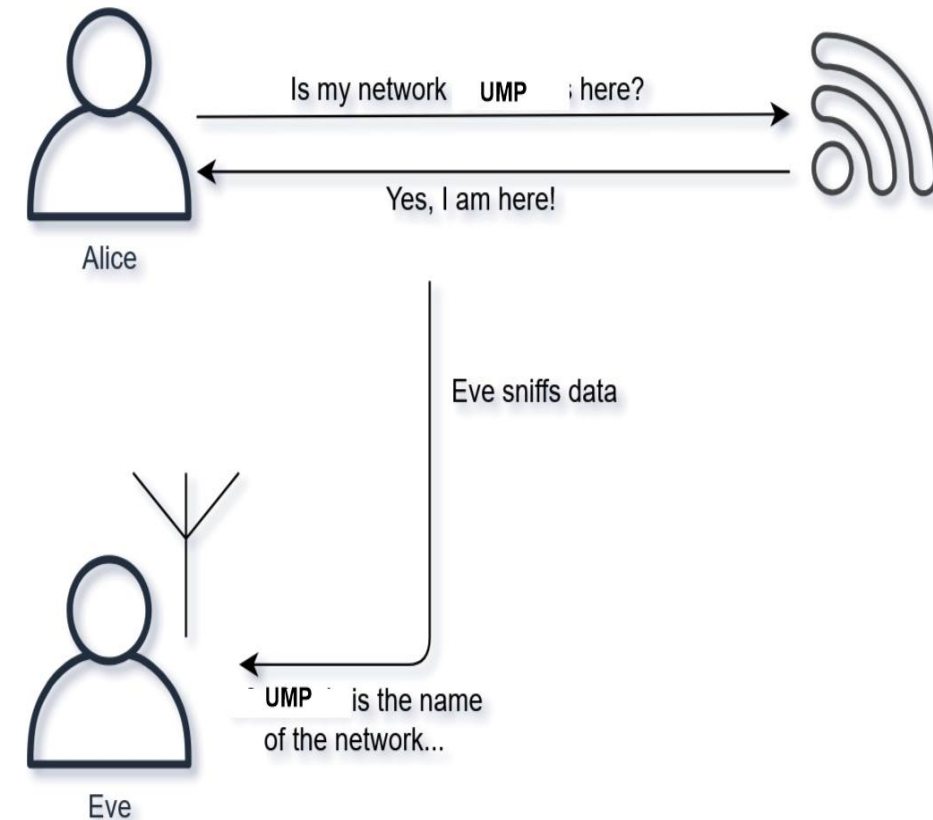
Réseaux WIFI ouverts

- Un réseau WIFI ouvert est un réseau sans mot de passe. La communication entre le point d'accès et les clients n'est pas cryptée et chacun doit s'appuyer sur ses propres sources de cryptage pour protéger son trafic. Ces types de réseaux sont très pratiques et accessibles aux utilisateurs, mais ils comportent des compromis en matière de sécurité.
- Un attaquant sur ce type de réseaux peut facilement voir ce que font les autres en reniflant simplement les paquets. Ces paquets peuvent contenir des détails sensibles ou simplement des détails sur ce que font les utilisateurs sur le réseau.



Hidden SSID /SSID caché

- SSID caché
- Les points d'accès peuvent souvent désactiver la diffusion du nom du réseau sans fil.
- Cela nécessite que les clients démontrent leur connaissance du SSID pour rejoindre le réseau. Il n'est pas considéré comme une bonne pratique d'activer le SSID masqué, car le nom du réseau est exposé à chaque fois qu'un client le rejoint. De plus, les clients doivent désormais demander et diffuser des informations sur le réseau qu'ils souhaitent rejoindre, partout où ils se déplacent.
- Un attaquant pourrait alors détecter le trafic WIFI des clients et potentiellement obtenir plus d'informations sur l'identité des clients et l'endroit où ils ont déjà rejoint les réseaux.

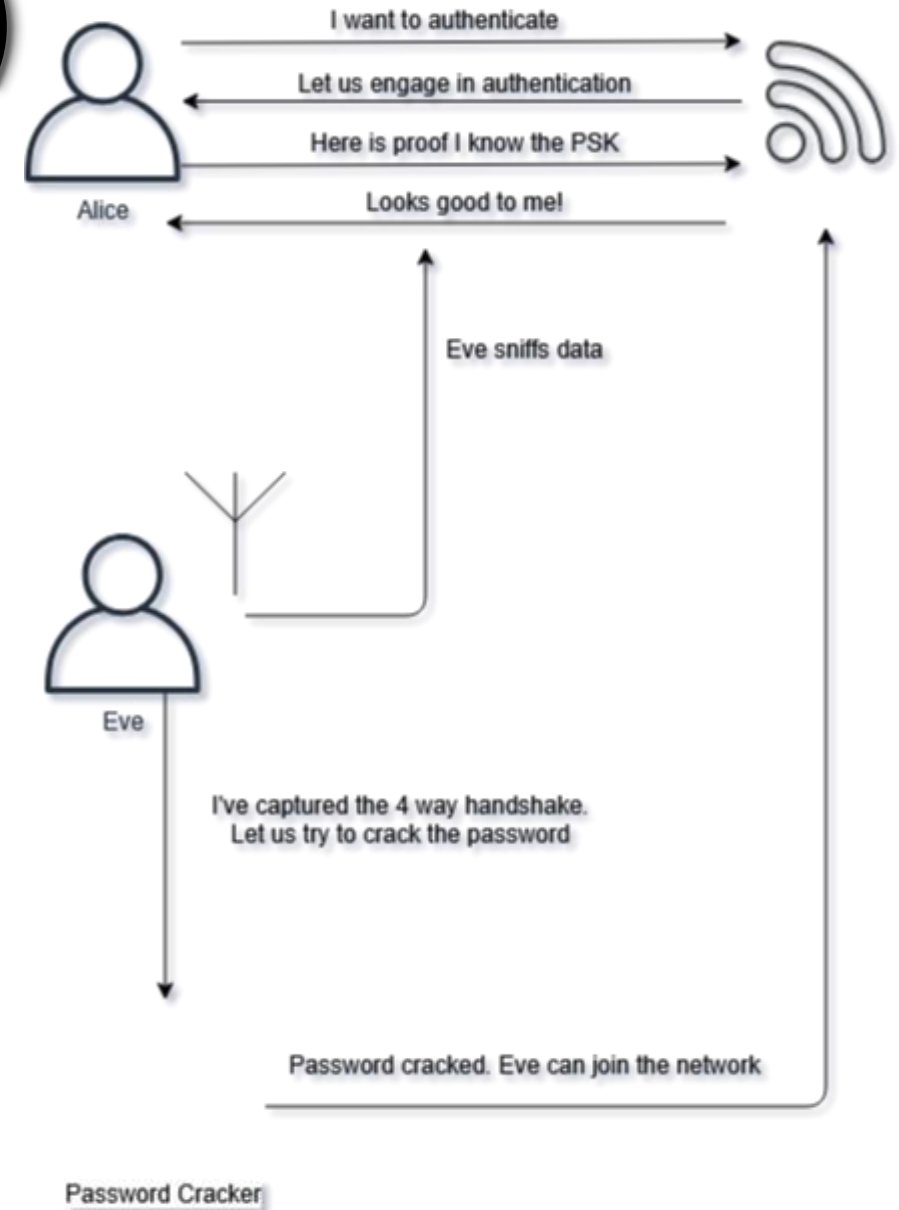


Filtrage d'adresses MAC

- Certains points d'accès prennent en charge le contrôle d'accès basé sur les adresses MAC. Le point d'accès peut créer une liste verte des adresses MAC qui doivent être autorisées à rejoindre et à communiquer sur le réseau.
- Cette approche n'est pas sécurisée. Un attaquant peut déjà renifler et observer d'autres systèmes communiquant sur le réseau. Enregistrez ensuite leurs adresses MAC et mettez à jour la propre adresse MAC des attaquants pour qu'elle soit déjà autorisée. Cela contourne efficacement l'exigence de filtrage d'adresses MAC.

PSK (« clé pré-partagée »)

- PSK signifie simplement que le réseau est configuré avec un mot de passe. La protection PSK est généralement mise en œuvre via un protocole appelé WPA (« WiFi Protected Access »). Des protocoles d'authentification plus anciens peuvent également être utilisés, par exemple WEP ("Wired Equivalent Privacy"), mais ils ont longtemps été considérés comme obsolètes car très peu sécurisés et faciles à pirater par les attaquants.
- WPA se présente sous différentes formes, WPA3 étant la dernière norme en date de 2021. WPA n'est pas non plus entièrement sûr contre les attaquants, mais offre bien plus de protection que WEP. Pour pénétrer dans un réseau compatible WPA, l'attaquant doit essayer de déchiffrer le mot de passe avec un pirate de mot de passe. Ceci est considéré comme un processus coûteux en termes de temps si le mot de passe est raisonnablement fort.
- Si un attaquant peut observer (renifler) toute personne qui s'authentifie sur le réseau, il en a suffisamment pour se lancer dans des activités de piratage de mots de passe. Des outils comme aircrack-ng ("<https://www.aircrack-ng.org/>") prennent en charge le craquage des mots de passe WiFi.



Authentification d'entreprise

- Les points d'accès d'entreprise peuvent également prendre en charge l'authentification des clients sur la base de certificats, ce qui nécessite une PKI (« Public Key Infrastructure ») ou des informations d'identification d'entreprise en s'intégrant à un service d'authentification centralisé.
- Cela présente certains avantages, notamment le concept de gestion des clés. Avec un réseau PSK, le défi inhérent réside dans la manière dont les mots de passe sont distribués, alternés et révoqués.
- Si l'authentification d'entreprise permet une meilleure gestion de la sécurité des clés, elle implique également une infrastructure plus complexe et offre d'autres opportunités aux attaquants.

Faux/Fake points d'accès WIFI

- Les attaquants peuvent facilement lancer des réseaux de diffusion en se faisant passer pour d'autres réseaux. Souvent, les clients se connectent automatiquement aux réseaux à portée s'ils se présentent avec le SSID approprié. Cela permet aux attaquants de connecter les clients au réseau des attaquants, leur permettant ainsi de détecter et de modifier le trafic à leur guise.

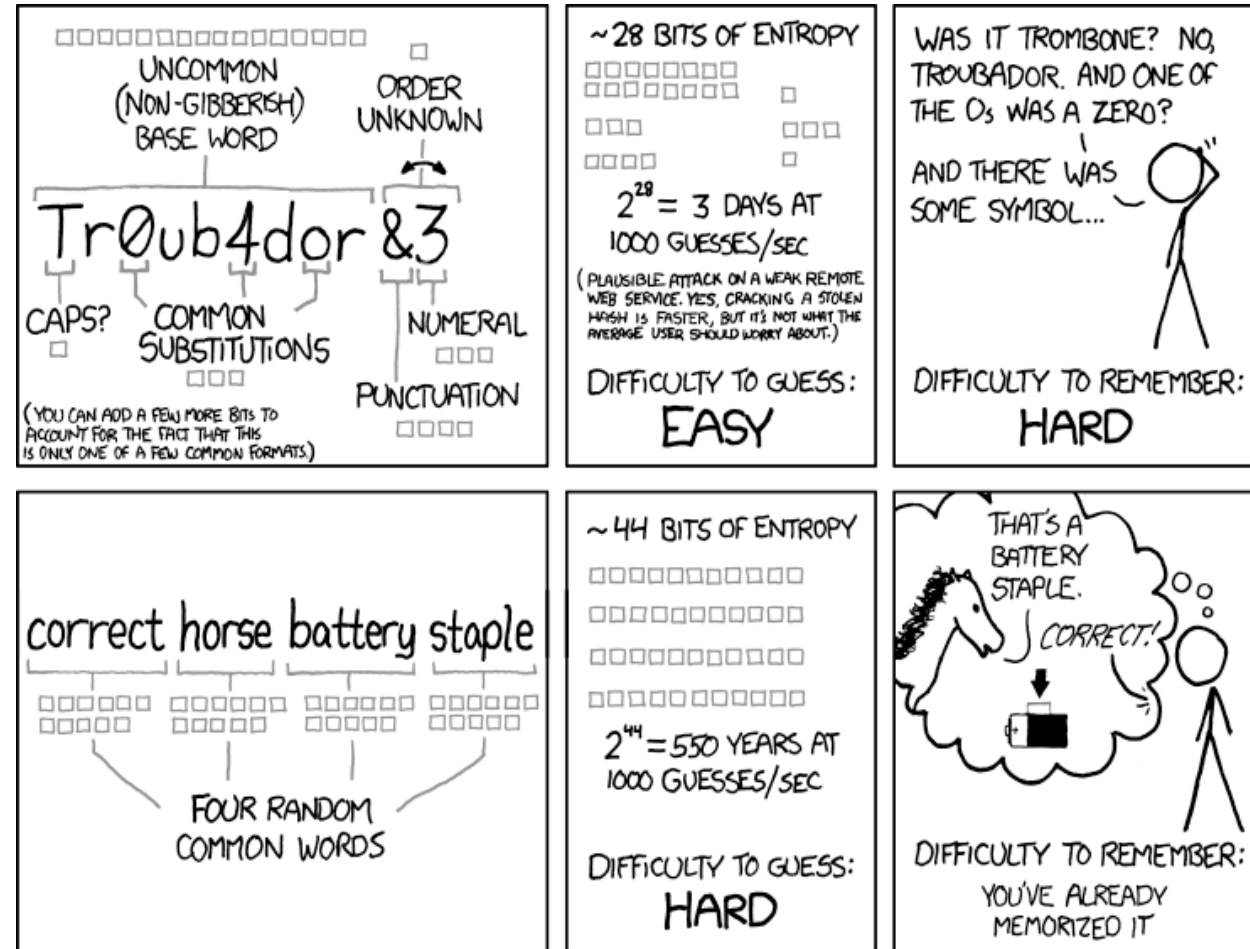


Cyber Security Passwords

De nombreux systèmes sont protégés par un simple mot de passe. Ce n'est pas idéal car les mots de passe peuvent dans de nombreux cas être facilement cassés, réutilisés ou abusés par des attaquants. Cette section explorera les attaques et les défenses concernant les mots de passe.

Force du mot de passe/ Password Strength

- Qu'est-ce qui détermine un mot de passe fort ? Est-ce à quel point le mot de passe est complexe ? Combien de personnages a-t-il ? Le nombre de caractères spéciaux ?
- Le célèbre créateur de bandes dessinées xkcd.com montre brillamment comment les mots de passe peuvent être attaqués dans la bande dessinée ci-dessous. Examinez-le pendant une seconde et discutons-en davantage.
- Remarque : L'entropie signifie le manque de prévisibilité. Plus l'entropie est élevée, plus il est difficile de craquer par des moyens standards.



THROUGH 20 YEARS OF EFFORT, WE'VE SUCCESSFULLY TRAINED EVERYONE TO USE PASSWORDS THAT ARE HARD FOR HUMANS TO REMEMBER, BUT EASY FOR COMPUTERS TO GUESS.

Règles de politique de mot de passe

- Si l'on considère le premier mot de passe **Tr0ub4dor&3**, ce mot de passe s'adaptera à la plupart des règles de politique de mot de passe, par exemple en ayant une lettre majuscule, des chiffres, des caractères spéciaux et une longueur de 11 caractères. Ce mot de passe présente cependant quelques problèmes, il s'agit de :
 - Difficile de s'en souvenir. Avez-vous remplacé le premier caractère o (la lettre) par un 0 (le chiffre), ou était-ce le deuxième ? Avez-vous remplacé le caractère a par un 4 ou pas ?
 - Difficile de taper. Vous devez saisir différentes lettres, chiffres et caractères spéciaux dans un ordre spécial. Ce ne seront probablement pas les mots les plus rapides à saisir sur votre clavier. Ce n'est pas très fort ! Le mot de passe est basé sur un mot assez courant et n'offre pas beaucoup de force, seulement environ 28 bits d'entropie.
- Au lieu de sélectionner des mots de passe présentant ces facteurs négatifs, nous pouvons augmenter considérablement l'entropie des mots de passe de manière simple. Si nous considérons le mot de passe **CorrectHorseBatteryStaple**, nous constatons une amélioration considérable du mot de passe :
- Le mot de passe est facile à saisir. Taper des mots ordinaires est pour beaucoup une activité quotidienne et vous pouvez y parvenir très rapidement. C'est facile à retenir. En utilisant une image visuelle du mot de passe, d'un cheval, d'une pile, d'une agrafe et du mot correct, nous pouvons nous en souvenir beaucoup plus facilement. Il est nettement plus puissant contre la plupart des activités de piratage de mots de passe ! Il offre environ 44 bits d'entropie, ce qui le rend très difficile à déchiffrer.
- Les mots de passe comme celui-ci sont appelés phrases secrètes et constituent généralement une bien meilleure pratique qu'un simple mot avec une certaine complexité. Réfléchissez à la façon dont vous pourriez améliorer le mot de passe pour qu'il soit encore plus fort et qu'il s'adapte aux règles de politique de mot de passe telles que les caractères spéciaux et les majuscules ! Vous pouvez même utiliser des espaces dans votre mot de passe, ce qui rend la saisie des phrases secrètes encore plus naturelle.

Gestionnaires de mots de passe/ Password Managers

- Écrire son mot de passe est depuis de nombreuses années considéré comme une mauvaise pratique, mais est-ce vraiment le cas ? L'utilisation du même mot de passe sur plusieurs services en ligne présente un risque important. Que se passera-t-il si l'une de ces plateformes est piratée ? Ce mot de passe est alors compromis et les attaquants peuvent le réutiliser sur tous les autres services où il est utilisé.
- Pour lutter contre ce problème, il est recommandé de ne pas réutiliser le même mot de passe sur plusieurs services. Cela rend la tâche très difficile pour les utilisateurs, car ils doivent non seulement utiliser des mots de passe uniques, mais en même temps créer des mots de passe forts et robustes ! Un gestionnaire de mots de passe aide à résoudre ce problème en proposant aux utilisateurs, de la manière la plus sécurisée possible, d'écrire leurs mots de passe dans un fichier, une base de données ou un autre système, ce qui rend les mots de passe facilement accessibles et garantit qu'ils sont forts et uniques dans différents services.
- Lorsqu'il est correctement mis en œuvre, un gestionnaire de mots de passe :
- Faire de l'utilisation d'Internet une activité beaucoup plus sécurisée
- Augmentez la productivité car les mots de passe de différents services peuvent facilement être trouvés, copiés et collés dans les services respectifs auxquels l'utilisateur souhaite se connecter
- Offrez des moyens simples de réinitialiser et de régénérer de nouveaux mots de passe en cas de besoin.
- Écrire des mots de passe est considéré comme un risque bien moindre pour nos utilisateurs que de les obliger à réutiliser leurs mots de passe. Oui, ce n'est pas une solution parfaite car le gestionnaire de mots de passe pourrait potentiellement être compromis, mais cette approche est considérée comme beaucoup plus sûre.

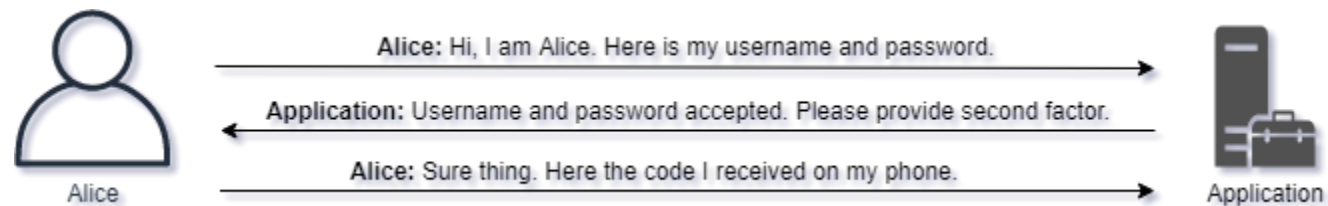
Solutions sans mot de passe/ Passwordless Solutions

- Si les mots de passe en eux-mêmes pouvaient disparaître ? Il y a toujours quelqu'un qui ne peut pas saisir chaque jour une phrase secrète plus longue comme mot de passe. Il peut y avoir plusieurs raisons à cela, par exemple :
 - Travailleurs non avertis en informatique au bureau
 - Un médecin qui visite chaque jour de nombreux ordinateurs différents à l'hôpital tout en rendant visite à différents patients dans différentes chambres
 - Il est difficile de saisir le mot de passe sur le système qui le nécessite
- Le développement et la mise en œuvre de systèmes qui n'exigent pas que les utilisateurs fournissent un mot de passe se développent rapidement. Au lieu de demander aux utilisateurs de s'authentifier avec un mot de passe, et si on leur permettait d'utiliser par exemple :
 - Quelque chose qu'ils sont, par exemple leur visage ou leurs empreintes digitales
 - Quelque chose qu'ils possèdent, par exemple un jeton ou leur téléphone portable
- Cela comporte des défis, mais en termes de sécurité, aggravons-nous réellement le problème ou l'améliorons-nous pour nos utilisateurs ? Nous devons nous rappeler que nous ne cherchons pas à mettre en œuvre des systèmes de sécurité parfaits, ils sont normalement hors de portée et non réalisables, nous devons donc réfléchir attentivement à la manière dont nous pouvons limiter les menaces et en même temps faciliter la vie de nos utilisateurs. Les mots de passe ne sont pas parfaits, pas plus que les solutions sans mot de passe. Lequel allez-vous mettre en œuvre pour vos utilisateurs ?

Authentication multifacteur

Multi-Factor Authentication MFA

- Alors que nous apprenons que quelle que soit la solution utilisée pour vérifier les utilisateurs, des risques importants seront toujours associés à leurs comptes, d'autres solutions peuvent être mises en œuvre pour contribuer à réduire les risques.
- L'authentification multifacteur permet aux solutions non seulement de vérifier un utilisateur en fonction, par exemple, de son mot de passe, mais en même temps d'exiger que les utilisateurs présentent un deuxième facteur pour prouver qui ils sont.



Authentification multifacteur

Multi-Factor Authentication MFA

- Il peut y avoir plusieurs manières différentes de demander un deuxième facteur. Voici exemples :
- Utiliser une application d'authentification sur un smartphone pour fournir un code secret
- Recevoir un code secret par SMS (« Short Message Service ») sur un téléphone
- Utiliser un jeton matériel pour fournir un code secret
- Présenter une empreinte digitale ou un visage pour identifier la personne
- Tout ce qui précède nécessite non seulement de connaître un mot de passe, mais demande également de fournir un deuxième élément (un facteur).
- De telles solutions sont parfois considérées comme très invasives pour les utilisateurs. Pour aider à résoudre ce problème, un concept de DAC (« Discretionary Access Control ») peut être appliqué. DAC permet à la solution de connexion d'envisager s'il convient ou non de défier un utilisateur avec un code multifacteur. Par exemple, un multifacteur peut être nécessaire uniquement lorsqu'un utilisateur :
 - Se connecte à partir d'un nouvel emplacement
 - Utilise un autre navigateur ou logiciel pour accéder à l'application
 - Essaie d'effectuer une action sensible dans l'application, par exemple changer le mot de passe ou effectuer une transaction monétaire au-dessus d'un certain seuil

Deviner le mot de passe /Password Guessing

- Lorsque les attaquants rencontrent des applications et des services, ils peuvent avoir la possibilité de deviner le mot de passe. La recherche de mots de passe est une activité qui implique que des attaquants interagissent avec l'application sur le réseau, en essayant des listes de différentes combinaisons de noms d'utilisateur et de mots de passe.
- La deviner le mot de passe donne à l'attaquant la possibilité de trouver des comptes avec une combinaison faible de nom d'utilisateur et de mot de passe.



Deviner le mot de passe /Password Guessing

- Si l'attaquant parvient à trouver un compte valide avec lequel se connecter, de nouvelles opportunités s'offrent à l'attaquant. Considérez quel type de fonctionnalités et de données sont désormais présentées à l'attaquant. Voici quelques exemples dans lesquels un attaquant réussit à deviner le mot de passe de quelqu'un :
- L'attaquant accède au compte de messagerie d'un employé. À l'intérieur, il y a des milliers de courriels remontant à des années dans l'histoire. Dans les e-mails, des mots de passe sont communiqués, permettant à l'attaquant de se connecter à davantage de systèmes. De plus, des centaines de pièces jointes sont présentes, certaines pouvant contenir des informations très sensibles.
- Les attaquants réussissent à deviner le mot de passe du compte administrateur d'un système CVC (« Chauffage, Ventilation et Climatisation ») dont la responsabilité est de refroidir la salle des serveurs. Les attaquants sont capables de modifier les paramètres du système CVC et, grâce à des modifications minutieuses, provoquent une surchauffe de la salle des serveurs.
- Un service VPN est disponible sur Internet, permettant aux collaborateurs d'accéder aux ressources internes. L'un des employés dispose d'un mot de passe faible qui est deviné par un attaquant après des jours de tentatives répétées de mot de passe. L'attaquant accède au service VPN et se trouve désormais sur le réseau interne de l'organisation. À partir de là, l'attaquant installe un ransomware au sein de l'organisation.
- Une application web est déployée sur Internet. Il ne présente aucune vulnérabilité évidente de l'extérieur, mais les attaquants ont pu deviner le mot de passe d'un compte d'utilisateur régulier sur le système. Étant donné que la société hébergeant l'application Web fait confiance à ses utilisateurs, la sécurité Web à l'intérieur de l'application était médiocre. À partir de là, l'attaquant a pu utiliser des exploits Web pour compromettre le serveur.

Deviner le mot de passe /Password Guessing

- De nombreux services réseau disposent de comptes d'administrateur intégrés, certains même avec le mot de passe par défaut inchangé depuis son installation. Pour chaque service du réseau, les attaquants peuvent tenter de se connecter avec les informations d'identification par défaut. De plus, l'attaquant peut essayer des mots de passe typiques et faibles. Voici quelques exemples de mots de passe typiques et faibles. Notez qu'ils se terminent tous par un point d'exclamation afin de vaincre les politiques de mot de passe :
- **Commentaire sur le mot de passe**
 - Été2026** : De nombreuses personnes, y compris les services d'assistance des entreprises, effectuent des réinitialisations de mot de passe et définissent le mot de passe en fonction de la saison de l'année et de l'année dans laquelle nous nous trouvons actuellement.
 - UMP123** : Le nom de l'entreprise est souvent utilisé comme mot de passe. Le nombre 123 et ! à la fin est sélectionné par les utilisateurs pour transmettre les politiques de mot de passe et le rendre un peu plus complexe.
 - Rosalynn2006** : Rosalynn, peut-être l'enfant de quelqu'un ? Les utilisateurs utilisent souvent quelque chose d'affection personnelle comme mot de passe. Les noms des enfants et peut-être leur année de naissance sont très populaires.
 - Aserty123456** : Un mot de passe apparemment aléatoire ? Ce mot de passe est celui d'une personne qui appuie sur les touches du clavier dans l'ordre, puis qui utilise des chiffres pour faire la même chose.

Deviner le mot de passe /Password Guessing

- Un outil qui nous permet de configurer facilement des listes de noms d'utilisateur et de mots de passe pour essayer une multitude de services différents est THC-Hydra (<https://github.com/vanhauser-thc/thc-hydra>). Il prend en charge de nombreux protocoles d'attaque tels que :
 - RDP ("Remote Desktop Protocol")
 - FTP ("File Transfer Protocol")
 - SMB ("Server Message Block")
 - Telnet
 - SSH ("Secure Sockets Host")
- Pour utiliser THC-Hydra pour cibler par exemple FTP, la commande suivante peut être utilisée : **hydra -L common_usernames.txt -P common_passwords.txt <ftp://localhost/>**
- Cette commande utilise une liste de noms d'utilisateur et de mots de passe courants pour essayer chacun d'eux avec le service FTP sur localhost ou une adresse IP de votre choix.

Bourrage d'informations d'identification /Credential Stuffing

- Une attaque courante utilisée par les attaquants est **le Credential Stuffing**. Cela implique que les attaquants téléchargent d'énormes bases de données d'informations d'identification et testent les informations d'identification applicables par rapport au service réseau. Une fuite d'informations d'identification se produit lorsqu'un service tiers est piraté, une base de données est volée puis divulguée sur Internet pour que quiconque puisse la télécharger.
- Malheureusement, de nombreux utilisateurs réutilisent le même mot de passe sur différents services, ce qui permet aux attaques de Credential Stuffing de devenir très efficaces contre les organisations.
- Remarque : n'importe qui, y compris vous, peut rechercher sur Internet des bases de données divulguées contenant des informations d'identification et des mots de passe. Ce n'est pas très difficile à pirater quand les gens ne changent pas leurs mots de passe ?!

Craquage de mot de passe Password Cracking

- Alors que la recherche de mots de passe est une attaque en ligne, le piratage de mots de passe est une attaque hors ligne. Cela implique que les attaquants volent d'abord les représentations de mot de passe d'une cible.
- Les mots de passe sont généralement représentés sous forme de hachage de mot de passe. Un hachage est un moyen de stocker les mots de passe des utilisateurs en les envoyant via une fonction unidirectionnelle, ce qui rend le mot de passe impossible à inverser à moins que le piratage du mot de passe ne soit utilisé.
Si l'attaquant est capable de récupérer les informations d'identification d'un système, ces informations d'identification seront probablement protégées par cryptage ou hachage. Le hachage est une fonction unidirectionnelle conçue pour ne pas être inversée vers sa valeur d'origine.
- Le craquage de mot de passe implique l'utilisation de la puissance de calcul, c'est-à-dire le CPU (« Central Processing Unit ») et le GPU (« Graphical Processing Unit »), pour essayer de créer des suppositions de mot de passe qui correspondent aux informations d'identification protégées récupérées du système.
Remarque : Le GPU est généralement bien meilleur en matière de piratage de mots de passe, car il possède des centaines de micro-cœurs qui sont tous capables d'effectuer de petites tâches par eux-mêmes. Cela permet à un pirate de mot de passe de devenir beaucoup plus rapide car il peut étendre les activités de craquage sur de nombreux cœurs différents.

Services sans authentification

- En explorant et en découvrant des applications, vous pouvez parfois rencontrer des applications qui ne sont pas protégées par authentification. Ces applications sont utiles à explorer par les attaquants, par exemple en profitant d'un champ de recherche à la recherche d'informations sensibles.
- De nombreuses applications sur un réseau peuvent être explorées librement, fournissant parfois aux attaquants les données exactes qu'ils recherchent.
- Lors des exercices de cartographie du réseau et d'analyse des ports, chaque système et service découvert doit être exploré.

Utiliser les informations d'identification existantes

- Généralement, un attaquant utilise déjà les informations d'identification des utilisateurs de l'environnement. Par exemple, si un attaquant a compromis le système informatique de quelqu'un, il peut réutiliser les informations d'identification déjà utilisées par le système.
- Cela offre aux attaquants beaucoup plus d'opportunités. Considérez toutes les applications qui pourraient désormais être utilisées à mauvais escient. Par exemple :
 - Courriel
 - SharePoint
 - RH et comptabilité
 - VPN (« Réseau Privé Virtuel »)
- Une fois qu'un attaquant a accès à une application derrière le contrôle d'accès, les vulnérabilités et les données sont souvent nombreuses.
- Les informations d'identification d'un système peuvent également être extraites par différents moyens, impliquant généralement un accès administrateur au système. Mimikatz (<https://github.com/gentilkiwi/mimikatz>) est un tel outil qui tente de supprimer les informations d'identification du système.

Cyber Security Penetration Testing

Tests d'intrusion et ingénierie sociale , Les tests d'intrusion constituent une mesure proactive pour tenter d'identifier les vulnérabilités des services et des organisations avant que d'autres attaquants ne le puissent.

Tests d'intrusion et ingénierie sociale

- Les tests d'intrusion constituent une mesure proactive pour tenter d'identifier les vulnérabilités des services et des organisations avant que d'autres attaquants ne le puissent. Les tests d'intrusion peuvent être proposés dans de nombreux domaines, par exemple :
- Applications Web.
- De nouvelles applications Web sont développées et publiées.
Réseau et infrastructures.
- De nombreuses applications ne sont pas des applications Web, mais utilisent d'autres protocoles. Ces applications d'organisation peuvent résider à la fois en externe et en interne.
- Tests internes / Simulation informatique infectée. Que se passe-t-il si un utilisateur reçoit des logiciels malveillants sur son système ? Cela équivaldrait presque à un attaquant ayant les mains sur le clavier de ce système, ce qui représenterait un risque sérieux pour toute organisation.
- Tests organisationnels externes. Un test qui vaut au sein de toute l'organisation comme champ d'application pour les testeurs d'intrusion. C'est l'idéal, mais cela implique souvent de disposer de leur propre équipe interne de tests d'intrusion pour se concentrer sur ce test à long terme, ou de coûts élevés impliquant l'embauche d'une équipe externe pour effectuer ce test.

Tests d'intrusion et ingénierie sociale

- Scénario de vol d'ordinateur portable. Décrit plus en détail dans nos scénarios ci-dessous.
- Applications côté client. De nombreuses applications existent dans une entreprise écrites dans différents langages tels que C, C++, Java, Flash, Silverlight ou autres logiciels compilés. Un test d'intrusion pourrait également se concentrer sur ces actifs.
- Réseaux sans fil. Un test qui sert à déterminer si le WIFI peut être piraté, si les appareils disposent de logiciels obsolètes et vulnérables et si une segmentation appropriée a été établie entre le réseau sans fil et les autres réseaux.
- Applications mobiles (Android, Windows Phone, IOS). Les applications mobiles peuvent comporter des vulnérabilités et inclure également des connexions et des références à des systèmes hébergés au sein de l'entreprise. Les applications mobiles peuvent également détenir des secrets tels que des clés API qui peuvent facilement être exploitées par des attaquants.
- Ingénierie sociale. Décrit plus en détail dans nos scénarios ci-dessous.
- Phishing et Vishing. Décrit plus en détail dans nos scénarios ci-dessous.
- Physique. Une équipe de tests d'intrusion pourrait essayer de voir ce qui se passe s'ils se présentent à un endroit avec un ordinateur portable et se connectent à une connexion réseau. Les attaques physiques peuvent également inclure d'autres types d'attaques secrètes contre des emplacements.
- ICS ("Industrial Control Systems") / SCADA ("Supervisory Control And Data Acquisition"). Ces systèmes contrôlent généralement certains des actifs les plus vulnérables et les plus critiques des organisations et, à ce titre, doivent faire l'objet d'un examen minutieux.

Tests d'intrusion sans connaissance

- Tests d'intrusion sans connaissance, connaissance partielle et connaissance complète.
- En fonction de l'engagement, l'organisation peut décider de fournir des informations à l'équipe effectuant les tests d'intrusion. Une pénétration sans connaissance, parfois appelée boîte noire, implique que l'attaquant n'en a aucune connaissance à l'avance. Une connaissance partielle, parfois appelée test de boîte grise, signifie que les attaquants acquièrent certaines connaissances, et avec un test d'intrusion complet, parfois appelé boîte blanche, les testeurs d'intrusion disposent de tout ce dont ils ont besoin : code source, diagrammes de réseau, journaux et bien plus encore.
- Plus une organisation peut fournir d'informations à l'équipe de tests d'intrusion, plus l'équipe peut apporter de valeur élevée.

Scénario d'ordinateur portable volé

- Un bon scénario de test d'intrusion consiste à prouver les conséquences d'un ordinateur portable volé ou perdu. Les systèmes disposent de privilèges et d'informations d'identification que les attaquants pourraient utiliser pour pénétrer dans l'organisation cible.
- Le système peut être protégé par un mot de passe, mais il existe de nombreuses techniques permettant aux attaquants de contourner cette protection. Par exemple :
- Le disque dur du système peut ne pas être entièrement chiffré, ce qui permet à un attaquant de monter le disque dur sur son propre système pour extraire des données et des informations d'identification. Ces informations d'identification pourraient à leur tour être déchiffrées et réutilisées sur de nombreuses pages de connexion de l'organisation.
- L'utilisateur a peut-être verrouillé le système, mais un utilisateur est toujours connecté. Cet utilisateur a des applications et des processus exécutés en arrière-plan, même s'il est verrouillé. Les attaquants pourraient tenter d'ajouter une carte réseau malveillante au système via, par exemple, USB. Cette carte réseau tente de devenir le moyen privilégié pour le système d'accéder à Internet. Si le système utilise cette carte réseau, les attaquants peuvent désormais voir le trafic réseau et tenter de trouver des données sensibles, voire de modifier des données.
- Dès que les attaquants ont accès au système, ils peuvent commencer à le piller pour obtenir des informations, qui peuvent être utilisées pour poursuivre leurs objectifs.

Social Engineering

- Un système n'est aussi fort que son membre le plus faible, et celui-ci est souvent un être humain. L'ingénierie sociale consiste à cibler les utilisateurs avec des attaques visant à les inciter à accomplir des actions qu'ils n'avaient pas l'intention de faire. Ce type de technique est très populaire et bon nombre des plus gros hacks au monde ont impliqué l'utilisation de techniques d'ingénierie sociale.

L'ingénierie sociale tente souvent d'abuser de certains aspects pour amener les victimes à se conformer à des actions, par exemple :

La plupart des gens désirent être polis, surtout envers les étrangers.

Les professionnels veulent paraître informés et intelligents

Si vous êtes félicité, vous parlerez souvent davantage et divulguez davantage

La plupart des gens ne mentiraient pas pour le plaisir de mentir

La plupart des gens réagissent gentiment aux personnes qui semblent s'inquiéter à leur sujet.

Lorsqu'une personne a été victime d'une bonne attaque d'ingénierie sociale, elle ne réalise souvent pas du tout qu'elle a été attaquée.

Scénario d'ingénierie sociale : être utile

- Les humains veulent généralement s'entraider. Nous aimons faire de belles choses !
- Prenons un scénario dans lequel Eve se précipite à la réception d'un grand bureau d'entreprise avec ses papiers trempés dans du café. La réceptionniste voit clairement Eve en détresse et se demande ce qui se passe. Eve explique qu'elle a un entretien d'embauche dans 5 minutes et qu'elle a vraiment besoin que ses documents soient imprimés pour l'entretien.
- Eve a préparé à l'avance une clé USB malveillante contenant des documents destinés à compromettre les ordinateurs sur lesquels elle est branchée. Elle tend à la réceptionniste la clé USB malveillante et demande en souriant si la réceptionniste peut imprimer les documents pour elle. C'est peut-être ce qu'il faut aux attaquants pour infecter un système sur le réseau interne, leur permettant ainsi de compromettre (pivoter) davantage de systèmes.

Scénario d'ingénierie sociale : utiliser la peur

- Les gens ont souvent peur d'échouer ou de ne pas faire ce qui leur est ordonné. Les attaquants utilisent souvent la peur pour tenter de contraindre leurs victimes à faire ce dont ils ont besoin. Ils peuvent par exemple essayer de se faire passer pour le chef d'entreprise qui demande des informations. Peut-être qu'une mise à jour sur les réseaux sociaux a révélé que le réalisateur est en vacances et que cela peut être utilisé pour organiser l'attaque.
- La victime ne veut probablement pas contester le directeur, et comme celui-ci est en vacances, il pourrait être plus difficile de vérifier l'information.

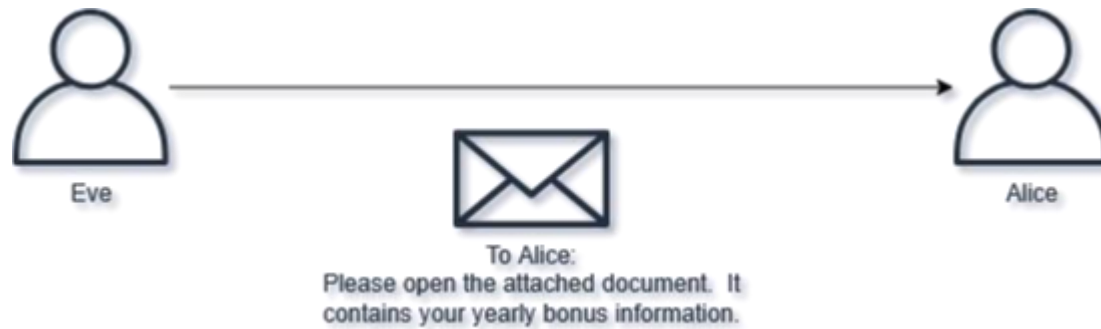
Scénario d'ingénierie sociale : jouer sur la réciprocité

- La réciprocité consiste à faire quelque chose en retour, comme une réponse à quelqu'un qui vous fait preuve de gentillesse.
- Si nous envisageons que quelqu'un vous tient la porte pour vous laisser entrer par la porte d'entrée de votre immeuble de bureaux. Pour cette raison, vous souhaitez probablement garder la porte d'à côté pour que la personne vous rende la pareille. Cette porte peut être derrière un contrôle d'accès, obligeant les employés à présenter leur badge, mais pour offrir la même gentillesse en retour, la porte est maintenue ouverte. C'est ce qu'on appelle le talonnage.

Scénario d'ingénierie sociale : exploiter la curiosité

- Les humains sont curieux par nature. Que feriez-vous si vous trouviez une clé USB par terre à l'extérieur de l'immeuble de bureaux ? Le brancher ? Que se passe-t-il si la clé USB contient un document intitulé « Informations sur les salaires – Mises à jour actuelles » ?
- Un attaquant pourrait délibérément laisser tomber de nombreuses clés USB malveillantes dans la zone où résident les employés, en espérant que quelqu'un les branchera.
- Les documents peuvent contenir des macros ou des exploits malveillants, ou simplement inciter les utilisateurs à effectuer certaines actions qui les amènent à se compromettre.

Phishing



- Le phishing est une technique généralement utilisée par courrier électronique. Les attaquants tenteront de contraindre et de tromper les employés pour qu'ils divulguent des informations sensibles telles que leurs informations d'identification ou de leur faire installer des applications malveillantes donnant aux attaquants le contrôle du système.
- Le phishing est une technique courante utilisée par les attaquants pour s'introduire, ce que les testeurs d'intrusion pourraient également essayer d'exploiter. Il est important de ne jamais sous-estimer le facteur humain en matière de cybersécurité. Tant que des humains seront impliqués, le phishing restera toujours un moyen possible pour les attaquants d'accéder aux systèmes.
- Le phishing ne doit pas être utilisé pour prouver que les humains font des erreurs, mais plutôt pour prouver les conséquences de ces erreurs. Il peut également être utilisé pour tester la puissance des filtres anti-spam et la sensibilisation des utilisateurs.
- Une campagne composée de plusieurs tentatives de phishing peut être menée au lieu d'un seul tour. Une campagne composée de plusieurs cycles de phishing peut aider à déterminer la sensibilisation globale de l'organisation et également à lui faire savoir que non seulement les attaquants tentent de tromper nos utilisateurs, mais également le service de sécurité.

Vishing

- Le vishing consiste à utiliser des appels téléphoniques pour tenter d'amener des employés sans méfiance à effectuer des actions pour les attaquants.
- Si l'employé croit qu'il est en communication téléphonique avec quelqu'un qu'il connaît, de préférence une personne ayant autorité, il peut être amené à commettre des actions non désirées.

Voici un exemple vishing où Eve appelle Alice

- **Eve** : Bonjour, c'est Miss Eve qui appelle. La PDG Margarethe m'a dit de vous appeler personnellement ; elle a dit que tu pourrais aider.
Alice : Ok... Qu'est-ce que je peux faire pour toi ?
Eve : Margarethe est en voyage en ce moment, mais demande de toute urgence que son mot de passe soit réinitialisé afin que nous puissions continuer une réunion d'affaires qui aura lieu dès son atterrissage.
Eve : Nous demandons de toute urgence que son mot de passe de messagerie soit réinitialisé afin qu'elle puisse animer la réunion.
Eve : Pouvez-vous procéder à la réinitialisation de son mot de passe sur Margareth123 ?
Alice : Je ne suis pas sûre...
Eve : S'il vous plaît, Margarethe vous a demandé personnellement de répondre à cette demande. Il faut le faire maintenant, je ne veux pas penser aux conséquences sinon...
Alice : D'accord. Le mot de passe est réinitialisé

Le vishing pourrait tenter d'amener les victimes à divulguer des informations révélant des informations sensibles. Il peut s'agir d'un attaquant demandant une copie d'un document sensible ou d'une feuille de calcul.

Le smishing

- (contraction de SMS et phishing) est une technique d'escroquerie par SMS visant à voler des données personnelles ou bancaires en incitant la victime à cliquer sur un lien malveillant ou à rappeler un numéro frauduleux. Ces messages usurpent souvent l'identité de banques, administrations ou services de livraison pour créer un sentiment d'urgence.
- **Comment repérer et éviter le smishing :**
- **Signaux d'alerte :** Un message inattendu, une orthographe approximative, un lien suspect (URL raccourcie) ou une demande urgente de paiement/mise à jour de données.
- **Les pièges courants :** Faux colis bloqué, amende impayée, problème de compte bancaire ou de carte Vitale.
- **Actions à prendre :** Ne jamais cliquer sur le lien, supprimer le message, et vérifier l'information en contactant directement l'organisme via son canal officiel.

Le futur de l'ingénierie sociale

- Avec le Deepfake ou le Deepvoice, la supercherie des ingénieurs sociaux sera encore plus dure à déceler. Le Deepfake permet de remplacer son visage par celui de sa victime, le Deepvoice permet de remplacer sa voix par celle de sa victime. Si la victime est un chef d'entreprise, alors il est facile, et à peu de frais de se faire passer pour lui.

Autrement dit, même un contact en video ne permet pas de savoir si la personne est véritablement la bonne.

Le Deepfake et le Deepvoice sont donc deux technologies pouvant être mises à profit par les cybercriminels dans le cadre d'une attaque par ingénierie sociale.

Les ports dans les réseaux

Qu'est-ce qu'un port informatique ?

Les ports sont des emplacements virtuels dans un système d'exploitation, où les connexions réseau commencent et se terminent. Ils aident les ordinateurs à trier le trafic réseau qu'ils reçoivent.

Qu'est-ce qu'un port et qu'un numéro de port ?

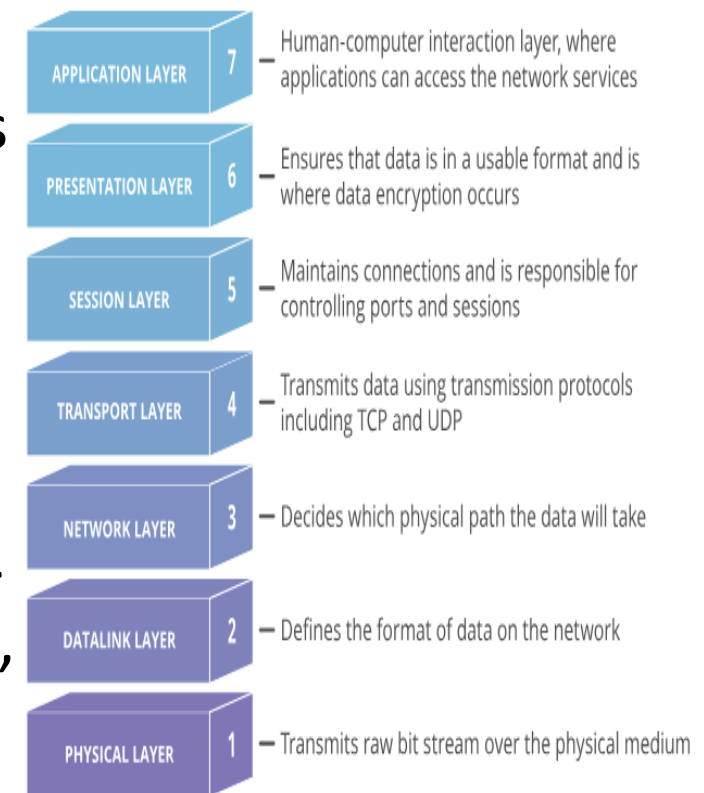
- **Qu'est-ce qu'un port ?**
- Un port est un point virtuel où les connexions réseau commencent et se terminent. Basés sur des logiciels, les ports sont gérés par le système d'exploitation d'un ordinateur. Chaque port est associé à un processus ou un service spécifique. Les ports permettent aux ordinateurs de différencier facilement les différents types de trafic : les e-mails, par exemple, sont acheminés vers un port différent de celui des pages web, même si les deux parviennent à un ordinateur via la même connexion Internet.
- **Qu'est-ce qu'un numéro de port ?**
- Les ports sont normalisés sur l'ensemble des appareils connectés au réseau, et un numéro est attribué à chaque port. La plupart des ports sont réservés à certains protocoles ; par exemple, tous les messages HTTP (Hypertext Transfer Protocol) sont envoyés au port 80. Alors que les adresses IP permettent aux messages d'être envoyés vers et depuis des appareils spécifiques, les numéros de port permettent de cibler des services ou des applications spécifiques sur ces appareils.

Comment les ports rendent-ils les connexions réseau plus efficaces ?

- Des types de données très différents circulent vers et depuis un ordinateur sur la même connexion réseau. L'utilisation des ports aide les ordinateurs à comprendre ce qu'ils doivent faire avec les données qu'ils reçoivent.
- Supposons que Bob transfère un enregistrement audio MP3 à Alice avec le protocole FTP (File Transfer Protocol). Si l'ordinateur d'Alice transmettait les données du fichier MP3 à l'application de messagerie d'Alice, celle-ci ne saurait pas comment les interpréter. Toutefois, comme le transfert de fichiers de Bob utilise le port désigné pour le protocole FTP (port 21), l'ordinateur d'Alice est en mesure de recevoir et de stocker le fichier.
- Pendant ce temps, l'ordinateur d'Alice peut charger simultanément des pages web HTTP en utilisant le port 80, même si les fichiers de la page web et le fichier audio MP3 arrivent sur l'ordinateur d'Alice via la même connexion WiFi.

les ports rendent-ils les connexions

- Les ports font-ils partie de la couche réseau ?
- Le modèle OSI est un modèle conceptuel expliquant le fonctionnement d'Internet. Il divise les différents services et processus Internet en 7 couches. Ces couches sont :
- Modèle OSI à 7 couches
- **Définition et utilité des ports**
- **Concept virtuel** : Un port est un point de terminaison logiciel géré par le système d'exploitation.
- **Différenciation du trafic** : Ils permettent à un ordinateur de distinguer plusieurs types de flux (e-mails, pages web, fichiers) arrivant par une même connexion réseau.
- **Association** : Chaque port est lié à un processus ou un service spécifique (ex: le port 80 pour le Web).



Les ports et TCP UDP

- Les ports sont un concept de la couche de transport (couche 4). Seul un protocole de transport, comme TCP (Transmission Control Protocol) ou UDP (User Datagram Protocol), peut indiquer à quel port un paquet doit être envoyé.
- Les en-têtes TCP et UDP comportent une section permettant d'indiquer les numéros de port. Les protocoles de la couche réseau, comme IP (Internet Protocol), par exemple, ne savent pas quel port est utilisé dans une connexion réseau donnée. Un en-tête IP standard ne comporte pas d'emplacement permettant d'indiquer à quel port le paquet de données doit être adressé. Les en-têtes IP indiquent uniquement l'adresse IP de destination, et non le numéro de port de cette adresse IP.

Place dans le modèle OSI

- Les ports appartiennent à la **couche de transport (couche 4)**.
- Ils sont spécifiés dans les en-têtes des protocoles **TCP** ou **UDP**.
- La couche réseau (IP) ne gère pas les ports, ce qui explique pourquoi un "ping" classique (ICMP) ne peut pas tester un port spécifique sans l'utilisation de protocoles de transport additionnels.
- **Sécurité et Pare-feu**
- Le pare-feu agit comme une barrière de sécurité en filtrant le trafic selon les numéros de ports :
- **Ports ouverts** : Seuls les ports essentiels (ex: 80, 443) sont généralement autorisés.
- **Ports fermés** : La majorité des ports sont bloqués par défaut pour empêcher les acteurs malveillants d'exploiter des vulnérabilités (ex: le port 3389 pour le RDP).

les différents numéros de port ?

- Il existe 65 535 numéros de port possibles, mais tous ne sont pas fréquemment utilisés. Voici quelques-uns des ports les plus couramment utilisés, ainsi que le protocole réseau qui leur est associé :
- **Ports 20 et 21** : File Transfer Protocol (FTP). Le protocole FTP permet de transférer des fichiers entre un client et un serveur.
- **Port 22** : Secure Shell (SSH). SSH est l'un des nombreux protocoles de **tunnellisation** permettant d'établir des connexions réseau sécurisées.
- **Port 25** : historiquement, **SMTP** (Simple Mail Transfer Protocol). SMTP est utilisé pour le **courrier électronique**.
- **Port 53 : DNS (Domain Name System)**. Le DNS est un processus essentiel du réseau Internet moderne. Il associe les **noms de domaines** lisibles par l'homme à des adresses IP lisibles par les ordinateurs, permettant aux utilisateurs de charger des sites web et des applications sans devoir mémoriser une longue liste d'adresses IP.
- **Port 80** : HTTP (Hypertext Transfer Protocol). Le protocole HTTP est ce qui rend Internet possible.
- **Port 123 : NTP** (Network Time Protocol). NTP permet aux horloges des ordinateurs de se synchroniser entre elles. Ce processus est essentiel pour le **chiffrement**.
- **Port 179 : BGP** (Border Gateway Protocol). BGP est essentiel à l'établissement d'itinéraires efficaces entre les grands réseaux qui constituent Internet (ces grands réseaux sont appelés **systèmes autonomes**). Les systèmes autonomes utilisent BGP pour diffuser les adresses IP qu'ils contrôlent.
- **Port 443 : HTTPS** (HTTP Secure) est la version sécurisée et chiffrée du protocole HTTP. Tout le trafic web HTTPS passe par le port 443. Les services réseau qui utilisent le HTTPS pour le chiffrement, comme **DNS over HTTPS**, se connectent également à ce port.
- **Port 500** : ISAKMP (Internet Security Association and Key Management Protocol) fait partie du processus d'établissement de connexions **IPsec** sécurisées.
- **Port 587** : protocole SMTP moderne et sécurisé utilisant le chiffrement.
- **Port 3389 : RDP** (Remote Desktop Protocol). Le protocole RDP permet aux utilisateurs de se connecter à distance à leur ordinateur de bureau depuis un autre appareil.
- L'organisme Internet Assigned Numbers **Authority (IANA)** tient à jour la liste complète des numéros de port et des protocoles qui leur sont attribués.

Penetration Testing

PENTEST

Tests d'intrusion



Nmap

Zenmap

Scan Tools Profile Help

Target: 196.200.156.100 Profile: Intense scan Scan Cancel

Command: nmap -T4 -A -v 196.200.156.100

Hosts Services

OS Host

196.200.156.100

Nmap Output Ports / Hosts Topology Host Details Scans

nmap -T4 -A -v 196.200.156.100 Details

Completed NSE at 16:37, 5.03s elapsed
Initiating NSE at 16:37
Completed NSE at 16:37, 1.19s elapsed
Initiating NSE at 16:37
Completed NSE at 16:37, 0.00s elapsed
Nmap scan report for 196.200.156.100
Host is up (0.0026s latency).
Not shown: 996 filtered tcp ports (no-response)

| PORT | STATE | SERVICE | VERSION |
|--------|-------|---------|--------------|
| 80/tcp | open | http | Apache httpd |

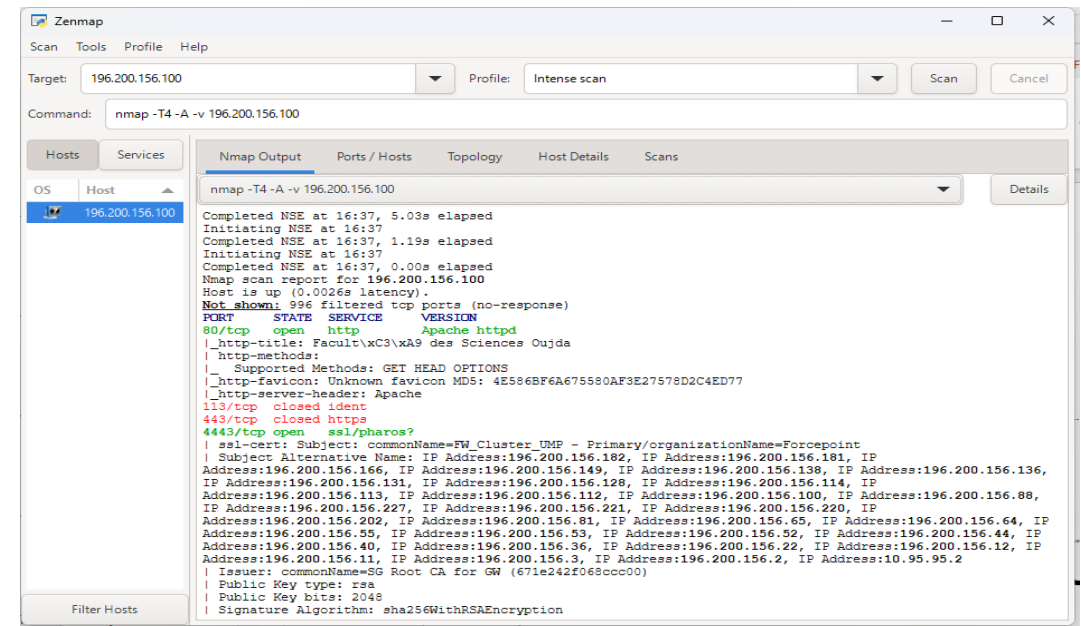
|_ http-title: Facult\XC3\XA9 des Sciences Oujda
|_ http-methods:
|_ Supported Methods: GET HEAD OPTIONS
|_ http-favicon: Unknown favicon MD5: 4E586BF6A675580AF9E27578D2C4ED77
|_ http-server-header: Apache
113/tcp closed ident
443/tcp closed https
4443/tcp open ssl/pharos?
|_ ssl-cert: Subject: commonName=FW_Cluster_UMP - Primary/organizationName=Forcepoint
| Subject Alternative Name: IP Address:196.200.156.182, IP Address:196.200.156.181, IP Address:196.200.156.166, IP Address:196.200.156.149, IP Address:196.200.156.138, IP Address:196.200.156.136, IP Address:196.200.156.131, IP Address:196.200.156.128, IP Address:196.200.156.114, IP Address:196.200.156.113, IP Address:196.200.156.112, IP Address:196.200.156.100, IP Address:196.200.156.88, IP Address:196.200.156.227, IP Address:196.200.156.221, IP Address:196.200.156.220, IP Address:196.200.156.202, IP Address:196.200.156.81, IP Address:196.200.156.65, IP Address:196.200.156.64, IP Address:196.200.156.55, IP Address:196.200.156.53, IP Address:196.200.156.52, IP Address:196.200.156.44, IP Address:196.200.156.40, IP Address:196.200.156.36, IP Address:196.200.156.22, IP Address:196.200.156.12, IP Address:196.200.156.11, IP Address:196.200.156.3, IP Address:196.200.156.2, IP Address:10.95.95.2
| Issuer: commonName=SG Root CA for GW (671e242f068ccc00)
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption

Filter Hosts

Méthodologie d'analyse/ScanningMethodology

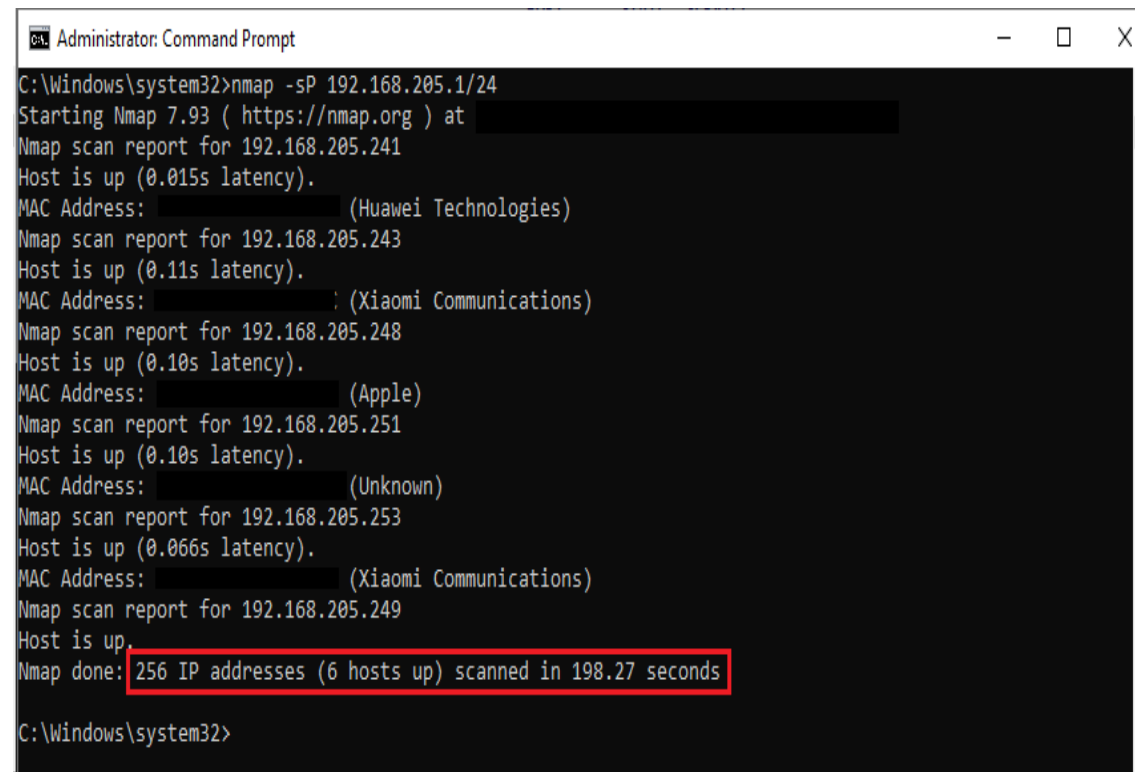
feuille de route

- Feuille de route de bout en bout de l'activité de test d'intrusion à l'aide de nmap.
- Tout d'abord, vous aurez besoin d'un outil d'exploration de réseau et d'un scanner de sécurité/port.
- Nous utiliserons l'outil nmap. Si Nmap n'est pas installé, vous pouvez l'obtenir à partir d'ici <https://nmap.org/download.html>. C'est gratuit
- Nous pouvons utiliser à la fois la version graphique ou via un terminal.
- Méthodologie
 - ✓ Recherchez des systèmes en direct
 - ✓ Vérifier les ports ouverts
 - ✓ Saisie de bannières
 - ✓ Analyse de vulnérabilité
 - ✓ Rapport de test d'intrusion



1. Vérifiez les systèmes en direct

- Nous devons rechercher tous les systèmes vivants présents dans notre environnement de portée. Nous allons effectuer un balayage sur un réseau.
`nmap -sp 192.168.205.1/24`
- Maintenant, nous avons un total de 6 hôtes qui sont en hausse sur 256 balayages d'adresses IP.



```
Administrator: Command Prompt
C:\Windows\system32>nmap -sp 192.168.205.1/24
Starting Nmap 7.93 ( https://nmap.org ) at 
Nmap scan report for 192.168.205.241
Host is up (0.015s latency).
MAC Address: (Huawei Technologies)
Nmap scan report for 192.168.205.243
Host is up (0.11s latency).
MAC Address: : (Xiaomi Communications)
Nmap scan report for 192.168.205.248
Host is up (0.10s latency).
MAC Address: (Apple)
Nmap scan report for 192.168.205.251
Host is up (0.10s latency).
MAC Address: (Unknown)
Nmap scan report for 192.168.205.253
Host is up (0.066s latency).
MAC Address: (Xiaomi Communications)
Nmap scan report for 192.168.205.249
Host is up
Nmap done: 256 IP addresses (6 hosts up) scanned in 198.27 seconds
C:\Windows\system32>
```

2. Vérifiez les ports ouverts

- La prochaine tâche à effectuer serait d'effectuer une analyse des ports pour obtenir des informations sur les ports ouverts exécutés sur le système. Choisissez un hôte spécifique. Nous connaissons les détails du port et les services qui y fonctionnent.
- **nmap 192.168.254.249**
- Au total, 6 ports ouverts sont trouvés, et nous pouvons également voir un service s'exécuter sur eux.

```
C:\Windows\system32>nmap 192.168.205.249
Starting Nmap 7.93 ( https://nmap.org ) at 
Nmap scan report for 192.168.205.249
Host is up (0.00051s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
443/tcp   open  https
445/tcp   open  microsoft-ds
3306/tcp  open  mysql

Nmap done: 1 IP address (1 host up) scanned in 0.33 seconds
```

3. Effectuer une capture de bannière

- Banner Grabbing est l'une des nombreuses techniques utilisées pour découvrir le type et/ou la version du logiciel utilisé.
Détection de versions
Pour activer la détection de version, le commutateur « -sV » est utilisé.
- **nmap -sV 192.168.254.249**
- Cela s'intéresse maintenant, nous avons appris à connaître les noms des applications et leur version également.

```
C:\Windows\system32>nmap -sV 192.168.205.249
Starting Nmap 7.93 ( https://nmap.org ) at 
NSOCK ERROR [0.0690s] ssl_init_helper(): OpenSSL legacy provider failed to load.

Nmap scan report for 192.168.205.249
Host is up (0.00017s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Apache httpd 2.4.54 ((Win64) OpenSSL/1.1.1p PHP/7.4.30)
135/tcp    open  msrpc        Microsoft Windows RPC
139/tcp    open  netbios-ssn  Microsoft Windows netbios-ssn
443/tcp    open  ssl/http     Apache httpd 2.4.54 ((Win64) OpenSSL/1.1.1p PHP/7.4.30)
445/tcp    open  microsoft-ds?
3306/tcp   open  mysql        MariaDB (unauthorized)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
```


Détection du système d'exploitation :

- Détection du système d'exploitation :
Pour activer la détection du système d'exploitation, le commutateur « -O » est utilisé.
- `nmap-O 192.168.205.249`
- Le système d'exploitation sur cet hôte est Windows 10.

```
C:\Windows\system32>nmap -O 192.168.205.249
Starting Nmap 7.93 ( https://nmap.org ) at 
Nmap scan report for 192.168.205.249
Host is up (0.00086s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
443/tcp   open  https
445/tcp   open  microsoft-ds
3306/tcp  open  mysql
Device type: general purpose
Running: Microsoft Windows 10
OS CPE: cpe:/o:microsoft:windows_10
OS details: Microsoft Windows 10 1809 - 1909
Network Distance: 0 hops

OS detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 1.97 seconds
```

- Vous pouvez également utiliser l'argument -A pour effectuer une analyse agressive. Il permet la détection du système d'exploitation, la détection de version et d'autres services.
- nmap -A 192.168.205.249**

```
Administrator: Command Prompt
C:\Windows\system32>nmap -A 192.168.205.249
Starting Nmap 7.93 ( https://nmap.org ) at 
NSOCK ERROR [0.5080s] ssl_init_helper(): OpenSSL legacy provider failed to load.

Nmap scan report for 192.168.205.249
Host is up (0.00024s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Apache httpd 2.4.54 ((Win64) OpenSSL/1.1.1p PHP/7.4.30)
|_ http-title: Welcome to XAMPP
|_ _Requested resource was http://192.168.205.249/dashboard/
|_ _http-server-header: Apache/2.4.54 (Win64) OpenSSL/1.1.1p PHP/7.4.30
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
443/tcp   open  ssl/http     Apache httpd 2.4.54 ((Win64) OpenSSL/1.1.1p PHP/7.4.30)
|_ http-title: Welcome to XAMPP
|_ _Requested resource was https://192.168.205.249/dashboard/
|_ _http-server-header: Apache/2.4.54 (Win64) OpenSSL/1.1.1p PHP/7.4.30
|_ _ssl-cert: Subject: commonName=localhost
|_   Not valid before: 2009-11-10T23:48:47
|_   Not valid after:  2019-11-08T23:48:47
|_ _ssl-date: TLS randomness does not represent time
|_ _tls-alpn:
|_   http/1.1
445/tcp   open  microsoft-ds?
3306/tcp  open  mysql        MariaDB (unauthorized)
Device type: general purpose
Running: Microsoft Windows 10
OS CPE: cpe:/o:microsoft:windows_10
OS details: Microsoft Windows 10 1809 - 1909
Network Distance: 0 hops
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ smb2-security-mode:
|_   311:
|_     Message signing enabled but not required
|_ smb2-time:
|_   date: 2022-11-05T03:08:41
|_   start_date: N/A

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 30.36 seconds
```

4. Analyse des vulnérabilités

- L'étape suivante consiste à déterminer la vulnérabilité qui existe dans l'hôte.

nmap --script vulnérabilité 192.168.205.249

- Le script Nmap Scripting Engine (NSE) est l'une des fonctionnalités les plus populaires et les plus puissantes de Nmap. Ces scripts d'analyse de vulnérabilité Nmap sont utilisés par les testeurs d'intrusion et les pirates informatiques pour examiner les vulnérabilités connues courantes.
- Les scripts NSE sont classés selon un ensemble de catégories prédéterminées auxquelles appartient chaque script. Authentification, diffusion, force brute, intrusive, malware, coffre-fort, version et vulnérabilité sont quelques-unes des catégories. Vous pouvez trouver tous les types de catégories de scripts NSE et leurs phases ici.
- Cela vous facilite la vie puisque vous pouvez trouver une vulnérabilité existante dans la base de données Common Vulnerabilities and Exploits (CVE) pour une version particulière du service.

```
Administrator: Command Prompt

Disclosure date: 2009-09-17
References:
  https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
  http://ha.ckers.org/slowloris/
http-dombased-xss: Couldn't find any DOM based XSS.
http-trace: TRACE is enabled
http-enum:
  /phpmyadmin/: phpMyAdmin
  /icons/: Potentially interesting folder w/ directory listing
  /img/: Potentially interesting directory w/ listing on 'apache/2.4.54 (win64) openssl/1.1.1p php/7.4.30'
  /licenses/: Potentially interesting directory w/ listing on 'apache/2.4.54 (win64) openssl/1.1.1p php/7.4.30'
  /server-info/: Potentially interesting folder
  /server-status/: Potentially interesting folder
http-stored-xss: Couldn't find any stored XSS vulnerabilities.
135/tcp open  msrpc
139/tcp open  netbios-ssn
443/tcp open  https
http-trace: TRACE is enabled
http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to debug)
http-slowloris-check:
  VULNERABLE:
    Slowloris DOS attack
    State: LIKELY VULNERABLE
    IDs: CVE:CVE-2007-6750
    Slowloris tries to keep many connections to the target web server open and hold them open as long as possible. It accomplishes this by opening connections to the target web server and sending a partial request. By doing so, it starves the http server's resources causing Denial Of Service.

Disclosure date: 2009-09-17
References:
  https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
  http://ha.ckers.org/slowloris/
http-stored-xss: Couldn't find any stored XSS vulnerabilities.
ssl-dh-params:
  VULNERABLE:
    Diffie-Hellman Key Exchange Insufficient Group Strength
    State: VULNERABLE
    Transport Layer Security (TLS) services that use Diffie-Hellman groups of insufficient strength, especially those using one of a few commonly shared groups, may be susceptible to passive eavesdropping attacks.
Check results:
```

CVE

- On peut donc voir plusieurs codes de vulnérabilité : CVE-2012-1182, CVE-2007-6750.

Les applications/services en cours d'exécution sont sujets à ces vulnérabilités. De plus amples détails peuvent être trouvés sur les bases de données de vulnérabilités

- **Vulnerability Databases:**
- https://cve.mitre.org/cve/search_cve_list.html
- <https://www.cvedetails.com/>
- <https://nvd.nist.gov/vuln/search>
- <https://vuldb.com/?search>

The screenshot shows the CVE Details website interface. At the top, the title 'CVE Details' is displayed in blue, with the tagline 'The ultimate security vulnerability datasource' in green. A search bar is located in the top right corner, with a 'Search' button and a 'View CVE' button. Below the search bar, there are links for 'Log In' and 'Register', and a red banner for 'Vulnerability Feeds & Widgets' with a link to 'www.itsecdb.com'. The main content area shows search results for 'apache 2.4'. The results are organized into sections: 'Browse:', 'Reports:', 'Search:', and 'Top 50:'. The 'Browse:' section includes links for 'Vendors', 'Products', 'Vulnerabilities By Date', and 'Vulnerabilities By Type'. The 'Reports:' section includes links for 'CVSS Score Report' and 'CVSS Score Distribution'. The 'Search:' section includes links for 'Vendor Search', 'Product Search', 'Version Search', 'Vulnerability Search', and 'By Microsoft References'. The 'Top 50:' section includes links for 'Vendors', 'Vendor Cvss Scores', 'Products', and 'Product Cvss Scores'. The search results for 'apache 2.4' show about 5,060 results in 0.25 seconds. The first result is 'Apache Http Server version 2.4.8 : Security vulnerabilities', with a link to 'www.cvedetails.com' and a version ID of 524065. The second result is 'Apache Http Server version 2.4.4 : Security vulnerabilities', with a link to 'www.cvedetails.com' and a version ID of 515514. The third result is 'Apache Http Server version 2.4.49 : Security vulnerabilities', with a link to 'www.cvedetails.com' and a version ID of 668692. The fourth result is 'Apache Http Server : List of security vulnerabilities'.

5. Rapport de tests d'intrusion

- Il est temps d'écrire les résultats. Quelques rubriques

à aborder dans un rapport de test Pen sont les suivantes :

Résume le contenu du rapport en petit paragraphe ; énoncé des tâches accomplies, de la méthodologie utilisée, des conclusions de haut niveau et des recommandations.

Portée des travaux :

Inclut les adresses IP testées et le type de test d'intrusion effectué. Durée pendant laquelle l'activité a été exercée.

Objectif du projet :

Ce que l'organisation peut réaliser après avoir connu le risque et l'avoir atténué.

Détails de la découverte :

Nombre de risques découverts, en fonction des priorités. Pour chaque constatation, décrivez le niveau de menace, l'évaluation de la vulnérabilité et l'impact.

Recommandations :

Présentez les solutions, les mesures d'atténuation ou d'autres suggestions pour réduire/éliminer la vulnérabilité.

Vous pouvez trouver plusieurs exemples de rapports de tests d'intrusion en ligne.

Les détails du contenu du rapport de test d'intrusion peuvent être trouvés sur SANS « <https://www.sans.org/white-papers/33343/> ».

Writing a Penetration Testing Report

Download File



Writing a Penetration Testing Report (PDF, 3.05MB)

Published: 29 Apr, 2010

Created by:

Mansour Alharbi

SHARE



TCPDUMP

Comment voir ce qui transite réellement sur votre réseau ?

TCPDump

ANALOGIE SIMPLE

Imaginez que votre réseau est une autoroute. TCPDump, c'est comme installer une caméra de surveillance qui filme toutes les voitures (les paquets) qui passent. Vous pouvez ensuite filtrer pour ne voir que les camions (le trafic HTTP), les voitures rouges (une IP spécifique), ou celles qui roulent trop vite (comportements anormaux).

- Votre serveur est lent, mais vous ne savez pas pourquoi. Vos utilisateurs signalent des déconnexions aléatoires. Ou pire : vous suspectez une intrusion, mais vous n'avez aucune preuve.

Comment voir ce qui tr

- **TCPDump** est la réponse. Cet outil en ligne de commande capture et affiche les paquets réseau en temps réel, comme un stéthoscope pour votre infrastructure. En 10 minutes, vous saurez capturer du trafic, filtrer les données pertinentes, et identifier des comportements suspects. **ansite réellement sur votre réseau ?**

Qu'est-ce que TCPDump ?

- ✓ **Installer TCPDump** sur Linux et macOS
- ✓ **Capturer le trafic** d'une interface réseau spécifique
- ✓ **Filtrer les paquets** par adresse IP, port, protocole
- ✓ **Sauvegarder et relire** des captures pour analyse ultérieure
- ✓ **Détecter des menaces** : scans de ports, attaques DoS, tentatives SSH
- ✓ **Exporter vers Wireshark** pour une analyse graphique approfondie

Qu'est-ce que TCPDump ?

- Le problème que résout TCPDump: Quand quelque chose ne va pas sur un réseau, les logs applicatifs ne suffisent pas toujours. Ils vous disent ce que l'application a fait, mais pas ce qui s'est passé sur le câble.
- Exemples de situations où les logs sont muets :
- TCPDump vous donne **la vérité brute** : ce qui entre et sort réellement de votre machine, paquet par paquet.

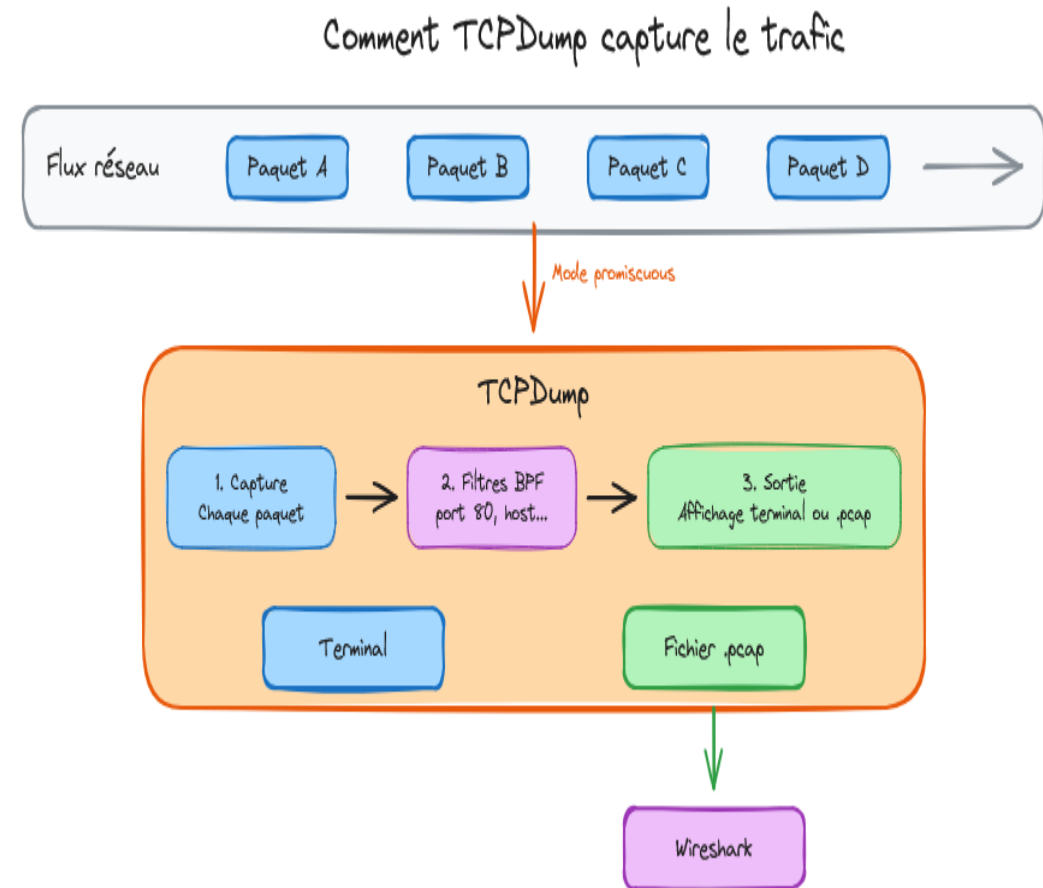
| Problème | Ce que les logs disent | Ce que TCPDump révèle |
|--------------------------|------------------------|---|
| Connexion lente | "Timeout après 30s" | Le serveur met 5s à répondre au SYN |
| Échec d'authentification | "Invalid credentials" | Les paquets n'arrivent même pas au serveur |
| Service inaccessible | "Connection refused" | Un pare-feu bloque le trafic en amont |
| Fuite de données | Rien du tout | Trafic sortant suspect vers une IP inconnue |

Comment fonctionne la capture de paquets

Quand une machine envoie ou reçoit des données sur le réseau, elles transitent sous forme de **paquets**. Chaque paquet contient :

- **L'en-tête** : adresses IP source/destination, port, protocole, flags **TCP**...
- **La charge utile (payload)** : les données réelles (requête HTTP, contenu de fichier...)

Normalement, une interface réseau ne traite que les paquets qui lui sont destinés. TCPDump met l'interface en **mode promiscuous** (promiscuité), ce qui lui permet de capturer **tout le trafic** qui passe, y compris celui destiné à d'autres machines (sur un réseau non commuté).



TCPDump vs Wireshark : quand utiliser lequel ?

- Les deux outils lisent le même format de fichier (.pcap), mais ont des usages différents :
- **Workflow recommandé** : Capturez avec TCPDump sur le serveur, puis analysez le fichier .pcap avec Wireshark sur votre poste.

| Critère | TCPDump | Wireshark |
|---------------------|------------------------|-----------------------|
| Interface | Ligne de commande | Graphique |
| Ressources | Léger (~500 KB) | Lourd (~100 MB) |
| Disponibilité | Pré-installé sur Linux | À installer |
| Usage serveur | ✅ Idéal (pas de GUI) | ❌ Nécessite un bureau |
| Analyse approfondie | Basique | Très avancée |
| Automatisation | ✅ Scripts <u>bash</u> | ❌ Manuel |

Installation de TCPDump

- **Vérifier si TCPDump est déjà installé**
- Sur la plupart des distributions Linux, TCPDump est pré-installé. Vérifiez avec :
- Fenêtre de terminal
- `tcpdump --version`
- **Résultat attendu :**
- `tcpdump version 4.99.4`
- `libpcap version 1.10.4 (with TPACKET_V3)`
- Si vous voyez `command not found`, passez à l'installation.
- `sudo apt update`
- `sudo apt install tcpdump`

Lister les interfaces réseau disponibles

- Avant de capturer, identifiez l'interface à surveiller :
- Fenêtre de terminal
- tcpdump -D
- **Exemple de sortie :**
 - ✓ 1.eth0 [Up, Running, Connected]
 - ✓ 2.any (Pseudo-device that captures on all interfaces) [Up, Running]
 - ✓ 3.lo [Up, Running, Loopback]
 - ✓ 4.docker0 [Up, Disconnected]
 - ✓ 5.virbr0 [Up, Disconnected]
- **Explications :**

| Interface | Description |
|---------------|--|
| eth0 / enp0s3 | Interface Ethernet principale |
| any | Capture sur toutes les interfaces |
| lo | Loopback (trafic local, 127.0.0.1) |
| docker0 | Bridge Docker |
| wlan0 / wlo1 | Interface Wi-Fi |

Votre première capture TCPDump

- **Capturer tout le trafic (déconseillé en production)**
- La commande la plus simple :
- Fenêtre de terminal : `sudo tcpdump -i eth0`
- **Pourquoi sudo ?** La capture de paquets nécessite des privilèges root pour mettre l'interface en mode promiscuous.
- **Sortie :**
 - ✓ 15:42:01.234567 IP 192.168.1.100.22 > 192.168.1.50.51234: Flags [P.], seq 1:37, ack 1, win 501, length 36
 - ✓ 15:42:01.234890 IP 192.168.1.50.51234 > 192.168.1.100.22: Flags [.], ack 37, win 502, length 0
 - ✓ 15:42:01.235123 IP 192.168.1.100.22 > 192.168.1.50.51234: Flags [P.], seq 37:101, ack 1, win 501, length 64
- **Arrêter la capture :** Ctrl + C

Comprendre la sortie de TCPDump

- La sortie de TCPDump peut sembler cryptique au premier abord, mais chaque élément a une signification précise. Apprendre à lire cette sortie vous permettra de diagnostiquer rapidement des problèmes réseau ou de repérer des comportements anormaux.
- Décortiquons une ligne :
 - ✓ 15:42:01.234567 IP 192.168.1.100.22 > 192.168.1.50.51234: Flags [P.], seq 1:37, ack 1, win 501, length 36
- Cette ligne nous indique qu'à 15h42, une machine (192.168.1.100) envoie 36 octets de données depuis son port 22 (SSH) vers une autre machine. Le flag [P.] signifie que les données doivent être transmises immédiatement (PUSH) et que le paquet précédent a été reçu (ACK).

Comprendre la sortie de TCPDump

| Élément | Signification |
|--------------------|---|
| 15:42:01.234567 | Horodatage (heure:minute:seconde.microsecondes) |
| IP | Protocole de couche réseau |
| 192.168.1.100.22 | IP source + port source (22 = SSH) |
| > | Direction (source → destination) |
| 192.168.1.50.51234 | IP destination + port destination |
| Flags [P.] | Flags TCP : P = PUSH, . = ACK |
| seq 1:37 | Numéros de séquence (37 octets de données) |
| ack 1 | Numéro d'acquittement |
| win 501 | Taille de fenêtre TCP |
| length 36 | Taille des données |

Netcat : Le couteau suisse du réseau

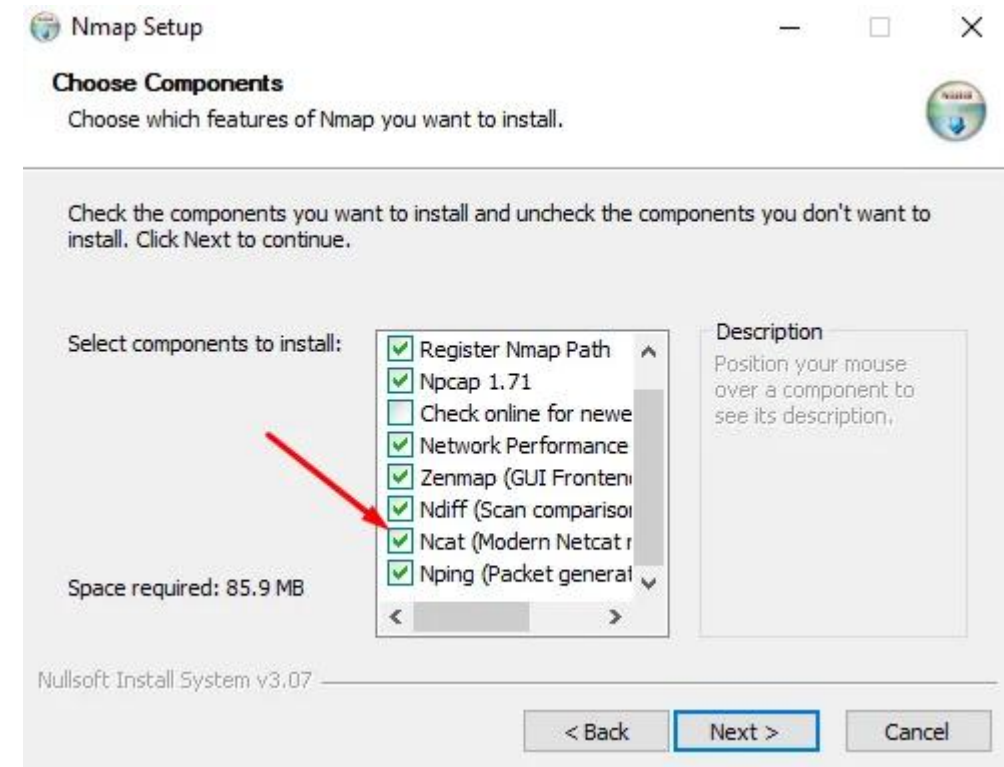
Qu'est-ce que Ncat (Netcat) ?

- Ncat est un outil réseau puissant et flexible utilisé pour le débogage, la surveillance et le transfert de données via des connexions TCP/IP. Il s'agit d'une version moderne de Netcat, développée et maintenue dans le cadre du projet Nmap.
 - cmd terminal et vérifier la version ncat ;
- ✓ ncat -v

```
C:\WINDOWS\system32\cmd.exe
Microsoft Windows [version 10.0.26200.8037]
(c) Microsoft Corporation. Tous droits réservés.

C:\Users\serrh>ncat -v
Ncat: Version 7.98 ( https://nmap.org/ncat )
Ncat: You must specify a host to connect to. QUITTING.

C:\Users\serrh>
```



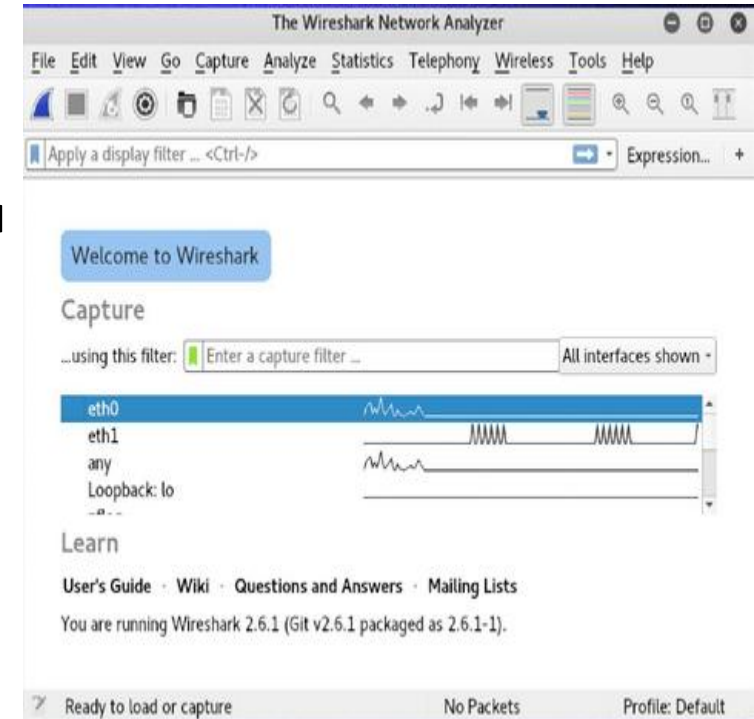
Qu'est-ce que Wireshark ?

<https://www.wireshark.org/download.html>

- Wireshark est un logiciel d'analyse de protocole réseau open source, largement considéré comme la norme de l'industrie. Une organisation mondiale de spécialistes des réseaux et de développeurs de logiciels soutient Wireshark et continue d'effectuer des mises à jour pour les nouvelles technologies réseau et méthodes de cryptage.

Les agences gouvernementales, les entreprises, les organisations à but non lucratif et les établissements d'enseignement utilisent Wireshark à des fins de dépannage et d'enseignement. Il n'y a vraiment pas de meilleur moyen d'apprendre les réseaux de bas niveau que d'observer le trafic au microscope de Wireshark.

Vous ne devez utiliser Wireshark que sur les réseaux sur lesquels vous êtes autorisé à inspecter les paquets réseau. Utiliser Wireshark pour consulter des paquets sans autorisation est illégal.



Comment fonctionne Wireshark ?

- Wireshark est un outil de renifleur et d'analyse de paquets. Il capture le trafic réseau provenant des connexions Ethernet, Bluetooth, sans fil (IEEE.802.11), Token Ring et Frame Relay, entre autres, et stocke ces données pour une analyse hors ligne.

Un « paquet » est un message unique provenant de n'importe quel protocole réseau (par exemple, TCP, DNS, etc.).

Le trafic LAN est en mode diffusion, ce qui signifie qu'un seul ordinateur avec Wireshark peut voir le trafic entre deux autres ordinateurs. Pour voir le trafic vers un site externe, vous devez capturer les paquets sur l'ordinateur local.

Wireshark vous permet de filtrer le journal avant le début de la capture ou pendant l'analyse, afin que vous puissiez affiner et vous concentrer sur ce que vous recherchez dans la trace réseau. Par exemple, vous pouvez définir un filtre pour voir le trafic TCP entre deux adresses IP, ou vous pouvez le définir uniquement pour vous montrer les paquets envoyés depuis un ordinateur. Les filtres de Wireshark sont l'une des principales raisons pour lesquelles il est devenu l'outil standard d'analyse des paquets.

Quand Wireshark doit-il être utilisé ?

- Wireshark peut être utilisé pour comprendre comment s'effectue la communication sur un réseau et pour analyser ce qui n'a pas fonctionné lorsqu'un problème de communication survient.

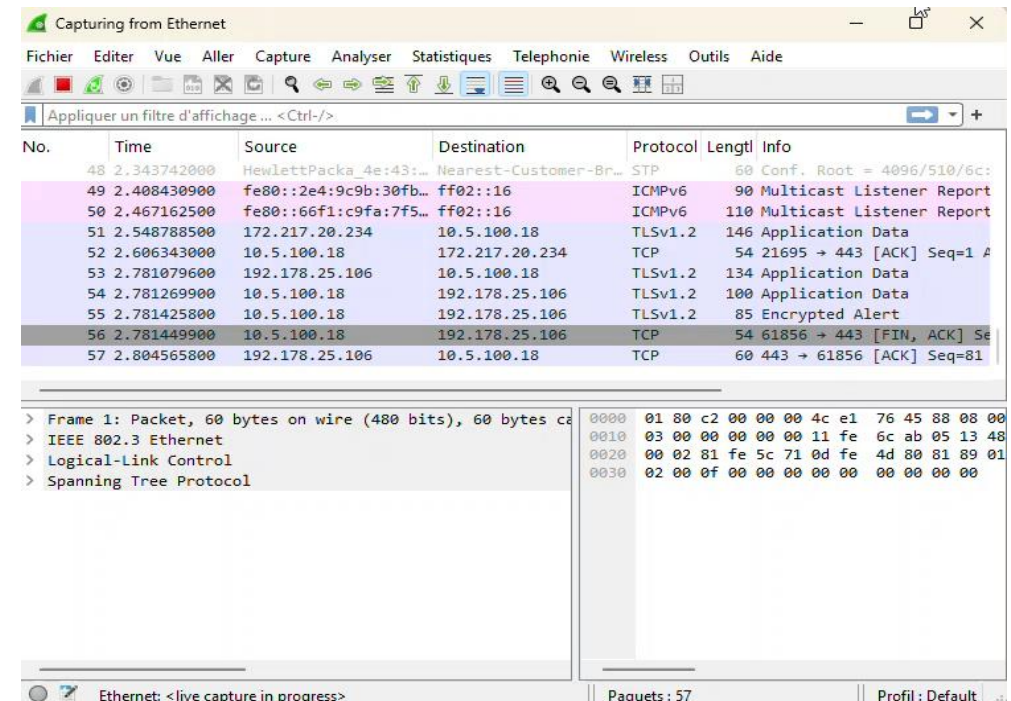
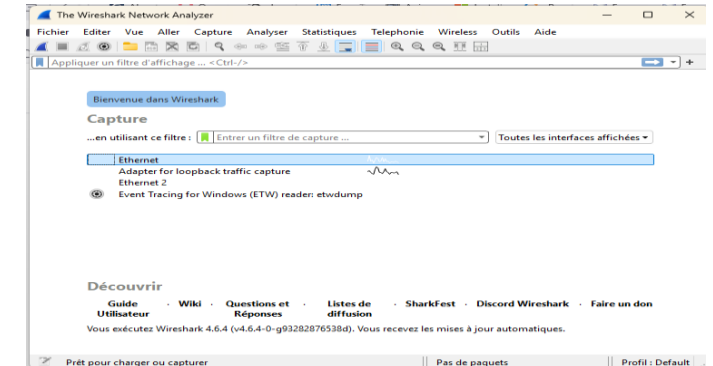
Wireshark aide :

- ✓ Les administrateurs réseau résolvent les problèmes sur un réseau
- ✓ Les ingénieurs en sécurité examinent les problèmes de sécurité sur un réseau
- ✓ Les ingénieurs QA vérifient les applications
- ✓ Les développeurs déboguent les implémentations du protocole
- ✓ Les utilisateurs du réseau découvrent un protocole spécifique

Capturer des paquets de données sur Wireshark

- Lorsque vous ouvrez Wireshark, vous voyez un écran vous montrant une liste de toutes les connexions réseau que vous pouvez surveiller. Vous disposez également d'un champ de filtre de capture pour capturer uniquement le trafic réseau que vous souhaitez voir.
- Cliquez sur le premier bouton de la barre d'outils, intitulé « Commencer à capturer les paquets ».
- Pendant la capture, Wireshark vous montrera les paquets capturés en temps réel.
- Une fois que vous avez capturé tous les paquets nécessaires, utilisez les mêmes boutons ou options de menu pour arrêter la capture que vous l'avez fait pour commencer.

Les meilleures pratiques imposent d'arrêter la capture des paquets de Wireshark avant l'analyse.



Analyser les paquets de données sur Wireshark

- Wireshark vous montre trois volets différents pour inspecter les données des paquets. La liste des paquets, le volet supérieur, répertorie tous les paquets de la capture. Lorsque vous cliquez sur un paquet, les deux autres volets changent pour vous montrer les détails du paquet sélectionné. Vous pouvez également savoir si le paquet fait partie d'une conversation. Voici les détails de chaque colonne du volet supérieur :

No. : Il s'agit de l'ordre numérique du paquet capturé. Le crochet indique que ce paquet fait partie d'une conversation.

Heure : Cette colonne indique combien de temps après le début de la capture, ce paquet particulier a été capturé. Vous pouvez modifier cette valeur dans le menu Paramètres pour afficher une option différente.

Source : Il s'agit de l'adresse du système qui a envoyé le paquet.

Destination : Il s'agit de l'adresse de destination du paquet.

Protocole : C'est le type de paquet. Par exemple : TCP, DNS, DHCPv6 ou ARP.

Longueur : cette colonne vous indique la longueur du paquet, mesurée en octets.

Info : Cette colonne vous montre plus d'informations sur le contenu du paquet, qui varie en fonction du type de paquet.

Détails du paquet, le volet du milieu, vous montre autant d'informations lisibles que possible sur le paquet, en fonction du type de paquet. Vous pouvez cliquer avec le bouton droit et créer des filtres basés sur le texte en surbrillance dans ce champ.

Le volet inférieur, Packet Bytes, affiche le paquet exactement tel qu'il a été capturé en hexadécimal.

Lorsque vous consultez un paquet faisant partie d'une conversation, vous pouvez cliquer avec le bouton droit sur le paquet et sélectionner Suivre pour voir uniquement les paquets faisant partie de cette conversation.

Filtres Wireshark

- Certaines des meilleures fonctionnalités de Wireshark sont les filtres de capture et les filtres d'affichage. Les filtres vous permettent de visualiser la capture de la manière dont vous avez besoin pour résoudre les problèmes rencontrés. Vous trouverez ci-dessous plusieurs filtres pour vous aider à démarrer.

Filtres de capture Wireshark

Les filtres de capture limitent les paquets capturés par le filtre choisi. Si les paquets ne correspondent pas au filtre, Wireshark ne les enregistrera pas. Voici des exemples de filtres de capture :

- ✓ Adresse IP de l'hôte : ce filtre limite le trafic capturé vers et depuis l'adresse IP
- ✓ net 192.168.0.0/24 : ce filtre capture tout le trafic sur le sous-réseau
- ✓ Adresse IP de l'hôte dst : capture les paquets envoyés à l'hôte spécifié
- ✓ port 53 : capturez le trafic sur le port 53 uniquement
- ✓ port non 53 et non arp : capturez tout le trafic sauf le trafic DNS et ARP

Filtres Wireshark

- Filtres d'affichage Wireshark

Les filtres d'affichage Wireshark modifient la vue de la capture pendant l'analyse. Après avoir arrêté la capture de paquets, utilisez des filtres d'affichage pour affiner les paquets dans la liste de paquets afin de résoudre votre problème.

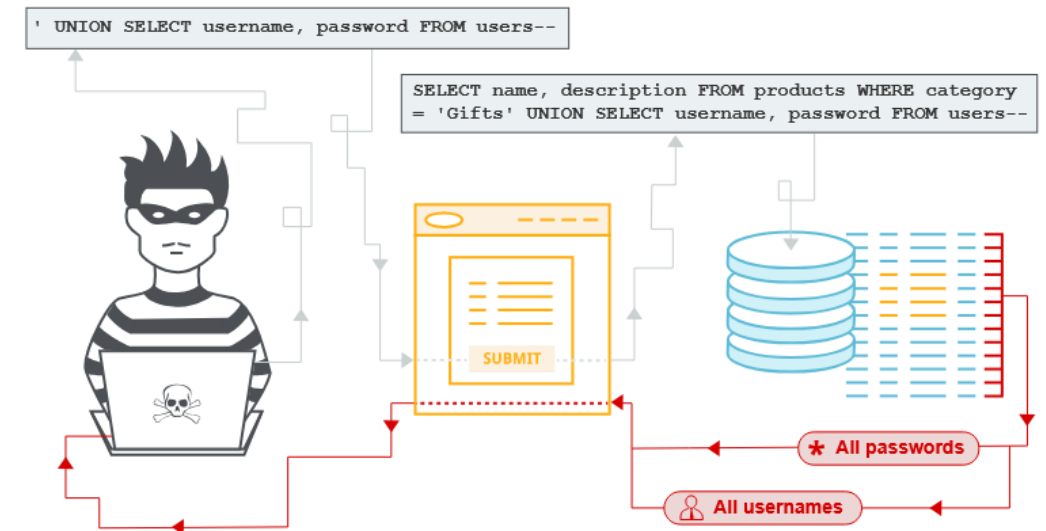
L'un des filtres d'affichage les plus utiles est :

- ✓ `ip.src==Adresse IP et ip.dst==Adresse IP`
- ✓ Ce filtre affiche les paquets envoyés d'un ordinateur (`ip.src`) à un autre (`ip.dst`). Vous pouvez également utiliser `ip.addr` pour afficher les paquets vers et depuis cette adresse IP. Les autres filtres incluent :
- ✓ `tcp.port eq 25` : Ce filtre vous montrera tout le trafic sur le port 25, qui est généralement du trafic SMTP
- ✓ `icmp` : ce filtre vous montrera uniquement le trafic ICMP dans la capture, il s'agit très probablement de pings
- ✓ `ip.addr != IP_address` : ce filtre vous montre tout le trafic à l'exception du trafic vers ou depuis l'ordinateur spécifié
- ✓ Les analystes créent même des filtres pour détecter des attaques spécifiques, comme ce filtre utilisé pour détecter le ver Sasser :
- ✓ `ls_ads.opnum==0x09`

l'injection SQL (SQLi)

Qu'est-ce que l'injection SQL (SQLi) ?

- L'injection SQL est une faille de sécurité permettant à un attaquant d'**interférer avec les requêtes** qu'une application adresse à sa base de données. Elle permet d'accéder à des données normalement inaccessibles (utilisateurs, informations sensibles) ou de les modifier/supprimer.



Détection des vulnérabilités

- La détection peut être automatisée (ex: Burp Scanner) ou manuelle en testant les points d'entrée avec :
- **Caractères spéciaux** : Utilisation de la quote simple ' pour provoquer des erreurs.
- **Syntaxe booléenne** : Injection de conditions comme OR 1=1 ou OR 1=2 pour observer les changements de réponse.
- **Délais temporels** : Payloads déclenchant une attente si la requête est exécutée.
- **Interactions Out-of-band (OAST)** : Déclenchement d'une interaction réseau externe.

Types d'attaques et exemples

- Les injections ne se limitent pas à la clause WHERE des requêtes SELECT ; elles peuvent toucher les instructions UPDATE, INSERT ou ORDER BY.
- **Subversion de la logique** : Utiliser des commentaires (--) pour ignorer la vérification du mot de passe lors d'une connexion.
- **Attaques UNION** : Combiner les résultats de la requête originale avec ceux d'une autre table pour extraire des données sensibles.
- **Injection Blind (Aveugle)** : L'application ne renvoie pas de données directement. L'attaquant doit déduire les informations via des réponses booléennes, des délais ou des interactions réseau.
- **Second-order SQLi (Stockée)** : L'entrée malveillante est d'abord stockée par l'application, puis exécutée ultérieurement lors d'une autre requête jugée "sûre" par le développeur.

Prévention : La méthode efficace

- La règle d'or pour prévenir les injections SQL est l'utilisation de **requêtes paramétrées** (ou "prepared statements").
- **Principe** : Au lieu de concaténer l'entrée utilisateur directement dans la chaîne SQL, on utilise des marqueurs (?).
- **Avantage** : La base de données traite l'entrée strictement comme une donnée et non comme une partie du code exécutable.
- **Cas particuliers** : Pour les noms de tables ou de colonnes (où les paramètres ne fonctionnent pas), il faut utiliser une **liste blanche (whitelisting)** de valeurs autorisées.
- **Attention** : L'injection de `OR 1=1` peut être dangereuse. Si cette condition atteint une commande `UPDATE` ou `DELETE`, elle peut entraîner la modification ou la suppression accidentelle de l'intégralité des données de la table.

Exemples d'injections SQL

- Il existe de nombreuses vulnérabilités, attaques et techniques d'injection SQL qui se produisent dans différentes situations. Voici quelques exemples courants d'injection SQL :
 - **Retrieving hidden data, Récupération de données cachées**, où vous pouvez modifier une requête SQL pour renvoyer des résultats supplémentaires.
 - Subverting application logic/Subversion de la logique de l'application, où vous pouvez modifier une requête pour interférer avec la logique de l'application.
 - **Attaques UNION**, où vous pouvez récupérer des données de différentes tables de base de données.
 - **Blind SQL injection/Injection SQL aveugle**, où les résultats d'une requête que vous contrôlez ne sont pas renvoyés dans les réponses de l'application.

Injection SQL : Récupération de Données Cachées

- **1. Le Fonctionnement Nominal**
- L'application filtre les produits par catégorie et ne montre que ceux qui sont publiés (**released = 1**).
- **Requête type** : <https://site.com/products?category=Gifts>
- Logique SQL :
- SQL SELECT * FROM products WHERE category = 'Gifts' AND released = 1
- This SQL query asks the database to return:
 - all details (*)
 - from the products table
 - where the category is Gifts
 - and released is 1.

Injection SQL : Récupération de Données Cachées

- La restriction `release = 1` est utilisée pour masquer les produits qui ne sont pas validés. On pourrait supposer pour les produits inédits, `publié = 0`.

L'application n'implémente aucune défense contre les attaques par injection SQL. Cela signifie qu'un attaquant peut construire l'attaque suivante, par exemple :

<https://insecure-website.com/products?category=Gifts'-->

Cela donne la requête SQL :

```
SELECT * FROM products WHERE category = 'Gifts'--' AND released = 1
```

Surtout, notez que `--` est un indicateur de commentaire en SQL. Cela signifie que le reste de la requête est interprété comme un commentaire, ce qui le supprime effectivement. Dans cet exemple, cela signifie que la requête n'inclut plus `AND release = 1`. Par conséquent, tous les produits sont affichés, y compris ceux qui ne sont pas encore publiés.

Vous pouvez utiliser une attaque similaire pour que l'application affiche tous les produits de n'importe quelle catégorie, y compris les catégories qu'elle ne connaît pas :

<https://insecure-website.com/products?category=Gifts'+OR+1=1-->

Cela donne la requête SQL :

```
SELECT * FROM products WHERE category = 'Gifts' OR 1=1--' AND released = 1
```

La requête modifiée renvoie tous les éléments pour lesquels **category is Gifts, or 1 is equal to 1. As 1=1** est toujours vrai, la requête renvoie tous les éléments.

Subvertir/ renverser la logique des applications

- Imaginez une application qui permet aux utilisateurs de se connecter avec un nom d'utilisateur et un mot de passe. Si un utilisateur soumet le nom d'utilisateur **wiener** et password **bluecheese** l'application vérifie les informations d'identification en effectuant la requête SQL suivante :
- `SELECT * FROM users WHERE username = 'wiener' AND password = 'bluecheese'` Si la requête renvoie les détails d'un utilisateur, la connexion réussit. Dans le cas contraire, il est rejeté.

Dans ce cas, un attaquant peut se connecter sous le nom de n'importe quel utilisateur sans avoir besoin d'un mot de passe. Ils peuvent le faire en utilisant la séquence de commentaires SQL – pour supprimer la vérification du mot de passe de la clause WHERE de la requête. Par exemple, soumettre le nom d'utilisateur **administrator'--** et un mot de passe vide entraîne la requête suivante :

- `SELECT * FROM users WHERE username = 'administrator'--' AND password = ''`
- Cette requête renvoie l'utilisateur dont le nom username est administrator et connecte avec succès l'attaquant en tant qu'utilisateur.

Récupération de données à partir d'autres tables de base de données

- Dans les cas où l'application répond avec les résultats d'une requête SQL, un attaquant peut utiliser une vulnérabilité d'injection SQL pour récupérer des données d'autres tables de la base de données. Vous pouvez utiliser le mot-clé **UNION** pour exécuter une requête **SELECT** supplémentaire et ajouter les résultats à la requête d'origine.

Par exemple, si une application exécute la requête suivante contenant l'entrée utilisateur **Gifts** :

- `SELECT name, description FROM products WHERE category = 'Gifts'`
- Un attaquant peut soumettre l'entrée : `' UNION SELECT username, password FROM users—`
- Cela amène l'application à renvoyer tous les noms d'utilisateur et mots de passe ainsi que les noms et descriptions des produits.

Vulnérabilités d'injection SQL aveugle

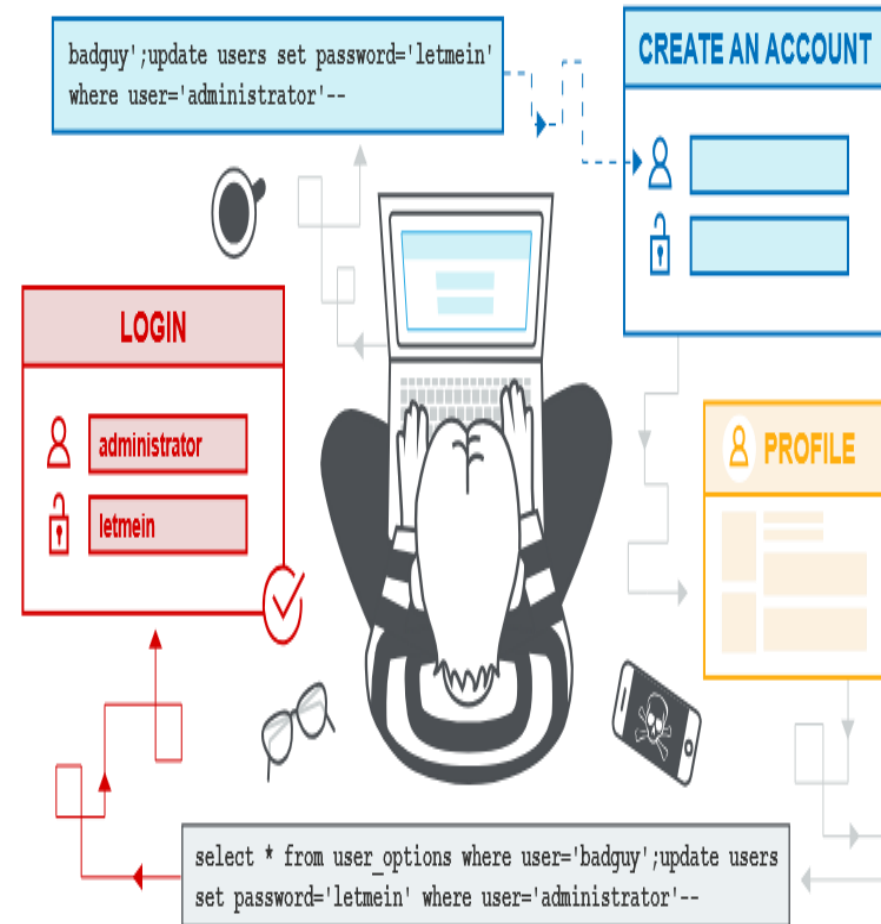
De nombreuses instances d'injection SQL sont des vulnérabilités aveugles. Cela signifie que l'application ne renvoie pas les résultats de la requête SQL ni les détails des erreurs de base de données dans ses réponses. Des vulnérabilités aveugles peuvent toujours être exploitées pour accéder à des données non autorisées, mais les techniques impliquées sont généralement plus compliquées et plus difficiles à mettre en œuvre.

Les techniques suivantes peuvent être utilisées pour exploiter les vulnérabilités d'injection SQL aveugle, en fonction de la nature de la vulnérabilité et de la base de données impliquée :

- ✓ Vous pouvez modifier la logique de la requête pour déclencher une différence détectable dans la réponse de l'application en fonction de la vérité d'une seule condition. Cela peut impliquer l'injection d'une nouvelle condition dans une logique booléenne ou le déclenchement conditionnel d'une erreur telle qu'une division par zéro.
- ✓ Vous pouvez conditionnellement déclencher un délai dans le traitement de la requête. Cela vous permet de déduire la véracité de la condition en fonction du temps nécessaire à l'application pour répondre.
- ✓ Vous pouvez déclencher une interaction réseau hors bande à l'aide des techniques OAST. Cette technique est extrêmement puissante et fonctionne dans des situations où les autres techniques ne le font pas. Souvent, vous pouvez exfiltrer directement les données via le canal hors bande. Par exemple, vous pouvez placer les données dans une recherche DNS pour un domaine que vous contrôlez.

Injection SQL de second ordre

- L'injection SQL de premier ordre se produit lorsque l'application traite l'entrée utilisateur à partir d'une requête HTTP et incorpore l'entrée dans une requête SQL de manière non sécurisée.
- L'injection SQL de second ordre se produit lorsque l'application prend les entrées de l'utilisateur à partir d'une requête HTTP et les stocke pour une utilisation ultérieure. Cela se fait généralement en plaçant les entrées dans une base de données, mais aucune vulnérabilité ne se produit au point où les données sont stockées. Plus tard, lors du traitement d'une requête HTTP différente, l'application récupère les données stockées et les intègre dans une requête SQL de manière non sécurisée. Pour cette raison, l'injection SQL de second ordre est également appelée injection SQL stockée.
- L'injection SQL de second ordre se produit souvent dans des situations où les développeurs sont conscients des vulnérabilités de l'injection SQL et gèrent ainsi en toute sécurité le placement initial de l'entrée dans la base de données. Lorsque les données sont traitées ultérieurement, elles sont considérées comme sûres, car elles ont été préalablement placées en toute sécurité dans la base de données. À ce stade, les données sont traitées de manière dangereuse, car le développeur les considère à tort comme étant fiables.



Examining the database

- Certaines fonctionnalités essentielles du langage SQL sont implémentées de la même manière sur les plates-formes de bases de données populaires, et de nombreuses façons de détecter et d'exploiter les vulnérabilités d'injection SQL fonctionnent de la même manière sur différents types de bases de données.
- Vous pouvez interroger les détails de la version de la base de données. Par exemple, sur Oracle vous pouvez exécuter :
SELECT * FROM v\$version
- Vous pouvez également identifier les tables de base de données existantes et les colonnes qu'elles contiennent. Par exemple, sur la plupart des bases de données, vous pouvez exécuter la requête suivante pour répertorier les tables :
SELECT * FROM information_schema.tables
- Ces différents formats peuvent vous offrir différentes manières de masquer/ obfuscate attacks les attaques qui seraient autrement bloquées en raison des WAF et d'autres mécanismes de défense. Les implémentations faibles recherchent souvent des mots-clés d'injection SQL courants dans la requête. Vous pourrez donc peut-être contourner ces filtres en codant ou en échappant les caractères dans les mots-clés interdits. Par exemple, l'injection SQL basée sur XML suivante utilise une séquence d'échappement XML pour coder le caractère **S** dans SELECT :
<stockCheck>
<productId>123</productId>
<storeId> 999 S ELECT * FROM information_schema.tables</storeId>
</stockCheck>

Comment empêcher l'injection SQL

- Vous pouvez empêcher la plupart des instances d'injection SQL à l'aide de requêtes paramétrées au lieu de la concaténation de chaînes dans la requête. Ces requêtes paramétrées sont également appelées « instructions préparées ».

Le code suivant est vulnérable à l'injection SQL car l'entrée utilisateur est concaténée directement dans la requête :

- Le code suivant est vulnérable à l'injection SQL car l'entrée utilisateur est concaténée directement dans la requête :

```
String query = "SELECT * FROM products WHERE category = '"+ input + "'"; Statement statement = connection.createStatement(); ResultSet resultSet = statement.executeQuery(query);
```

Vous pouvez réécrire ce code de manière à empêcher les entrées de l'utilisateur d'interférer avec la structure de la requête :

```
PreparedStatement statement = connection.prepareStatement("SELECT * FROM products WHERE category = ?");
```

```
statement.setString(1, input);
```

```
ResultSet resultSet = statement.executeQuery();
```

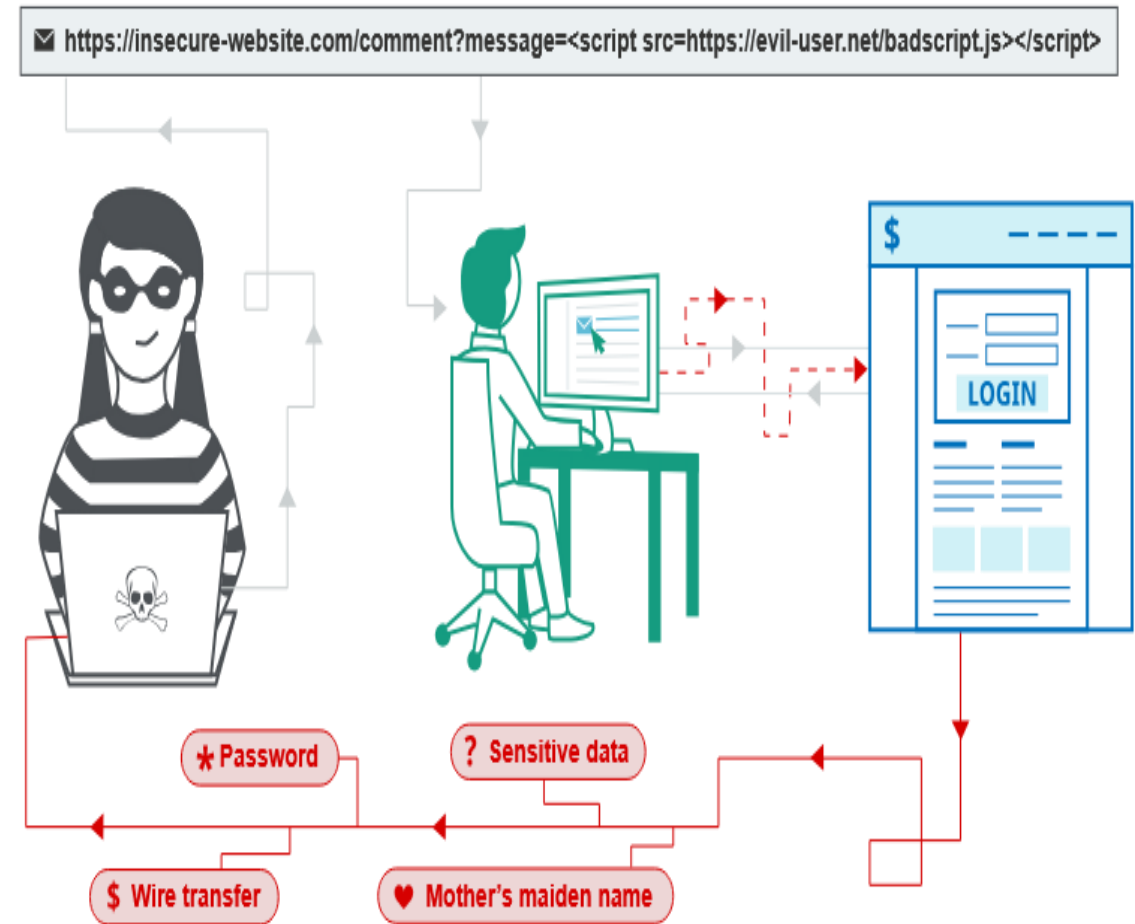
Cross-site scripting

Qu'est-ce que le cross-site scripting (XSS) ?

- Le cross-site scripting (également connu sous le nom de **XSS**) est une vulnérabilité de sécurité **Web** qui permet à un attaquant de compromettre les interactions des utilisateurs avec une application vulnérable. Cela permet à un attaquant de contourner la même politique d'origine, conçue pour séparer les différents sites Web les uns des autres. Les vulnérabilités de cross-site scripting permettent normalement à un attaquant de se faire passer pour un utilisateur victime, d'effectuer toutes les actions que l'utilisateur est capable d'effectuer et d'accéder à ses données. Si l'utilisateur victime dispose d'un accès privilégié à l'application, l'attaquant pourrait alors être en mesure d'obtenir un contrôle total sur toutes les fonctionnalités et données de l'application.

Comment fonctionne XSS ?

- Les scripts intersites fonctionnent en manipulant un site Web vulnérable afin qu'il renvoie du JavaScript malveillant aux utilisateurs. Lorsque le code malveillant s'exécute dans le navigateur d'une victime, l'attaquant peut totalement compromettre son interaction avec l'application.
- **Validation d'une faille XSS : de alert() à print()**
- Pour confirmer une vulnérabilité XSS, la méthode classique consiste à injecter un script simple comme alert(), car il est visuel et inoffensif. Cependant, depuis la version 92 de **Chrome**, l'utilisation de alert() est bloquée dans les **iframes cross-origin**, ce qui peut entraver certains Proof of Concept (PoC) avancés. Dans ces situations, il est désormais recommandé d'utiliser la fonction **print()** comme alternative universelle. Cette méthode reste tout aussi simple à implémenter tout en contournant les restrictions récentes du navigateur pour valider l'exécution arbitraire de JavaScript.



Quels sont les types d'attaques XSS ?

- Il existe trois principaux types d'attaques XSS. Ce sont :
 - ✓ **XSS réfléchi/ Reflected XSS**, où le script malveillant provient de la requête HTTP actuelle.
 - ✓ **XSS stocké/ Stored XSS**, où le script malveillant provient de la base de données du site Web.
 - ✓ **XSS basé sur DOM/ DOM-based XSS**, où la vulnérabilité existe dans le code côté client plutôt que dans le code côté serveur.

Reflected XSS

- **Définition du XSS Réfléchi**
- Le XSS réfléchi survient lorsqu'une application reçoit des données dans une requête HTTP et les inclut immédiatement dans la réponse de manière non sécurisée. L'attaquant transmet une charge utile (payload) via un paramètre (ex: une recherche) qui, une fois cliqué par une victime, exécute un script malveillant dans le navigateur de celle-ci.

Scripts intersites réfléchis

Reflected XSS

- Reflected XSS est la variété la plus simple de scripts intersites. Cela se produit lorsqu'une application reçoit des données dans une requête HTTP et inclut ces données dans la réponse immédiate de manière dangereuse.
- Voici un exemple simple d'une vulnérabilité XSS reflétée :

`https://insecure-website.com/status?message=All+is+well. <p>Status: All is well.</p>`

L'application n'effectue aucun autre traitement des données, un attaquant peut donc facilement construire une attaque comme celle-ci :

`https://insecure-website.com/status?message=<script>/*+Bad+stuff+here...+*/</script>
<p>Status: <script>/* Bad stuff here... */</script></p>`

Si l'utilisateur visite l'URL construite par l'attaquant, le script de l'attaquant s'exécute dans le navigateur de l'utilisateur, dans le contexte de la session de cet utilisateur avec l'application. À ce stade, le script peut effectuer n'importe quelle action et récupérer toutes les données auxquelles l'utilisateur a accès.

L'impact d'une attaque XSS réfléchie

- réside dans la capacité de l'attaquant à exécuter un script malveillant dans le navigateur de la victime. Une fois ce contrôle établi, le compromis est généralement total. Voici les points clés à retenir :
- 1. Pouvoirs de l'attaquant Si le script s'exécute, l'attaquant peut agir au nom de l'utilisateur :
 - Actions : Effectuer toute opération autorisée à l'utilisateur (achats, modification de paramètres, etc.).
 - Accès aux données : Consulter ou modifier toutes les informations auxquelles l'utilisateur a accès.
 - Usurpation d'identité : Initier des interactions avec d'autres utilisateurs qui sembleront provenir de la victime initiale.
- 2. Vecteurs de diffusion Contrairement au XSS stocké, l'attaque nécessite un vecteur externe pour inciter la victime à envoyer la requête piégée :
 - Liens malveillants sur un site contrôlé par l'attaquant.
 - Contenu généré sur des sites tiers (commentaires, forums).
 - Envoi direct via email, messagerie instantanée ou réseaux sociaux.
- 3. Gravité relative
- Bien que critique, le XSS réfléchi est souvent considéré comme moins sévère que le XSS stocké pour une raison simple : il dépend d'un mécanisme de livraison externe (comme l'ingénierie sociale) pour atteindre sa cible, alors que le XSS stocké est hébergé directement par l'application vulnérable.
- Résumé technique :
- L'attaque permet une compromission complète de la session utilisateur, mais son efficacité dépend de la capacité de l'attaquant à piéger l'utilisateur pour qu'il clique sur un lien spécifique.

Scripts intersites stockés

- Le XSS stocké (également appelé XSS persistant ou de second ordre) se produit lorsqu'une application reçoit des données d'une source non fiable et inclut ces données dans ses réponses HTTP ultérieures de manière non sécurisée.
- Les données en question peuvent être soumises à l'application via des requêtes HTTP ; par exemple, des commentaires sur un article de blog, des surnoms d'utilisateurs dans une salle de discussion ou des coordonnées sur une commande client. Dans d'autres cas, les données peuvent provenir d'autres sources non fiables ; par exemple, une application de messagerie Web affichant les messages reçus via SMTP, une application marketing affichant des publications sur les réseaux sociaux ou une application de surveillance réseau affichant les données par paquets du trafic réseau.
- Voici un exemple simple d'une vulnérabilité XSS stockée. Une application de forum de discussion permet aux utilisateurs de soumettre des messages, qui sont affichés aux autres utilisateurs :

`<p>Bonjour, voici mon message !</p>`

L'application n'effectue aucun autre traitement des données, donc un attaquant peut facilement envoyer un message qui attaque d'autres utilisateurs :

`<p><script>/* De mauvaises choses ici... */</script></p>`

le XSS stocké car il nécessite un vecteur de diffusion externe (email, lien piégé).

DOM-based cross-site scripting

- Le XSS basé sur DOM (également connu sous le nom de DOM XSS) survient lorsqu'une application contient du JavaScript côté client qui traite les données provenant d'une source non fiable de manière dangereuse, généralement en réécrivant les données dans le DOM.

Dans l'exemple suivant, une application utilise du JavaScript pour lire la valeur d'un champ de saisie et écrire cette valeur dans un élément du code HTML :

```
var search = document.getElementById('search').value;  
var results = document.getElementById('results');  
results.innerHTML = 'You searched for: ' + search;
```

Si l'attaquant peut contrôler la valeur du champ de saisie, il peut facilement construire une valeur malveillante qui provoque l'exécution de son propre script :

You searched for:

Dans un cas typique, le champ de saisie serait renseigné à partir d'une partie de la requête HTTP, telle qu'un paramètre de chaîne de requête URL, permettant à l'attaquant de lancer une attaque en utilisant une URL malveillante, de la même manière que le XSS reflété.

Ce code est un exemple typique d'une vulnérabilité XSS (Cross-Site Scripting) basée sur le DOM.

- ✓ **var search = document.getElementById('search').value;** Le script récupère le texte que l'utilisateur a tapé dans un champ de saisie (un `<input>` dont l'ID est search) et le stocke dans la variable search.
- ✓ Ciblage de l'affichage JavaScript : **var results = document.getElementById('results');** Le script identifie l'endroit de la page (probablement une `<div>` ou un `<span>` avec l'ID results) où il doit afficher un message.
- ✓ L'injection (La partie dangereuse) JavaScript : **results.innerHTML = 'You searched for: ' + search;**

C'est ici que se situe la faille. L'utilisation de `.innerHTML` demande au navigateur d'interpréter la chaîne de caractères comme du code HTML.

Ce code est un exemple typique d'une vulnérabilité XSS (Cross-Site Scripting) basée sur le DOM.

Pourquoi est-ce dangereux ? (Scénario d'attaque) Si un utilisateur normal tape ordinateur, la page affichera simplement : You searched for: ordinateur.

Cependant, si un attaquant saisit du code JavaScript à la place d'un mot, par exemple :
HTML `<img src=x onerror=print(>`

Le navigateur va exécuter ce code : Il essaie d'afficher une image avec une source invalide (`src=x`). Cela déclenche l'événement d'erreur `onerror`. Le code `print()` est alors exécuté, ouvrant la fenêtre d'impression.

Comment corriger cela ?

Pour sécuriser ce code, il ne faut jamais utiliser `.innerHTML` avec des données provenant de l'utilisateur. On utilise à la place `.textContent`, qui traite la saisie comme du texte pur et n'exécute aucun code :

JavaScript // Version sécurisée

```
results.textContent = 'You searched for: '
```

Exemple PHP

- Le formulaire HTML sur lequel divers champs de saisie : des champs de texte obligatoires et facultatifs, des boutons radio et un bouton de soumission :
- `<form method="post" action="<?php echo htmlspecialchars($_SERVER["PHP_SELF"]);?>">`
- Qu'est-ce que la fonction `htmlspecialchars()` ?

La fonction `htmlspecialchars()` convertit les caractères spéciaux en entités HTML. Cela signifie qu'il remplacera les caractères HTML comme `<` et `>` par `<` et `>`. Cela empêche les attaquants d'exploiter le code en injectant du code HTML ou Javascript (attaques Cross-site Scripting) dans les formulaires.

PHP Form Validation Example

* required field

Name: *

E-mail: *

Website:

Comment:

Gender: ☐ Female ☐ Male ☐ Other *

Your Input:

Impact et Capacités d'une Attaque XSS

Ce qu'un attaquant peut faire :

- **Usurpation d'identité** : Agir au nom de la victime et accéder à ses sessions.
 - **Contrôle total des actions** : Effectuer toute opération autorisée pour l'utilisateur (achats, transferts, etc.).
 - **Vol de données** : Lire des informations confidentielles ou capturer des identifiants (via *keylogging*).
 - **Altération du site** : Dégradation visuelle (*defacement*) ou injection de fonctionnalités malveillantes (chevaux de Troie).
-
- **Gravité de l'impact selon le contexte** :
 - Le danger réel dépend de la nature de l'application et du profil de la victime :

| Type d'application | Impact Typique | Conséquence |
|-----------------------------------|----------------|---|
| Site vitrine (public) | Minimal | Risque d'image limité. |
| Données sensibles (banque, santé) | Sérieux | Fuite de données privées et vol financier. |
| Compte Privilégié (admin) | Critique | Prise de contrôle totale de l'infrastructure. |

Comment trouver et tester les vulnérabilités XSS

- Méthodes de détection
- Automatisée : Utilisation de scanners de vulnérabilités (ex: Burp Suite,owasp....).
- Manuelle : Injection de valeurs uniques pour observer comment elles sont restituées dans les réponses HTTP ou le DOM, puis test de charges utiles JavaScript (comme alert() ou print()).

Stratégies de prévention

- Filtrer les entrées : Valider strictement les données reçues selon un modèle attendu.
- Encoder les sorties : Transformer les données utilisateur avant affichage (HTML, URL, JS) pour qu'elles soient traitées comme du texte et non comme du code.
- Utiliser des en-têtes HTTP : Configurer Content-Type et X-Content-Type-Options pour guider l'interprétation du navigateur.
- Content Security Policy (CSP) : Déployer une CSP comme couche de défense finale pour limiter l'exécution de scripts non autorisés.

Introduction au Centre d'Opérations de Sécurité (SOC)

Prf Mohammed Serrhini
Cours cyber Sécurité 2025-2026

Sommaire

1. Introduction
2. Origine (Historique)
3. Contexte et enjeux actuels
4. Incident Majeur / des cas
5. Concept et ingénierie
6. Techniques de base
7. Les normes
8. Techniques avancées
9. Certifications

Introduction :

Objectifs du cours

Ce cours d'introduction au Security Operations Center (SOC) vise à fournir une compréhension des concepts fondamentaux, des processus et des technologies associés à la gestion d'un SOC :

- ▶ Comprendre le rôle et l'importance d'un SOC dans la cybersécurité.
- ▶ Identifier les composants clés d'un SOC, y compris les outils, les processus et les équipes.
- ▶ Appréhender les bases de la détection, de l'analyse et de la réponse aux incidents de sécurité.
- ▶ Découvrir les bonnes pratiques pour optimiser les opérations d'un SOC.

Introduction :

La cybersécurité ?

La cybersécurité regroupe l'ensemble **des pratiques, technologies et processus** conçus pour protéger

1. les systèmes informatiques,
2. les réseaux,
3. les données et
4. les logiciels

Contre les accès non autorisés, les cyberattaques, les dommages ou les utilisations malveillantes.

Aujourd'hui la numérisation domine, des petites entreprises aux grandes organisations, la cybersécurité est devenue une priorité stratégique pour assurer la continuité des opérations.

Elle protège les informations sensibles, comme les données personnelles ou financières, tout en préservant la confiance des clients et partenaires.

Introduction :

CIA

La triade CIA, forme la base conceptuelle de la cybersécurité.

- ▶ **La confidentialité** garantit que seules les personnes autorisées accèdent aux données sensibles, comme les informations personnelles ou les secrets commerciaux, grâce à des outils comme le chiffrement ou les contrôles d'accès stricts.
- ▶ **L'intégrité** veille à ce que les données restent exactes et inchangées, qu'il s'agisse d'erreurs accidentelles ou d'altérations malveillantes, en utilisant des techniques comme les hachages cryptographiques pour vérifier leur authenticité.
- ▶ **La disponibilité** assure que les systèmes et données restent accessibles aux utilisateurs légitimes, même face à des perturbations comme les attaques par déni de service (DDoS). Dans un SOC,



Introduction :

Définitions clés : SOC, surveillance, réponse aux incidents

Un **Security Operations Center (SOC)** est une entité centralisée au sein d'une organisation, dédiée à la surveillance, à la détection, à l'analyse et à la réponse aux menaces de cybersécurité en temps réel. Il regroupe des experts en sécurité, des technologies avancées et des processus bien définis pour protéger les actifs numériques d'une organisation contre les cyberattaques.

Rôles principaux d'un SOC :

- ▶ **Surveillance continue** : Supervision des systèmes et réseaux pour détecter les activités suspectes.
- ▶ **Détection des incidents** : Identification des menaces potentielles à l'aide d'outils comme les SIEM (Security Information and Event Management).
- ▶ **Réponse aux incidents** : Gestion et mitigation des incidents pour limiter les impacts.
- ▶ **Analyse et amélioration** : Étude des incidents passés pour renforcer les défenses et prévenir les futures attaques.

Introduction :

Définitions clés : SOC, surveillance, réponse aux incidents



Introduction :

Importance des SOC

Dans un paysage numérique en constante évolution, les cybermenaces telles que les ransomwares, les violations de données et les attaques par hameçonnage sont de plus en plus sophistiquées.

Un SOC permet de :

1. **Protection contre les cybermenaces évolutives**
2. **Réduction des risques financiers et réputationnels**
3. **Conformité réglementaire**
4. **Centralisation et coordination de la sécurité**
5. **Amélioration continue de la posture de sécurité**

Impact :

- ▶ **Réactivité accrue** : Grâce à une surveillance 24/7, un SOC peut détecter et répondre aux menaces en temps réel, réduisant le temps de latence entre la détection et la remédiation.
- ▶ **Optimisation des ressources** : En centralisant les opérations de sécurité, un SOC permet d'utiliser efficacement les outils et le personnel, évitant la dispersion des efforts.
- ▶ **Confiance renforcée** : Les clients et partenaires sont rassurés par la présence d'un SOC, qui témoigne d'une approche professionnelle et proactive de la cybersécurité.

Introduction :

SOC et tendances

- ▶ Intégration massive de l'IA et du Machine Learning :
 - ▶ Automatisation de la détection des menaces pour réduire les faux positifs.
 - ▶ Analyse prédictive des attaques sophistiquées comme les ransomwares et APT.
- ▶ Croissance des modèles SOC-as-a-Service (SOCaaS) :
 - ▶ Adoption du cloud et du BYOD.
 - ▶ Offre scalable et économique pour les PME, avec surveillance 24/7 externalisée.
- ▶ Focus sur la maturité et la conformité :
 - ▶ Amélioration des capacités de détection (hausse de 4 % en 2025 via IA).
 - ▶ Respect accru des réglementations comme NIS2 et RGPD, avec un marché SOC global à 47,74 milliards USD.

Les SOC évoluent vers des centres proactifs, boostés par l'IA, pour contrer un paysage de menaces en expansion (IoT, cloud hybride).

Origine (Historique) :

Évolution des SOC : des centres de surveillance aux SOC modernes

Le **Security Operations Center (SOC)** a considérablement évolué au fil des décennies, passant de simples centres de surveillance à des entités complexes et stratégiques au cœur de la cybersécurité. Cette évolution reflète les avancées technologiques, l'augmentation de la sophistication des cybermenaces et les besoins croissants des organisations en matière de sécurité.

Les débuts : Centres de surveillance (années 1990 - début 2000)

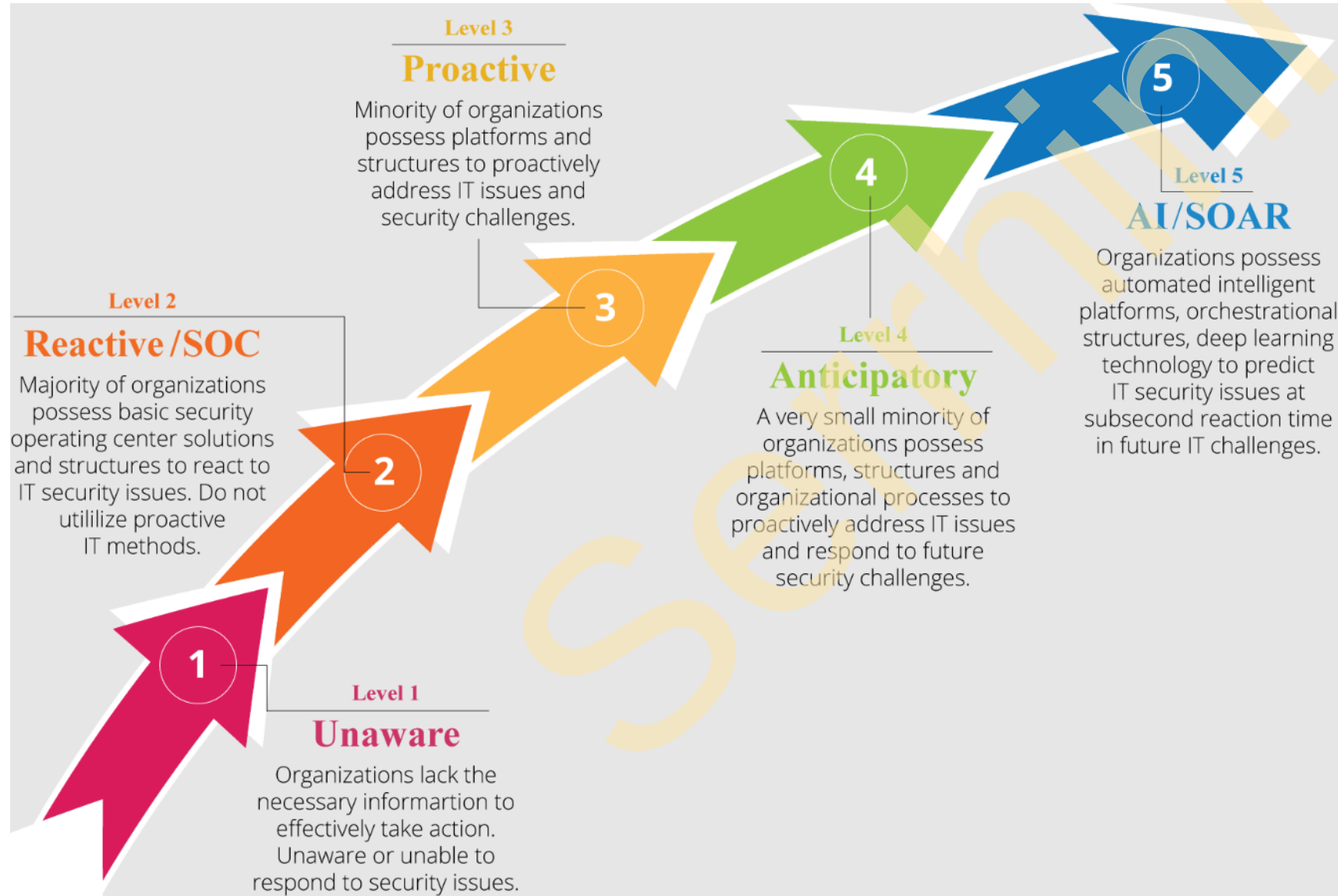
À leurs débuts, les SOC étaient principalement des **centres de surveillance des réseaux**, avec des fonctions limitées :

- ▶ **Rôle principal** : Surveillance des journaux d'événements (logs) pour détecter des anomalies basiques, comme des tentatives d'accès non autorisées.
- ▶ **Technologies utilisées** : Outils rudimentaires comme les systèmes de détection d'intrusion (IDS) et des pare-feu.
- ▶ **Limites** :
 - ▶ Analyse manuelle des logs, longue et sujette aux erreurs.
 - ▶ Réactivité limitée face aux menaces émergentes.
 - ▶ Absence d'automatisation et de coordination avec d'autres départements.

Les premiers SOC se concentraient sur la détection réactive, avec peu de capacités pour anticiper ou répondre efficacement aux attaques complexes.

Origine (Historique) :

Évolution des SOC : des centres de surveillance aux SOC modernes



Origine (Historique) :

Création des premiers SOC dans les années 2000

Avec la montée des cyberattaques plus sophistiquées (virus, malwares, attaques par déni de service), les SOC ont commencé à se professionnaliser :

- ▶ **Introduction des SIEM** : Les systèmes de gestion des informations et des événements de sécurité (SIEM) ont permis de collecter, corréler et analyser les logs en temps réel.
- ▶ **Équipes spécialisées** : Apparition de rôles dédiés comme les analystes de niveau 1, 2 et 3 pour trier les alertes, enquêter et répondre aux incidents.
- ▶ **Focus sur la réponse aux incidents** : Les SOC ont commencé à développer des processus formels pour la gestion des incidents, incluant l'identification, le confinement et la remédiation.
- ▶ **Défis** :
 - ▶ Volume croissant d'alertes, entraînant une fatigue des analystes.
 - ▶ Manque d'intégration avec les autres fonctions de l'entreprise.

À cette époque, les SOC sont devenus des entités centralisées, mais leurs capacités restaient limitées par des technologies encore en développement.

Origine (Historique) :

Les SOC modernes

Les SOC modernes se distinguent par leur approche proactive, leur intégration technologique avancée et leur rôle stratégique dans les organisations :

1. **Automatisation et orchestration** : Adoption des plateformes **SOAR** (Security Orchestration, Automation, and Response) pour automatiser les réponses aux incidents courants et réduire le temps de réaction et l'utilisation de l'intelligence artificielle (IA) et de l'apprentissage automatique pour détecter les menaces complexes, comme les attaques zero-day ou les comportements anormaux.
2. **Intégration avec le Threat Intelligence** : Les SOC modernes exploitent des flux de renseignement sur les menaces (Threat Intelligence) pour anticiper les attaques et contextualiser les alertes, et la collaboration avec des bases de données mondiales pour identifier les nouvelles tendances en matière de cybermenaces.
3. **Approche proactive** : Mise en place de **chasse aux menaces** (Threat Hunting) pour rechercher activement les vulnérabilités avant qu'elles ne soient exploitées et les simulations d'attaques (red teaming) pour tester la résilience des systèmes.
4. **Cloud et hybridation** : Avec la migration vers le cloud, les SOC surveillent désormais des environnements hybrides (on-premise et cloud), utilisant des solutions comme les CASB (Cloud Access Security Brokers) et l'adaptation aux architectures décentralisées et aux technologies comme les conteneurs et les microservices.
5. **Collaboration interdépartementale** : Les SOC modernes travaillent en étroite collaboration avec les équipes DevOps, les départements juridiques et les responsables de la conformité pour une approche holistique de la sécurité.
6. **Focus sur la résilience** : En plus de la détection et de la réponse, les SOC modernes mettent l'accent sur la récupération rapide et la continuité des activités après un incident.

Origine (Historique) :

Impact de l'augmentation des cybermenaces sur les SOC

L'explosion du nombre et de la complexité des cybermenaces a intensifié les exigences pesant sur les SOC :

- ▶ **Volume d'alertes** : La multiplication des incidents génère un flux massif d'alertes, entraînant une surcharge pour les analystes et un risque de fatigue face aux faux positifs.
- ▶ **Vitesse de réaction** : Les attaques rapides, comme les ransomwares qui chiffrent les données en quelques minutes, obligent les SOC à réduire le temps de détection et de réponse (Mean Time to Detect/Respond, MTDD/MTTR).
- ▶ **Sophistication des menaces** : Les attaquants utilisent des techniques avancées, comme l'intelligence artificielle ou les attaques furtives (living-off-the-land), rendant la détection plus complexe.
- ▶ **Pénurie de talents** : La demande croissante pour des experts en cybersécurité dépasse l'offre, obligeant les SOC à rivaliser pour recruter et retenir des analystes compétents.
- ▶ **Nouvelles compétences** : Les analystes doivent maîtriser des domaines comme l'analyse des malwares, la chasse aux menaces (Threat Hunting) et la gestion des environnements cloud.
- ▶ **Collaboration interdépartementale** : Les SOC doivent travailler avec les équipes DevOps, juridiques et de conformité pour répondre aux menaces complexes et respecter les réglementations.

Origine (Historique) :

Transition vers des SOC basés sur le cloud et l'automatisation

Face à des cybermenaces croissantes et des infrastructures numériques complexes, les **Security Operations Centers (SOC)** évoluent vers des modèles basés sur le cloud et l'automatisation pour gagner en efficacité, scalabilité et réactivité.

Raisons de la transition :

- ▶ **Complexité des environnements** : Surveillance des infrastructures hybrides (cloud, on-premise, IoT).
- ▶ **Volume des données** : Nécessité de gérer un grand nombre d'alertes.
- ▶ **Réactivité** : Réponse rapide aux menaces comme les ransomwares.
- ▶ **Coûts** : Réduction des investissements via des solutions cloud et SOC-as-a-Service.

Avantages

- ▶ **Scalabilité** : Adaptation dynamique aux besoins avec le cloud.
- ▶ **Automatisation** : SOAR et IA réduisent les tâches manuelles et accélèrent les réponses.
- ▶ **Visibilité** : Centralisation des données pour une analyse unifiée.
- ▶ **Technologies avancées** : Accès à l'IA, Threat Intelligence et outils cloud (CASB, SASE).
- ▶ **Coûts réduits** : Moins de dépenses en matériel et maintenance.

Contexte et enjeux actuels :

Paysage actuel des cybermenaces : ransomware, APT, phishing

Le paysage actuel des cybermenaces, marqué par les ransomwares, les attaques persistantes avancées (APT) et le phishing, exerce une pression croissante sur les **Security Operations Centers (SOC)**. Ces menaces, de plus en plus sophistiquées, exigent des SOC une adaptation rapide en termes de détection, réponse et prévention.

Principales cybermenaces :

- ▶ **Ransomwares** : Logiciels malveillants chiffrant les données pour exiger une rançon, souvent combinés à des extorsions de données.
- ▶ **APT (Advanced Persistent Threats)** : Attaques ciblées, furtives et prolongées, visant à voler des données sensibles ou à compromettre des systèmes critiques.
- ▶ **Phishing** : Campagnes d'hameçonnage utilisant des e-mails ou messages frauduleux pour dérober des identifiants ou déployer des malwares.

Impact sur les SOC

- ▶ **Surcharge d'alertes** : Volume massif d'alertes provenant des ransomwares et phishing, augmentant le risque de fatigue des analystes.
- ▶ **Complexité de détection** : Les APT, utilisant des techniques furtives, nécessitent des outils avancés comme l'IA et l'analyse comportementale (UEBA).
- ▶ **Réactivité accrue** : Les ransomwares exigent une réponse en temps réel pour limiter les dommages, réduisant le temps de détection/réponse (MTTD/MTTR).
- ▶ **Surveillance élargie** : Les SOC doivent couvrir des environnements divers (cloud, IoT, OT) face à des attaques multi-vecteurs.

Contexte et enjeux actuels :

Enjeux des SOC : détection rapide, réduction des temps de réponse

Un SOC efficace permet à l'organisation de :

- ▶ **Détecter rapidement** les menaces avant qu'elles n'affectent la production.
- ▶ **Réduire le temps de réponse** (MTTR – Mean Time To Respond) grâce à des procédures standardisées.
- ▶ **Limiter les impacts financiers** (perte de données, interruption d'activité, réputation).
- ▶ Passer d'une approche réactive (réponse après attaque) à une approche proactive :
 - ▶ Threat hunting (chasse aux menaces)
 - ▶ Analyse comportementale et prédictive (IA, machine learning)

L'efficacité du SOC se mesure par sa capacité à réagir vite et minimiser les dégâts.

Contexte et enjeux actuels :

Défis liés à la complexité des environnements (cloud, IoT, hybride)

Les SOC font face à des complexités :

1. Diversité des environnements :

- ▶ Systèmes sur site, infrastructures Cloud (AWS, Azure, GCP), IoT et environnements hybrides.
- ▶ OT (Operational Technology) dans les secteurs industriels.

2. Explosion des données de sécurité :

- ▶ Volumes massifs de logs, d'alertes et d'événements.
- ▶ Besoin d'outils de corrélation (SIEM, SOAR).

3. Alert fatigue (fatigue liée aux alertes) :

- ▶ Trop d'alertes = risque de passer à côté d'un incident critique.
- ▶ Importance de l'automatisation et de la priorisation intelligente.

Le SOC doit être capable de trier, corréler et automatiser pour rester efficace.

Contexte et enjeux actuels :

Rôle des SOC dans la résilience organisationnelle

- ▶ **Détection précoce** : incidents contenus avant propagation.
- ▶ **Résilience accrue** : capacité d'absorber les chocs cyber et de continuer l'activité.
- ▶ Réduction du **temps de reprise** (RTO/RPO) après un incident.
- ▶ Contribution directe au **Plan de Continuité d'Activité (PCA)** et au **Plan de Reprise d'Activité (PRA)**.
- ▶ Préparation aux scénarios de crise (exercices, simulations, Red Team vs Blue Team).

Le SOC est un acteur clé de la cybersécurité organisationnelle et de la survie en cas d'attaque majeure.

Contexte et enjeux actuels :

Importance de la conformité réglementaire (ex. : RGPD, NIST)

Un SOC ne protège pas seulement contre les menaces, il doit aussi :

- ▶ Respecter les normes et lois applicables :
 - ▶ **RGPD (Europe)** : protection des données personnelles et obligation de notification en cas de fuite.
 - ▶ **NIST (USA)** : référentiel de bonnes pratiques en cybersécurité.
 - ▶ **ISO/IEC 27001** : système de management de la sécurité de l'information.
 - ▶ Autres normes sectorielles : PCI-DSS (paiement), HIPAA (santé).
- ▶ **Apporter des garanties** aux clients et partenaires :
 - ▶ Confiance accrue.
 - ▶ Image de sérieux et conformité.

La conformité transforme le SOC en un levier stratégique et légal, pas seulement technique.

Contexte et enjeux actuels :

Collaboration interdisciplinaire (NOC, SOC, équipes de maintenance)

Un SOC n'est pas isolé. Il interagit avec plusieurs autres équipes :

- ▶ **NOC (Network Operations Center)** : assure la disponibilité et la performance du réseau.
- ▶ **Équipes IT & Maintenance** : appliquent les correctifs, assurent la gestion des vulnérabilités.
- ▶ **Équipes métiers et direction** : participent à la gestion de crise et à la prise de décision.
- ▶ **Partenaires externes (CERT, CSIRT, MSSP)** : assistance spécialisée en cas d'attaque.

La collaboration interdisciplinaire est la clé pour une cybersécurité globale, efficace et résiliente.

Incident majeur / des cas :

Étude de cas : Attaque sur Target (2013) – Défaillance du SOC

- ▶ Contexte :
 - ▶ En 2013, Target subit une attaque massive.
 - ▶ Les pirates ont compromis un prestataire HVAC (climatisation) pour entrer dans le réseau.
- ▶ Déroulement de l'attaque :
 - ▶ Malware installé sur les terminaux de paiement (POS).
 - ▶ 40 millions de cartes bancaires volées.
 - ▶ Données personnelles de 70 millions de clients exposées.
- ▶ Défaillance du SOC :
 - ▶ Alertes SIEM générées mais ignorées.
 - ▶ Manque de suivi et de réaction des analystes.

Incident majeur / des cas :

Analyse des causes des échecs ou succès des SOC

- ▶ Causes d'échec :
 - ▶ Mauvaise priorisation des alertes (Target).
 - ▶ Surcharge d'informations (alert fatigue).
 - ▶ Manque de formation ou de coordination.
 - ▶ Processus de réponse trop lents.
- ▶ Facteurs de succès :
 - ▶ Proactivité (threat hunting, Red Team/Blue Team).
 - ▶ Automatisation via SOAR (orchestration de la réponse).
 - ▶ Collaboration avec partenaires externes (CERT, MSSP).
 - ▶ Capacité à communiquer rapidement aux parties prenantes.

Un SOC efficace dépend autant de la technologie que de l'organisation humaine.

Incident majeur / des cas :

Conséquences des incidents mal gérés

- ▶ Conséquences financières :
 - ▶ Amendes (RGPD, PCI-DSS).
 - ▶ Pertes directes (fraudes, vols de données).
 - ▶ Coûts de remédiation élevés.
- ▶ Conséquences réputationnelles :
 - ▶ Perte de confiance des clients et partenaires.
 - ▶ Dégradation de l'image de marque.
- ▶ Conséquences opérationnelles :
 - ▶ Interruption de services.
 - ▶ Perturbation de la supply chain.

Un SOC qui échoue peut transformer un incident isolé en crise majeure.

Incident majeur / des cas :

Leçons tirées pour optimiser les opérations du SOC

- ▶ Améliorer la détection :
 - ▶ Surveiller les signaux faibles.
 - ▶ Éviter la négligence d'alertes critiques.
- ▶ Réduire les délais de réponse :
 - ▶ Automatiser les processus (SOAR).
 - ▶ Standardiser les procédures (playbooks).
- ▶ Renforcer la formation et la vigilance :
 - ▶ Exercer régulièrement les équipes (simulation d'attaques).
 - ▶ Investir dans le développement des compétences SOC.
- ▶ Adopter une approche globale :
 - ▶ Collaboration avec NOC, IT, juridique, communication.
- ▶ Intégration dans la stratégie globale de résilience.

Les échecs du passé servent à construire des SOC plus robustes et intelligents.

Concept et ingénierie :

Définition d'un SOC et ses objectifs principaux

Un Security Operations Center (SOC) est une entité organisationnelle et technique dédiée à la surveillance, détection, analyse et réponse aux incidents de sécurité.

C'est le centre nerveux de la cybersécurité d'une organisation.

- ▶ Objectifs principaux :
 - ▶ Assurer une surveillance continue 24/7.
 - ▶ Détecter les menaces de manière précoce.
 - ▶ Répondre rapidement aux incidents pour limiter les impacts.
 - ▶ Garantir la conformité réglementaire.
 - ▶ Contribuer à la résilience organisationnelle.

Le SOC est à la fois une fonction technique et un levier stratégique pour l'entreprise.

Concept et ingénierie :

Modèles de SOC : interne, externalisé, hybride

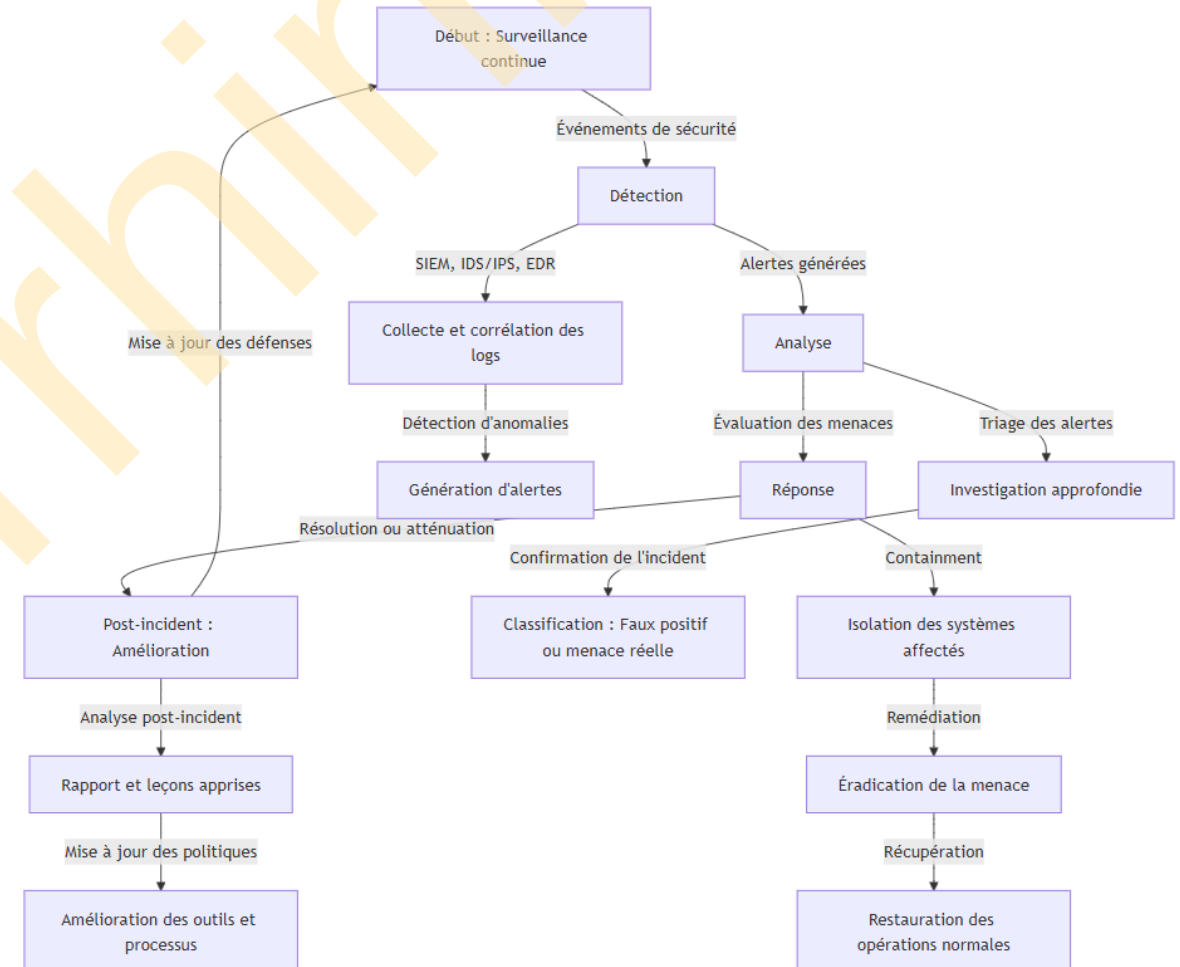
- ▶ SOC interne :
 - ▶ Déployé et géré en interne par l'organisation.
 - ▶ Contrôle total, confidentialité élevée.
 - ▶ Coûts élevés (infrastructure + experts).
- ▶ SOC externalisé (MSSP) :
 - ▶ Géré par un prestataire spécialisé.
 - ▶ Réduction des coûts, expertise disponible.
 - ▶ Dépendance au fournisseur, confidentialité limitée.
- ▶ SOC hybride :
 - ▶ Combinaison des deux modèles.
 - ▶ Exemple : détection en interne, réponse externalisée.

Le choix dépend de la taille, des besoins et du budget de l'organisation.

Concept et ingénierie :

Cycle de vie des opérations SOC : détection, analyse, réponse

- ▶ Collecte & détection :
 - ▶ Centralisation des logs (SIEM).
 - ▶ Détection d'anomalies ou d'alertes.
- ▶ Analyse :
 - ▶ Validation de la menace.
 - ▶ Corrélation des événements.
 - ▶ Attribution de priorité.
- ▶ Réponse :
 - ▶ Containment (isolation de la menace).
 - ▶ Remédiation (patches, correctifs).
 - ▶ Rétablissement du service.
- ▶ Retour d'expérience :
 - ▶ Leçons apprises.
 - ▶ Ajustement des règles et procédures.



Cycle itératif = amélioration continue du SOC.

Concept et ingénierie :

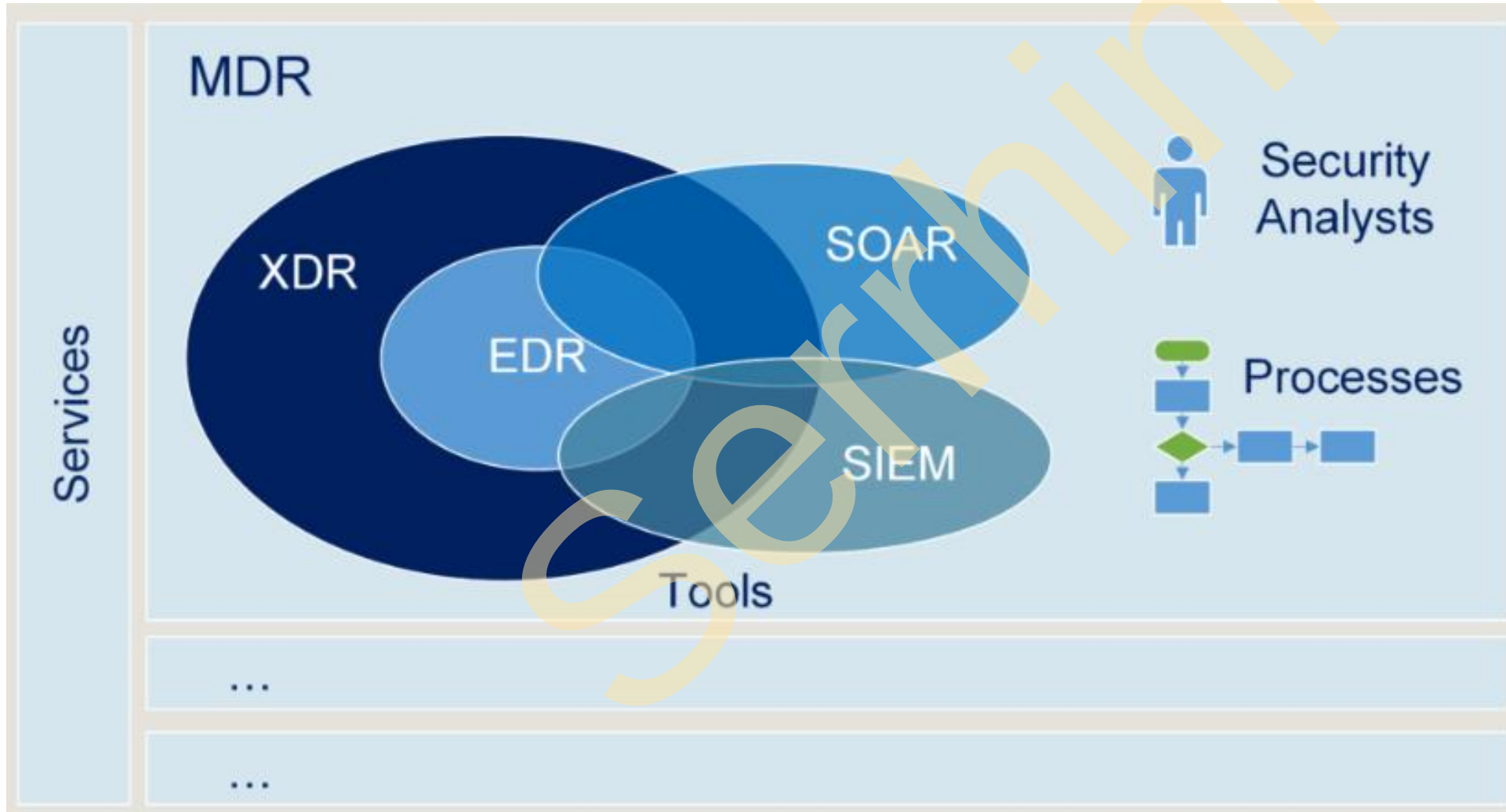
Ingénierie d'un SOC : infrastructure et intégration

- ▶ Infrastructure technique :
 - ▶ SIEM (Security Information and Event Management).
 - ▶ EDR/XDR (Endpoint/Extended Detection & Response).
 - ▶ IDS/IPS (Intrusion Detection/Prevention Systems).
 - ▶ SOAR (Security Orchestration, Automation & Response).
- ▶ Intégration :
 - ▶ Collecte depuis serveurs, réseaux, endpoints, cloud.
 - ▶ Corrélation automatisée pour réduire la charge humaine.
 - ▶ Intégration avec les outils IT (ticketing, CMDB).

Un SOC efficace repose sur une architecture robuste et interconnectée.

Concept et ingénierie :

Ingénierie d'un SOC : infrastructure et intégration



Concept et ingénierie :

Rôles et responsabilités dans un SOC (analystes, ingénieurs)

- ▶ Niveaux d'analystes :
 - ▶ Niveau 1 (Tier 1) : Surveillance en continu, traitement initial des alertes.
 - ▶ Niveau 2 (Tier 2) : Analyse approfondie, investigation, escalade.
 - ▶ Niveau 3 (Tier 3) : Threat hunting, reverse engineering, expertise avancée.
- ▶ Ingénieurs SOC :
 - ▶ Gestion des outils (SIEM, SOAR).
 - ▶ Développement de règles et automatisations.
- ▶ Responsables SOC / CISO :
 - ▶ Supervision stratégique.
 - ▶ Coordination avec direction et parties prenantes.

Le facteur humain est aussi important que la technologie.

Concept et ingénierie :

Rôles et responsabilités dans un SOC (analystes, ingénieurs)

SOC Analysts



Tier 1
Analyst



Tier 2
Analyst



Tier 3
Analyst



SOC Team
Lead

Specialized Roles



Incident
Responder



Threat
Hunter



Threat Intel
Analyst



Security
Engineer



Vulnerability
Manager



Forensic
Analyst



Malware
Analyst

Management Roles



SOC
Manager



Director of
Security



CISO

Concept et ingénierie :

Rôle des KPI pour mesurer la performance et l'amélioration du SOC

- ▶ Indicateurs clés (KPI) :
 - ▶ MTTD (Mean Time To Detect) : délai moyen de détection.
 - ▶ MTTR (Mean Time To Respond) : délai moyen de réponse.
 - ▶ Taux de faux positifs vs vrais incidents.
 - ▶ Volume d'incidents traités par analyste.
 - ▶ Taux de conformité réglementaire.
- ▶ Utilité des KPI :
 - ▶ Identifier les faiblesses.
 - ▶ Mesurer l'efficacité des processus.
 - ▶ Orienter les investissements et améliorations.

Les KPI sont le thermomètre de la maturité SOC.

Technique de base :

Surveillance des événements de sécurité via SIEM

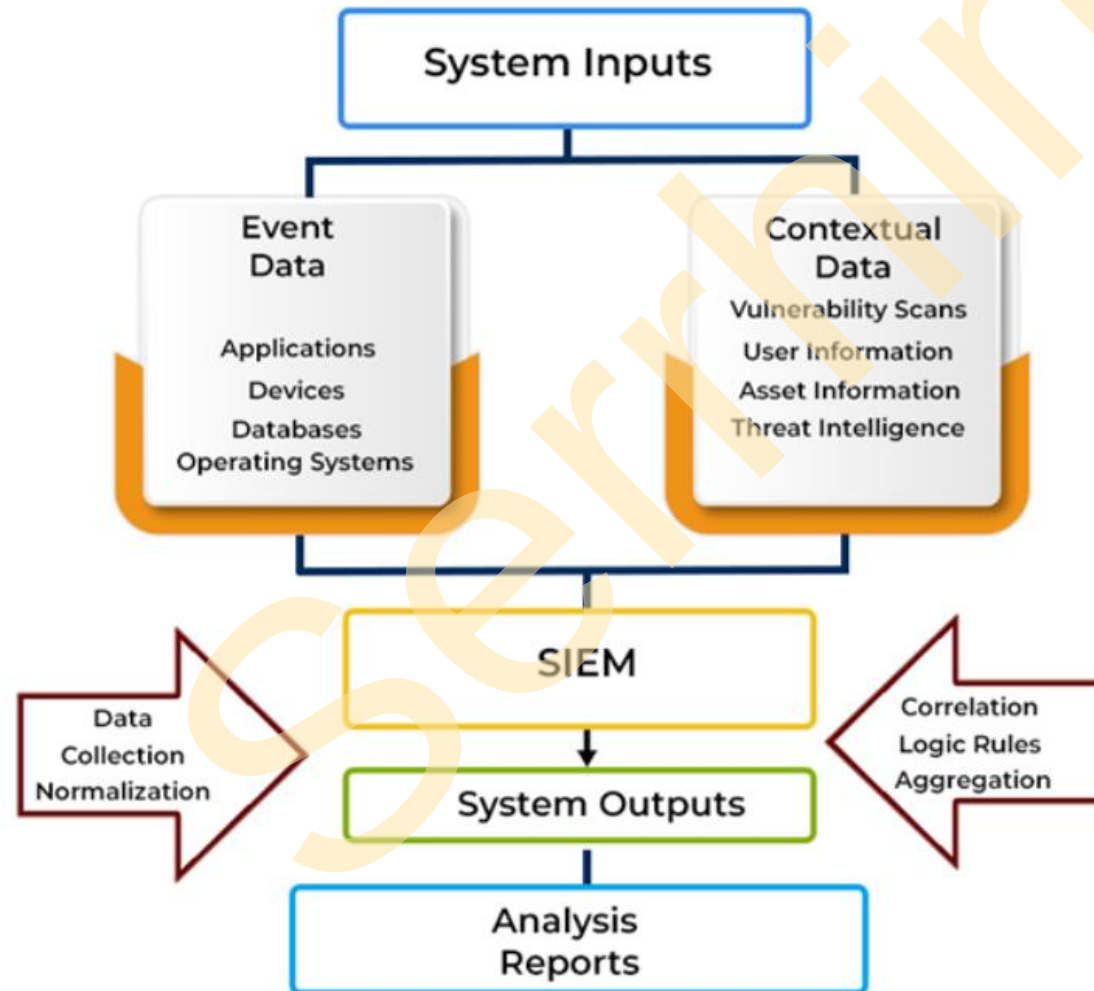
Le SIEM (Security Information and Event Management) centralise les journaux et événements de sécurité provenant de plusieurs sources (serveurs, applications, réseaux, endpoints).

- ▶ Rôle :
 - ▶ Collecte et normalisation des logs.
 - ▶ Corrélation des événements pour détecter des patterns suspects.
 - ▶ Génération d'alertes en temps réel.
- ▶ Exemples d'outils : Splunk, IBM QRadar, ArcSight, WAZUH.

Le SIEM est la colonne vertébrale de la détection SOC.

Technique de base :

Surveillance des événements de sécurité via SIEM



Technique de base :

Gestion des alertes et triage des incidents

Un SOC reçoit des milliers d'alertes par jour → toutes ne sont pas critiques.

- ▶ Processus de triage :
 - ▶ Vérifier la validité de l'alerte (faux positifs vs vrais incidents).
 - ▶ Attribuer une priorité selon l'impact et la criticité.
 - ▶ Escalader si nécessaire aux analystes de niveau supérieur.
- ▶ Bonnes pratiques :
 - ▶ Automatiser la catégorisation (SOAR).
 - ▶ Définir des playbooks pour uniformiser la réponse.

Le triage est essentiel pour éviter la fatigue des analystes.

Technique de base :

Analyse des journaux (logs) et détection des anomalies

- ▶ Journaux collectés :
 - ▶ Authentifications (succès/échecs).
 - ▶ Flux réseaux (firewalls, proxys).
 - ▶ Activités systèmes (Windows Event Logs, Syslog Linux).
 - ▶ Activités applicatives (bases de données, serveurs web).
- ▶ Objectifs :
 - ▶ Identifier des comportements anormaux (ex. : connexions à des heures inhabituelles).
 - ▶ Détecter des patterns d'attaque (bruteforce, exfiltration).

L'analyse des logs est la première ligne de défense contre les intrusions.

Technique de base :

Analyse des logs pour identifier les signaux faibles

Les signaux faibles = petites anomalies isolées qui, corrélées, révèlent une attaque.

▶ Exemples :

- ▶ Plusieurs échecs de connexion depuis des IP dispersées.
- ▶ Processus systèmes lancés de manière inhabituelle.
- ▶ Envoi anormalement élevé de données vers l'extérieur.

▶ Méthodes :

- ▶ Corrélation multi-sources dans le SIEM.
- ▶ Analyse comportementale (UEBA – User & Entity Behavior Analytics).
- ▶ Threat hunting manuel par les analystes SOC.

Savoir voir l'invisible différencie un SOC proactif d'un SOC réactif.

Technique de base :

Procédures de réponse initiale aux incidents

- ▶ Étapes initiales en cas d'incident :
 - ▶ Confinement : isoler la machine compromise.
 - ▶ Collecte d'indices : sauvegarder les journaux et artefacts.
 - ▶ Communication interne : alerter les responsables.
 - ▶ Escalade si l'incident dépasse le périmètre SOC niveau 1.
- ▶ Outils :
 - ▶ EDR (Endpoint Detection & Response).
 - ▶ Scripts automatisés (SOAR).

Une réponse rapide peut éviter la propagation d'une attaque.

Technique de base :

Communication et coordination avec les équipes internes

Un SOC n'agit pas seul → la coordination est indispensable.

- ▶ Acteurs impliqués :
 - ▶ Équipe IT (patches, correctifs).
 - ▶ NOC (réseau et connectivité).
 - ▶ Direction / CISO (prise de décision stratégique).
 - ▶ Équipe communication (si crise publique).
- ▶ Pratiques efficaces :
 - ▶ Procédures d'escalade claires.
 - ▶ Canaux de communication sécurisés.
 - ▶ Exercices réguliers (simulation d'incidents).

Une bonne communication évite la confusion et la perte de temps.

Technique de base :

Outils de base : firewalls, IDS/IPS, antivirus

- ▶ Firewalls : filtrage du trafic entrant/sortant.
- ▶ IDS/IPS : détection et prévention des intrusions réseau.
- ▶ Antivirus & EDR : protection et détection sur les postes de travail.
- ▶ SIEM : collecte et corrélation des logs.
- ▶ Outils forensiques : analyse post-incident.

Ces outils constituent le socle technique minimum pour tout SOC.

Technique de base :

Outils de base : firewalls, IDS/IPS, antivirus



Exercice

Triage des alertes

Vous êtes un analyste T1 dans un SOC d'une entreprise. Le SIEM génère 5 alertes en une heure, issues de logs réseau, EDR et IDS.

Votre mission est de trier chaque alerte, déterminer si elle est un vrai positif (incident réel), un faux positif (bénin), ou nécessite une escalade vers un analyste T2.

Vous devez fournir une justification et une action recommandée, en respectant les KPI

Alerte 1 : Trafic réseau suspect vers une IP inconnue

- ▶ **Source** : IDS
- ▶ **Détails** : Trafic TCP sortant depuis l'hôte interne 192.168.1.100 (poste utilisateur) vers l'IP externe 185.125.190.20, port 4444, à 07:45 AM. Fréquence : 10 connexions en 2 minutes.
- ▶ **Contexte** : L'IP 185.125.190.20 n'est pas dans la liste blanche de l'entreprise. Aucun service légitime n'utilise le port 4444.

Exercice

Triage des alertes

Alerte 2 : Tentative de connexion échouée répétée

- ▶ **Source** : Active Directory Logs (via SIEM)
- ▶ **Détails** : 50 tentatives de connexion échouées sur le compte "admin_user" depuis l'hôte 192.168.1.50 en 5 minutes, à 07:50 AM. Source : Poste utilisateur interne.
- ▶ **Contexte** : L'utilisateur "admin_user" est un compte privilégié. L'hôte 192.168.1.50 est attribué à un employé du marketing.

Exercice

Triage des alertes

Alerte 3 : Scan réseau détecté

- ▶ **Source** : Réseau
- ▶ **Détails** : Scan TCP sur ports 22, 80, 443, 3389 depuis 192.168.1.200 vers 192.168.1.0/24, à 08:05 AM.
- ▶ **Contexte** : 192.168.1.200 est un serveur de gestion IT pour inventaire réseau.

Normes :

Rôle de la conformité dans le SOC

La conformité dans un SOC consiste à aligner les activités de sécurité (surveillance, détection, réponse) avec les exigences légales, réglementaires et contractuelles. Les objectifs sont :

- ▶ **Protection des données** : Sécuriser les données sensibles (ex. : données personnelles, financières) conformément aux lois.
- ▶ **Réduction des risques** : Minimiser les amendes, pertes de réputation, ou interruptions opérationnelles.
- ▶ **Auditabilité** : Fournir des rapports et des preuves d'activité conformes pour les audits internes/externes.
- ▶ **Amélioration continue** : Intégrer les retours des audits pour optimiser les processus.

Dans un SOC, la conformité touche :

- ▶ **La gestion des incidents** : Documentation et reporting des incidents (ex. : notification dans les 72h pour RGPD).
- ▶ **La surveillance** : Configuration des outils (SIEM, EDR) pour détecter les violations spécifiques.
- ▶ **La formation** : Sensibilisation des analystes aux exigences réglementaires.
- ▶ **Les audits** : Vérification régulière des contrôles de sécurité.

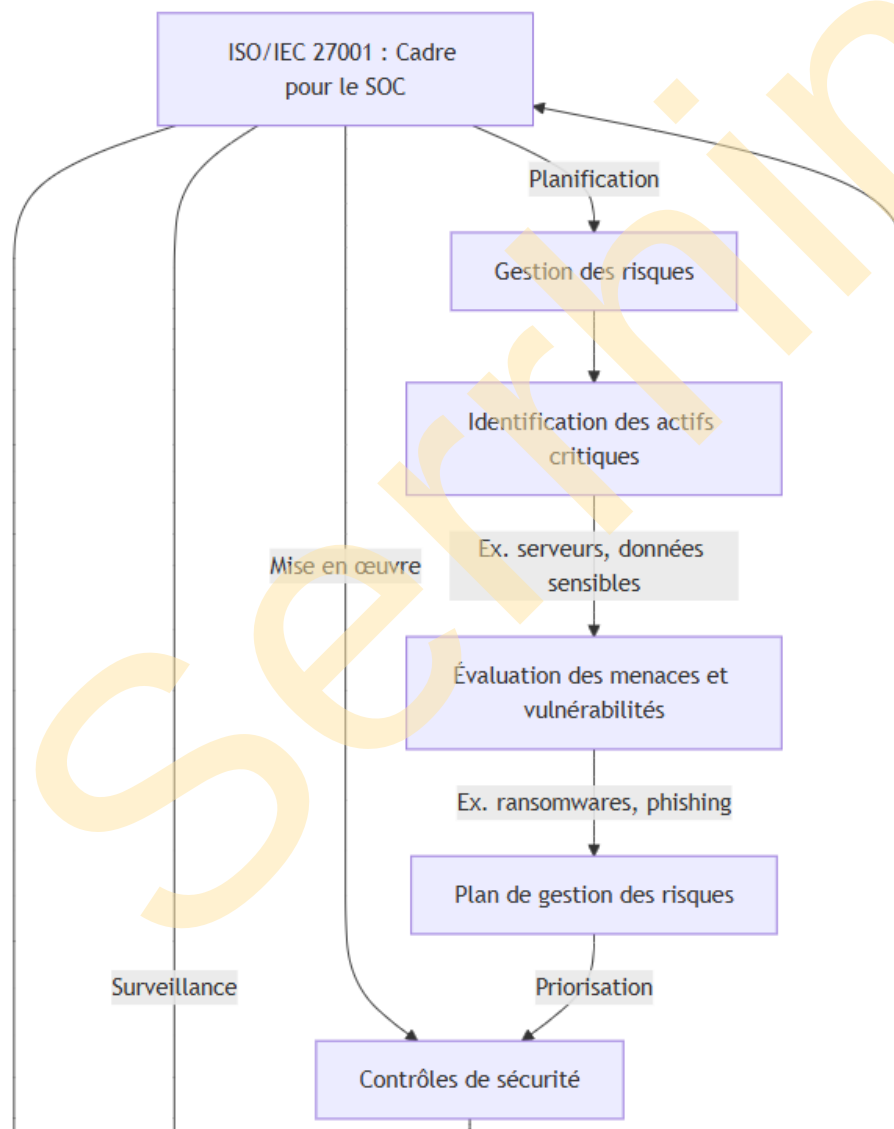
Normes :

Normes applicables aux SOC : ISO/IEC 27001

- ▶ La norme ISO/IEC 27001 est une norme internationale qui définit les exigences pour établir, mettre en œuvre, maintenir et améliorer un système de management de la sécurité de l'information (SMSI).
- ▶ Dans le contexte d'un Security Operation Center (SOC), elle fournit un cadre structuré pour
 - ▶ Protéger les informations sensibles,
 - ▶ Garantir la conformité
 - ▶ Renforcer la résilience face aux cybermenaces.
- ▶ Cette norme met l'accent sur une approche basée sur les risques, obligeant les SOC à identifier les actifs critiques (comme les serveurs ou les bases de données), évaluer les menaces potentielles et mettre en place des contrôles appropriés,
- ▶ En adoptant ISO 27001, un SOC peut démontrer à ses parties prenantes – clients, partenaires, régulateurs – son engagement envers des pratiques de sécurité robustes, tout en alignant ses opérations sur les meilleures pratiques internationales, ce qui est essentiel pour maintenir la confiance et répondre aux exigences réglementaires.

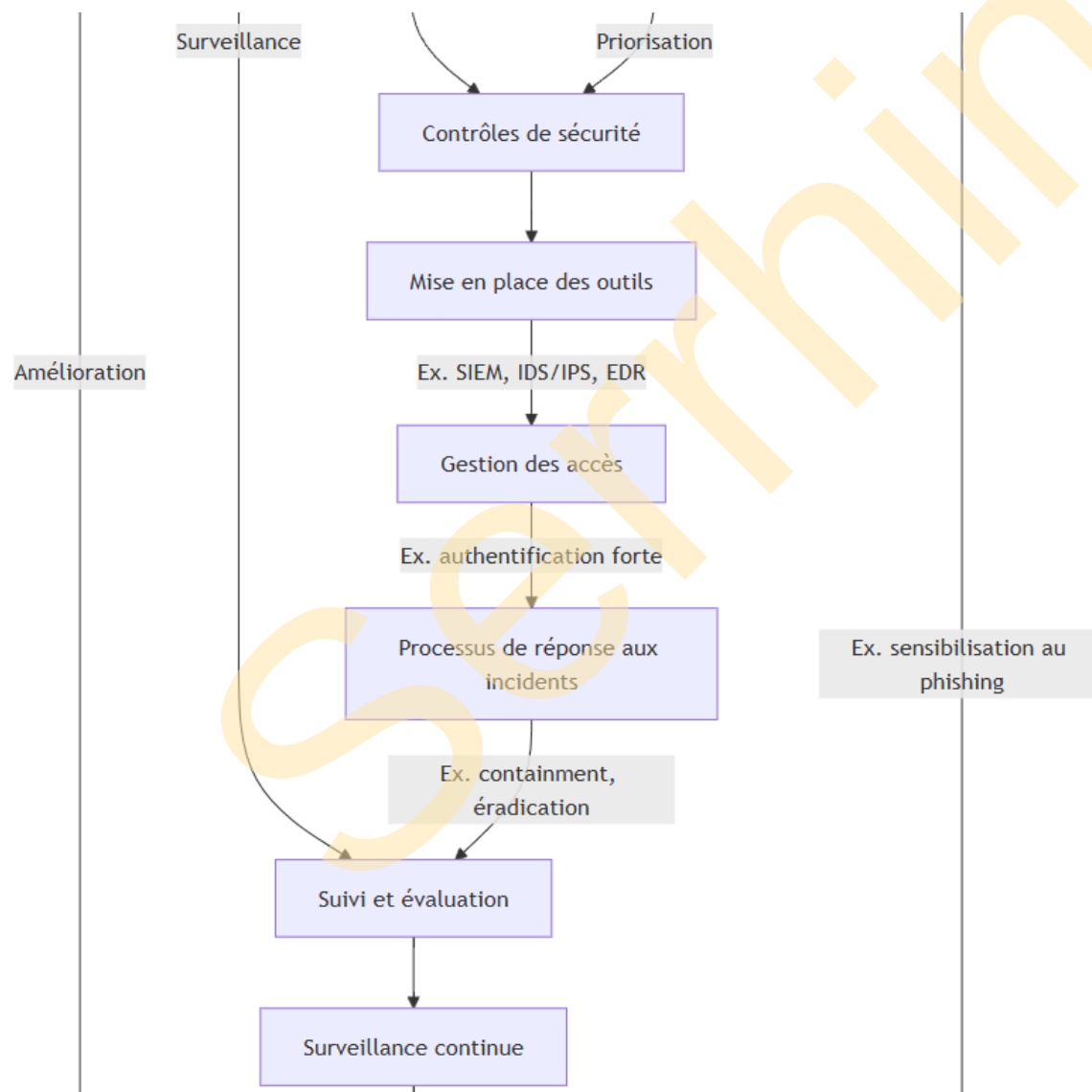
Normes :

Normes applicables aux SOC : ISO/IEC 27001



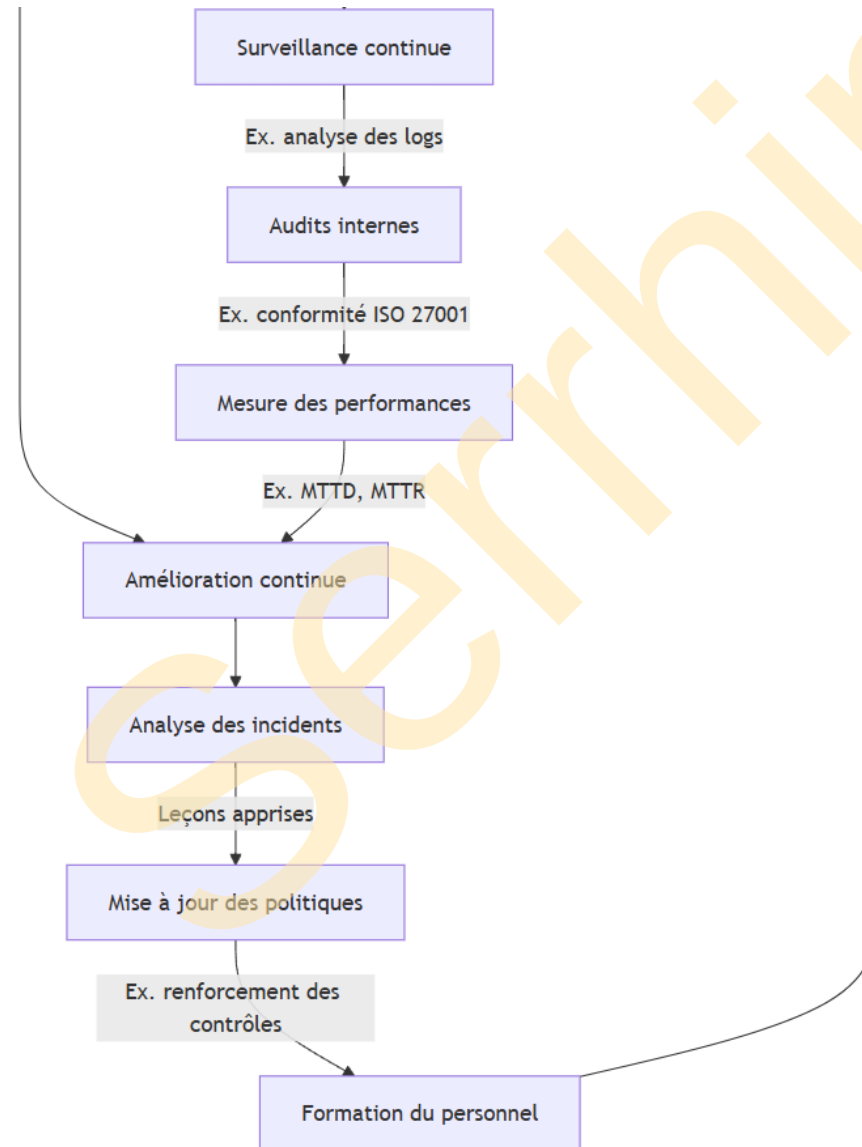
Normes :

Normes applicables aux SOC : ISO/IEC 27001



Normes :

Normes applicables aux SOC : ISO/IEC 27001



Normes :

NIST Cybersecurity Framework pour les opérations SOC

- ▶ Le NIST Cybersecurity Framework (CSF), développé par le National Institute of Standards and Technology, est un cadre volontaire conçu pour aider les organisations à gérer et réduire les risques de cybersécurité.
- ▶ Pour un Security Operation Center (SOC), le NIST CSF fournit une structure flexible et robuste à travers cinq fonctions principales : **Identifier, Protéger, Détecter, Répondre et Récupérer**.
- ▶ Ces fonctions permettent au SOC d'organiser ses activités de manière systématique, en alignant les efforts de cybersécurité avec les objectifs stratégiques de l'entreprise.

Par exemple,

- ▶ La fonction Identifier aide le SOC à cartographier les actifs critiques, comme les serveurs ou les bases de données, et à évaluer les risques associés,
- ▶ La fonction Détecter repose sur des outils comme les systèmes SIEM pour repérer les anomalies en temps réel.

Le NIST CSF est particulièrement apprécié pour sa flexibilité, permettant aux SOC de s'adapter à des environnements variés, qu'il s'agisse de petites entreprises ou de grandes infrastructures critiques, tout en intégrant des bonnes pratiques pour contrer des menaces comme les ransomwares ou les attaques par déni de service.

Normes :

Conformité et audits des processus SOC

- ▶ La conformité réglementaire est un pilier essentiel pour un Security Operation Center (SOC), car elle garantit que les pratiques de cybersécurité respectent les lois, normes et réglementations applicables, tout en renforçant la confiance des parties prenantes.
- ▶ Les SOC doivent s'aligner sur des cadres comme l'ISO/IEC 27001, qui exige un système de management de la sécurité de l'information (SMSI), ou le RGPD en Europe, qui impose des mesures strictes pour protéger les données personnelles, avec des amendes pouvant atteindre 20 millions d'euros en cas de non-conformité.
- ▶ Dans des secteurs spécifiques, comme la finance, la norme PCI-DSS régit la sécurité des transactions par carte, obligeant les SOC à surveiller les systèmes de paiement et à signaler tout incident.
- ▶ La conformité implique de mettre en place des politiques claires, comme des contrôles d'accès stricts ou des journaux d'événements traçables, et de documenter chaque processus, de la détection des menaces à la réponse aux incidents.
- ▶ Pour un SOC, respecter ces exigences signifie non seulement éviter des sanctions, mais aussi démontrer un engagement envers la protection des données et la continuité des opérations, ce qui est crucial pour maintenir la réputation de l'organisation.

Normes :

Défis de la Conformité dans le SOC

1. **Conflits entre normes** : Ex. : RGPD exige la suppression des données après un certain temps, mais PCI DSS peut exiger leur conservation pour audits.
2. **Évolution réglementaire** : Les normes évoluent (ex. : RGPD renforcé en 2025 avec focus sur l'IA). Le SOC doit s'adapter.
3. **Coût et complexité** : Configurer des outils conformes (ex. : SIEM avec retention de logs pour 7 ans pour PCI DSS) est coûteux.
4. **Faux positifs** : Les règles de conformité génèrent souvent des alertes inutiles, nécessitant un triage efficace.

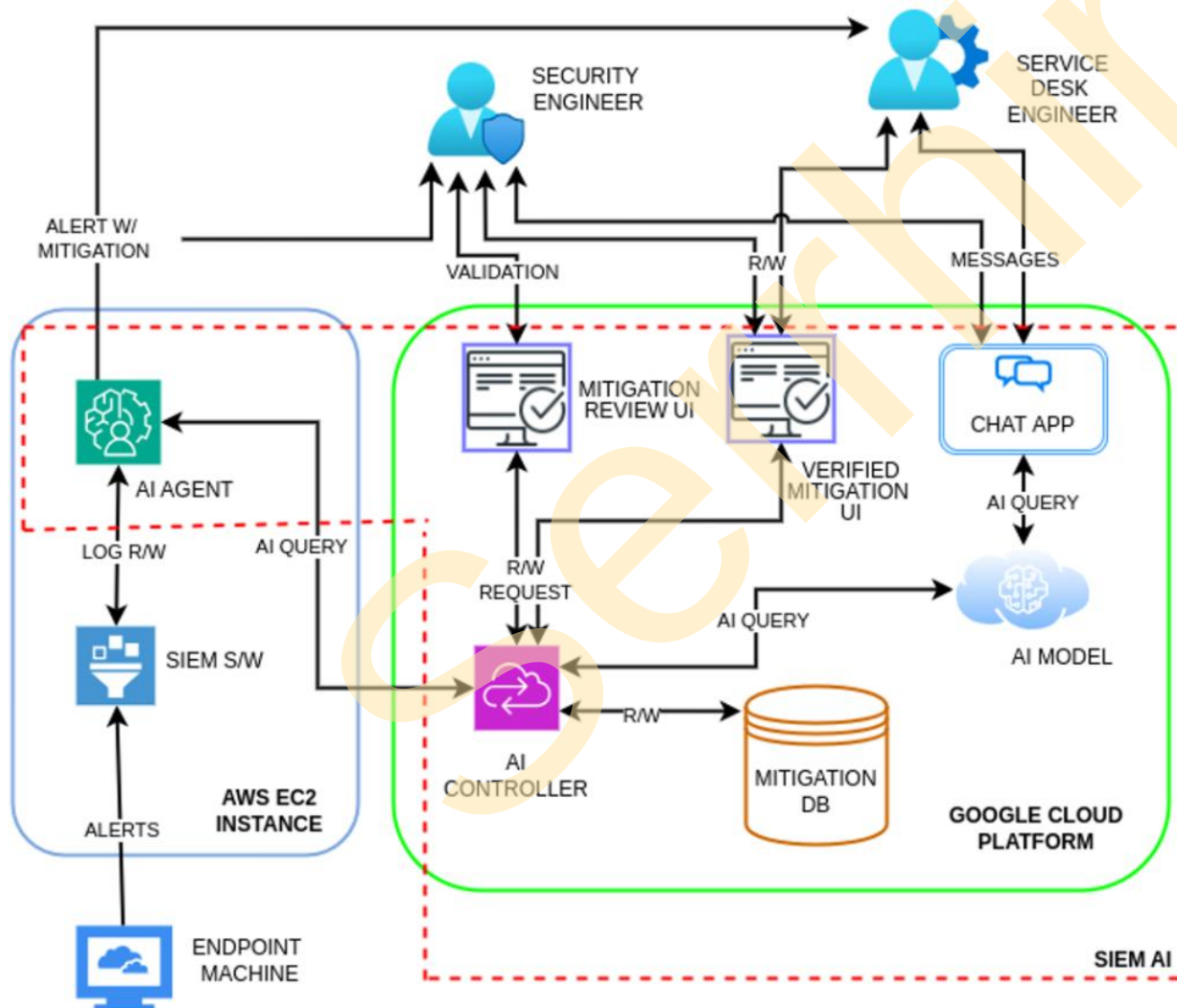
Techniques avancées :

Utilisation de l'intelligence artificielle pour l'analyse des menaces

- ▶ L'intégration de l'intelligence artificielle (IA) et du machine learning (ML) dans les systèmes SIEM représente une avancée majeure pour les Security Operation Centers (SOC), en permettant une détection des menaces plus rapide, précise et proactive.
- ▶ Contrairement aux SIEM traditionnels, qui reposent sur des règles statiques pour générer des alertes (par exemple, détecter un nombre fixe de tentatives de connexion échouées), les SIEM boostés par l'IA, comme **Splunk Enterprise Security** ou **Microsoft Sentinel**, utilisent des algorithmes ML pour analyser des volumes massifs de données – logs réseau, activités des utilisateurs, événements système – et identifier des anomalies subtiles qui échappent aux approches conventionnelles.
- ▶ Cependant, les analystes SOC doivent comprendre les sorties de l'IA, souvent sous forme de scores de risque ou de probabilités, pour trier efficacement les alertes et réduire les faux positifs, ce qui nécessite une formation sur l'interprétation des modèles ML et une collaboration étroite avec les data scientists pour affiner les algorithmes.

Techniques avancées :

Utilisation de l'intelligence artificielle pour l'analyse des menaces



Techniques avancées :

Utilisation de l'intelligence artificielle pour l'analyse des menaces

- ▶ L'intégration de l'IA dans un SIEM transforme les processus de détection, d'analyse et de réponse aux incidents, mais elle exige une approche stratégique pour maximiser son efficacité.
- ▶ Par exemple, un SIEM comme IBM QRadar peut utiliser l'IA pour corréler des millions d'événements en temps réel, en identifiant des schémas suspects.
- ▶ Les analystes configurent des modèles ML pour prioriser les alertes selon leur gravité, en s'appuyant sur des scores de confiance générés par l'IA, ce qui permet de réduire le temps moyen de détection (MTTD).
- ▶ Pratiquement, l'IA peut automatiser le triage initial des alertes : une alerte de faible priorité, comme une mise à jour logicielle non critique, peut être filtrée, tandis qu'une alerte de haute priorité, comme une tentative d'élévation de privilèges, est immédiatement transmise à un analyste niveau 2.
- ▶ Cependant, des défis subsistent : les modèles ML nécessitent des données d'entraînement de qualité pour éviter les biais, et les faux positifs peuvent surcharger les équipes si les seuils ne sont pas bien calibrés.
- ▶ De plus, les SOC doivent intégrer l'IA avec d'autres outils, comme les EDR (Endpoint Detection and Response) ou les plateformes SOAR, pour orchestrer des réponses automatisées, comme bloquer une IP suspecte. Les analystes doivent également rester vigilants face aux attaquants qui exploitent l'IA à leur tour (ex. attaques adverses pour tromper les modèles ML), soulignant l'importance d'une supervision humaine et d'une amélioration continue des algorithmes.

Techniques avancées :

Threat hunting

Le threat hunting, ou chasse aux menaces, est une approche proactive adoptée par les Security Operation Centers (SOC) pour identifier les cybermenaces furtives, comme les Advanced Persistent Threats (APT) ou les malwares zero-day, avant qu'elles ne déclenchent des alertes automatiques dans des systèmes comme les SIEM.

- ▶ Le cadre MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge) joue un rôle central dans cette démarche en fournissant une base de connaissances détaillée des tactiques, techniques et procédures (TTP) utilisées par les attaquants.
- ▶ Contrairement aux méthodes réactives basées sur les signatures, ATT&CK permet aux analystes SOC de formuler des hypothèses basées sur les comportements des attaquants, comme l'utilisation de techniques spécifiques (ex. T1078 – Valid Accounts pour l'accès initial via des identifiants volés).
- ▶ Par exemple, un analyste peut supposer qu'un attaquant utilise des outils légitimes, comme PowerShell, pour se déplacer latéralement dans le réseau, et interroger les logs pour détecter des commandes suspectes. Le cadre ATT&CK structure le threat hunting en organisant les investigations autour de ses matrices, qui couvrent des phases comme la reconnaissance, l'exécution, la persistance ou l'exfiltration.
- ▶ Cette approche permet aux SOC de prioriser les recherches en fonction des menaces les plus probables dans leur environnement, comme les attaques ciblant des serveurs Active Directory dans un contexte d'entreprise.
- ▶ Les défis incluent la nécessité d'une expertise approfondie pour interpréter les TTP, la gestion du bruit dans les données analysées, et l'intégration des résultats dans des playbooks pour enrichir les défenses.

Techniques avancées :

Threat hunting

- ▶ Supposons qu'un SOC reçoit des informations de renseignement sur les menaces indiquant des attaques utilisant des techniques de spear-phishing (**T1566**) pour obtenir un accès initial, suivies d'une persistance via la création de tâches planifiées (**T1053**).
- ▶ L'analyste SOC formule une hypothèse : "Un attaquant a compromis un compte utilisateur via un e-mail de phishing et utilise des tâches planifiées pour maintenir l'accès." En s'appuyant sur la matrice ATT&CK, l'analyste concentre son investigation sur la tactique "Persistence" et la technique **T1053.005** (Scheduled Task/Job).
- ▶ À l'aide d'un outil SIEM, il interroge les logs système pour identifier les tâches planifiées créées récemment, en filtrant sur des horaires inhabituels (ex. exécution à 2h du matin) ou des comptes non autorisés.
- ▶ L'analyse révèle une tâche suspecte exécutant un script PowerShell vers une IP externe, correspondant à la technique **T1071.001** (Command and Control via Web Protocols).
- ▶ En croisant ces données avec les journaux d'authentification, l'analyste découvre un accès initial via un compte compromis, lié à un e-mail de phishing contenant une pièce jointe malveillante.
- ▶ Ce processus illustre comment ATT&CK guide le threat hunting en structurant l'investigation autour des TTP, permettant une détection précoce et une réponse ciblée, comme l'isolation du système affecté et la mise à jour des règles SIEM pour détecter des comportements similaires.

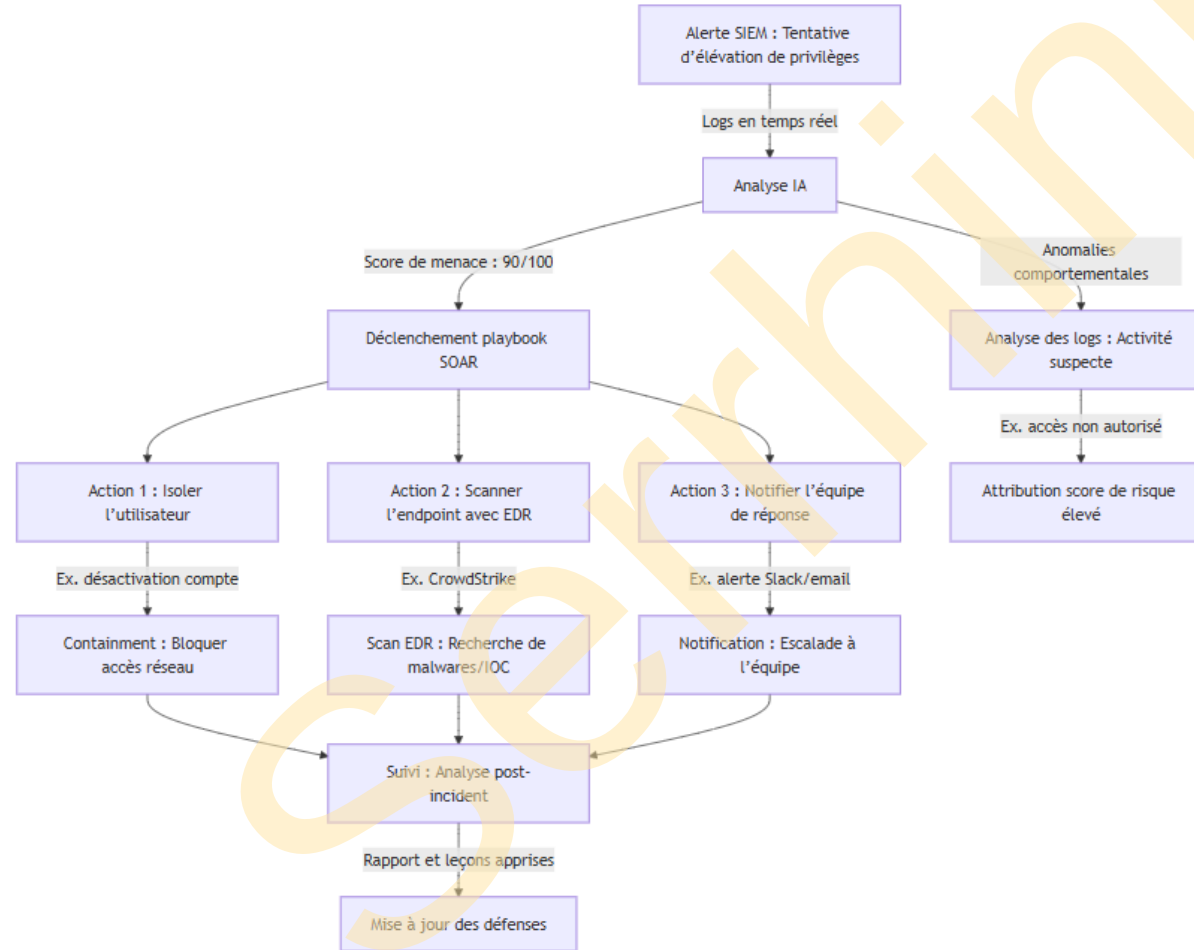
Techniques avancées :

Intégration des solutions SOAR pour l'automatisation

- ▶ Les plateformes SOAR (Security Orchestration, Automation, and Response), telles que Splunk SOAR, Palo Alto Cortex XSOAR ou IBM Resilient, transforment les opérations d'un Security Operation Center (SOC) en automatisant les tâches répétitives et en orchestrant les workflows entre différents outils de cybersécurité.
- ▶ L'implémentation d'un SOAR commence par une analyse des processus existants du SOC, comme le triage des alertes, la réponse aux incidents ou la collecte de renseignements sur les menaces. Par exemple, face à une alerte de phishing détectée par un SIEM, un playbook SOAR peut automatiquement vérifier l'URL suspecte dans une base de données comme VirusTotal, bloquer l'adresse IP associée via un pare-feu, et créer un ticket d'incident pour l'équipe IT, tout en documentant chaque étape pour assurer la traçabilité. L'implémentation nécessite une intégration avec les outils existants (SIEM, EDR, pare-feu) via des API, ce qui permet au SOAR de centraliser les données et de coordonner les actions.
- ▶ Les analystes doivent concevoir des playbooks clairs, en définissant des déclencheurs (ex. une alerte SIEM avec un score de risque élevé) et des actions conditionnelles (ex. isoler un endpoint si une menace est confirmée).
- ▶ Une implémentation réussie repose sur une planification rigoureuse, incluant des tests réguliers des playbooks pour éviter des erreurs d'automatisation, ainsi qu'une formation des analystes pour superviser et ajuster les processus automatisés, garantissant que les décisions critiques restent sous contrôle humain.

Techniques avancées :

Intégration des solutions SOAR pour l'automatisation



Techniques avancées :

Tendances du SOC : Blockchain

- ▶ En 2025, la blockchain émerge comme une technologie transformative pour les Security Operation Centers (SOC), en offrant des solutions pour sécuriser les logs d'événements, les enregistrements d'incidents et les partages de renseignements sur les menaces, tout en répondant aux défis croissants des cyberattaques sophistiquées.
- ▶ Dans un SOC, la blockchain permet de créer des journaux immuables et transparents, empêchant la falsification des données critiques comme les alertes SIEM ou les rapports d'incidents, ce qui est essentiel pour la conformité aux normes comme ISO 27001 ou NIST.
- ▶ Par exemple, des plateformes comme IBM Blockchain ou Hyperledger Fabric sont utilisées pour stocker des indicateurs de compromission (IOC) de manière décentralisée, facilitant le partage sécurisé entre organisations.
- ▶ Cette tendance s'aligne avec l'adoption accrue dans les secteurs critiques (santé, finance, supply chain), où la blockchain réduit les risques de manipulation de données et améliore la traçabilité des incidents.
- ▶ Cependant, les SOC doivent naviguer des défis comme la scalabilité et la consommation énergétique, bien que des solutions éco-responsables (ex. Proof-of-Stake) gagnent du terrain pour une intégration durable.
- ▶ Globalement, la blockchain transforme les SOC en centres proactifs, en renforçant la confiance et l'efficacité opérationnelle face à un paysage de menaces en expansion.

Techniques avancées :

Tendances du SOC : Blockchain

- ▶ L'intégration de la blockchain dans les SOC en 2025 se concrétise par des applications concrètes qui optimisent la détection, l'analyse et la réponse aux incidents, tout en adressant les vulnérabilités inhérentes aux systèmes centralisés.
- ▶ Par exemple, dans un SOC gérant des environnements cloud hybrides, la blockchain peut sécuriser les enregistrements de logs via des smart contracts, automatisant la vérification d'authenticité et la détection d'anomalies en temps réel, comme dans les solutions de Kaspersky Blockchain Security qui utilisent l'IA pour analyser les transactions et prévenir les fraudes.
- ▶ Une tendance clé est l'utilisation de la blockchain pour la gestion des identités décentralisées (DID), permettant aux analystes SOC de vérifier les accès sans points de défaillance uniques, réduisant ainsi les risques d'attaques comme les credential stuffing.
- ▶ De plus, dans les chaînes d'approvisionnement critiques, des entreprises comme FedEx intègrent la blockchain pour tracer les incidents de sécurité de bout en bout, offrant aux SOC une visibilité accrue sur les menaces externes.
- ▶ Néanmoins, des défis persistent : la complexité d'intégration avec des outils existants comme les SIEM (ex. Splunk), les risques quantiques qui menacent les cryptographies traditionnelles, et la nécessité de former les analystes à des protocoles hybrides IA-blockchain.
- ▶ Les SOC adoptant ces tendances, comme via des audits réguliers et des solutions post-quantiques, peuvent transformer la blockchain en un pilier de résilience, minimisant les temps de réponse (MTTR) et renforçant la collaboration inter-organisationnelle pour une cybersécurité collective plus efficace.

Techniques avancées :

Tendances du SOC : Zero-trust architecture ZTA

- ▶ L'architecture Zero Trust (ZTA), basée sur le principe "ne jamais faire confiance, toujours vérifier", redéfinit la manière dont les Security Operation Centers (SOC) protègent les actifs critiques face aux cybermenaces complexes de 2025, telles que les attaques APT, les ransomwares ou les compromissions internes.
- ▶ Contrairement aux approches traditionnelles qui supposent une sécurité à l'intérieur du périmètre réseau, Zero Trust exige une vérification stricte et continue de chaque utilisateur, appareil et connexion, qu'ils soient internes ou externes.
- ▶ Dans un SOC, ZTA se traduit par la mise en œuvre de contrôles d'accès dynamiques, comme l'authentification multifacteur (MFA) pour les analystes accédant aux systèmes SIEM, ou la segmentation micro-périmétrique des serveurs critiques pour limiter les mouvements latéraux des attaquants.
- ▶ Un SOC peut utiliser une solution comme Okta ou Microsoft Azure AD pour vérifier l'identité des utilisateurs en temps réel, en s'appuyant sur des signaux contextuels (localisation, comportement, type d'appareil).
- ▶ Cette approche renforce la capacité du SOC à détecter les anomalies, comme une tentative d'accès non autorisé à une base de données sensible, tout en réduisant les risques d'exploitation des identifiants volés.
- ▶ ZTA s'aligne également avec les cadres réglementaires comme NIST 800-207, qui recommande des politiques d'accès basées sur le principe du moindre privilège.
- ▶ Cependant, l'implémentation de ZTA dans un SOC nécessite une refonte des architectures réseau, une intégration complexe avec les outils existants (SIEM, EDR), et une formation des analystes pour gérer des flux de données plus granulaires, tout en maintenant une surveillance proactive pour garantir la conformité et l'efficacité opérationnelle.

Techniques avancées :

Tendances du SOC : impact de la 5G

- ▶ La technologie 5G, avec ses vitesses ultra-élevées, sa faible latence et sa capacité à connecter des milliards d'appareils IoT, redéfinit le fonctionnement des Security Operation Centers (SOC) en 2025, en offrant des opportunités sans précédent pour améliorer la détection, l'analyse et la réponse aux cybermenaces.
- ▶ La 5G permet aux SOC de collecter et d'analyser des volumes massifs de données en temps réel, comme les logs réseau ou les métadonnées IoT, grâce à une bande passante accrue et une latence réduite à moins de 1 ms.
- ▶ Par exemple, un SOC surveillant un réseau d'entreprise peut utiliser la 5G pour transmettre instantanément des alertes SIEM depuis des capteurs distribués, permettant une détection quasi-instantanée d'anomalies, comme une tentative d'exfiltration de données via un appareil IoT compromis.
- ▶ Cette connectivité accélère également l'intégration de l'intelligence artificielle (IA) et des plateformes SOAR, en facilitant l'automatisation des réponses, comme le blocage d'une IP suspecte en quelques secondes. De plus, la 5G soutient les SOC décentralisés, où les analystes collaborent à distance via des réseaux sécurisés à haute vitesse, renforçant la résilience face aux incidents critiques.
- ▶ Cependant, cette dépendance accrue à la 5G exige des SOC qu'ils adoptent des protocoles de sécurité robustes, comme le chiffrement de bout en bout, pour protéger les flux de données massifs et garantir la conformité aux normes comme ISO 27001 ou NIST.

Techniques avancées :

Tendances du SOC : AR/VR

- ▶ La réalité augmentée (AR) et la réalité virtuelle (VR), regroupées sous le terme de réalité étendue (XR), émergent comme des tendances clés pour transformer les Security Operation Centers (SOC) en environnements immersifs et proactifs, en intégrant l'intelligence artificielle (IA) et la connectivité 5G pour une détection et une réponse aux menaces plus intuitive.
- ▶ Le marché de l'XR en cybersécurité est projeté à une croissance exponentielle, tiré par l'utilisation de ces technologies pour la formation immersive des analystes, où des simulations VR reproduisent des attaques réelles comme des APT ou des ransomwares, permettant aux équipes SOC de s'entraîner sans risque sur des scénarios complexes.
- ▶ Par exemple, des plateformes comme celles de Meta ou Microsoft HoloLens intègrent l'AR pour superposer des visualisations en temps réel sur des dashboards SIEM, aidant les analystes à identifier des anomalies réseau ou des flux de données suspects dans un contexte 3D interactif, réduisant ainsi le temps de détection (MTTD) de manière significative.
- ▶ Ces tendances s'alignent avec l'évolution des SOC vers des modèles prédictifs, où l'XR facilite la collaboration à distance via des espaces virtuels partagés, renforçant la résilience face aux menaces hybrides (cyber-physiques). Cependant, les SOC doivent anticiper les défis comme la cybersécurité des casques XR eux-mêmes, vulnérables aux attaques de type deepfakes ou aux fuites de données biométriques, soulignant l'importance d'une intégration sécurisée avec des outils comme Zero Trust pour protéger ces environnements immersifs.

Certifications :

Certifications pour les débutants SOC

- ▶ **CompTIA Security+**
 - ▶ Introduction aux concepts de base en cybersécurité.
 - ▶ Recommandé pour les analystes SOC L1.
- ▶ **EC-Council Certified SOC Analyst (CSA)**
 - ▶ Conçu spécifiquement pour les analystes SOC débutants.
 - ▶ Focus sur les alertes, triage, monitoring.
- ▶ **CompTIA CySA+ (Cybersecurity Analyst)**
 - ▶ Détection de menaces, analyse comportementale.
 - ▶ Appropriée pour un analyste L1/L2.
- ▶ **Microsoft SC-200 (Security Operations Analyst Associate)**
 - ▶ Pour ceux travaillant dans des environnements Microsoft Sentinel, Defender.

Certifications :

Certifications pour les professionnels SOC

- ▶ **SANS/GIAC GCIA (Certified Intrusion Analyst)**
 - ▶ Analyse de trafic réseau, détection d'intrusions.
 - ▶ Très valorisé pour les analystes L2/L3.
- ▶ **SANS/GIAC GCIH (Incident Handler)**
 - ▶ Gestion des incidents, réponse et investigation.
 - ▶ Idéal pour analyste SOC avancé ou Incident Responder.
- ▶ **Cisco CyberOps Associate / Professional**
 - ▶ Cisco-centric mais utile pour concepts de SOC et SIEM.
 - ▶ Niveau Professional pour analystes expérimentés.
- ▶ **Blue Team Level 1 (BTL1) / Level 2 (BTL2)**
 - ▶ Très pratique, axée défense, investigation, outils SOC réels.

Certifications :

Certifications pour les professionnels SOC

- ▶ **SANS/GIAC GCFA (Forensic Analyst)**
 - ▶ Analyse forensique avancée sur systèmes Windows/Linux.
- ▶ **SANS/GIAC GNFA (Network Forensic Analyst)**
 - ▶ Spécialisée en forensic réseau, trafic, PCAP.
- ▶ **SANS/GIAC GDAT (GIAC Defending Advanced Threats)**
 - ▶ Pour les SOC spécialisés dans la chasse aux menaces (threat hunting).
- ▶ **MITRE ATT&CK Defender (MAD)**
 - ▶ Focus MITRE ATT&CK, tactiques et techniques adverses.

Certifications :

Certifications pour les managers SOC

- ▶ **Certified SOC Manager (EC-Council)**
- ▶ Spécifique à la gestion d'un centre SOC.
- ▶ **SANS/GIAC GSOM (Security Operations Manager)**
- ▶ Nouveau standard pour les managers de SOC.
- ▶ **CISM (Certified Information Security Manager)**
- ▶ ISACA. Hautement reconnu. Conception, gouvernance et gestion de la sécurité.
- ▶ **ISO/IEC 27001 Lead Implementer / Lead Auditor**
- ▶ Gouvernance sécurité, mise en conformité, audits, gestion ISO 27001

Certifications :

Certifications pour les auditeurs SOC

- ▶ **CISA (Certified Information Systems Auditor) – ISACA** Focus audit des systèmes d'information, y compris SOC.
- ▶ **CRISC (Certified in Risk and Information Systems Control) – ISACA** Gestion des risques IT et contrôle.
- ▶ **Lead Auditor ISO 22301 / ISO 27035** Gestion de la continuité (22301) et réponse aux incidents (27035).
- ▶ Autres certificats sont aussi demandées

Certifications :

Parcours

| Rôle | Certifications recommandées |
|-------------------|---|
| SOC Analyst L1 | Security+, CSA, CySA+, SC-200 |
| SOC Analyst L2/L3 | GCIH, GCIA, BTL2, MAD |
| Threat Hunter | GDAT, GCFA, MITRE ATT&CK Defender |
| Forensic Expert | GCFA, GNFA |
| SOC Manager | GSOM, CISM, SOC Manager (EC-Council), ISO 27001 |
| Auditeur sécurité | CISA, CRISC, ISO 27001 Lead Auditor |
| Analyste SIEM | Splunk, Elastic, QRadar, Sentinel, ArcSight |

Security Information and Event Management (SIEM)

Pr M. Serrhini

2025-2026

Sommaire

1. Introduction
2. Origine (Historique)
3. Contexte et enjeux actuels
4. Incident Majeur / des cas
5. Concept et ingénierie
6. Techniques de base

Introduction :

SIEM

3

- ▶ Les logiciels Les logiciels SIEM intègrent diverses sources de données, telles que les équipements de sécurité, les applications, l'activité des terminaux (endpoints) et les systèmes d'exploitation, dans un référentiel centralisé. Les journaux sont collectés via des protocoles standards comme syslog ou SNMP traps. Des processus de normalisation reformulent les entrées dans un schéma uniforme pour accélérer les recherches et la corrélation (Gast, 2021).
- ▶ Ensuite, des moteurs de corrélation analysent les contenus des journaux pour identifier des relations indiquant des incidents potentiels. Des règles détectent des schémas connus, comme des tentatives de connexion échouées, des signatures de malwares ou des modifications de politiques.
- ▶ L'intelligence artificielle (IA) mature élargit ces règles grâce à l'apprentissage automatique non supervisé (ML), qui regroupe des événements similaires mais non identifiés. L'établissement de comportements de référence permet également de repérer des anomalies justifiant une investigation.

Introduction :

SIEM

4

- ▶ Les alertes générées sont soumises à un score de risque, quantifiant leur impact pour prioriser l'examen par les analystes. Des attributs tels que l'ampleur, la sensibilité des données et les implications de conformité influencent cette priorisation.
- ▶ L'automatisation achemine ensuite les problèmes à haut risque vers les systèmes appropriés de gestion de tickets, de cas ou d'orchestration, selon des playbooks prédéfinis. Les avertissements de moindre priorité alimentent les solutions de surveillance.
- ▶ Des capacités de recherche et d'analyse puissantes accélèrent les enquêtes. Les recherches par mots-clés permettent de trouver rapidement des entrées liées sans analyser les journaux bruts.
- ▶ Les vues chronologiques graphiques reconstituent les séquences d'événements. L'analyse pivot explore en profondeur les alertes initiales à travers les preuves corrélées.
- ▶ Les rapports statistiques et les tableaux de bord résument les indicateurs clés de performance, les tendances des attaques et l'adhésion aux politiques.

Introduction :

Intégrations et évolutivité

5

- ▶ L'utilité des SIEM s'accroît grâce à leurs intégrations. Des connecteurs préconfigurés fournissent des tableaux de bord et des rapports à partir de la gestion unifiée des terminaux, des pare-feu, des proxys web et des fournisseurs de sécurité cloud.
- ▶ Des scripts personnalisés s'adaptent aux environnements sur mesure. Les API exposent les enregistrements de journaux et les enrichissements contextuels aux plateformes d'orchestration, aux outils forensiques et aux systèmes de tickets pour des flux de travail automatisés.
- ▶ Avec l'augmentation des volumes, l'évolutivité devient cruciale. Des appliances performantes indexent des pétaoctets annuellement avec des temps de réponse aux requêtes en millisecondes. La planification de la capacité projette la durée de vie du matériel tout en gérant les niveaux de stockage et la compression.
- ▶ Le partitionnement (sharding) répartit les charges de requêtes sur des clusters. Des journaux d'audit immuables respectent les durées de conservation réglementaires.

Origine (Historique) :

Origines

6

Le concept des SIEM trouve ses racines dans les années 1990, avec l'émergence des premiers outils de gestion des journaux (logs) pour surveiller les systèmes informatiques. À cette époque, les entreprises utilisaient des outils séparés pour collecter et analyser les journaux, comme les systèmes de détection d'intrusion (IDS) et les pare-feu, mais ces solutions manquaient d'intégration et de centralisation.

- ▶ **Premiers pas : Gestion des journaux** Les outils de gestion des journaux, comme les systèmes syslog, permettaient de collecter des données brutes à partir de serveurs et de réseaux. Cependant, l'analyse était manuelle et laborieuse, souvent réalisée par des administrateurs système sans automatisation ni corrélation.
- ▶ **Naissance du terme SIEM (1997-2000)** Le terme « SIEM » a été introduit à la fin des années 1990 par des analystes comme ceux du Gartner Group, qui ont combiné **Security Information Management (SIM)** (gestion des informations de sécurité, axée sur la collecte et le stockage des logs) et **Security Event Management (SEM)** (gestion des événements de sécurité, axée sur l'analyse en temps réel et la réponse). Cette fusion a marqué la reconnaissance du besoin d'une solution unifiée pour gérer à la fois les informations historiques et les événements en temps réel.
- ▶ **Premiers acteurs** Des entreprises comme **ArcSight** (fondée en 2000) et **NetIQ** ont été parmi les pionnières à développer des solutions SIEM commerciales. ArcSight, par exemple, a introduit des capacités de corrélation pour détecter des modèles d'attaques à partir de journaux hétérogènes, posant les bases des SIEM modernes.

Origine (Historique) :

Évolution

7

Dans les années 2000, les cyberattaques sont devenues plus sophistiquées (vers, malwares, attaques ciblées), et la conformité réglementaire (comme SOX, PCI-DSS, HIPAA) a poussé les organisations à adopter des outils capables de prouver la sécurité de leurs systèmes.

- ▶ **Centralisation et corrélation** Les SIEM ont évolué pour centraliser les données provenant de sources multiples (pare-feu, antivirus, serveurs, applications) et utiliser des moteurs de corrélation pour identifier les menaces potentielles. Les règles prédéfinies permettaient de détecter des schémas comme des tentatives répétées de connexion ou des transferts de données suspects.
- ▶ **Premiers défis** Les premiers SIEM étaient coûteux, complexes à déployer et nécessitaient une expertise significative pour configurer les règles et gérer les faux positifs. Les solutions comme **IBM QRadar** (lancé dans les années 2000 sous Guardium) et **Splunk** (fondé en 2003, bien que plus orienté analyse de données au départ) ont commencé à simplifier l'interface utilisateur et à améliorer la scalabilité.
- ▶ **Conformité comme moteur** La conformité réglementaire a été un facteur clé de l'adoption des SIEM. Les organisations devaient conserver des journaux pour des audits, et les SIEM offraient des capacités de stockage à long terme et de reporting.

Origine (Historique) :

Modernisation

8

À partir des années 2010, l'explosion des volumes de données, l'adoption du cloud et l'émergence de nouvelles menaces (comme les APT, ransomwares) ont transformé les SIEM.

- ▶ **Intégration de l'intelligence artificielle** Les SIEM ont commencé à intégrer l'apprentissage automatique (ML) pour détecter des anomalies et réduire les faux positifs. Par exemple, **Splunk Enterprise Security** et **Elastic Security** (basé sur l'ELK Stack, popularisé dans les années 2010) ont introduit des capacités d'analyse comportementale (UEBA - User and Entity Behavior Analytics).
- ▶ **Cloud et scalabilité** Avec la migration vers le cloud, les SIEM ont dû s'adapter pour gérer des données provenant d'environnements hybrides (on-premise et cloud). Des solutions comme **Elastic Stack** (open-source, avec des fonctionnalités SIEM gratuites à partir de 2019) et **Microsoft Sentinel** (lancé en 2019) ont proposé des architectures cloud-natives, scalables et économiques.
- ▶ **Open-source et démocratisation** L'ELK Stack (Elasticsearch, Logstash, Kibana), lancé par Elastic en 2012, a démocratisé l'accès aux SIEM grâce à sa licence open-source. Des forks comme **OpenSearch** (2021, après des changements de licence d'Elastic) ont renforcé l'écosystème open-source, rendant les SIEM accessibles aux petites entreprises.

Origine (Historique) :

Ère moderne

9

Depuis 2020, les SIEM ont évolué vers des plateformes de sécurité unifiées, intégrant des fonctionnalités comme l'XDR (Extended Detection and Response), l'automatisation et l'IA avancée.

- ▶ **SIEM nouvelle génération** Les SIEM modernes, comme **Elastic Security**, **Splunk**, ou **Microsoft Sentinel**, ne se contentent plus de corréler des journaux. Ils intègrent l'analyse prédictive, l'IA générative (par exemple, l'Elastic AI Assistant en 2025), et des capacités de réponse automatisée via SOAR (Security Orchestration, Automation, and Response). Ces plateformes visent à réduire le temps moyen de détection (MTTD) et de réponse (MTTR).
- ▶ **Focus sur l'IA et l'automatisation** En 2025, l'IA joue un rôle central. Les SIEM utilisent des modèles d'apprentissage automatique pour détecter des menaces furtives (comme les attaques sans fichier) et des LLMs (modèles de langage) pour fournir des analyses contextuelles aux analystes. Par exemple, Elastic Security a été reconnu dans le rapport Forrester Wave 2025 pour ses capacités AI-ready.
- ▶ **Convergence avec XDR** Les SIEM modernes s'intègrent à des solutions XDR, combinant les données des endpoints, réseaux, et cloud pour une visibilité holistique. Cela répond à la complexité des environnements multi-cloud et des attaques distribuées.
- ▶ **Défis et tendances** Les défis incluent la gestion des volumes massifs de données (pétaoctets par an), la réduction des coûts (via des modèles basés sur le cloud) et la simplification des interfaces pour les équipes SOC limitées en ressources. Les tendances incluent l'adoption de l'open-source (comme OpenSearch), l'intégration avec des frameworks comme MITRE ATT&CK, et une focalisation sur la conformité et la confidentialité des données (RGPD, CCPA).

Contexte et enjeux actuels :

Gestion des volumes massifs de données

10

Les SIEM font face à plusieurs défis critiques pour rester pertinents dans ce contexte. Voici les enjeux principaux, avec leurs implications et les réponses apportées par les solutions modernes :

- ▶ **Enjeu** : Les SIEM doivent ingérer, stocker et analyser des quantités croissantes de données tout en maintenant des performances optimales. Les coûts de stockage et de traitement peuvent devenir prohibitifs.
- ▶ **Contexte** : Les organisations génèrent des téraoctets à pétaoctets de journaux quotidiennement, notamment avec l'essor des IoT et des applications cloud.
- ▶ **Solutions** :
 - ▶ Architectures **data lake** (comme Elastic Stack) pour séparer stockage et calcul, réduisant les coûts.
 - ▶ Compression avancée et indexation efficace (ex. : Elasticsearch avec searchable snapshots).
 - ▶ Modèles cloud-natifs (Microsoft Sentinel, Splunk Cloud) pour une scalabilité élastique.

Contexte et enjeux actuels :

Détection des menaces avancées

11

- ▶ **Enjeu** : Les attaques furtives (ex. : zero-day, attaques sans fichier) nécessitent une détection proactive et une corrélation intelligente au-delà des règles statiques.
- ▶ **Contexte** : Les attaquants utilisent l'IA pour créer des malwares polymorphes, rendant les signatures traditionnelles obsolètes.
- ▶ **Solutions** :
 - ▶ Intégration de l'**apprentissage automatique (ML)** pour détecter les anomalies (ex. : Elastic Security avec ML non supervisé).
 - ▶ Utilisation de l'**IA générative** pour contextualiser les alertes (ex. : Elastic AI Assistant, Microsoft Sentinel AI).
 - ▶ Règles alignées sur des frameworks comme MITRE ATT&CK pour cartographier les tactiques des attaquants.

Contexte et enjeux actuels :

Automatisation et réduction des faux positifs

12

- ▶ **Enjeu** : Les équipes SOC sont submergées par les alertes, dont beaucoup sont des faux positifs, ce qui ralentit la réponse aux incidents.
- ▶ **Contexte** : Les SOC manquent de personnel qualifié, et le temps moyen de réponse (MTTR) reste un indicateur clé.
- ▶ **Solutions** :
 - ▶ **Playbooks automatisés** pour trier et prioriser les alertes (ex. : Splunk SOAR, QRadar SOAR).
 - ▶ Scoring des risques basé sur l'IA pour filtrer les alertes critiques.
 - ▶ Intégration avec des outils SOAR pour automatiser les réponses (ex. : blocage d'IP, isolation d'un terminal).

Contexte et enjeux actuels :

Conformité

13

Les SIEM doivent garantir la confidentialité des données sensibles et répondre aux exigences réglementaires tout en offrant une visibilité complète.

- ▶ **Contexte** : Les amendes liées au RGPD ou à la non-conformité augmentent, et les audits exigent des journaux immuables sur plusieurs années.
- ▶ **Solutions** :
 - ▶ Chiffrement des données en transit et au repos (standard dans Elastic, QRadar).
 - ▶ Politiques de rétention automatisées pour respecter les durées légales (ex. : 7 ans pour certains règlements).
 - ▶ Schémas de classification des données pour limiter l'accès des analystes (RBAC dans Elastic Security).

Contexte et enjeux actuels :

Benchmark des outils

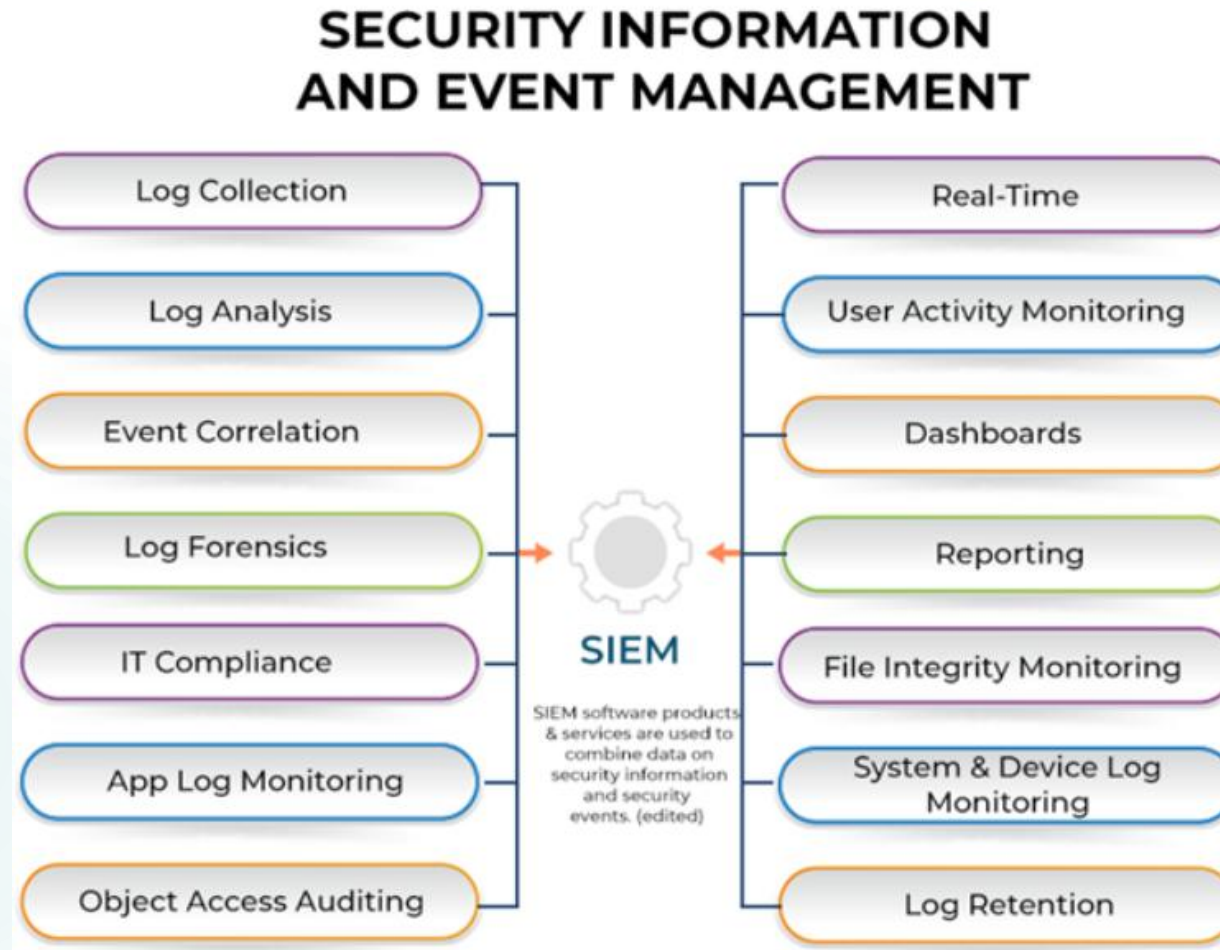
14

| Outil | Type | Déploiement | Fonctionnalités clés | Scalabilité | Coût (approx.) | Évaluation (sur 5) | Avantages/Inconvénients |
|------------------------------|-----------------------------|--------------------------------|---|------------------------------------|---|--------------------------------|---|
| Wazuh | Open source | On-prem, cloud, conteneurs | Collecte logs, détection intrusions, règles personnalisables, intégration ELK | Haute (millions d'événements/jour) | Gratuit (support payant ~5k\$/an) | 4.5 | Avantages : Léger, communauté active, facile pour PME. Inconvénients : Moins d'IA native, configuration manuelle requise. |
| Elastic Security (ELK Stack) | Open source (Basic gratuit) | On-prem, cloud (Elastic Cloud) | Recherche full-text, ML anomalies, règles MITRE, XDR intégré | Très haute (pétaoctets) | Gratuit ; tiers payants ~0.02\$/GB/mois | 4.7 (Leader Forrester 2025) | Avantages : Scalable, open et flexible, IA avancée. Inconvénients : Courbe d'apprentissage pour setups complexes ; features premium payantes. |
| Graylog | Open source | On-prem, cloud | Agrégation logs, alertes, dashboards, corrélation basique | Moyenne à haute (TB/jour) | Gratuit ; Enterprise ~10k\$/an | 4.3 | Avantages : Interface intuitive, bon pour logs. Inconvénients : SIEM limité sans add-ons payants ; moins d'automatisation. |
| Splunk Enterprise Security | Payant | On-prem, cloud (SaaS) | Corrélation avancée, ML prédictif, SOAR intégré, threat intel | Très haute (exabytes) | ~150\$/GB/mois ou 1.8k\$/an/user | 4.8 (Leader Forrester/Gartner) | Avantages : Puissant pour entreprises, écosystème riche. Inconvénients : Coût élevé, complexe pour petits déploiements. |
| IBM QRadar | Payant | On-prem, cloud, hybride | Analytics UEBA, corrélation temps réel, conformité automatisée | Haute (multi-cloud) | ~50k\$/an (base) + usage | 4.4 | Avantages : Robuste pour conformité (PCI-DSS), intégrations larges. Inconvénients : Interface datée, support variable. |
| Microsoft Sentinel | Payant | Cloud (Azure) | IA générative, XDR natif, playbooks automatisés, intégration M365 | Très haute (cloud-native) | ~2.5\$/GB ingéré | 4.6 (Leader Forrester 2025) | Avantages : Intégré Azure, coût par usage flexible, AI forte. Inconvénients : Dépendant de l'écosystème Microsoft ; moins pour on-prem pur. |

Concept et ingénierie:

Architecture

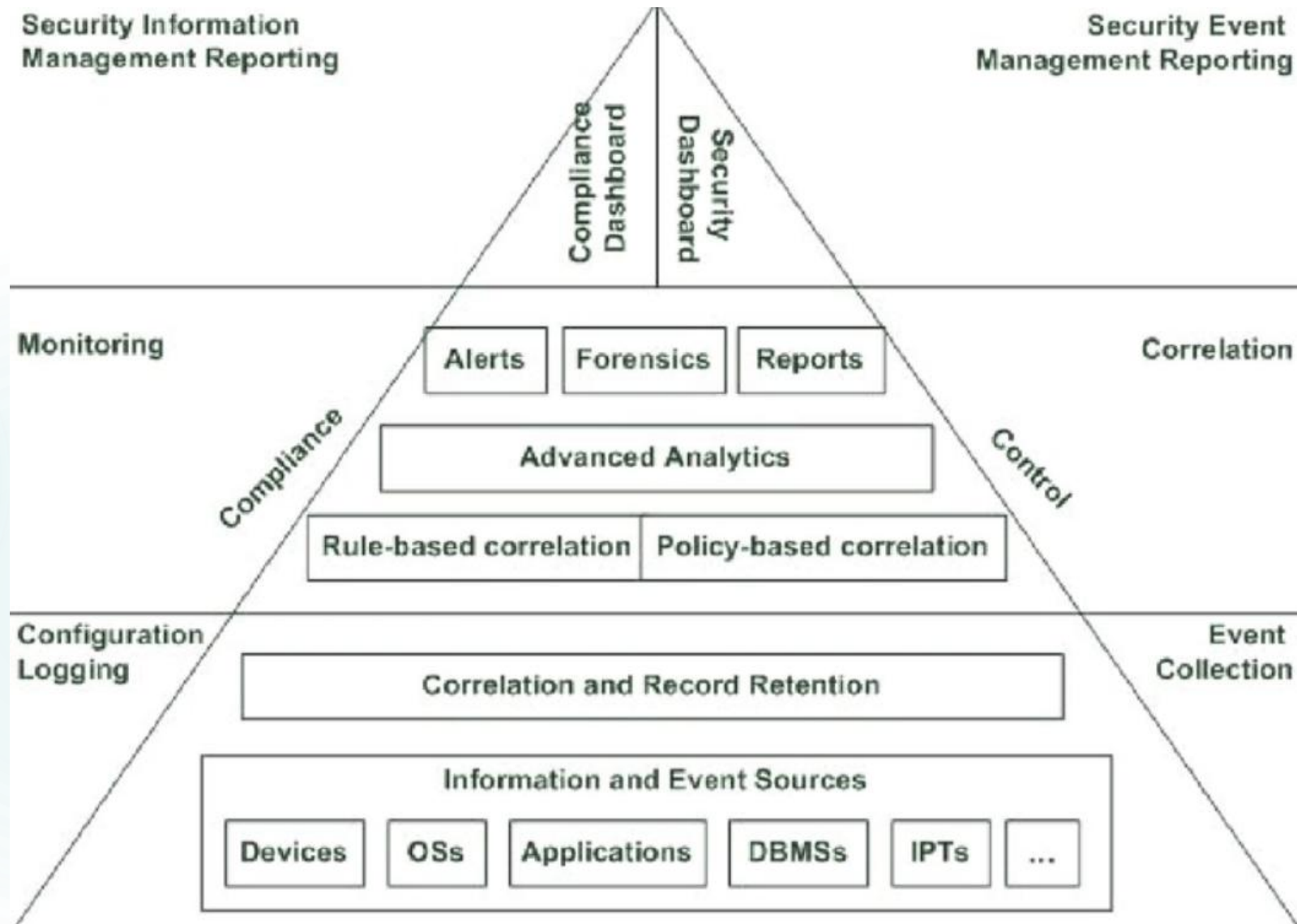
15



Concept et ingénierie:

Architecture

16



Technique de base

17

La corrélation

La corrélation efficace des journaux de sécurité massifs est essentielle pour détecter les menaces furtives. Une optimisation continue améliore la détection grâce à la normalisation, aux règles, à l'IA et à la collaboration.

► Normalisation des données

L'ingestion de sources variées (terminaux, réseaux, applications) nécessite un nettoyage et un ajout de contexte. La normalisation traduit les formats de journaux en un format commun (CEF), permettant des comparaisons d'attributs. La standardisation facilite la création de requêtes de recherche corrélées et l'ajustement des modèles de détection via des expressions régulières (regex). L'intégration de bases de données CVE relie les attaques associées.

► Enrichissement avec du contexte

Compléter les détails des journaux avec un contexte critique optimise la corrélation. La liaison avec des bases de gestion de configuration (CMDB) attribue des étiquettes d'actifs détaillant leur criticité, leur département et leur localisation géographique. La cartographie de découverte réseau relie les adresses IP source et destination internes, tandis que les services d'identité associent les noms d'utilisateur aux attributs et groupes d'accès. Ensemble, ces enrichissements encapsulent les données des journaux dans une compréhension complète des infrastructures dynamiques. Par exemple, des connexions administratives anormales corrélées à des identifiants exposés via les services d'identité peuvent révéler un accès non autorisé.

► Développement de règles heuristiques

L'utilisation d'analyses statistiques mettant en évidence des relations fréquentes entre événements aide à développer des règles de corrélation initiales. Les paramètres équilibrent la spécificité face au surajustement des problèmes connus par rapport à la généralisation pour les menaces inconnues. Des tests valident les règles contre les détections passées, modifiant les attributs pour les cas limites non détectés. Les faux positifs indiquent des seuils de preuves adaptés aux variantes via un réglage des expressions régulières ou des champs enrichis.

► Formation des modèles d'apprentissage automatique

Le regroupement non supervisé aide à découvrir des schémas dans les données brutes, établissant des comportements de référence. Les modèles de classification supervisée reconnaissent les menaces connues en fonction des classifications des cas par les analystes, améliorant la couverture de détection. Une rééducation régulière renforce la précision en intégrant les classifications passées et les exceptions signalées. L'apprentissage incrémental limite les coûts computationnels de la rééducation par lots sur des pétaoctets d'événements. Les retours des analystes améliorent également les performances des modèles semi-supervisés à long terme.

Technique de base

Exemple de la corrélation sur SIEM WAZUH

19



Technique de base

Atelier SIEM

20

- ▶ Lancer SIEM Wazuh appliance VM
- ▶ Configuration des agents (agent ubuntu)
- ▶ Monitoring des évènements
- ▶ Exemple alerte en temps réel
- ▶ Survol des Règles de matching

